Supplément au rapport de stage

Quantification du SCR lié à la non-conformité
au règlement DORA

Kélian Kaddouri

ENSAE Paris, Nexialog Consulting, 2026

Ce document accompagne la version du mémoire déposée à l'ENSAE comme rapport de stage de fin d'études. Il rassemble les contenus que ce rapport, ramené à moins de cent pages, ne reprend pas. Ses chapitres sont numérotés S1 à S4, comme dans les renvois du rapport ; ses renvois vers les chapitres du rapport portent les numéros de celui-ci.

S1, adaptations par pilier. Queue de sévérité par pilier, pilier des tiers comme nœud d'accumulation, indicateurs pilotables et test de résistance inversé.

S2, pistes pour de futurs mémoires d'actuariat.

S3, questionnaire d'élicitation. Le questionnaire diffusé, sans les valeurs des questions d'étalonnage.

S4, compléments retirés du corps du rapport. Les passages des chapitres 1, 3 à 7, 9 et 10 et de la conclusion que le rapport résume, recopiés à l'identique, ainsi que le protocole d'élicitation et les relectures de praticiens.

La version complète du mémoire, déposée à l'Institut des actuaires, porte S1 et S2 comme annexes B et F, S3 comme section C.3, et les passages de S4 dans ses chapitres et son annexe C. Son matériel complémentaire, annexes H à J, est déposé dans le même dépôt Zenodo.

S1

Adaptations par pilier

Idée directrice, et statut de cette annexe. Le modèle fait passer le Vasicek d'un facteur unique à un facteur *par pilier*. Les autres composants doivent-ils suivre ? Les cinq piliers ne sont pas cinq exemplaires du même risque : la queue de sévérité, l'accumulation par tiers et la détection sont des objets de nature différente. Cette annexe les adapte pilier par pilier, sous la *même* discipline que le chapitre 8 : on n'adopte un raffinement que si la donnée le soutient, et ce qu'elle ne fixe pas, on le borne. Elle est reportée hors du corps parce que son verdict est constant et ne modifie aucune conclusion : chaque adaptation relève le niveau, aucune ne renverse le classement.

S1.1 La queue de sévérité par pilier

Aujourd'hui une seule queue ξ est appliquée aux cinq piliers. La queue est pourtant hétérogène selon la catégorie Bâle : sur une table recalculée pour ce mémoire, ξ varie de 0,87 (*Employment*) à 1,37 (*Execution, Delivery & Process Management*), soit une dispersion de 0,50. Faut-il un ξ_j par pilier ? La réponse distingue deux choses.

> **L'hétérogénéité est un fait, l'assignation n'en est pas un.** On ne peut pas *poser* $\xi_j = f(\text{pilier})$: les catégories Bâle décrivent la nature de la perte, pas les domaines de contrôle DORA, et la catégorie la plus proche du TIC (*Business Disruption & System Failures*) n'a que 111 observations, sous le seuil d'estimation de 150. On applique donc la logique du chapitre 8 : chaque pilier reçoit une des cinq queues observées, on énumère les 120 assignations, et l'on borne le SCR. Pour isoler l'hétérogénéité du niveau, les cinq queues sont centrées sur la valeur de référence.

Le résultat est net, et en partie inattendu. L'hétérogénéité de queue n'est pas neutre en capital : même en gardant la moyenne des queues fixe, donner à chaque pilier sa propre queue relève le SCR de +55 % à +96 %. C'est un effet de convexité, la VaR croissant plus vite que linéairement en ξ, de sorte qu'une queue lourde sur un pilier n'est pas compensée par une queue légère ailleurs. Supposer une queue commune sous-estime donc le capital, une raison de plus de lire le niveau en bande. Le classement, lui, résiste : le pilier de tête reste dominant dans 83 % des assignations (figure S1.1), dominant sans être invariant.

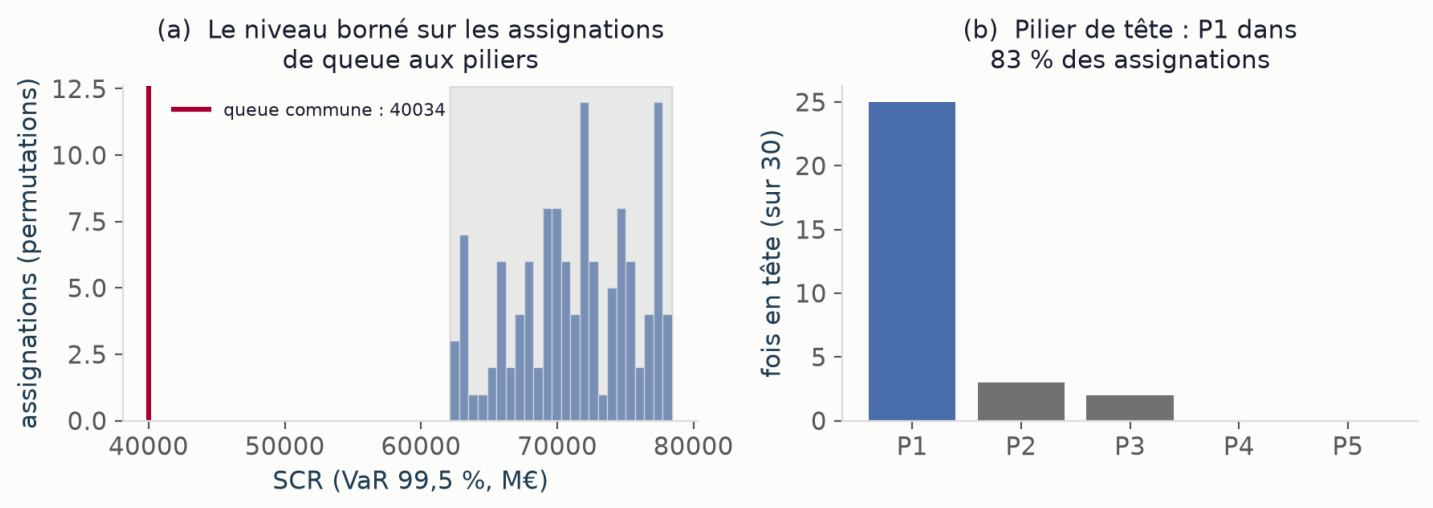


Figure S1.1. Queue de sévérité par pilier. (a) Le niveau du SCR borné sur les 120 assignations des queues observées aux piliers ; une queue commune (trait) est en bas de la bande. (b) Le pilier de tête par contribution à la queue ne dépend pas de l'assignation.

S1.2 Le pilier des tiers comme nœud d'accumulation

P4 (prestataires tiers) n'est pas un nœud de cascade comme les autres. Une défaillance d'un prestataire *partagé* dégrade plusieurs piliers simultanément, par dépendance commune, au lieu de se propager de proche en proche : c'est le mécanisme de MOVEit, 191 victimes d'un seul choc *(voir le Matériel Complémentaire en ligne)*. On lui substitue donc un *choc commun*, où P4 et chaque autre pilier tombent ensemble avec une probabilité φ_{cs}, plutôt qu'une propagation dirigée.

Pourquoi P4 échappe à la limite d'identification de W. Le choc commun est une *co-occurrence symétrique* : P4 et P_j tombent ensemble, sans direction. Or la co-occurrence est la partie *identifiée* du modèle, le S de la décomposition $W = S + A$ (chapitre 8), celle que la donnée voit (MOVEit, concentration cloud). L'accumulation de P4 est donc la seule structure inter-piliers que la donnée soutient, par contraste avec la direction, non identifiée. C'est un point de force, pas une limite.

L'intensité φ_{cs} au sein d'une entité isolée n'est pas identifiée (le *batch* observé est un phénomène de portefeuille) : on la borne sur $[0, \gamma]$, où $\gamma = 0{,}68$ est la concentration cloud déjà retenue. Le SCR se lit alors en bande, et à $\varphi_{cs} = \gamma$ une dépendance partagée emporte en moyenne 3,7 piliers d'un coup, soit +19 % de SCR par rapport au traitement en nœud de cascade. Surtout, la simultanéité crée une co-occurrence multiple que la propagation séquentielle ne produit presque jamais : la probabilité qu'un incident P4 touche au moins trois piliers passe de 0,22 (cascade) à 0,90 (choc commun), figure S1.2.

S1.2.1 Le seuil de déclenchement, et l'accumulation bornée par la dépendance de queue

Il faut séparer deux questions, celle de la *marge* et celle de la *dépendance*.

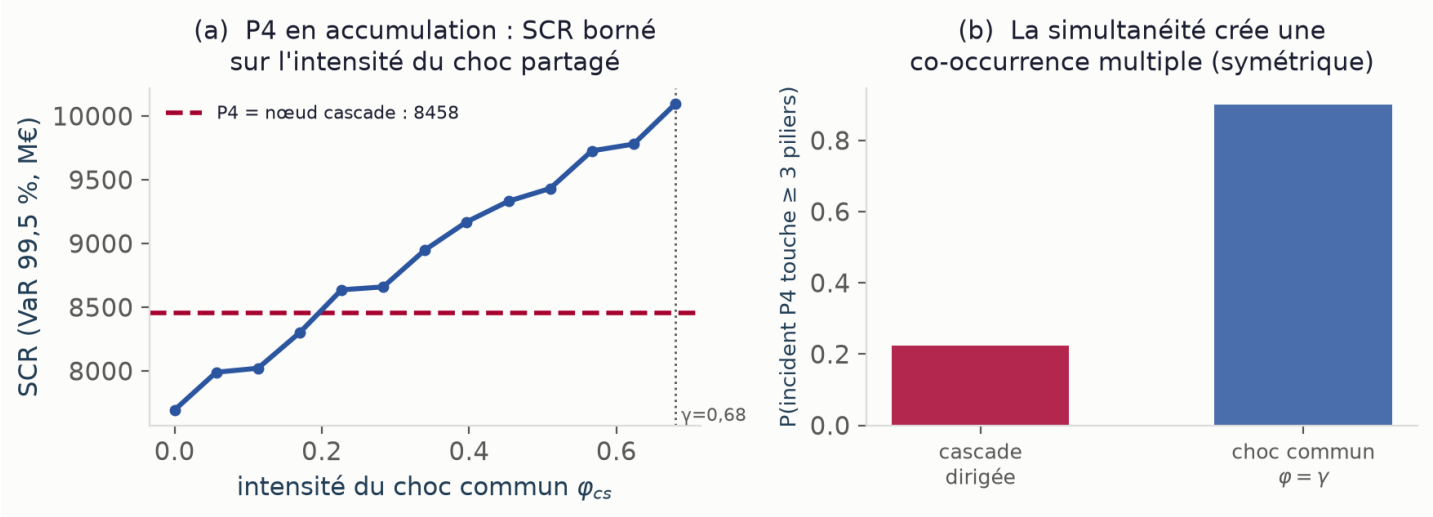


FIGURE S1.2. Le pilier des tiers en accumulation. (a) SCR borné sur l'intensité du choc partagé $\varphi_{cs} \in [0, \gamma]$, comparé au traitement de P4 en nœud de cascade (trait). (b) La simultanéité crée une co-occurrence multiple, structure symétrique donc identifiée.

La marge : quand un pilier bascule. Le déclenchement est un franchissement,

$$\{\text{pilier } j \text{ déclenché}\} \;=\; \{X_j \geq K_j\}, \qquad K_j = F^{-1}(1 - p_j), \tag{S1.1}$$

et pour P_4, $p_4 = 0{,}151$ donne $K_4 = 1{,}03$. La loi F de la latente n'y est qu'une *normalisation* : par construction $\mathbb{P}(X_j \geq K_j) = p_j$ *quelle que soit* F continue et strictement croissante, de sorte que le choix de F ne transporte aucune information sur la fréquence de déclenchement. La queue lourde du capital vit dans la sévérité (GPD, chapitre 4), non dans ce seuil : une loi normale y est donc inoffensive.

La dépendance : combien de piliers ensemble. L'accumulation, elle, est gouvernée par la dépendance de queue supérieure de la copule C liant les latentes,

$$\lambda_U \;=\; \lim_{u \to 1^-} \mathbb{P}\big(U_2 > u \,\big|\, U_1 > u\big) \;=\; \lim_{u \to 1^-} \frac{1 - 2u + C(u,u)}{1 - u}. \tag{S1.2}$$

Une copule gaussienne vérifie $\lambda_U = 0$ quelle que soit sa corrélation, tandis que la copule de Gumbel de paramètre $\theta > 1$ donne

$$\lambda_U^{\text{Gumbel}} \;=\; 2 - 2^{1/\theta}, \tag{S1.3}$$

soit 0,53 pour le $\theta = 1{,}8$ retenu ailleurs dans le mémoire. Retenir une copule gaussienne ici sous-estimerait donc structurellement le co-extrême, en contradiction avec ce choix.

> **Borner l'accumulation, à dépendance moyenne égale.** On ne tranche pas la copule : on lit le co-déclenchement en bande, à τ de Kendall égal, entre le plancher gaussien et le haut de Gumbel. La fréquence *marginale* d'un pilier reste $p_4 = 0{,}15$ pour les deux (la copule ne change pas combien un pilier bascule seul, mais s'ils basculent *ensemble*) ; seul le co-extrême diverge : la probabilité que les cinq piliers tombent avec P4 passe de 0,17 (gaussien) à 0,39 (Gumbel),

> un facteur 2,3, exactement le scénario MOVEit que la queue gaussienne manque (figure S1.3). Le co-déclenchement d'un autre pilier tient alors dans $[0{,}48\,;\,0{,}58]$, sous la borne $\gamma = 0{,}68$ du choc commun, qui reçoit ainsi son origine structurelle. Tout est *par pilier* : un nombre de piliers de l'entité, non une fraction de portefeuille : la vue inter-clients (MOVEit et ses centaines d'entités victimes) serait une loi de Vasicek en dimension entité, hors du SCR par entité.

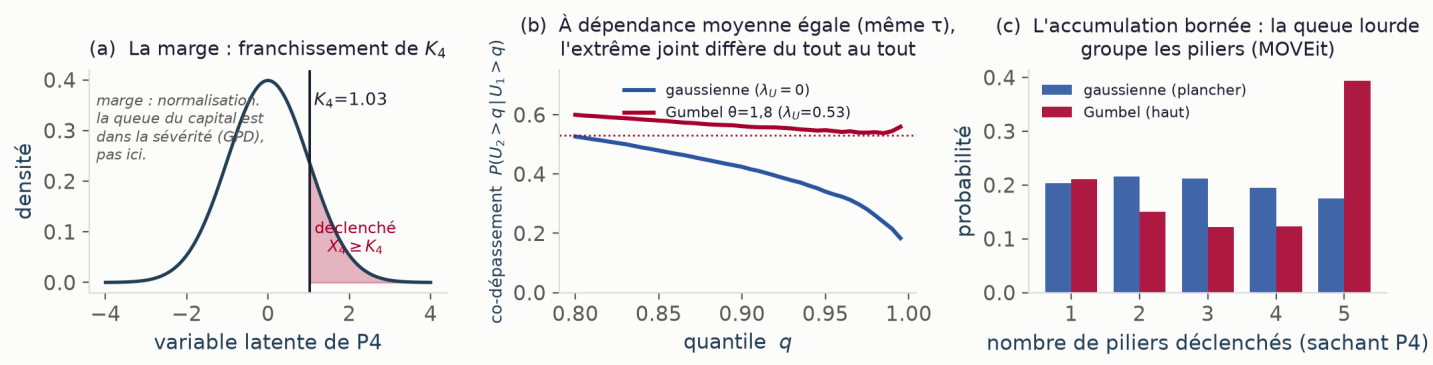


Figure S1.3. Le seuil de P4 et l'accumulation bornée. (a) la marge : franchissement de K_4, où la normale n'est qu'une normalisation. (b) à dépendance moyenne égale, le co-dépassement s'effondre vers 0 pour la gaussienne mais plafonne à 0,53 pour la Gumbel. (c) l'accumulation par pilier, la Gumbel concentrant la masse sur les cinq piliers groupés.

S1.2.2 Le déclenchement comme temps d'arrêt

Le seuil z^* est jusqu'ici un niveau statique. Si le facteur tiers est un processus $(Z_t)_{t\geq 0}$ adapté à une filtration $(\mathcal{F}_t)$, le déclenchement devient un temps de premier passage

$$\tau \;=\; \inf\{\, t \geq 0 \;:\; Z_t \geq z^* \,\}, \tag{S1.4}$$

qui est un temps d'arrêt, puisque $\{\tau \leq t\} = \{\sup_{s\leq t} Z_s \geq z^*\} \in \mathcal{F}_t$. Le « moment » de déclenchement prend ainsi un sens temporel littéral.

Proposition S1.1 (Loi du délai de déclenchement)**.** *Si (Z_t) est un mouvement brownien standard issu de* 0*, donc une martingale, alors pour tout horizon $T > 0$*

$$\mathbb{P}(\tau \leq T) \;=\; 2\,\Phi\!\left(-\frac{z^*}{\sqrt{T}}\right) \;=\; 2\,\mathbb{P}(Z_T \geq z^*). \tag{S1.5}$$

Démonstration. C'est le principe de réflexion. Par symétrie du mouvement brownien après τ, on a $\mathbb{P}(\tau \leq T,\; Z_T < z^*) = \mathbb{P}(\tau \leq T,\; Z_T > z^*) = \mathbb{P}(Z_T > z^*)$, la dernière égalité tenant car $\{Z_T > z^*\} \subset \{\tau \leq T\}$. En sommant les deux événements disjoints, $\mathbb{P}(\tau \leq T) = 2\,\mathbb{P}(Z_T > z^*) = 2\,\Phi(-z^*/\sqrt{T})$. □

La lecture dynamique vaut donc *le double* de la lecture statique $\mathbb{P}(Z_T \geq z^*)$: elle compte tous les franchissements survenus avant l'horizon, et non la seule position finale. À $\rho = 0{,}50$, la probabilité

de déclenchement de P4 en moins d'un an est 0,14 (délai médian de l'ordre de cinq ans) ; à $\rho = 0{,}75$, elle monte à 0,23 (médian d'environ trois ans), figure S1.4.

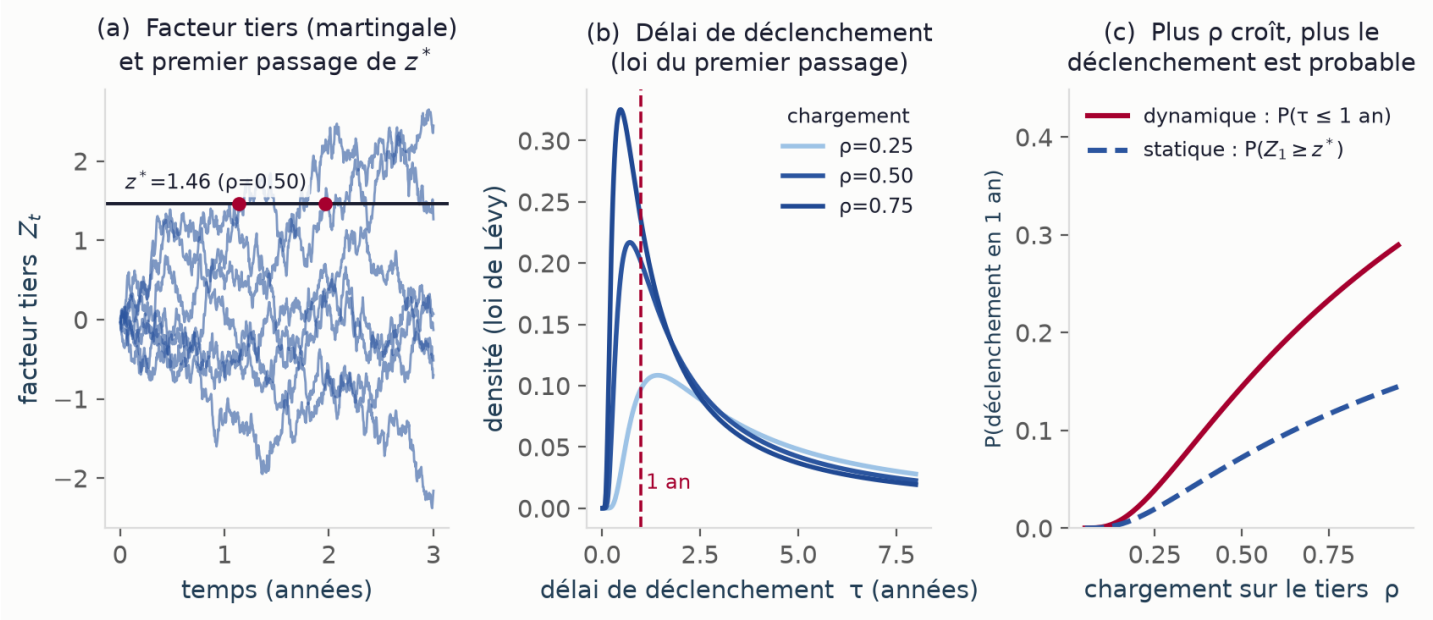


FIGURE S1.4. Le déclenchement de P4 comme temps d'arrêt. (a) le facteur tiers (martingale) et le premier passage de z^*. (b) la loi du délai de déclenchement (premier passage). (c) la lecture dynamique $\mathbb{P}(\tau \leq 1 \text{ an})$ vaut environ le double de la statique.

Un temps de premier passage, et la propriété utilisée n'est pas celle qu'on nomme. Z_t sans dérive est une martingale, mais le principe de réflexion ne s'appuie pas sur cette propriété : il repose sur la propriété de Markov forte et sur la symétrie des accroissements. Nommer la martingale ici était décoratif, et il faut se garder du rapprochement avec le chapitre 7, où le même mot désigne la forme de Dirichlet d'une chaîne : le lien entre les deux usages est de vocabulaire et non de mathématique. Ce qu'ils ont réellement en commun est plus modeste et plus important, ils vivent tous deux sous la mesure physique. Aucun test de martingalité au sens des générateurs de scénarios économiques n'est conduit dans ce mémoire, aucun changement de mesure n'y intervient, et le seuil $z^\star$ ne se déduit d'aucun test de ce genre : il vient de la calibration du facteur tiers. Le cadre complet, avec les hypothèses effectivement requises, est déporté *(voir le Matériel Complémentaire en ligne)*.

Réserve assumée : le brownien pur atteint le niveau presque sûrement mais d'espérance de délai infinie ; un facteur *moyen-réversif* (Ornstein-Uhlenbeck) donnerait un taux de déclenchement récurrent fini, plus réaliste pour un facteur systémique. Le brownien est le cas propre qui porte le calcul explicite.

S1.2.3 Le sous-process tiers sur donnée ouverte : ce qu'on peut ancrer avant le registre

Descendre P4 au niveau *sous-process* (quel sous-traitant, quelle fonction critique, quelle substituabilité) suppose le registre d'externalisation DORA, dont la structure est fixée par l'ITS (Commission européenne, 2024) mais que seules les données de l'entité fournissent. En attendant, la donnée

ouverte tranche déjà deux points opposés (figure S1.5). D'un côté, la **taxonomie fine** du tiers y est trop rare : la sous-catégorie « Vendors & Suppliers » d'OpRisk ne compte que 20 incidents en finance (1 % du TIC), et `actor.Partner` du VCDB 56, qui s'effondrent à zéro deux niveaux plus bas : le même mur de sparsité que partout, qui renvoie au registre. De l'autre, l'origination et la concentration tierces sont, elles, ancrées sur donnée européenne officielle, ce qui *valide de l'extérieur* deux paramètres jusqu'ici posés :

- le premier rapport d'incidents DORA des ESAs (Autorités européennes de surveillance (ESAs), 2026) établit que 29 % des 3 383 incidents TIC majeurs de 2025 proviennent d'une défaillance de tiers : P4 est bien une amorce majeure, ce que le classeur posait par jugement ($\texttt{ROOT}[4] = 0{,}90$) ;
- l'analyse des registres d'externalisation par la BCE (Banque centrale européenne, 2024) montre que plus de 30 % du budget des grandes banques va à 10 fournisseurs (et 50 % du budget critique à 30), et les ESAs ont désigné 19 fournisseurs TIC critiques : cela ancre le paramètre d'accumulation $\gamma = 0{,}68$, jusque-là un proxy cloud, sur un chiffre de concentration officiel.

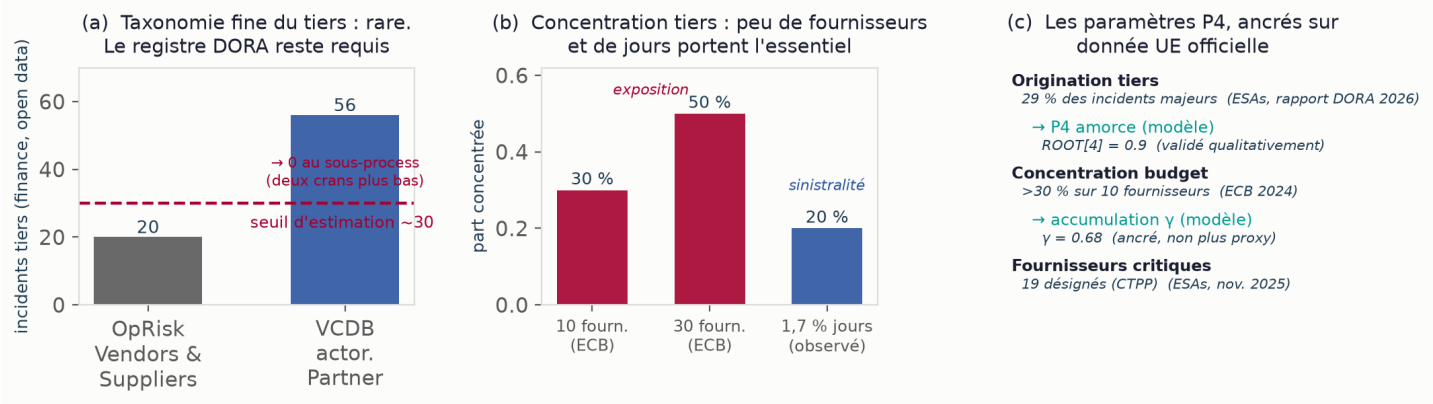


FIGURE S1.5. Le sous-process tiers sur donnée ouverte. (a) la taxonomie fine du tiers est sous le seuil d'estimation (registre DORA requis). (b) la concentration, elle, est nette, côté exposition (BCE) comme côté sinistralité (Gini 0,69). (c) origination et concentration tierces ancrées sur donnée UE officielle.

S1.3 LA DÉTECTION DE P2 ET P3 COMME COURBE DE SURVIE

P2 (gestion des incidents) et P3 (tests) ne sont pas des nœuds de sévérité : ils gouvernent le temps de détection. Un incident non détecté à temps escalade et devient matériel. Le modèle résume cela par un multiplicateur du taux de matérialité (0,85 conforme, 1,20 non conforme). On le remplace par une lecture de survie, ancrée sur donnée.

Le VCDB donne la distribution du délai de découverte en finance ($n = 278$), et elle est *bimodale* : 47 % le jour même, 8 % en semaines, 45 % en mois ou plus. La matérialité vient des incidents à découverte lente, d'où un taux de matérialité proportionnel à la part de découverte lente, ancrée à $\pi_{\text{slow}} = 0{,}45$.

> **Un point observé, une élasticité bornée.** Le point $\pi_{\text{slow}} = 0{,}45$ est mesuré ; l'élasticité de la détection à la maturité de P2/P3 (de combien un pilier conforme détecte-t-il plus vite ?) ne l'est pas, et on la borne. Le surcoût du *seul* canal détection est alors une bande, de 1 775 à 8 052 M€ selon l'élasticité. Fait notable : le multiplicateur grossier actuel (0,85/1,20) est retrouvé à une élasticité $\eta \approx 0{,}36$: il n'est donc pas arbitraire, c'est un point de la courbe de survie ancrée sur le VCDB (figure S1.6).

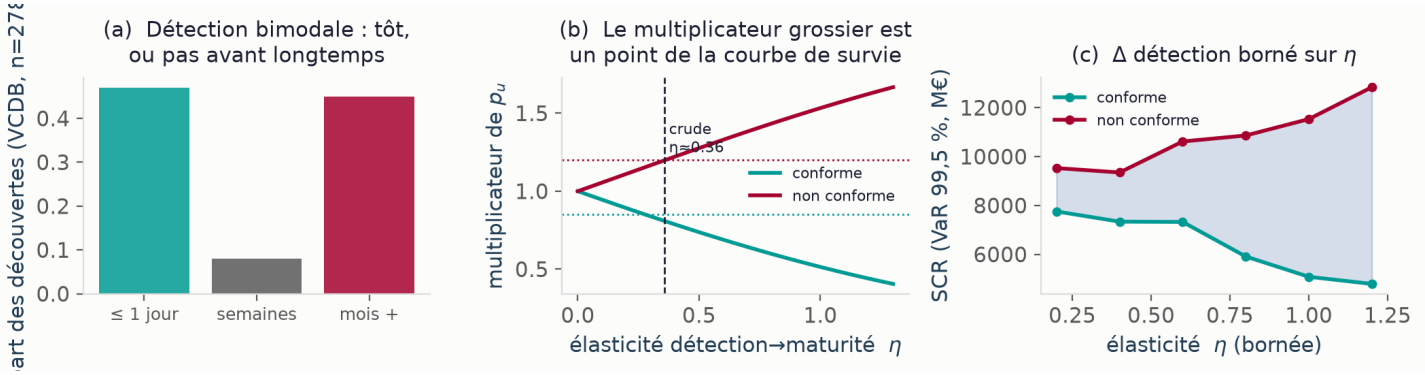


FIGURE S1.6. P2/P3, la détection comme courbe de survie. (a) La distribution bimodale observée au VCDB. (b) Le multiplicateur de matérialité comme point de la courbe de survie ; le multiplicateur grossier actuel correspond à $\eta \approx 0{,}36$. (c) Le surcoût du canal détection, borné sur l'élasticité.

S1.4 CAS D'USAGE : DES ADAPTATIONS AUX KPI PILOTABLES

Les adaptations qui précèdent se lisent enfin comme un tableau de bord opérationnel, opposable à un souscripteur ou à un superviseur. Chaque KPI observable, de la fréquence d'entrée au délai de notification (P2), au délai de confinement (P3) et à la concentration tiers (P4), est rattaché à un canal du moteur, et l'on mesure le capital en jeu derrière lui : l'écart de capital entre l'état conforme et l'état non conforme, soit 14 139 M€ (6 049 → 20 188).

Un canal se lit de trois façons, et elles ne sont pas interchangeables. On peut partir de l'état conforme et n'y dégrader que ce canal (lecture *isolée*), partir de l'état non conforme et n'y remédier que ce canal (marginal de *fermeture*), ou moyenner sur les vingt-quatre ordres d'entrée (valeur de *Shapley*). Les trois lectures sont comparées à la figure S1.7(b), et une seule somme à l'écart total : la lecture isolée manque 5 001 M€ et celle de fermeture le dépasse d'autant, le rapport des deux allant de 1,5 à 3,1 selon le canal. Le sens de cet écart est le point utile pour une direction des risques : remédier un canal rapporte davantage à une entité défaillante partout qu'à une entité déjà conforme, puisque ce canal ferme aussi les effets croisés qu'il portait. Seule la lecture de fermeture correspond donc à une entité réelle en début de remédiation.

> **Deux des trois sommes ne mesurent rien, et il ne faut pas les resommer.** La question a été posée en séance sous la forme d'un soupçon de double comptage, la somme des fermetures paraissant proche du double de celle des effets isolés. Il n'y a pas de double comptage, et c'est

une identité : en notant $m(S)$ les coefficients de Möbius,

$$\sum_i \text{isolé}(i) = \sum_{|S|=1} m(S), \qquad \sum_i \text{fermeture}(i) = \sum_S |S|\, m(S), \qquad \sum_i \varphi_i = \sum_S m(S) = \Delta.$$

Fermer un canal lui fait porter l'intégralité des croisés auxquels il participe, et un croisé d'ordre k est donc compté k fois : $1{\times}9\,138{+}2{\times}5\,345{+}3{\times}(-691){+}4{\times}346 = 19\,141$, à la précision machine. Ce qui est en revanche une propriété est l'encadrement $9\,138 \le 14\,139 \le 19\,141$, valable dès que la fonction de capital est sur-modulaire, ce que la cascade est. Shapley est la seule lecture qui répartisse l'interaction sans la perdre ni la dupliquer, mais c'est une *convention* d'attribution et non une prévision : deux des quatre canaux sont bornés, de sorte que leur part n'est pas un budget actionnable. Le défaut de la colonne isolée est celui que l'analyse de sensibilité rencontre dès que les entrées cessent d'être indépendantes, les indices de Sobol ne sommant alors plus au total quand la valeur de Shapley y somme par construction (Owen, 2014 ; Iooss et Prieur, 2019) ; ces travaux décomposent toutefois une *variance* quand la fonction caractéristique employée ici est un *écart de capital*, donc l'argument se transpose, pas le résultat.

L'état non conforme est le coin supérieur du pavé, et c'est une propriété testée. Sur les soixante-cinq paires emboîtées des seize configurations, relâcher un canal de plus ne fait jamais baisser le capital, graine par graine et non seulement en moyenne. Le maximum est donc atteint au coin haut, et un test de résistance sur le pavé des quatre canaux se réduit à une seule évaluation. C'est la forme que prend ici le résultat de statique comparative monotone du préprint cité au chapitre 2 (Karimi et al., 2026).

Deux réserves, et la seconde commande la lecture du chiffre de tête. La borne vaut au sens du quantile et non trajectoire par trajectoire : à uniformes communs, la perte d'une année donnée baisse dans 16,2 % des cas quand on relâche la propagation et dans 30,7 % quand on relâche la détection, pour un motif qui diffère selon le canal, la table des sous-ensembles dans le premier cas et la transformation de sévérité dans le second. Obtenir la version trajectorielle demanderait un couplage monotone, donc d'autres tirages, ce que le gel interdit pour un renforcement d'énoncé sans déplacement de conclusion. Et un coin peut être *infaisable* : deux des quatre canaux sont des bornes posées et non des valeurs observées, donc rien ne garantit qu'une entité présente les quatre canaux à leur maximum simultanément. Le coin est un majorant sur un pavé déclaré, non la description d'une entité.

S1.4.1 Le test de résistance inversé

La monotonie qui précède autorise la question réciproque, celle qu'un dispositif ORSA pose aussi : au lieu de fixer un état et de lire un capital, on fixe le *capital* et l'on cherche les états qui le produisent. L'ensemble des configurations atteignant une cible est alors *croissant*, donc entièrement décrit par ses éléments minimaux, qui ne sont jamais plus de quatre sur seize.

Cible	configurations minimales qui l'atteignent	minimum de canaux
8 000	fréq. ; dét.+prop. ; dét.+accum. ; prop.+accum.	1
10 000	fréq. ; dét.+prop.+accum.	1
12 000	fréq.+dét. ; fréq.+prop. ; fréq.+accum.	2
15 000	les trois triplets contenant la fréquence	3
18 000	les quatre canaux	4

Deux nombres résument le tableau. Le canal de fréquence seul atteint 10 377 M€, soit 1,72 fois l'état conforme, quand les trois autres canaux réunis n'atteignent que 11 413, soit 1,89 fois, et l'ordre de ces deux bornes tient sur les quatre graines. Toute cible sous le premier seuil se produit donc par un canal unique ; toute cible au-dessus du second exige la fréquence. Aucun autre canal seul n'atteint même la cible la plus basse, la détection plafonnant à 7 497 M€, la propagation à 7 682 et l'accumulation à 7 777 : une exposition à un canal unique est, dans ce modèle, une exposition à la fréquence.

> **Le canal d'accumulation n'admet pas d'inversion continue, et son effet isolé est un *net*.** À l'état conforme, le pilier des tiers est un nœud de cascade ordinaire ; à l'état non conforme il devient un choc commun. Ce sont deux structures de table et non les extrémités d'un continuum, si bien qu'un test inverse ne peut pas demander à ce canal jusqu'où il doit se dégrader. La bascule à paramètre nul fait d'ailleurs baisser le capital de 239 M€, résolu sur les quatre graines, parce qu'elle retire la propagation propre du pilier avant d'ajouter le choc commun : l'effet isolé publié de 1 728 M€ est le net d'un retrait de 239 et d'un ajout de 1 967, une raison de plus de ne jamais sommer les quatre canaux.

Deux réserves, de nature différente. L'inatteignabilité porte sur un pavé *déclaré* et jamais sur une entité, deux canaux sur quatre étant des bornes posées. Et une configuration proche d'une cible n'est pas classée, son appartenance dépendant de la graine : une frontière non résolue est un résultat, elle dit que la cible tombe dans le bruit de simulation.

L'interaction n'est plus un résidu : elle se décompose, et elle vit aux paires. La décomposition de Möbius sur le treillis des seize configurations rend compte des +5 001 M€ terme par terme : quatre effets principaux (9 138 M€), six croisés de paires (5 345), quatre de triplets (−691) et un croisé des quatre (+346), dont la somme vaut 14 139 à la précision machine. Ce n'est pas une vérification statistique mais une identité : elle atteste que la table est complète. Les trois paires porteuses passent toutes par la fréquence et font 86 % de l'ordre 2, fréquence × détection 1 739 ± 708, fréquence × accumulation 1 666 ± 354 et fréquence × propagation 1 182 ± 444 M€. Ces ± sont des étendues de *simulation* à paramètres fixés, et une loi d'échelle le montre : l'écart-type tombe de 1 785 à 339 M€ lorsque le nombre d'années simulées passe de 10 000 à 160 000, soit une pente de −0,60 contre −0,50 attendu pour du Monte-Carlo. Cette largeur s'achète en temps de machine ; celle qui ne s'achète pas est dix fois plus grande, le même croisé allant de 429 à 7 998 M€ aux deux bornes de l'IC90 de $\hat{\xi}$. Le classement des deux premières paires n'est pas résolu et n'a pas à l'être, elles se tiennent à 73 M€ et leur ordre s'inverse en perte moyenne.

Les états mixtes décomposent, ils ne se reportent pas. Sur les seize configurations, quatorze mélangent des canaux conformes et non conformes, et aucune entité ne se trouve dans un tel état. Ce sont ici des intermédiaires de calcul : ils répartissent un total dont les deux extrémités sont cohérentes, et la décomposition les fait disparaître par construction. Un chiffrage qui *reporterait* un état mixte présenterait comme atteignable une situation qui ne l'est pas.

Une seule paire est négative, et elle borne ce qu'on peut attribuer à la contagion. Propagation × accumulation vaut −330 ± 242 M€, négative sur les seize graines et sur les deux métriques. Les deux canaux sont substituts et non compléments : la cascade et le choc commun sont deux façons de faire tomber plusieurs piliers sur un même sinistre, et le premier actif, il reste moins à gagner au second. Le capital est donc super-additif en euros mais sous-additif entre ses deux canaux de co-occurrence, ce qui borne l'amplitude imputable à la contagion prise en général.

D'où vient l'interaction : les canaux se composent de façon quasi multiplicative. Une décomposition *additive* d'effets qui se *multiplient* produit une interaction positive par simple arithmétique, $(1+a)(1+b)-1$ dépassant $a+b$. La décomposition refaite sur le logarithme du capital le montre. Le produit des quatre facteurs isolés vaut 3,47 quand le facteur publié vaut 3,34, soit 0,961 fois ce produit ; un modèle purement multiplicatif produirait 5 813 M€ d'interaction, et les 5 001 M€ publiés en valent 86 %. Aucune des seize configurations ne s'écarte de plus de 8,1 % du produit de ses facteurs isolés. L'interaction en euros est donc entièrement expliquée par la multiplicativité, et le résidu propre est une légère *sous*-multiplicativité, portée par la paire propagation × accumulation. Deux canaux suivent même une forme fermée : par l'approximation de la perte unique (Böcker et Klüppelberg, 2005), le quantile croît comme $(\lambda\, p_u)^{\xi}$, ce qui prédit un facteur $(53{,}62/21{,}56)^{0{,}5954} = 1{,}720$ pour la fréquence contre 1,715 simulé, et 1,228 pour la détection contre 1,239. Les conclusions de gestion n'en changent pas, remédier un canal rapportant toujours davantage à une entité défaillante partout ; elles changent de statut, puisqu'elles se démontrent au lieu de se constater, et l'interaction ne se lit pas comme un effet propre de la contagion (figure S1.7).

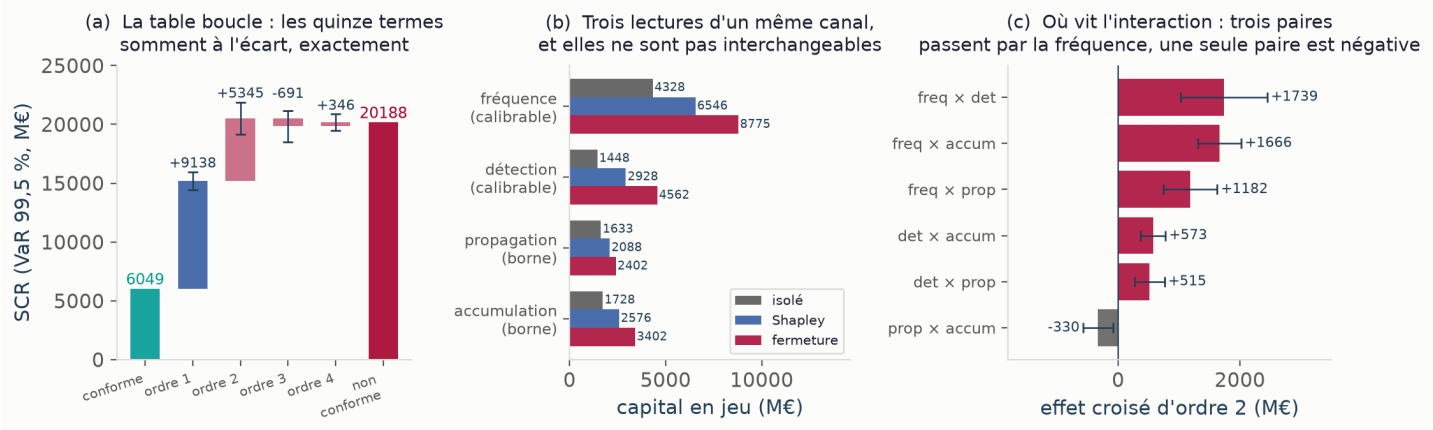


FIGURE S1.7. La table complète des quatre canaux. (a) la réconciliation par ordre : les quinze termes de Möbius somment à l'écart, exactement. (b) les trois lectures d'un même canal, isolée, Shapley et fermeture. (c) les six croisés de paires avec leur écart-type de simulation ; une seule est négative.

Classer par capital *et* par statut. Les KPI à fort capital et calibrables (fréquence, détection) sont les leviers de remédiation à activer en priorité ; ceux à fort capital mais bornés (propagation, accumulation) mesurent surtout une incertitude, à résorber par la donnée, c'est-à-dire par le registre DORA, plutôt que par une action directe (figure S1.8).

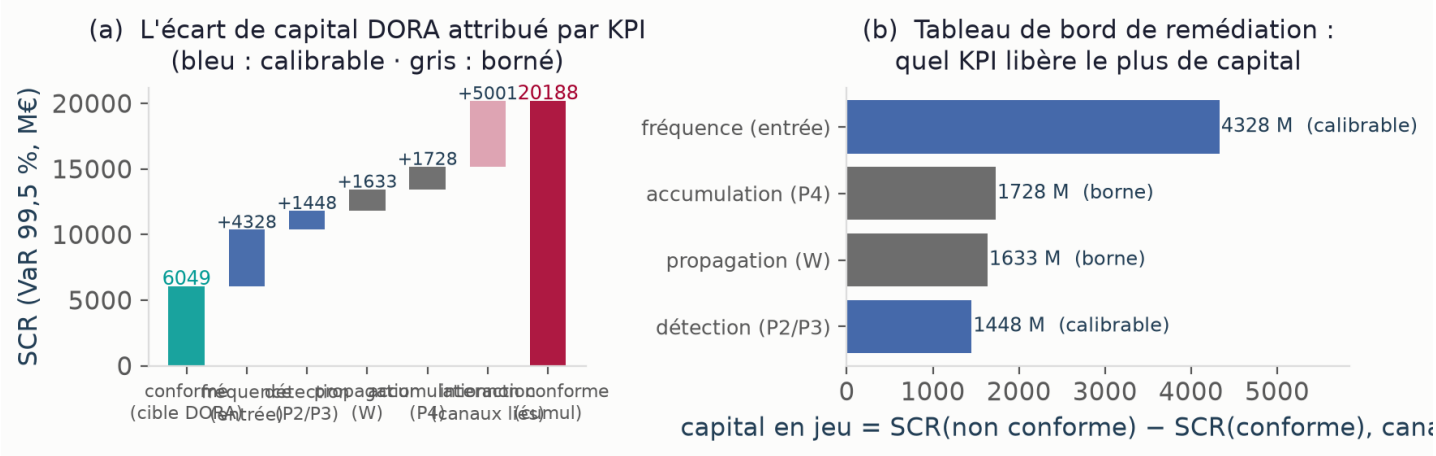


FIGURE S1.8. Des KPI descriptifs aux KPI pilotables. (a) l'écart de capital DORA attribué par KPI, chaque canal isolé (bleu : calibrable ; gris : borné), avec l'interaction qui referme la cascade. (b) le tableau de bord de remédiation, les KPI classés par capital libéré.

S1.4.2 Le retour sur investissement de la conformité

Le tableau de bord se lit enfin en euros, et deux mots doivent y être définis avant tout calcul. Le *portage* d'abord : détenir du capital n'est pas gratuit, et sous Solvabilité II son coût de détention se lit dans la marge de risque, un pourcentage par an du capital immobilisé. Au taux de 6 % du règlement délégué, les 14 139 M€ que libère la conformité totale valent donc 848 M€ par an, et non une fois, la fréquence en portant à elle seule près de la moitié.

Le plancher porte sur le bénéfice, non sur la durée. Le bénéfice a deux composantes et le calcul ci-dessus n'en monétise qu'une : le portage économisé vaut 848 M€/an quand la sinistralité évitée en vaut 3 247, la charge annuelle moyenne passant de 3 869 à 622 M€. La composante laissée de côté vaut 3,8 fois celle qui est retenue, donc le portage seul minore le bénéfice. Il en résulte que le retour de 6 à 35 ans, calculé face à un coût de remédiation de 25 à 150 M€ par grande entité, soit 5 à 30 Md€ pour deux cents entités, est un *majorant* : le compte réel est plus court, jamais plus long. Les deux composantes réunies donnent 4 095 M€/an, soit un retour de 1 à 7 ans, mais cette addition mêle un flux de compte de résultat à un coût du capital : c'est une convention de retour sur investissement, non une sortie du modèle, et le chiffre de référence reste le portage seul avec le sens de sa borne.

Ce taux n'est pas un critère de décision d'investissement. Il rémunère l'immobilisation de fonds propres sous Solvabilité II ; il n'est ni le coût moyen pondéré du capital de l'entité, ni son taux d'exigence sur un projet. Une durée de retour exprimée dans cette unité est une grandeur de comparaison

prudentielle, non un test d'opportunité, et la confusion entre les deux est fréquente en pratique.

Une réserve sur le taux, déclarée plutôt que corrigée. Le taux de 6 % est celui du règlement délégué 2015/35 ; la directive (UE) 2025/2 le ramène à 4,75 %, taux qu'emploient les calculs d'échelle d'entité. Le portage monétisé tombe alors à 672 M€/an, soit une baisse de 21 %, et le majorant du retour passe de 35 à 45 ans. Aucune conclusion ne bascule, la durée demeurant un majorant et la composante dominante du bénéfice n'étant pas monétisée ; la chaîne publiée reste au taux historique, la calibration étant gelée (figure S1.9).

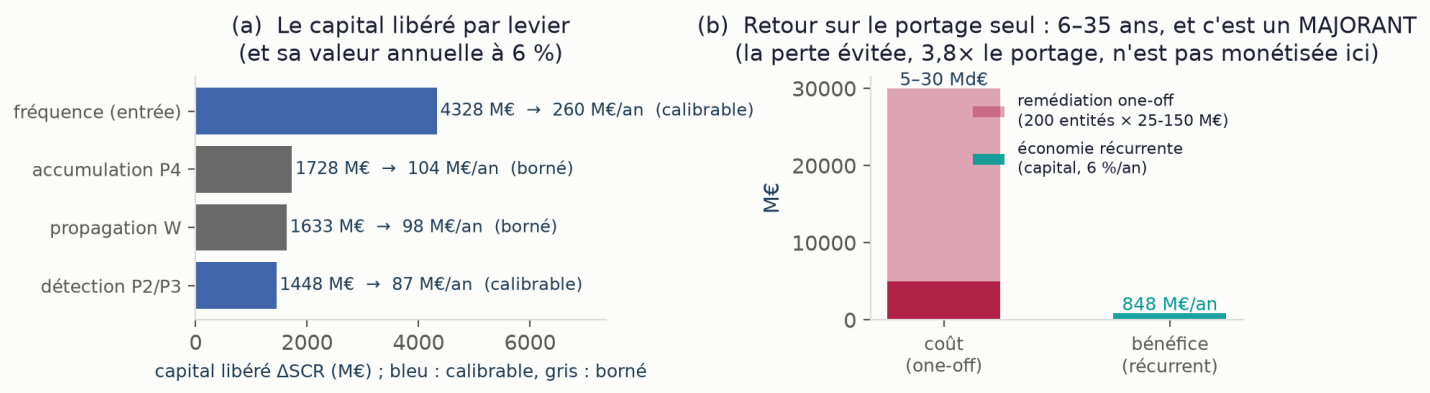


FIGURE S1.9. Le ROI de la conformité. (a) le capital libéré par levier, classé, avec sa valeur annuelle à 6 % (bleu : calibrable, gris : borné). (b) coût de remédiation *one-off* contre économie *récurrente* de portage du capital ; le retour sur le portage seul est de 6 à 35 ans, et c'est un majorant, la perte évitée n'étant pas monétisée ici.

La conformité comme levier de capital. Le bénéfice, le capital libéré, est issu du modèle ; le coût est externe et incertain, affiché comme tel. La conclusion tient : la conformité n'est pas un pur coût mais un levier de capital, à prioriser par capital libéré, les leviers calibrables d'abord.

S1.5 CE QUI RESTE EN PERSPECTIVE : P1 ET P5

Deux piliers appelleraient un traitement propre mais *aucune donnée ne le soutient*, et il serait contraire à toute la démarche de les modéliser par des paramètres non identifiables. Ils restent donc en perspective.

- **P1 (gouvernance)** ressemble moins à un nœud qu'à un *modificateur systémique* : une gouvernance défaillante charge la sensibilité ρ de tous les piliers à la fois. Aucune donnée ne relie la qualité de gouvernance à une hausse de hasard : à borner, pas à estimer.
- **P5 (partage d'informations)** agit plutôt comme un *réducteur de fréquence*, l'alerte précoce diminuant les entrées. Là encore, rien ne le mesure.

Le fil de ce chapitre. Chaque pilier, correctement modélisé, révèle une structure *localement identifiée* (hétérogénéité de queue, accumulation symétrique, courbe de détection) que la donnée soutient sur un point et que l'on borne pour le reste. Toutes ces adaptations relèvent le niveau du

capital, et aucune ne renverse le classement des piliers. C'est, décliné composant par composant, la thèse du mémoire : le niveau est illustratif, l'ordre et les écarts sont ce qui résiste, et la limite d'identification se solde partout en une même spécification de reporting.

S2

Pistes pour de futurs mémoires d'actuariat

Idée directrice. Les pistes ci-dessous ne sont pas des suggestions générales. Chacune correspond à un travail que ce mémoire a instruit, outillé, puis laissé ouvert pour une raison qu'il énonce : une donnée qui n'existe pas encore, un protocole diffusé resté sans réponse, ou une limite dont il démontre qu'elle est structurelle. Elles sont classées par ce qu'il resterait à faire, du plus immédiatement exécutable au plus exploratoire.

S2.1 Exécuter l'élicitation structurée préparée par ce mémoire

L'annexe S4.63 décrit un protocole de Cooke complet, préparé et diffusé, resté sans réponse : la direction de la contagion n'étant pas identifiable sur la donnée disponible, le jugement d'experts est la seule source qui puisse la fixer. Le questionnaire est rédigé, sa partie d'étalonnage comporte dix questions de graine dont les valeurs vraies sont calculées et contrôlées, et la convention d'orientation des liens y est fixée sans ambiguïté.

Ce qui manque est le panel. Un mémoire qui conduirait cette élicitation auprès de responsables de la résilience opérationnelle disposerait donc d'un instrument prêt, et son apport propre porterait sur ce que ce mémoire n'a pas pu faire : la constitution du panel, la mesure de la calibration des experts sur les questions de graine, la pondération des avis qui en découle, et la confrontation des poids obtenus aux directions que le corpus documentaire indique déjà.

> **Une précaution à ne pas perdre.** Les valeurs vraies des questions de graine ne sont pas publiées dans ce mémoire, et ne doivent pas l'être : les publier brûlerait l'instrument pour toute élicitation ultérieure. Un futur mémoire qui reprendrait le protocole doit maintenir cette séparation entre le questionnaire et son barème.

S2.2 Documenter la dépendance entre gouvernance et gestion des incidents

Le chapitre 10.8 hiérarchise les données manquantes par la valeur d'information qu'elles portent, et ce classement est très inégal. Fixer le seul sens de la dépendance entre la gouvernance du risque TIC et la gestion des incidents lèverait 28,9 % de l'ambiguïté de capital ; fixer celui du lien entre tests et prestataires tiers n'en lèverait rien.

La dépendance la plus précieuse est précisément celle que le corpus de rapports publics ne couvre pas. La lecture documentaire a livré ce qu'elle pouvait livrer, et le reste exige de la donnée d'entité : une chronologie interne d'incidents, horodatée à la survenance et catégorisée par domaine de contrôle. Un mémoire conduit chez un assureur disposant de ce registre interne aurait accès à ce que ce travail a dû traiter en bornes, et pourrait mesurer de combien la bande se resserre réellement, là où ce mémoire ne peut en donner que la valeur théorique.

S2.3 Le second codage en aveugle du corpus de rapports post-incident

La direction des dépendances est codée à partir de rapports post-incident officiels. Ce codage est le fait d'un seul lecteur, et le mémoire le déclare comme une limite : un biais de narration mesuré, non supposé.

La réception d'un second codage indépendant est outillée : le script d'accord inter-codeurs ne fabrique rien en l'absence de donnée et attend le second jeu. Un futur travail qui ferait coder le même corpus en aveugle par un second lecteur produirait la mesure d'accord qui manque, et permettrait de dire si la direction retenue tient à la lecture ou au texte. C'est un apport modeste en volume mais qui porte sur le maillon le plus contesté de la chaîne.

S2.4 Calibrer l'amplitude des liens, et non leur seul sens

Le chapitre 10.8 établit un résultat qui ferme une porte et en ouvre une autre : même les dix directions connues, une bande de capital subsisterait, imputable à la seule amplitude des coefficients. Connaître le sens d'un lien ne donne pas sa force. L'identification partielle n'est donc pas un état provisoire que la donnée finirait par lever.

Toute la valeur d'information mesurée ici, jusqu'à 66 % de resserrement si l'on retenait le sens documenté par les rapports publics, porte sur la direction. L'amplitude reste posée, et le mémoire ne s'appuie que sur l'ordre des niveaux de propagation, le capital étant croissant en eux. Un mémoire qui s'attaquerait à l'estimation des amplitudes, par exemple sur des séries d'incidents d'une même entité où la sévérité transmise est observable, traiterait la moitié du problème que celui-ci laisse intacte.

S2.5 La dérive d'échelle des pertes, mesurée et non modélisée

Le backtest hors échantillon couvre correctement la forme de la queue et la loi de fréquence, mais pas le niveau de la charge annuelle. L'écart s'explique par une dérive de l'échelle des pertes dans le temps, que ce mémoire mesure et signale sans la modéliser : la calibration reste stationnaire.

Un mémoire portant sur la non-stationnarité de la sévérité cyber (inflation des coûts de remédiation, évolution des montants de rançon, effet du durcissement des garanties) corrigerait la seule composante du backtest que ce travail échoue à couvrir. Le diagnostic est posé et chiffré ici, ce qui donne à un tel travail son point de départ et son critère de réussite.

S2.6 Le passage de l'échelle sectorielle à l'entité

Le besoin de capital produit ici est ramené à l'échelle d'une entité au moyen de rapports publics de solvabilité, et le mémoire publie la borne inférieure de validité de cette opération. C'est le point où un lecteur d'entreprise demandera légitimement davantage.

Un mémoire conduit à l'intérieur d'une entité, avec son exposition réelle, son registre de prestataires au sens du règlement d'exécution et son propre historique d'incidents, remplacerait cet ancrage par une mesure directe. Il pourrait en outre traiter la question que ce travail ne fait qu'ouvrir : comment un besoin de capital de type ORSA, sensible à l'état de conformité, s'articule avec une Formule Standard qui ne comporte aucun module DORA.

S2.7 Le coût d'un sinistre multi-piliers : d'un exposant à un mécanisme

Lorsqu'un incident touche plusieurs piliers, ce mémoire additionne les coûts des piliers atteints. C'est une hypothèse de construction, et la plus lourde de celles qu'il ne teste pas : il la relâche par un exposant sur le nombre de piliers touchés et mesure ce qu'elle coûte, plutôt que de la corriger (§10.7). Le signe et l'ordre de l'écart survivent à toute la plage d'exposants ; le *sens* de l'effet, lui, ne se déclare pas, et ce n'est pas faute de mesure. Deux mécanismes tirent en sens contraire : la mutualisation de la remédiation rend le coût sous-additif, une même cellule de crise traitant plusieurs domaines à la fois, quand la saturation de la capacité de réponse le rend sur-additif au-delà d'un certain nombre de domaines simultanés. Un exposant unique ne peut pas porter les deux.

Un mémoire qui remplacerait cet exposant par un modèle de coût à contrainte de capacité trancherait ce que celui-ci se borne à encadrer : un tel modèle produit un exposant implicite inférieur à un à charge faible et supérieur à un à charge élevée, donc non monotone, et le sens de l'effet en devient une conséquence au lieu d'un scénario. L'enjeu se mesure, l'exposant mordant plus fort à l'état non conforme qu'à l'état conforme, élasticités 0,95 contre 0,39 et facteur 2,42, parce qu'il ne

pèse que sur les sinistres multi-piliers, majoritaires au seul état non conforme. L'hypothèse n'est donc pas neutre entre les deux états comparés. Ce qu'il faudrait pour l'identifier n'existe dans aucune source publique : un registre interne d'incidents portant, pour chaque incident, son coût et le nombre de domaines de contrôle touchés.

S2.8 La contagion entre entités, par le prestataire partagé

La cascade construite ici court entre les cinq piliers d'une entité, non entre entités, et c'est une restriction de périmètre assumée (chapitre 2). Une tension subsiste pourtant, et elle désigne l'extension naturelle : le canal d'accumulation par un prestataire commun est ancré sur la concentration du marché de l'informatique en nuage et sur les prestataires critiques désignés par les autorités européennes de surveillance, c'est-à-dire sur des faits concernant ce que les entités *partagent*, employés à paramétrer un canal interne à une entité. Le règlement est systémique pour cette raison : son pilier des tiers existe parce que de nombreuses entités dépendent des mêmes fournisseurs.

Une cascade à deux étages, entre piliers dans l'entité et entre entités par le prestataire partagé, changerait la nature de l'objet calculé, qui deviendrait un besoin de capital de place. La donnée existe, et ce mémoire la réclame déjà : le registre d'informations exigé par le règlement liste les prestataires de chaque entité, et croiser ces registres donne le graphe des fournisseurs partagés. Ce graphe est surtout *observé*, ce qui distingue cette piste de toutes les précédentes, partager un fournisseur étant un fait déclaré et non une direction reconstruite d'un récit : l'extension n'hériterait pas du problème d'identification qui commande ce travail. Elle en hériterait un autre, méthodologique, car les bornes de capital s'obtiennent ici en énumérant les sommets de l'ensemble admissible, ce que cinq piliers rendent possible et qu'un modèle à deux étages mettrait hors de portée. L'identification partielle devrait y passer par une optimisation plutôt que par une énumération, travail de méthode indépendant de toute donnée nouvelle qui conditionne la réutilisation de l'approche.

Ce qui se lègue avec ces pistes. Les quatre premières sont exécutables avec ce qui existe déjà au dossier : un protocole d'élicitation rédigé et étalonné, un classement chiffré des données manquantes, un dispositif de second codage en attente de sa donnée, et un diagnostic de dérive posé avec sa mesure. Les deux suivantes demandent un accès à de la donnée d'entité, que ce mémoire n'a pas eu. Les deux dernières sont d'une autre nature : elles ne demandent pas de compléter ce modèle mais d'en modifier la structure, sur les deux points où il sait lui-même qu'il est le plus contraint, le coût d'un sinistre qui touche plusieurs domaines et le périmètre d'une seule entité. Aucune ne suppose de reprendre le travail à zéro.

S3

Questionnaire d'élicitation

Décrire un instrument ne suffit pas à établir qu'il existe. Il est donc reproduit ici dans la forme sous laquelle il aurait été soumis, de façon qu'un lecteur puisse juger sur pièce ce que la section précédente affirme, et le réutiliser si la décision était rouverte. Le formulaire complet, avec sa consigne, son exemple traité, sa mention d'usage et de conservation et son accord signé du répondant, est versionné à part dans le dépôt du mémoire ; la présente annexe en reprend les deux tables et l'essentiel de la consigne.

> **L'instrument reproduit ici est la version révisée, et il diffère de l'exemplaire de travail.** Celui-ci portait une question d'étalonnage sur l'indice de queue de sévérité, retirée pour les deux motifs exposés plus haut. Elle n'est pas corrigée mais *remplacée*, et le remplacement a lui-même été arbitré : un indice de Gini de la concentration avait d'abord été retenu, puis écarté parce qu'il fait doublon avec la question qui compte les incidents portant la moitié du volume, et parce qu'une valeur vraie de 0,97 se devine sans rien connaître du dossier. La graine retenue porte sur la durée de confinement, qui est une performance de résilience et donc du même domaine que les cibles. L'exemplaire de travail ne doit pas être soumis en l'état.

La règle que s'impose l'instrument, vérifiée graine par graine. Une graine doit être une *grandeur réalisée*, reproductible par une sortie de script versionnée, et jamais un paramètre estimé. Les dix graines retenues sont donc des comptages, des parts, des délais ou des quantiles observés : aucune ne demande d'ajuster un modèle. Un script les calcule et leur applique quatre contrôles, portant sur ce caractère réalisé, sur la non-dégénérescence de la valeur, sur le respect des bornes naturelles, et sur le pouvoir de séparation entre experts. Une seule graine est signalée comme potentiellement devinable, celle qui porte sur la part du piratage ; elle est conservée avec son motif : sa valeur vraie est nettement au-dessus de la réponse spontanée, si bien qu'elle sépare malgré son caractère extrême.

Aucune graine ne porte une grandeur de capital, choix délibéré. Un praticien de la résilience observe des incidents, des délais et des concentrations ; il n'observe pas un quantile de charge annuelle. Noter un expert sur une telle grandeur mesurerait sa familiarité avec le présent mémoire, non son jugement sur le risque.

Consigne remise à l'expert

Comment répondre. Pour chaque quantité, donnez trois nombres : une valeur *basse* (5 %), une valeur *médiane* (50 %), une valeur *haute* (95 %), telles que vous estimez à 90 % de chances que la vraie valeur soit comprise entre votre 5 % et votre 95 %. Il n'y a pas de réponse attendue : donnez votre meilleure estimation *et* votre incertitude. Répondez même incertain, un intervalle large étant une réponse honnête et parfaitement valable. Ne cherchez pas les vraies valeurs : l'objet est de mesurer votre jugement.

Partie A, les dix questions d'étalonnage

Des quantités observées dans les bases du mémoire, dont la valeur vraie est connue de l'analyste et n'est pas affichée au répondant. Elles servent à pondérer les experts, non à les piéger. Les trois colonnes de droite sont vides dans les deux tables qui suivent : c'est l'espace de réponse du formulaire, non une donnée manquante.

	Quantité, sur les incidents notifiés de la chronologie	**5 %**	**50 %**	**95 %**
G1	Délai médian entre la survenance d'un incident et sa déclaration, en jours			
G2	Part des incidents déclarés plus de quatre-vingt-dix jours après leur survenance, en %			
G3	Délai médian de déclaration d'un incident de type piratage, en jours			
G4	Durée médiane entre le début et la fin d'exposition d'un incident, en jours			
G5	Nombre médian d'enregistrements touchés par incident			
G6	Nombre d'incidents qui portent à eux seuls la moitié du volume touché sur sept exercices			
G7	Part des incidents dont l'exposition a duré plus de trente jours, en %			
G8	Part des incidents de type piratage parmi ceux dont le vecteur est renseigné, en %			
G9	Part des lignes de la chronologie qui sont des doublons de notification d'un même incident, en %			
G10	Rapport du quatre-vingt-dix-neuvième centile à la médiane des pertes cyber du secteur financier			

Ce que chaque graine cherche à mesurer. G1 à G3 portent sur le *délai de détection*, qui est le canal que la conformité déplace le plus directement. G4 et G7 portent sur le *confinement*. G5, G6 et G10 portent sur la *concentration* de la perte, c'est-à-dire sur l'intuition de queue lourde. G8 porte

sur la structure des vecteurs et G9 sur la qualité de la donnée déclarative, dont un praticien de la notification a une expérience directe.

PARTIE B, LES SIX LIENS DIRIGÉS ENTRE PILIERS

Force du lien dirigé de j vers k, entre 0 et 1 : 0 signifie qu'une défaillance du pilier j n'entraîne jamais celle de k, 1 qu'elle l'entraîne quasi certainement dans la foulée. Les trois mêmes quantiles sont demandés.

> **Le sens des lettres n'est pas une coquetterie de notation.** La matrice du modèle s'écrit W_{jk} avec j la *source* et k la *cible* : la ligne émet, la colonne reçoit, et deux scripts vérifient cette convention avant tout calcul. Un formulaire qui demanderait la force du lien *de k vers j* ferait donc saisir la matrice *transposée*. Or c'est précisément entre une matrice et sa transposée que le chapitre 7 montre que la donnée ne tranche pas, et le chapitre 5 que le capital et la décision diffèrent. Une inversion de lettres dans l'instrument produirait donc exactement l'erreur que tout le mémoire s'emploie à ne pas commettre, et elle ne serait rattrapée par aucun contrôle numérique.

	Lien dirigé $j \to k$, j émet	**5 %**	**50 %**	**95 %**
B1	P1 → P2 : une défaillance de gouvernance entraîne des incidents			
B2	P2 → P1 : des incidents entraînent une défaillance de gouvernance			
B3	P4 → P2 : une défaillance d'un tiers entraîne des incidents			
B4	P1 → P4 : une défaillance de gouvernance entraîne une défaillance côté tiers			
B5	P3 → P1 : une défaillance des tests de résilience entraîne une défaillance de gouvernance			
B6	P5 → P2 : une défaillance du partage d'information entraîne des incidents			

Le couple B1 et B2 est l'objet même du mémoire. Les deux questions portent sur le *même* couple de piliers, dans les deux sens. Une donnée de co-occurrence ne les distingue pas ; un expert, lui, peut les séparer. C'est précisément la quantité que le chapitre 7 montre non identifiable : ce questionnaire aurait donc eu une valeur que nulle autre source du dossier ne porte.

Ce qui est fait des réponses. La partie A mesure la calibration du répondant, c'est-à-dire la justesse de ses intervalles, et son information, c'est-à-dire leur finesse ; ces deux grandeurs fixent son poids dans l'agrégation. La partie B, pondérée par ce poids et croisée avec les réponses des autres experts, produirait chaque lien de la matrice sous forme d'*intervalle* et non de point. Le traitement est automatique et aucune donnée d'incident n'est requise, seulement le jugement.

S4

Compléments retirés du corps du rapport

S4.1 La fréquence seule et la forme fermée de la perte unique

Seule, la fréquence porte le besoin de capital à 10 377 M€, facteur que la forme fermée de la perte unique retrouve à moins de 1 %.

S4.2 Un risque de perte, de propagation et de dépendance

S4.2.1 Définition et périmètre du risque cyber

Le risque cyber désigne les pertes liées à une défaillance des systèmes d'information, qu'elle soit malveillante ou non. Cette formulation, volontairement large, recouvre l'atteinte à la confidentialité des données, à leur intégrité et à la disponibilité des services qui en dépendent. Elle englobe aussi bien le vol d'un fichier clients que l'arrêt d'une chaîne de traitement, et aussi bien l'acte délibéré que l'erreur de manipulation.

Deux notions se confondent couramment et gagnent à être distinguées, car elles ne délimitent pas le même périmètre assurable. L'*incident* est tout événement, intentionnel ou non, qui affecte la sécurité d'un système d'information : il inclut les erreurs humaines, les pannes matérielles et les défauts de conception. La *cyberattaque* en est un sous-ensemble, caractérisé par trois conditions cumulatives, l'intention malveillante, un impact significatif pour l'organisation et l'aboutissement effectif de l'action (OpinionWay et CESIN, 2026). Une tentative neutralisée par les dispositifs de prévention n'est donc pas comptée comme une attaque, ce qui explique qu'un même exercice puisse afficher des millions de tentatives bloquées et quelques centaines d'attaques abouties.

Cette distinction commande le périmètre du présent travail. Le règlement DORA retient la notion la plus large, celle de l'incident lié aux technologies de l'information et de la communication, et non celle de la seule attaque. Une mise à jour défectueuse qui immobilise un système d'information entre pleinement dans son champ, sans qu'aucun adversaire soit en cause. Le modèle construit ici suit ce périmètre : il ne modélise pas une intention, il modélise une défaillance et sa propagation.

Quatre familles d'incidents. Du point de vue de leurs conséquences financières, la diversité des modes opératoires se ramène à quatre familles.

- Le **rançongiciel** chiffre les systèmes et conditionne leur restitution au versement d'une rançon. Son coût principal n'est en général pas la rançon mais l'interruption d'activité qu'il provoque et la reconstruction qu'il impose.
- La **fuite ou le vol de données** porte atteinte à la confidentialité. Son coût se matérialise avec retard, par les obligations de notification, les actions de groupe et les sanctions du règlement général sur la protection des données.
- Le **déni de service** rend un service indisponible sans compromettre les données. Il produit une perte d'exploitation nette, bornée dans le temps.
- La **défaillance d'un prestataire ou d'un logiciel tiers** atteint simultanément tous ses clients. C'est la seule des quatre familles dont la perte n'est pas individualisable : elle produit, par construction, des sinistres corrélés.

S4.2.2 Des incidents individuels aux chocs de cause commune

La quatrième famille change la nature du problème actuariel, et c'est elle qui justifie l'existence de ce mémoire. Les trois premières produisent des sinistres que la mutualisation absorbe : un portefeuille suffisamment large en lisse la charge, et la loi des grands nombres fait son office. La quatrième produit une *accumulation* que la mutualisation ne réduit pas, puisqu'un même événement, la compromission d'un prestataire partagé, frappe simultanément un grand nombre d'assurés qui n'ont d'autre lien entre eux que ce fournisseur.

Ce passage de l'incident individuel au choc de cause commune se joue aussi à l'intérieur d'une seule entité, et c'est le niveau que le mémoire modélise. Les domaines de maîtrise d'une organisation ne cèdent pas indépendamment : une gouvernance défaillante retarde la détection des incidents ; une dépendance non maîtrisée à un prestataire ouvre une porte que les tests n'ont pas explorée ; une détection tardive prive le partage d'informations de sa matière. La défaillance ne reste pas dans son domaine, elle se propage.

Et la propagation a un sens, ce qui n'est pas un détail. Une défaillance qui *entraîne* les autres n'appelle pas la même remédiation qu'une défaillance qui les *subit*, alors que les deux se ressemblent dans les statistiques disponibles, lesquelles n'enregistrent qu'une co-occurrence. Distinguer ces deux situations est l'objet du mécanisme construit au chapitre 5, et la difficulté de les distinguer est celle du chapitre 7.

S4.2.3 Études de cas de dépendance, de propagation et d'accumulation

Quatre incidents publics suffisent à illustrer les trois mécanismes. Ils sont retenus non pour leur ampleur mais parce que chacun met en défaut une hypothèse différente.

WannaCry, 2017 *: l'échelle de la propagation.* Un rançongiciel auto-propagable, exploitant une faille du protocole de partage de fichiers Windows, s'est propagé en quelques jours à des organisations de dizaines de pays, dont des hôpitaux du service de santé britannique et des chaînes de

production industrielles. Sur les onze mois qui suivent, un seul éditeur de sécurité déclare avoir bloqué plus de 64 millions de *tentatives* en Russie et près de 19 millions en Ukraine comme en Inde (Avast Threat Labs, 2018).

Ces tentatives ne sont pas des sinistres, et la distinction posée à la sous-section 1.1.1 vaut ici pleinement. Une tentative bloquée n'est ni un incident ni une perte : ce que ces nombres mesurent est la *persistance de l'exposition* d'une même vulnérabilité, pas une sinistralité. Ils ne sont donc comparables à aucune grandeur du modèle, et ils ne sont pas cités pour leur niveau. Ils établissent un seul point, qui est celui de la sous-section 1.2.2 : une vulnérabilité unique reste sollicitée à cette échelle près d'un an après sa divulgation, si bien que l'exposition qu'elle crée est commune à tous ceux qui la portent et n'est réduite par aucune mutualisation (figure S4.1).

NotPetya, 2017 *: la propagation.* Un logiciel destructeur diffusé par la mise à jour d'un logiciel comptable ukrainien s'est propagé aux réseaux de groupes internationaux et en a paralysé l'activité pendant plusieurs semaines. L'incident naît chez un prestataire (P4), se propage faute de cloisonnement et de gouvernance des accès (P1), et met à l'épreuve la gestion de crise (P2). Son traitement assurantiel a en outre donné lieu à des contentieux sur l'exclusion de guerre des contrats, ce qui rappelle qu'un sinistre cyber peut être avéré sans être couvert.

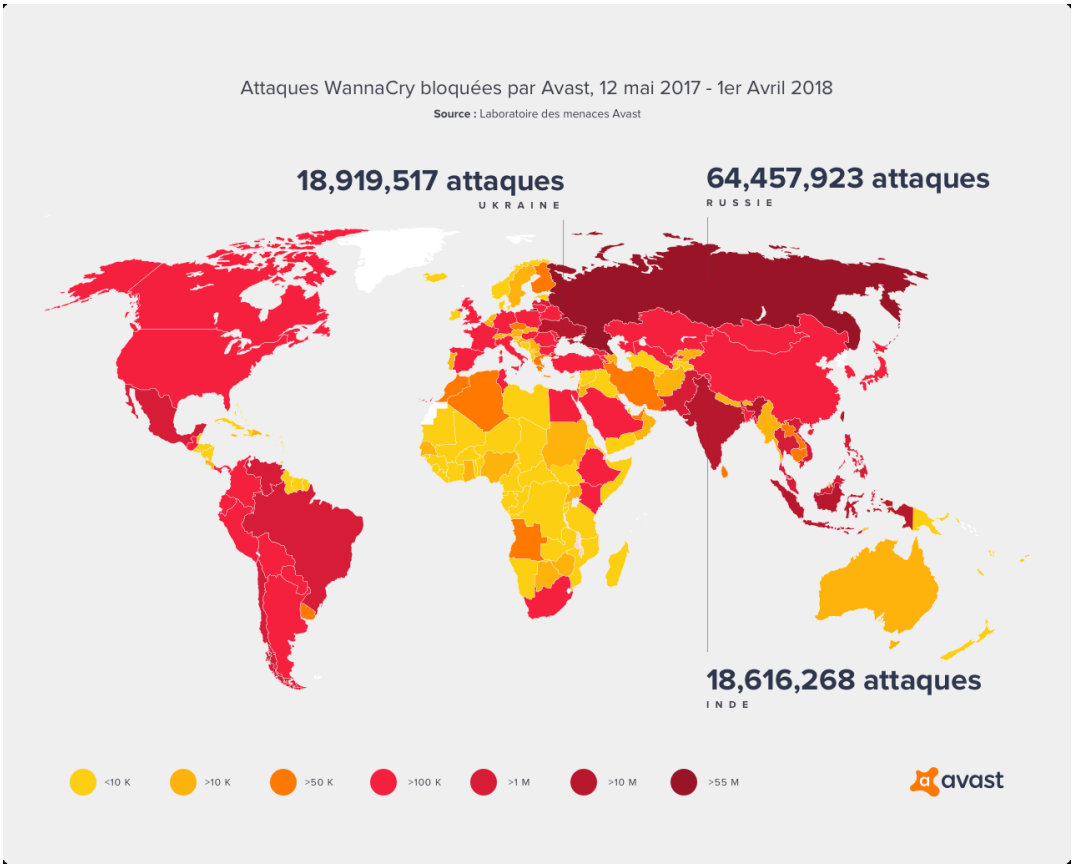


FIGURE S4.1. Tentatives d'attaque WannaCry bloquées par pays, 12 mai 2017 au 1er avril 2018. L'échelle logarithmique de la légende (de moins de 10 000 à plus de 55 millions) donne la mesure de la dispersion entre pays. Source : laboratoire des menaces Avast (Avast Threat Labs, 2018).

MOVEit, 2023 *: l'accumulation.* Une vulnérabilité d'un logiciel de transfert de fichiers, exploitée par un groupe criminel, a permis de dérober des données chez des milliers d'organisations, souvent atteintes à travers leurs propres prestataires. C'est un choc de cause commune à l'état pur : une seule défaillance tierce produit de nombreux sinistres simultanés. Le mémoire l'utilise comme expérience naturelle au chapitre 7.

CrowdStrike, 2024 *: la dépendance sans adversaire.* Une mise à jour défectueuse d'un logiciel de sécurité a bloqué des millions de postes de travail dans le transport aérien, la banque et la santé. Aucune attaque n'est en cause : l'incident relève de la dépendance à un prestataire (P4) et de l'absence de tests progressifs avant déploiement (P3). Il entre pleinement dans le champ de DORA, et il montre qu'un périmètre restreint aux seules attaques manquerait une part substantielle du risque que le règlement vise.

Ces quatre cas ont une structure commune : un incident naît sur un domaine de contrôle et en dégrade d'autres, dans un ordre. Aucune mesure de dépendance symétrique ne restitue cette structure.

S4.3 UN RISQUE DIFFICILE À ASSURER ET À CAPITALISER

S4.3.1 Fréquence, sévérité et contrat d'assurance

La charge annuelle d'un risque se décompose classiquement en un nombre d'événements et un coût par événement, la fréquence et la sévérité. Cette décomposition n'est pas une commodité de présentation : elle sépare deux mécanismes que les mêmes mesures ne réduisent pas. Une sensibilisation des collaborateurs agit sur la fréquence, une capacité de reprise agit sur la sévérité, et un ratio agrégé qui mélange les deux ne dit pas laquelle est à l'œuvre. Le mémoire applique cette discipline jusqu'au bout, en décomposant l'écart de capital entre états de conformité plutôt qu'en l'annonçant en niveau global (chapitre 9).

Le contrat d'assurance introduit deux transformations qu'il faut avoir en tête avant toute comparaison de montants. La *franchise* laisse à la charge de l'assuré la première tranche du sinistre ; la *capacité* plafonne l'engagement de l'assureur. Ce que l'assureur verse n'est donc ni la perte subie ni une fraction fixe de celle-ci, mais une perte subie transformée par ces deux paramètres, qui varient d'un contrat à l'autre et d'un exercice à l'autre. Une charge indemnisée et une perte brute ne se comparent ni en niveau ni en quantile.

Cette transformation crée une ambiguïté d'interprétation. Sur des données agrégées, une baisse de franchise et une aggravation réelle de la menace produisent le même signal, une charge indemnisée qui monte. Deux mécanismes, une seule observable, et rien dans la donnée pour les séparer. C'est, à l'échelle du marché, la situation exacte que le chapitre 7 rencontre à l'échelle des domaines de contrôle, et le traitement retenu y est le même : borner plutôt que poser.

S4.3.2 Dépendance, accumulation et risque systémique

L'assurabilité d'un risque suppose plusieurs conditions, et le cyber les met toutes en tension. La *mutualisation* suppose des sinistres suffisamment indépendants : la défaillance tierce la met en défaut par construction. L'*aléa* suppose une survenance non contrôlée par un tiers intéressé : une attaque ciblée le contredit. La *quantification* suppose un historique suffisant, dont la sous-section suivante montre l'absence là où elle compte. L'*aléa moral* et l'*anti-sélection* sont enfin renforcés par l'asymétrie d'information entre l'assureur et l'assuré sur l'état réel du système d'information de ce dernier.

Ce dernier point mérite d'être retenu, car c'est celui sur lequel la réglementation agit. DORA réduit l'asymétrie : il impose un registre des accords avec les prestataires, une notification des incidents majeurs et des tests de résilience, c'est-à-dire un ensemble d'informations observables sur la maîtrise du risque. Une méthode qui traduit ce niveau de maîtrise en capital utilise donc une information que le règlement rend disponible, et qui ne l'était pas avant lui.

S4.3.3 Rareté des données extrêmes et limite de l'historique français

Le capital de solvabilité se mesure par un *quantile* à 99,5 % de la charge annuelle, c'est-à-dire par le montant qui n'est dépassé qu'une année sur deux cents. Il se joue donc entièrement dans les sinistres les plus lourds, et non dans les sinistres courants. Or la donnée française y est presque vide, ce que la section 1.3 établit en chiffres.

La conséquence est méthodologique et elle engage tout le mémoire. La méthode usuelle d'estimation d'une queue de distribution, dite *par dépassement de seuil*, ne retient que les pertes au-dessus d'un montant élevé et ajuste une loi sur ces seules observations. Elle exige donc un effectif suffisant au-dessus du seuil, et l'historique national n'en offre aucun : il s'arrête avant le haut de la distribution, là précisément où se joue le quantile recherché. Une estimation conduite sur cette base serait instable d'un exercice à l'autre et sous-estimerait le risque, faute d'avoir observé les pertes qui le portent. C'est le motif, repris au chapitre 3, de calibrer la sévérité sur une base internationale.

Cette rareté ne traduit pas une protection particulière du marché français : les analyses de sinistres européennes relèvent un recul d'environ 20 % des sinistres cyber en 2024 qui laisse le niveau près d'un tiers au-dessus des exercices 2020 à 2022 (Marsh, 2025), et le marché britannique voisin est décrit comme plus développé et plus exposé aux sinistres sévères (UK Government, Department for Science, Innovation and Technology, 2025).

S4.4 DIFFUSION DE LA COUVERTURE ET FRAGILITÉS TECHNIQUES DU MARCHÉ FRANÇAIS

S4.4.1 Périmètre du portefeuille LUCY et précautions d'interprétation

L'étude LUCY de l'AMRAE, dont l'édition 2026 porte sur l'exercice 2025, observe le marché français à partir de 20 996 polices et 1 251 sinistres déclarés, recueillis auprès de douze courtiers

et d'un assureur (AMRAE, 2026). La série est engagée depuis 2019, ce qui donne sept exercices comparables et permet de distinguer un régime d'un accident d'exercice. L'auteur de ce mémoire a co-écrit, avec son tuteur, l'analyse actuarielle de cette édition publiée par Nexialog Consulting (Rapior et Kaddouri, 2026).

Cette source est employée sous un statut précis, celui de *citation externe non recalculable* : ses valeurs sont reprises telles qu'elle les publie, sans que le mémoire soit en mesure de les recalculer depuis la donnée d'origine, qui ne lui appartient pas. Aucune n'entre donc dans un calcul du modèle et aucune ne porte un montant de capital. Ce qui est vérifiable l'est néanmoins : les valeurs sont recopiées dans un script du dépôt, qui contrôle que le rapport des sinistres aux primes redonne bien la série des ratios publiée, que la somme des classes de taille redonne la charge annuelle sur les sept exercices, et que chaque multiplicateur cité se retrouve à partir des niveaux qui l'encadrent. Ces contrôles portent sur la fidélité de la recopie, non sur la collecte ni sur le périmètre de l'étude citée, qui relèvent de celle-ci.

> **Ces montants ne se comparent pas à ceux du mémoire.** La charge citée dans cette section est une charge *indemnisée*, donc nette de franchise et plafonnée par la capacité, au sens de la sous-section 1.2.1. Elle vaut 83,2 M€ en 2025 contre 54,5 l'exercice précédent, soit une hausse de 53 %. La sévérité que le présent mémoire modélise est d'une tout autre nature : c'est la perte *brute* subie par une entité financière, avant toute assurance. Les rapprocher conduirait à lire un écart de définition comme une contradiction.

S4.4.2 Soft market, baisse des prix et dégradation de la sinistralité

Entre 2024 et 2025, le nombre d'entreprises assurées croît de 49 % quand les primes souscrites reculent de 3 %, et le ratio sinistres sur primes remonte pour le troisième exercice, de 12 % en 2023 à 27 % en 2025, loin toutefois des 169 % de 2020. Le marché se diffuse donc par le volume et non par le budget : davantage d'entreprises sont couvertes, pour une prime moyenne plus faible, au moment même où la sinistralité remonte (figure S4.2).

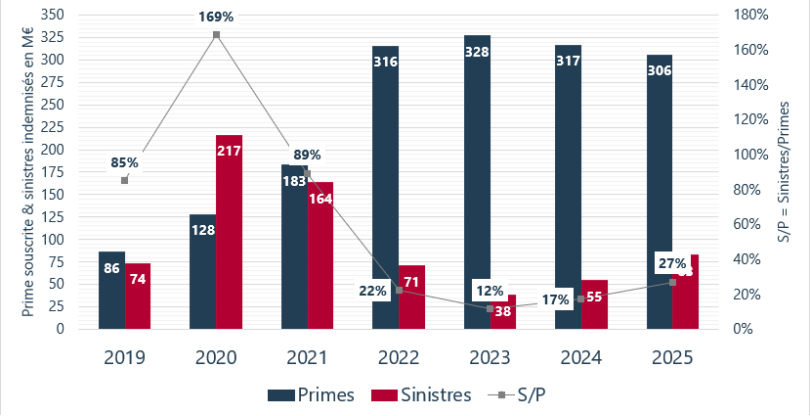


Figure S4.2. Primes souscrites, sinistres indemnisés et ratio sinistres sur primes, 2019–2025. La sinistralité remonte pour le troisième exercice consécutif alors que les primes reculent. Source : rapport LUCY 2026, Nexialog Consulting (Rapior et Kaddouri, 2026).

Cette configuration est instable par construction, et c'est ce qui donne un intérêt opérationnel à une mesure du risque indépendante du cycle tarifaire. Le recul du taux de prime atteint 33 % sur les grandes entreprises et 23 % sur les entreprises de taille intermédiaire : l'assouplissement est réel, mais il ne repose sur aucune amélioration mesurée de la maîtrise du risque.

S4.4.3 Un régime de sévérité en 2024, un régime de fréquence en 2025

L'indicateur suivi par le marché est le ratio sinistres sur primes, c'est-à-dire la part de la prime qui part en indemnisation. Il a monté deux exercices de suite, mais pour deux raisons opposées, et seule sa décomposition le montre. La charge d'une année se met en effet sous la forme d'un produit de deux termes, le *nombre* de sinistres survenus et le *sinistre moyen*. Le tableau compare chaque terme à sa valeur de l'année précédente, sous la forme d'un multiplicateur.

	nombre	**sinistre moyen**	**charge**	**régime**
Marché, exercice 2024	×0,73	×1,96	×1,43	sévérité
Marché, exercice 2025	×2,79	×0,55	×1,53	fréquence
Exercice 2025*, par bloc*				
grandes entreprises	×1,24	×0,82	×1,02	absorbé
bloc intermédiaire	×2,14	×1,65	×3,53	les deux
micro-entreprises	×9,52	×0,73	×6,97	nombre seul

En 2024 le nombre de sinistres a baissé alors que leur coût moyen a doublé : la charge a monté parce que les sinistres étaient plus lourds. En 2025 c'est l'inverse, le coût moyen a baissé de moitié alors que le nombre a presque triplé. Le ratio seul ne permet pas de distinguer ces deux situations, qui n'appellent pourtant pas les mêmes mesures. Le bloc intermédiaire est le seul segment où le nombre et le coût moyen augmentent en même temps, ce qui explique sa charge multipliée par 3,53.
Ces multiplicateurs portent sur le *nombre* de sinistres, un total, et non sur la *fréquence*, qui le rapporte au nombre d'assurés : l'égalité charge = nombre × coût moyen n'est exacte qu'avec le nombre.

S4.4.4 Polarisation du marché et limites de la donnée assurantielle

La divergence entre le prix et le risque ne se répartit pas uniformément (figure S4.3). Le segment dont la sinistralité progresse le plus n'est pas celui dont le tarif se redresse, et les multiplicateurs les plus spectaculaires portent sur les micro-entreprises, dont la part dans la charge totale reste marginale. Un multiplicateur hiérarchise des dynamiques, jamais des enjeux.

La limite qui engage le mémoire est ailleurs, et elle est dans la queue. Deux exercices sur sept ne portent aucun sinistre de la classe de taille la plus haute ; un exercice en porte 135 M€ et l'exercice sous revue 19 M€, pour un seul sinistre dépassant 10 M€. Le maximum de la série vaut 7,11 fois le montant de l'exercice sous revue, ce qui donne la mesure de l'irrégularité (figure 1.1).

C'est la mesure annoncée à la sous-section 1.2.3, et elle tranche le choix de la base de calibration.

S4.5 Le règlement DORA, de la résilience opérationnelle à la maîtrise des dépendances

S4.5.1 Le cadre réglementaire européen du cyber

Le cadre européen s'est construit par strates, et quatre textes en forment aujourd'hui l'ossature. La directive sur la sécurité des réseaux et des systèmes d'information a posé des exigences minimales de sécurité et de notification pour les opérateurs de services essentiels ; sa refonte, dite NIS 2 (Union européenne, 2022b), en a élargi le périmètre aux entités *essentielles* et *importantes* et a rendu l'organe de direction responsable des mesures de gestion du risque. Le règlement général sur la protection des données (Union européenne, 2016) fixe, en parallèle, un régime de notification et de sanction propre aux données personnelles. La directive sur la résilience des entités critiques (Union européenne, 2022c) étend la même logique aux activités dont l'interruption affecte des fonctions sociétales vitales, et vise la continuité physique autant que numérique. Le règlement sur la cyberrésilience (Union européenne, 2024), enfin, déplace la contrainte vers l'amont : il l'impose aux produits comportant des éléments numériques plutôt qu'à leurs utilisateurs.

Aucun de ces textes ne porte sur la continuité d'une activité financière. Les deux premiers visent la sécurité et la confidentialité, le troisième la criticité sectorielle, le quatrième la conformité du produit mis sur le marché. C'est ce que le règlement sur la résilience opérationnelle numérique du secteur financier, dit DORA (Union européenne, 2022a), vient combler. Entré en application le 17 janvier 2025, il s'adresse à une vingtaine de catégories d'entités financières, dont les entreprises d'assurance, et il déplace l'objectif : il ne s'agit plus seulement d'empêcher l'incident mais de garantir que l'entité *résiste, réagit et se rétablit* lorsqu'il survient. Cette bascule est celle qui rend le sujet actuariel, car un objectif de continuité se mesure en pertes évitées et en durées d'indisponibilité, donc en grandeurs que l'on peut chiffrer.

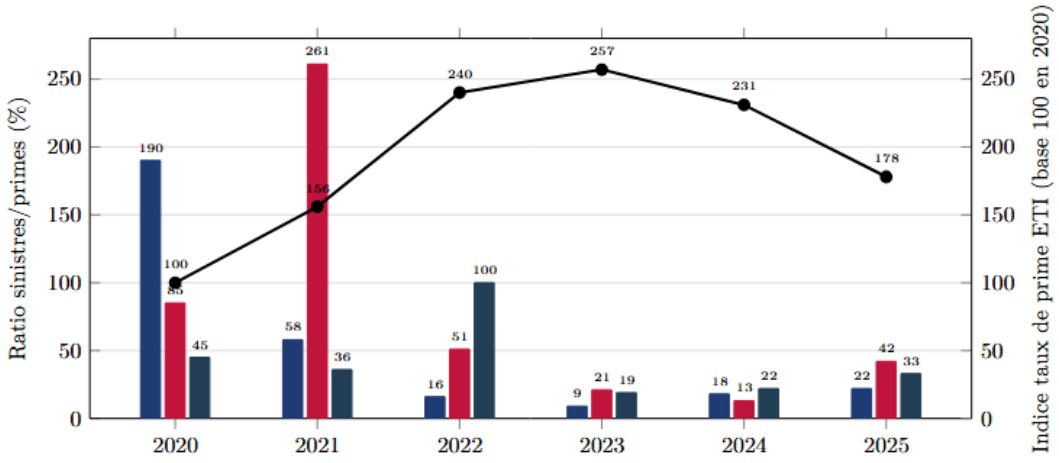


Figure S4.3. Divergence entre le prix et le risque par segment. Le segment dont la sinistralité progresse le plus n'est pas celui dont le tarif se redresse. Source : rapport LUCY 2026, Nexialog Consulting (Rapior et Kaddouri, 2026).

Ce que le mémoire retient de cet ensemble, et ce qu'il laisse de côté. Seul DORA est modélisé, et le motif est de mesure et non d'importance : il est le seul de ces textes à découper la résilience en domaines de contrôle dont la défaillance se lit dans des données d'incidents, et le seul dont la non-conformité s'adresse à l'entité qui porte le capital. Les autres interviennent comme contexte. Le règlement sur la cyberrésilience, applicable à partir de décembre 2027, agit sur la fréquence future des vulnérabilités logicielles, donc sur une grandeur que la calibration du chapitre 3 estime sur l'historique et ne projette pas. Les cadres applicables à l'intelligence artificielle et à l'identité numérique ne sont pas traités : la cartographie de la sous-section 1.5.1 fait apparaître un risque lié à l'intelligence artificielle, mais aucune source ne le rattache aujourd'hui à un domaine de contrôle de DORA, et l'y rattacher par analogie serait poser ce que le mémoire prétend mesurer.

S4.5.2 Les cinq piliers de DORA

Le règlement organise la résilience autour de cinq domaines, que le mémoire note P1 à P5 et traite comme des domaines de *contrôle* plutôt que comme des obligations à cocher.

- **P1, gouvernance du risque lié aux technologies** (articles 5 à 16). L'organe de direction est explicitement responsable du dispositif, et cette responsabilité n'est pas délégable : stratégie de résilience, cartographie des actifs informationnels et des dépendances critiques, politique de sécurité documentée, et contrôle interne continu plutôt qu'audits ponctuels.
- **P2, gestion, classification et notification des incidents** (articles 17 à 23). Détection, qualification selon des critères de matérialité, puis notification des incidents *majeurs* selon un calendrier resserré : alerte sous quatre heures après classification et au plus tard vingt-quatre heures après détection, rapport intermédiaire sous soixante-douze heures, rapport final sous un mois.
- **P3, tests de résilience opérationnelle numérique** (articles 24 à 27). Les procédures ne se documentent plus, elles s'éprouvent. Les entités identifiées comme significatives sont soumises à des tests de pénétration guidés par la menace (article 26), à mener au moins tous les trois ans en conditions proches du réel.
- **P4, gestion du risque lié aux prestataires tiers** (articles 28 à 44). Recensement des contrats critiques dans un registre d'informations harmonisé, clauses contractuelles impératives de l'article 30, stratégie de sortie, et surveillance directe des prestataires tiers jugés critiques par les autorités européennes, jusqu'au troisième rang de la chaîne de sous-traitance.
- **P5, partage d'informations sur les cybermenaces** (article 45). Échange, sur une base volontaire et encadrée, de renseignements entre entités financières. C'est le pilier le moins mobilisable dans un calibrage actuariel, et il rappelle que la résilience porte une dimension collective au-delà de l'entité.

La lecture que le mémoire en fait. Ces cinq domaines ne sont pas indépendants, et c'est l'hypothèse de travail de tout le document. La défaillance de l'un dégrade la capacité de l'entité à tenir les autres, selon le mécanisme décrit à la sous-section 1.1.2 et formalisé au chapitre 5. La non-conformité ne reste pas dans son pilier.

S4.5.3 Prestataires TIC, concentration et propagation du risque

Le quatrième pilier est celui qui a motivé le règlement autant que les autres réunis. La chaîne de sous-traitance informatique du secteur financier est concentrée sur un petit nombre de fournisseurs d'infrastructure, de logiciels de gestion et de services de sécurité, si bien qu'une défaillance chez l'un d'eux atteint simultanément de nombreuses entités sans qu'aucune n'ait commis de faute. C'est la raison pour laquelle DORA ne se contente pas d'exiger des clauses contractuelles : il instaure un cadre de surveillance directe des prestataires désignés comme critiques, ce qui est une nouveauté dans l'architecture prudentielle européenne.

Cette concentration n'est pas une conjecture : la sous-section 1.5.1 la mesure, en montrant que l'attaque indirecte par un tiers est, parmi les vecteurs dont la part s'élève avec la taille de l'entité, celui dont le *niveau* est de loin le plus haut.

Le premier bilan des notifications la confirme du côté des victimes. En 2025, les sociétés de gestion ont adressé à l'Autorité des marchés financiers 47 notifications initiales, dont 31 ont été confirmées comme incidents majeurs ; 27 d'entre eux, soit 87 %, trouvent leur origine chez un prestataire, par cyberattaque (68 %) ou par défaillance accidentelle (19 %) (Autorité des marchés financiers, 2026). Un incident y est compté par société déclarante, et la compromission d'un même prestataire en touche plusieurs : c'est l'accumulation du quatrième pilier, observée sur une population entière. Cette part mesure une origine, non une probabilité de transfert entre domaines de contrôle, et ne calibre aucun paramètre du modèle. L'écart entre notifications et incidents confirmés annonce ce que sera le registre : une collecte au-dessus d'un seuil de matérialité, non un recensement exhaustif.

Le registre d'informations pèse plus que les autres exigences pour la modélisation. En imposant le recensement exhaustif des contrats TIC critiques et de leurs chaînes de sous-traitance, le règlement produit une donnée exploitable pour modéliser le risque de concentration technologique. Cette donnée faisait défaut à l'évaluation interne des risques traditionnelle, qui décrivait la dépendance sans pouvoir la chiffrer. C'est le point de contact le plus direct entre une obligation réglementaire et une entrée de modèle. La section 10.8 y revient pour dire précisément ce que ce registre donnera et ce qu'il ne donnera pas : il porte sur les accords contractuels, donc sur la dépendance *déclarée*, et non sur l'ordre dans lequel les défaillances s'enchaînent.

S4.5.4 Les autorités françaises et la supervision de la résilience numérique

La supervision se répartit entre plusieurs autorités aux compétences distinctes. L'Autorité de contrôle prudentiel et de résolution supervise les entreprises d'assurance et intègre le risque informatique à sa démarche prudentielle ; l'Autorité des marchés financiers encadre les sociétés de gestion ; l'Agence nationale de la sécurité des systèmes d'information porte la prévention et la réponse aux incidents affectant les systèmes critiques ; et la Commission nationale de l'informatique et des libertés veille au respect du régime des données personnelles. Au niveau européen, les trois autorités de surveillance sectorielles coordonnent la désignation et la surveillance des prestataires tiers critiques.

Cette répartition a une conséquence pour le mémoire : aucune de ces autorités ne publie de

probabilité de propagation entre domaines de contrôle. Elles publient des attentes prudentielles et des échelles de maturité, ce qui n'est pas la même chose. C'est le motif pour lequel les valeurs de propagation du modèle sont posées à dire d'expert puis bornées, et non présentées comme calibrées sur une source officielle.

S4.6 Un risque prioritaire sans traduction prudentielle directe

S4.6.1 La perception prospective selon France Assureurs et le CESIN

Deux sources annuelles, de nature différente, situent le risque cyber. La cartographie prospective de la profession classe les risques selon leur fréquence et leur gravité anticipées (France Assureurs, 2026) ; le baromètre mené auprès des responsables de la sécurité des systèmes d'information recense les vecteurs et les conséquences *déclarés* (OpinionWay et CESIN, 2026). La première mesure une anticipation, la seconde un constat.

Le risque cyber sature au sommet de la cartographie. Il occupe la première place pour le huitième exercice consécutif, avec un score moyen de 4,1 sur 5, devant l'environnement économique à 4,0 et le dérèglement climatique à 3,9. Mais son score ne monte plus : il culmine à 4,48 lors de l'édition 2022 et redescend à 4,10 en 2026. Une préoccupation installée au sommet d'un classement cesse d'être informative par son rang, et le renseignement passe dans la manière dont elle se déforme (figure S4.4).

Et la déformation est un changement de régime. Entre 2025 et 2026, le risque de cyberattaques recule de 0,45 point en fréquence anticipée et progresse de 0,25 point en sévérité : moins d'événements attendus, mais plus lourds.

Et le cyber n'est pas seul dans ce régime. Six risques de la cartographie se déplacent nettement, et deux seulement gagnent en sévérité tout en reculant en fréquence : le cyber, à +0,25 point de sévérité pour −0,45 de fréquence, et la qualité des données et la conformité des processus informatiques, à +0,30 pour −0,20. C'est ce second qui progresse le plus en sévérité des deux. Le déplacement le plus fort de l'édition en sévérité appartient en revanche à l'environnement politique, à +0,32, mais il s'accompagne d'une hausse de fréquence de +0,30 : ce n'est donc pas le même régime. La cartographie fait par ailleurs désormais figurer un risque de non-conformité et de sanctions ainsi qu'un risque lié à l'intelligence artificielle. La préoccupation de la profession se déplace de la menace vers sa *gouvernance*, ce qui est l'objet même de DORA.

Le baromètre confirme le recul de fréquence et nomme le vecteur qui compte. Sur l'exercice 2025, 40 % des entreprises interrogées déclarent avoir subi au moins une cyberattaque significative. Parmi les 159 qui en ont constaté une, l'hameçonnage domine à 55 %, devant l'exploitation d'une faille à 41 %. Chaque entreprise attaquée cite en moyenne 3,3 vecteurs, contre 4,0 à la vague précédente : une attaque n'emprunte presque jamais un chemin unique (figure S4.5).

Le troisième vecteur est celui que le mémoire modélise. L'attaque indirecte par un tiers pèse 35 %, et sa part monte à 43 % chez les grandes entreprises. Plus une entité est grande, plus son exposition passe par ses prestataires : c'est le domaine P4, mesuré de l'extérieur par une source sans lien avec ce travail.

Mais c'est son niveau qui compte, non sa croissance. Cinq vecteurs sont significativement plus fréquents chez les grandes entreprises, et l'attaque par un tiers n'est ni celle qui progresse le plus en points, la fuite par erreur de configuration gagnant neuf points contre huit, ni celle qui progresse le plus en proportion, où elle arrive au contraire *dernière* des cinq. Ce qui la distingue est qu'elle part déjà du niveau le plus élevé et le reste : 43 % contre 36 % pour la deuxième. La dépendance aux tiers n'explose donc pas avec la taille, elle est dominante à toutes les tailles.

Trois des quatre autres vecteurs concernés, la fuite par erreur de configuration à 36 %, l'activation d'un composant malveillant à 22 % et l'exfiltration par un accès légitime à 21 %, relèvent de la gouvernance des accès, c'est-à-dire du domaine P1. Le cinquième, l'hypertrucage à 9 %, relève de l'ingénierie sociale et n'entre dans aucun des deux. Les vecteurs qui montent avec la taille sont donc ceux qui passent par un tiers ou par un accès autorisé, non ceux qui forcent un périmètre.

Les conséquences, et celle qu'il faut isoler. Quatre entreprises attaquées sur cinq déclarent un impact sur leur activité, soit 81 % contre 19 % sans impact. Les conséquences dominantes sont la perturbation de la production à 28 % et la perte d'image à 26 %, devant la compromission de savoir-

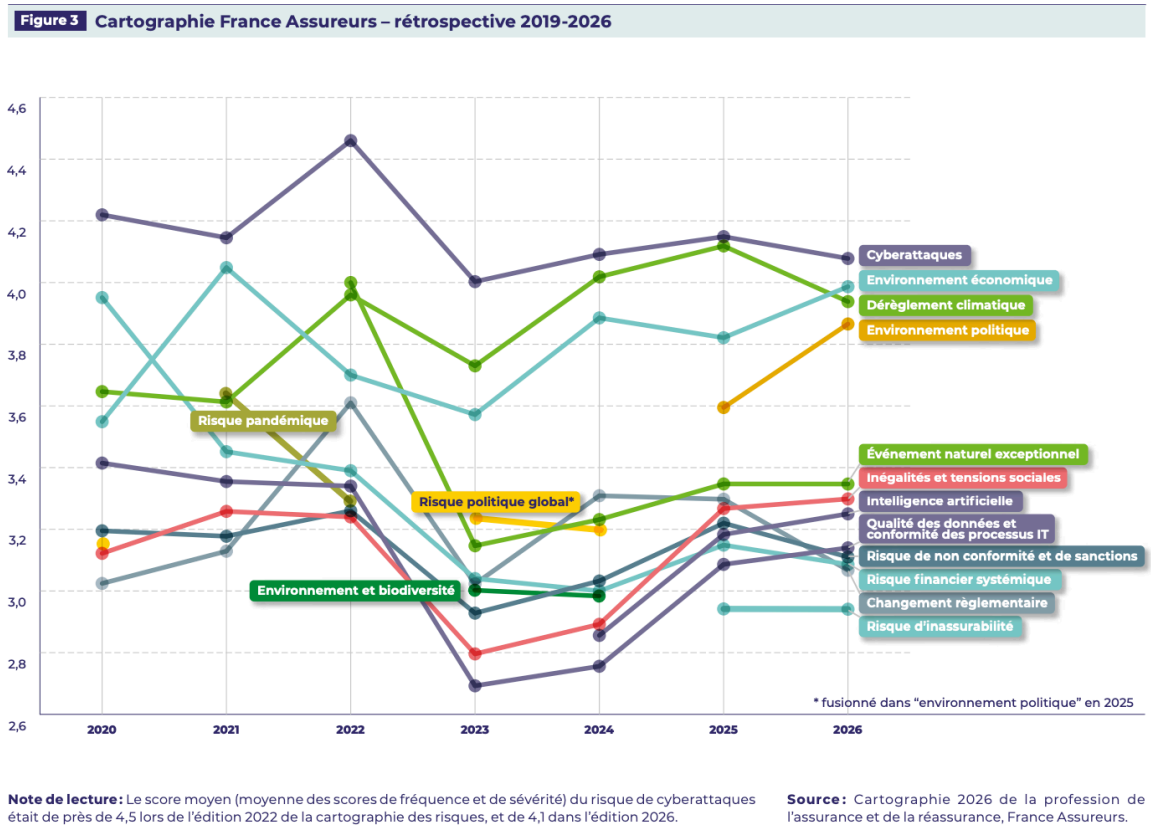


FIGURE S4.4. Trajectoire des scores de la cartographie prospective, 2020–2026. Le risque de cyberattaques reste au premier rang mais son score a cessé de monter depuis 2022. Source : cartographie prospective des risques, France Assureurs (France Assureurs, 2026).

faire et la perte de chiffre d'affaires à 18 % chacune. La sanction d'une autorité ne concerne que 3 % des cas : le canal réglementaire est réel mais minoritaire, et un modèle qui ferait de l'amende le principal coût de la non-conformité se tromperait de mécanisme.

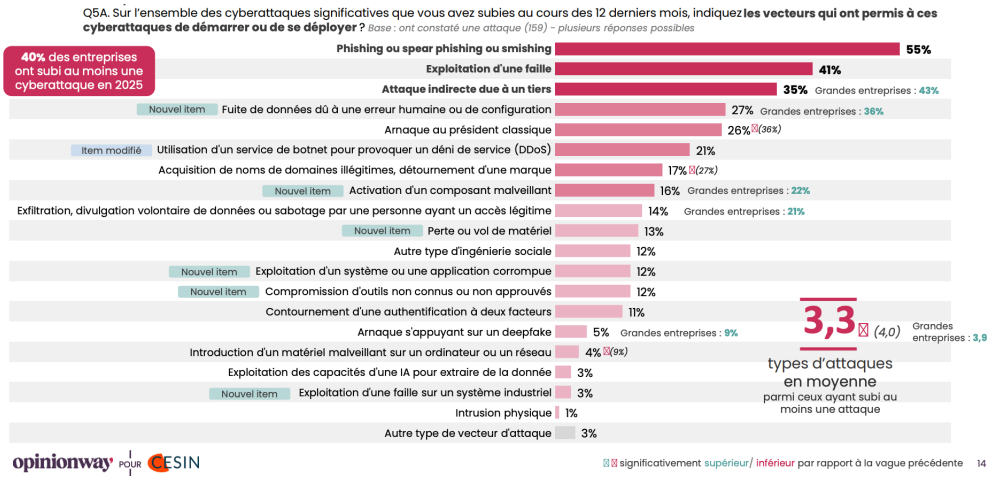


FIGURE S4.5. Vecteurs ayant permis aux cyberattaques de démarrer ou de se déployer, exercice 2025. Les mentions de droite donnent la part chez les grandes entreprises là où elle diffère significativement de la moyenne. Source : baromètre de la cybersécurité des entreprises, OpinionWay pour le CESIN (OpinionWay et CESIN, 2026).

Une conséquence mérite d'être isolée. La déconnexion par les tiers, c'est-à-dire la mise en quarantaine de l'entité par ses propres partenaires, est citée dans 12 % des cas. Elle renverse le constat précédent : une entité n'est pas seulement atteinte *par* ses partenaires, elle est aussi coupée *par* eux lorsqu'elle est atteinte. La dépendance joue dans les deux sens, et les deux sens n'ont ni le même coût ni la même prévention. Aucune mesure de dépendance symétrique ne peut les distinguer.

> **Deux sources qui semblent se contredire, et ne se contredisent pas.** Le baromètre et la cartographie décrivent un recul de la fréquence, quand le marché assuré affiche un nombre de sinistres presque triplé (sous-section S4.4.3). Les deux constats sont compatibles : le nombre de sinistres du marché est un *total*, porté par une base d'assurés élargie de 49 % sur le même exercice, alors que les deux autres sources mesurent une exposition *par entité*. Un marché peut enregistrer davantage de sinistres tout en assurant des entités individuellement moins exposées. Confondre le total et la fréquence conduirait à lire une aggravation là où il y a une extension de périmètre. Ces deux enquêtes sont par ailleurs déclaratives : elles mesurent ce que les organisations constatent, non ce qui survient.

S4.6.2 Les limites de Solvabilité II et de la Formule Standard

Le risque cyber est donc au premier rang des préoccupations, mesuré par plusieurs sources indépendantes, et encadré depuis 2025 par un règlement qui en rend la maîtrise observable. Aucun dispositif prudentiel ne traduit pourtant ce niveau de maîtrise en capital.

La Formule Standard de Solvabilité II charge le risque opérationnel par un pourcentage de primes ou de provisions techniques. Ce forfait est *plat* en conformité : deux entités de bilan identique et de

maturité opposée sur les cinq domaines de DORA acquittent exactement la même charge. Aucun sous-module cyber n'existe, et le risque couvert par les garanties affirmatives ne correspond à aucun module standard, ce qui renvoie les assureurs à leurs modèles internes et à leur évaluation interne des risques et de la solvabilité. L'articulation juridique complète entre les deux textes est traitée à la section 1.6.

Les outils actuariels usuels ne comblent pas ce vide. Une copule capturerait la co-occurrence des pertes entre domaines de contrôle, mais symétriquement : elle ne distingue pas une défaillance qui *entraîne* les autres d'une défaillance qui les *subit*. Or c'est cette asymétrie qui devrait commander la priorité de remédiation. Deux matrices de dépendance transposées l'une de l'autre, que les statistiques usuelles ne permettent pas de distinguer, conduisent à un capital et à une décision différents : le chapitre 5 le démontre.

S4.7 Le cadre prudentiel de capital et son articulation avec DORA

Le risque modélisé ici, risque opérationnel d'origine technologique et manquement aux exigences de résilience numérique, se situe à l'intersection de trois cadres construits successivement selon des philosophies distinctes : le dispositif bancaire de Bâle, la directive Solvabilité II propre à l'assurance, et le règlement transsectoriel DORA. Leur articulation ouvre un *pont quantitatif* entre exigence de capital et résilience opérationnelle, et permet de poser la non-conformité comme un état par domaine de contrôle, gradué et évolutif, dont le chapitre 6 tire la dynamique et le chapitre 9 le coût en capital.

Le risque opérationnel : une définition partagée, des traitements divergents. Le risque opérationnel reçoit la même définition dans les secteurs bancaire et assurantiel. Défini par le Comité de Bâle puis repris par la directive Solvabilité II, il désigne le risque de perte résultant de l'inadaptation ou de la défaillance de procédures internes, de personnels et de systèmes, ou d'événements extérieurs. Cette définition inclut le risque juridique mais exclut les risques stratégiques et de réputation.

Si la définition est partagée, les modes de quantification ont divergé. Le secteur bancaire a abandonné les modèles internes au profit d'une approche standardisée, tandis que l'assurance a conservé une liberté méthodologique. Cette asymétrie commande le choix méthodologique du mémoire : Solvabilité II laisse subsister un espace de modélisation interne, où la quantification du risque cyber par une distribution de pertes reste recevable.

Bâle III/IV. Le secteur bancaire a retiré en 2022 les modèles internes de mesure avancée au profit d'une approche standardisée, sans invalider l'approche par distribution des pertes comme outil de modélisation : le mémoire en reprend les deux marges, fréquence et sévérité, et en remplace l'agrégation par une cascade dirigée. Le détail est déporté *(voir le Matériel Complémentaire en ligne)*.

Solvabilité II : l'asymétrie réglementaire et le maintien du choix méthodologique. Contrairement au secteur bancaire, le secteur de l'assurance conserve sous Solvabilité II une liberté de choix pour la

quantification du risque opérationnel : formule standard, paramètres propres à l'entreprise (USP), ou modèle interne, partiel ou global, approuvé par l'autorité de contrôle. Dans la formule standard, l'exigence pour risque opérationnel (SCR_{Op}) s'ajoute au capital de solvabilité requis de base ($BSCR$), ajusté de la capacité d'absorption des pertes : où $Op = \max(Op_{premiums}, Op_{provisions})$ est calculé à partir de coefficients forfaitaires appliqués aux primes et provisions, vie et non-vie. La forme donnée ici est simplifiée ; la formule complète de l'Article 204 du règlement délégué 2015/35 comporte en outre des termes de croissance, sous la forme $\max(0;\ 0{,}04 \times \Delta)$, pénalisant les hausses de primes supérieures à 20 % d'un exercice à l'autre.

Fondée sur les seuls indicateurs de volume, cette approche pose que deux assureurs gérant le même volume de primes ont la même exposition au risque opérationnel, quelles que soient la qualité de leur infrastructure informatique, l'automatisation de leurs processus ou leur dépendance à des prestataires d'externalisation critiques. C'est cette dépendance technologique que DORA encadre, et dont le mémoire mesure l'effet sur le capital.

Pilier 1 et Pilier 2. Le SCR_{Op} relève du Pilier 1, quantitatif et forfaitaire. Mais Solvabilité II comporte un second pilier, l'évaluation interne des risques et de la solvabilité (*Own Risk and Solvency Assessment*, ORSA), qui impose à l'assureur une évaluation prospective de l'adéquation entre son profil de risque réel et ses besoins de solvabilité. C'est dans le cadre de l'ORSA, et non du forfait de Pilier 1 plafonné à 30 % du $BSCR$, que se situe la modélisation du mémoire : l'ORSA admet, et encourage, les scénarios de stress stochastiques que la formule standard ne sait pas produire.

L'additivité que l'équation ci-dessus donne à la charge opérationnelle n'est pas un détail de présentation. Elle décide de ce que le capital total retient d'un besoin de nature opérationnelle, et elle le fait dans un sens qui n'est pas neutre pour l'entité : le §9.12 le chiffre sur les quatre bilans réels, et montre que le plafond lui-même borne ce qu'un forfait saurait exprimer.

DORA, rappelé en une ligne et non réexposé. Le règlement sur la résilience opérationnelle numérique du secteur financier, ses cinq domaines de maîtrise et son dispositif de surveillance des prestataires tiers critiques sont présentés au §1.4. Ce chapitre ne les redit pas : il traite de ce que le chapitre 1 laisse ouvert, à savoir l'articulation du règlement avec les exigences de capital qui, elles, préexistent.

Position dans l'écosystème. La progression Bâle → Solvabilité II → DORA traduit un déplacement du centre de gravité prudentiel : de la *couverture financière* du risque (détenir assez de capital) vers la *continuité opérationnelle* (rester capable d'opérer). DORA ne remplace pas les exigences de capital ; il en révèle l'angle mort, à savoir la dynamique propre des défaillances technologiques, que ni le SCR_{Op} forfaitaire ni l'ORSA qualitatif ne savaient capturer.

ORSA et DORA. Les deux cadres partagent un objet, le risque opérationnel d'origine technologique, et une exigence d'évaluation prospective, mais pas leur finalité : Solvabilité II vise la continuité financière, DORA la continuité opérationnelle. La contribution du mémoire se loge dans leur recouvrement, en utilisant les artefacts produits par DORA pour quantifier dans l'ORSA ce que celui-ci ne savait que décrire. Les limites de l'ORSA traditionnel, la table comparative des deux cadres et

leurs zones de divergence sont déportées *(voir le Matériel Complémentaire en ligne)*.

S4.8 CARTOGRAPHIE DES SOURCES ET DE LEURS RÔLES

Aucune base n'est utilisée seule : chaque source alimente une composante précise du modèle, selon ce qu'elle sait porter.

Source	**Rôle dans le modèle**	**Justification / limite**
PRC 2025	Sévérité alternative via conversion Jacobs ; fréquence de référence λ_{ref}, sans rôle de niveau	Périmètre défini, mais sévérité dérivée d'un modèle log-log
SAS OpRisk Global	Sévérité (montants réels) et fréquence d'entrée du moteur (λ)	Montants observés, mais biais vers les grandes entités financières
Hackmageddon	Parts par vecteur d'attaque (structure du risque)	Ne fixe aucun niveau : pondère le multiplicateur qui fait passer λ d'un état de conformité à l'autre

Cette répartition écarte un écueil fréquent : traiter une base généraliste comme si elle pouvait, seule, calibrer un modèle fréquence-sévérité. Chaque source est mobilisée là où elle est la plus fiable, et ses limites sont déclarées.

L'usage d'un modèle interne, même partiel, est encadré par la directive Solvabilité II. L'Article 19 du Règlement Délégué (UE) 2015/35 impose que les données servant au calcul de la distribution de probabilité prévisionnelle respectent trois critères cumulatifs : exactitude, exhaustivité et pertinence.

Sur le risque cyber, aucune base publique ou commerciale ne satisfait ces trois critères. L'actuaire doit donc documenter les biais des données historiques et justifier les retraitements. La validité du capital calculé ne tient pas à la perfection de la donnée, qui n'existe pas, mais à la déclaration des limites et à la robustesse du modèle face à ces biais.

S4.9 TROIS BIAIS STATISTIQUES À DÉCLARER AVANT TOUT USAGE

L'utilisation conjointe des bases *Privacy Rights Clearinghouse* (PRC) et SAS OpRisk Global permet de croiser les perspectives, mais nécessite d'identifier trois biais statistiques majeurs qui altèrent l'estimation de l'indice de queue ξ.

1. Le biais de sélection (Selection Bias). Ce biais affecte particulièrement la base OpRisk Global, qui se nourrit principalement d'événements rendus publics dans la presse financière ou les rapports annuels. Par construction, un incident cyber n'atteint ce seuil de visibilité que s'il frappe une entité

d'une certaine taille (généralement des institutions systémiques ou de grandes banques internationales) ou si son montant est exceptionnellement élevé. Ce biais de taille sur-représente les événements extrêmes et sous-représente la sinistralité d'attrition. Calibrer directement sur cette base un modèle destiné à une entité de taille moyenne, une mutuelle régionale par exemple, surestime mécaniquement la probabilité de perte extrême. C'est pourquoi la fréquence et la sévérité sont ramenées à la taille de l'entité par deux élasticités estimées (§3.5 et chapitre 9).

2. Le biais de déclaration (Reporting Bias). La base PRC est soumise à un biais de déclaration lié aux asymétries réglementaires. Aux États-Unis, la notification des fuites de données personnelles (Data Breaches) est obligatoire dans la plupart des États, ce qui rend la base PRC très riche sur ce vecteur d'attaque. En revanche, un rançongiciel (Ransomware) qui paralyse les serveurs de l'entreprise mais n'exfiltre aucune donnée personnelle peut ne déclencher aucune obligation de notification légale (avant l'entrée en vigueur d'actes récents comme le CIRCIA). Calibrer une fréquence globale sur la PRC sous-estime donc le risque d'interruption d'activité au profit du seul risque de compromission de données. C'est pourquoi la fréquence qui porte le capital n'est pas lue sur la PRC mais sur OpRisk, qui recense les pertes matérielles quel que soit le vecteur, et pourquoi la répartition par vecteur, rançongiciels compris, est prise dans la base Hackmageddon plutôt que dans la PRC.

3. Le biais de survie (Survivorship Bias). Dans les bases de pertes opérationnelles, la sévérité maximale observée est paradoxalement bornée par la capacité de survie de l'entité. Une cyberattaque ayant entraîné la faillite pure et simple de l'entreprise (ruine) disparaît souvent des bases de pertes opérationnelles classiques, car il n'y a plus d'entité survivante pour reporter la perte financière finale et les coûts de remédiation à long terme. Ce biais tronque artificiellement l'extrême queue de distribution. La théorie des valeurs extrêmes ne le corrige pas : une loi de Pareto généralisée ajustée sur un échantillon tronqué hérite de la troncature, et si elle permet d'extrapoler au-delà du maximum observé, elle le fait à partir d'une queue allégée. Le biais de survie va donc dans le sens d'une sous-estimation de la queue, et il s'ajoute aux écarts anti-conservateurs déclarés au chapitre 10.

S4.10 L'HÉTÉROGÉNÉITÉ TEMPORELLE ET L'ACTUALISATION DES SINISTRES

L'hétérogénéité temporelle des bases de données constitue une autre infraction potentielle au critère d'exactitude de Solvabilité II. La base OpRisk Global agrège des pertes de 2000 à 2026. Employer un montant de 2018 tel quel dans un modèle de capital de 2026 fausse le résultat, l'inflation des sinistres technologiques ne suivant pas l'indice des prix à la consommation.

Le coût d'un sinistre cyber est principalement tiré par trois facteurs :

- **L'inflation salariale IT :** Le coût des experts en remédiation (forensic, restauration de systèmes) connaît une inflation nettement supérieure à l'indice des prix à la consommation, en raison de la pénurie de talents en cybersécurité.
- **L'inflation juridique et réglementaire :** L'entrée en vigueur du RGPD en 2018 a drastique-

ment modifié l'échelle des sanctions. Une fuite de données en 2015 coûtait infiniment moins cher en amendes administratives que la même fuite en 2025.

- **L'escalade des rançons :** La professionnalisation du cybercrime (Ransomware-as-a-Service) a transformé les demandes de rançons de quelques milliers de dollars en 2016 à plusieurs dizaines de millions d'euros en 2026.

Pour respecter les exigences de l'Article 19, les sinistres historiques doivent être actualisés en euros de l'année de modélisation (2026). Soit L_t la perte observée l'année t, la perte actualisée $\tilde{L}_{2026}$ s'écrit :

$$\tilde{L}_{2026} = L_t \times \prod_{k=t}^{2025} (1 + i_k^{cyber}) \tag{S4.1}$$

où i_k^{cyber} est un taux d'inflation propre aux sinistres technologiques, que les indices sectoriels situent entre 5 et 10 % par an. La base OpRisk porte deux montants pour chaque perte : le montant enregistré l'année de l'événement et sa valeur courante, corrigée de l'inflation générale. La chaîne publiée lit le premier, donc des montants *nominaux*. Le rapport entre les deux colonnes vaut un pour les années récentes et 1,747 en 2004, ce qui fixe l'inflation implicite à 2,19 % par an. Cette homogénéisation n'est pas appliquée à la calibration gelée : elle minore les sinistres anciens ramenés en euros courants, donc la queue et le capital, et son effet sur la dérive des pertes est mesuré au §4.7. Aucun indice d'inflation spécifique au cyber ne fait aujourd'hui consensus, de sorte que la valeur courante de la base, fondée sur l'indice général, reste elle-même un minorant de l'actualisation que l'équation demande.

Par ailleurs, le traitement des données manquantes dans la PRC (qui recense parfois le nombre d'enregistrements compromis sans le montant financier) est géré par la conversion de Jacobs (2014). Bien qu'utile comme *proxy*, ce modèle de régression log-log lisse la variance et minore les extrêmes. C'est le motif de ne pas plafonner la calibration issue directement d'OpRisk, où les montants sont observés de bout en bout.

Les limites épistémiques et statistiques exposées ci-dessus contraignent aujourd'hui le calcul du SCR cyber à de larges intervalles d'incertitude. Cependant, cette situation est transitoire. L'apport fondamental du règlement DORA ne réside pas uniquement dans l'imposition de normes de sécurité (Chapitre II), mais dans la création d'un cadre de notification harmonisée des incidents majeurs liés aux TIC (Chapitre III, Article 19 de DORA).

DORA impose aux entités financières de reporter à leur autorité compétente (l'ACPR en France) les incidents majeurs selon une taxonomie standardisée (causes, vecteurs, temps de résolution, pertes financières directes et indirectes). À terme, le règlement prévoit la centralisation de ces rapports au sein d'un pôle de l'Union européenne (EU Hub).

Ce registre atténuerait les trois failles actuelles sans les faire disparaître :

- **Biais de déclaration :** la notification étant obligatoire, la base couvrirait les incidents *majeurs* au sens du règlement. Elle resterait donc tronquée au seuil de matérialité, et non exhaustive : le biais change de nature plutôt qu'il ne disparaît.
- **Biais de sélection :** le registre couvrirait toutes les strates du marché financier, courtiers, mu-

tuelles et sociétés de gestion compris, ce qui donnerait la granularité nécessaire pour conditionner la sévérité par taille d'entité.

- **Visibilité sur les tiers :** le registre cartographierait l'implication des prestataires tiers TIC. C'est exactement la donnée qui manque pour identifier la direction de la contagion, et le chapitre 8 chiffre en euros de capital ce que son obtention ferait gagner.

L'architecture retenue ici (approche par distribution des pertes, théorie des valeurs extrêmes, facteur de Vasicek, allocation d'Euler) ne dépend pas de la source : le modèle et les scripts sont agnostiques aux données d'entrée. Substituer une base d'incidents DORA harmonisée aux bases PRC et OpRisk ne demanderait donc aucune réécriture. Le gain porterait sur la qualité des entrées, non sur la structure du modèle, et il resterait borné par ce que le registre ne couvrira pas : les incidents sous le seuil de matérialité, et la direction de la contagion tant que le registre ne l'horodate pas.

Automatisation du reclassement par NLP. En attendant ce registre harmonisé, une partie du travail de fiabilisation peut déjà être outillée. Le reclassement manuel par grille de mots-clés opéré plus haut sur la taxonomie Hackmageddon, nécessaire pour isoler le ransomware qui n'existait pas comme catégorie en 2023, illustre une limite récurrente des bases de sinistralité cyber : une taxonomie déclarative instable, dont la correction repose sur un travail manuel documenté mais non reproductible à grande échelle.

Les travaux de recherche menés chez Nexialog Consulting sur le traitement automatique du langage appliqué aux bases de sinistralité cyber (rapports d'incidents, bases de vulnérabilités, publications techniques) ouvrent une voie pour systématiser ce reclassement. Le gain serait double : une classification supervisée validée statistiquement remplacerait la grille ad hoc, et la procédure deviendrait transposable à d'autres bases, OpRisk comme le futur registre DORA. Faute de corpus annoté dans le périmètre de ce travail, cette piste n'a pas été mise en œuvre ; elle constitue un prolongement direct.

La base *Privacy Rights Clearinghouse* (PRC) fournit la fréquence de référence λ_{ref}, qui compte des notifications sans seuil de matérialité et ne porte donc aucun niveau de capital (§suivante). Son intérêt tient à son périmètre défini et à sa couverture longitudinale.

La PRC joue toutefois un second rôle, plus fragile : celui de source de sévérité indirecte, via une conversion dite de Jacobs, qui traduit un nombre d'enregistrements compromis en un montant de perte financière à partir d'un modèle log-log. Ce mécanisme permet d'élargir le spectre de tailles d'incidents disponibles, mais introduit un biais de modèle supplémentaire : la sévérité qui en résulte n'est pas observée directement, elle est *dérivée*. La calibration en queue de distribution obtenue sur la PRC, réalisée en propre sur les 15 053 incidents 2019–2025 de la base brute, via la conversion Jacobs $\ln(L) = 7{,}68 + 0{,}76\ \ln(X)$, donne un paramètre de forme $\hat{\xi}_{\text{PRC}} = 1{,}03$ (IC90% [0,97 ; 1,09]), caractéristique d'une queue extrêmement lourde, à espérance infinie, résultat qui, pris seul, rendrait toute simulation numériquement instable et qui doit donc être lu avec le plafond de sévérité propre à cette source *(voir le Matériel Complémentaire en ligne)*.

La PRC reste utile malgré ces limites parce qu'elle est la seule source alternative de sévérité : elle éprouve la calibration OpRisk sur un autre périmètre, sans porter elle-même le niveau.

S4.11 TROIS FRÉQUENCES ET LEUR SEUIL DE COLLECTE

Le seuil de collecte et la double lecture de λ. La fréquence est la seule brique du modèle dont la valeur dépende explicitement du *périmètre de comptage* de la source, et cette dépendance doit être déclarée avant tout usage du niveau. Un contrôle mené sur le panel firme-année du SAS OpRisk (sous-catégories TIC, 2005–2022, fenêtre d'observation propre à chaque firme, de sorte qu'une année sans événement soit un vrai zéro) donne 0,10 événement par firme et par an toutes firmes confondues, et 0,21 pour les firmes à au moins dix événements. Ces deux valeurs sont des *seaux* et ne décrivent aucune entité en particulier : le chapitre 9 estime λ comme une fonction de la taille de firme et la lit à celle de l'entité visée, ce qui donne 0,092. Toutes trois sont sans commune mesure avec le taux posé dans le modèle. L'écart n'est pas une erreur de calage : la base OpRisk ne retient que les pertes au-dessus d'un seuil de collecte, si bien que le taux qu'on y lit est celui des événements TIC *matériels*, générateurs d'une perte enregistrée, et non celui de tous les incidents au sens du reporting DORA. C'est la maille pertinente pour un modèle de capital, mais elle n'est pas la maille réglementaire, et les deux ne doivent jamais être comparées terme à terme.

Il en découle une règle de lecture qui vaut pour tout le mémoire. Le taux λ est une propriété d'entité, lisible sur un panel firme-année ; la charge systémique commune, elle, ne se lit qu'au niveau *agrégé* et après retrait de tendance, car la surdispersion d'un panel firme-année est dominée par l'hétérogénéité de taille des firmes, non par un choc commun. Confondre les deux niveaux d'observation reviendrait à imputer au risque systémique ce qui n'est qu'un effet de taille. Cette séparation commande l'interprétation des niveaux de capital du chapitre 9 : selon l'échelle à laquelle λ est lu, le même modèle décrit un secteur ou une entité, et le tableau 9.5 en donne la traduction chiffrée.

> **Trois nombres portent le nom de « fréquence », et il faut les distinguer une fois pour toutes.** Le mémoire mobilise trois taux, à trois niveaux d'observation. Les confondre serait une faute de lecture, et l'on prend donc soin de les nommer séparément.

Symbole	Source	Valeur	Ce qu'il compte
λ_{ref}	PRC	341/an	notifications de violation de données des *organisations financières* de la base PRC (code `BSF`), et non de la base entière, qui en compte 2 150 par an. Sert à *répartir* par vecteur d'attaque, pas à fixer un niveau de capital.
λ	OpRisk	21,6/an	incidents TIC *matériels* du secteur financier mondial. C'est l'entrée du moteur de cascade et le seul des trois qui porte le capital.
$\lambda_{\text{entité}}$	OpRisk	0,092/an	les mêmes incidents matériels, rapportés à *une* firme et lus *à la taille* de l'entité visée, non dans un seau. C'est l'échelle de lecture d'une entité soumise à DORA.

Le facteur 3 719 entre les extrêmes n'est donc pas une incohérence : c'est l'écart entre un comptage de notifications, un comptage de pertes matérielles sectorielles et un comptage de pertes matérielles par entité. Il est recalculé à chaque exécution du pipeline, de sorte qu'il ne peut plus se désynchroniser des trois fréquences dont il découle. Seul λ alimente le moteur, et lui seul doit être invoqué quand le mémoire parle de « la fréquence du modèle ».

S4.12 Deux biais déclarés et leur effet chiffré sur le résultat

Déclarer un biais ne coûte rien ; le mesurer engage. Les deux limites les plus souvent opposées à une calibration sur OpRisk, le biais de taille et la troncature à droite, sont ici chiffrées ; la figure est déportée *(voir le Matériel Complémentaire en ligne)*.

Les deux mesures. Le biais de taille est réel mais faible : corrigée de la troncature au seuil de collecte, l'élasticité de la sévérité à la taille vaut $b = 0{,}087$, et la sévérité transposée à l'entité notionnelle n'est multipliée que par 0,85. La troncature à droite se corrige par chain-ladder : les 97 événements observés sur 2023–2025 deviennent 255 à l'ultime, et le risque TIC n'a pas baissé après 2022, il n'est pas encore remonté. Les régressions, le triangle de développement et la figure sont déportés *(voir le Matériel Complémentaire en ligne)*.

Le résultat qui compte, et qui n'était pas prévisible. Les deux corrections vont en sens opposés et se compensent presque exactement sur la perte moyenne : $0{,}861 \times 1{,}147 = 0{,}987$, soit un effet net de 1,3 %, inférieur à l'incertitude d'estimation de chacune prise isolément. Elles ne se compensent pas sur le capital. À queue lourde, la VaR 99,5 % obéit au principe du grand saut

unique : elle répond à la *sévérité* bien plus qu'à la *fréquence*. La correction de taille agit sur la sévérité et se transmet donc au quantile ; celle de troncature agit sur la fréquence et s'y transmet mal. Deux biais qui s'annulent sur l'espérance peuvent ainsi ne pas s'annuler sur le quantile, et *c'est le quantile qui fait le SCR*. Une compensation constatée en moyenne n'autorise donc pas à ignorer les deux biais.

S4.13 HACKMAGEDDON ET LA STRUCTURE DU RISQUE

Cette source a déjà été présentée au §3.1 comme celle qui porte la *structure* du risque et non son niveau. Reste à en donner le périmètre exact et les deux limites qui bornent son usage.

Périmètre consolidé. Le décompte retenu porte sur le semestre complet et contigu janvier–juin 2026, soit 1 041 incidents. La couverture pluriannuelle initialement envisagée a été abandonnée : l'année 2024 est absente du jeu consulté, et 2025 n'est disponible que partiellement. La base est donc exploitée pour la *structure* du risque, non pour son *niveau* ou sa dynamique temporelle : elle ne fixe aucune fréquence, et ses parts ne servent qu'à pondérer le multiplicateur de fréquence entre états (§6.3).

> **Ces deux décomptes sont une citation, non un résultat du dispositif.** Contrairement aux bases PRC et OpRisk, versionnées dans le dépôt du mémoire et rejouables par script, le jeu Hackmageddon a été consulté puis non conservé. Les 1 041 incidents et les 840 à vecteur identifié ne sont donc reproductibles par aucun script, et le contrôle de non-régression du dépôt les signale explicitement comme tels plutôt que de les compter parmi les sorties vérifiées. Ils sont à lire comme un chiffre de rapport de place, avec sa date de consultation, et non comme une sortie du modèle. Ces décomptes fixent les parts π_v de répartition par vecteur, qui ne portent aucun niveau mais pondèrent le multiplicateur de fréquence entre états de conformité (§6.3) : leur statut de citation s'étend donc à ce multiplicateur, limite déclarée comme telle. Les faire porter un niveau de capital serait en revanche indéfendable.
>
> Reste à savoir ce que cette limite coûte, et la réponse est mesurée plus loin dans ce même chapitre : la catégorie d'un incident *informe* la probabilité qu'il soit lourd, mais trop faiblement pour porter une segmentation. Trois instruments indépendants le montrent, un V de Cramér sous 0,20, un ε^2 sous 0,08 et des corrélations de rang sous 0,16 (§3.8). La source la moins traçable du dispositif est donc aussi celle dont le modèle dépend le moins, et cette coïncidence n'en est pas une : c'est parce que Hackmageddon ne pouvait pas porter davantage qu'il ne lui a été demandé que cela.

Apport : structure du risque et mapping DORA. Sur les 1 041 incidents, 840 disposent d'un vecteur d'accès initial identifié (81 %), regroupés en familles et reliés directement aux articles DORA :

Vecteur d'attaque	Part	Exigence DORA
Phishing / Ingénierie sociale	38,8 %	Art. 13, sensibilisation & formation
Exploitation vuln. exposée	33,8 %	Art. 26, tests TLPT ; Art. 8–10
Chaîne d'approvisionnement / tiers TIC	15,8 %	Art. 28–44, gestion du risque tiers
Identifiants compromis	6,3 %	Art. 9, contrôle d'accès & MFA

Deux chiffres sont structurants pour la construction des scénarios du chapitre 6 : 15,8 % des attaques empruntent le vecteur tiers/supply chain, coeur des articles 28–44 ; et 49,6 % relèvent de vecteurs qu'un test TLPT (art. 26) est censé détecter en amont (exploitation et tiers cumulés).

Limite 1 : biais de visibilité. Hackmageddon recense des incidents rendus publics, majoritairement médiatiques ou déclarés, ce qui sur-représente structurellement les événements les plus visibles au détriment des incidents ordinaires, moins commentés. La base ne peut donc servir à estimer un niveau absolu de fréquence, seulement une répartition relative entre vecteurs d'attaque.

Limite 2 : taxonomie instable. Une comparaison de structure entre 2023 (3 019 incidents, Q3 manquant) et 2026 a mis en évidence un artefact de taxonomie. La catégorie « Ransomware » n'existait pas en 2023, les incidents correspondants étant alors classés sous « Malware ». Une lecture naïve suggérait une hausse du ransomware de +11 points ; après reclassement par grille de mots-clés commune, le ransomware *recule* en réalité de 23 points.

Dimension	2023	2026	Δ
Cybercriminalité (motivation)	81,1 %	73,9 %	−7,2
Cyberespionnage (motivation)	9,6 %	20,6 %	+11,0
Ransomware (reclassé)	35,8 %	12,7 %	−23,1

Seules les motivations (taxonomie stable de haut niveau) sont donc comparables directement dans le temps ; les types d'attaque ne le sont qu'après un travail de reclassement documenté. Le signal robuste qui demeure est la bascule du cybercrime de masse vers l'espionnage ciblé, une information pertinente pour la discussion du risque systémique au chapitre 9, mais qui illustre aussi la fragilité méthodologique de toute lecture brute d'une base de ce type.

S4.14 OPRISK GLOBAL ET LA SÉVÉRITÉ EN EUROS

Nature et périmètre. OpRisk Global est la base de référence historique du risque opérationnel au sens de Bâle 2/3, comptant 41 975 incidents après nettoyage d'une aberration de saisie. Le risque cyber n'y constitue pas une catégorie native : il est reconstruit à partir des catégories « Systems Security » et « Business Disruption and System Failures ». Le périmètre cyber × finance retenu

compte 582 incidents sur la période 2000–2026. La même base porte l'étude des coûts cyber de Eling et Wirfs (2019), qui en extraient de même les pertes d'origine informatique.

Lien avec l'approche AMA. Cette base est historiquement celle qui alimentait les modèles internes de type *Advanced Measurement Approach* évoqués à la section 1.6, avant leur retrait au profit de la SMA sous Bâle III/IV. Son usage ici renoue donc, à des fins de modélisation interne et non de calcul réglementaire de Pilier 1, avec la logique originelle de la LDA bancaire : calibrer une sévérité extrême à partir de pertes réellement observées plutôt qu'à partir d'un indicateur de volume forfaitaire.

Statistiques de sévérité. Elles portent sur la population de la fréquence et de la descente d'échelle : secteur financier, catégories TIC, fenêtre 2005–2022, soit 1 476 observations. La loi de Pareto généralisée, elle, est ajustée sur le périmètre cyber × finance du paragraphe précédent, 582 pertes sur 2000–2026. Les deux populations ne coïncident pas, et la table ci-dessous décrit la première.

Indicateur	**Valeur**	**Indicateur**	**Valeur**
Médiane	1,20 M$	P99	419,3 M$
Moyenne	33,8 M$	Maximum	10 970,8 M$
P90	25,3 M$	Total cumulé	49,8 Md$

La concentration extrême de la sévérité constitue une signature de queue lourde qui justifie directement le recours à la théorie des valeurs extrêmes développée au chapitre 4 : le décile supérieur porte 92,3 % de la perte totale, et le seul centile supérieur en porte 65,1 %.

Choix du seuil POT. Le choix du seuil u au-dessus duquel la loi de Pareto généralisée est calibrée résulte d'un compromis classique biais-variance, arbitré graphiquement. Le *mean excess plot* (figure S4.6) présente une pente positive et globalement linéaire au-delà de $u = 20$ M€, signature attendue d'un régime GPD à queue lourde ($\xi > 0$) ; c'est ce seuil, correspondant au percentile 85 de la distribution des montants, qui est retenu pour la suite.

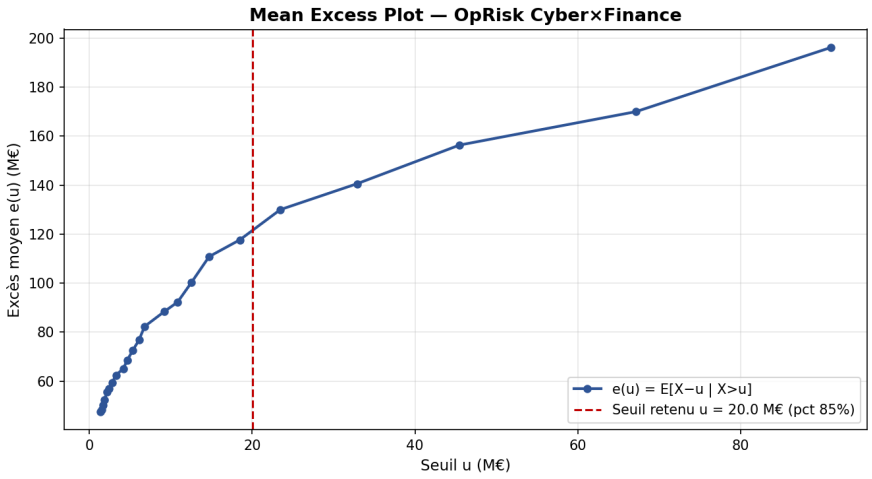


FIGURE S4.6. Mean excess plot sur le périmètre cyber×finance d'OpRisk Global. La linéarité de $e(u)$ au-delà du seuil retenu $u = 20$ M€ (pointillés) confirme le régime de queue lourde justifiant l'ajustement GPD.

Calibration GPD et validation croisée. Au seuil du percentile 85 (u = 20,0 M€, 91 excès), la calibration GPD donne :

$$\hat{\xi} = 0{,}595 \quad (\mathrm{IC}_{90\%} = [0{,}30\,;\,0{,}83]), \qquad \hat{\sigma} = 58{,}0\ \text{M€}, \qquad q_{99{,}5\%}(X) = 663\ \text{M€}.$$

Le dernier terme est le quantile de la sévérité d'un sinistre, pas un capital : le besoin de capital est le quantile de la charge *annuelle agrégée*, obtenu plus loin par composition avec la fréquence. L'intervalle de confiance bootstrap qui entoure ce quantile est [411 ; 1037] M€, soit un facteur 2,5 entre les bornes, une ampleur qui, à elle seule, illustre que le SCR ne peut être présenté comme un point.

La comparaison avec la PRC ($\hat{\xi}_{\mathrm{PRC}} = 1{,}03$ contre $\hat{\xi}_{\mathrm{OpRisk}} = 0{,}595$) ne se lit pas comme une différence de risque, car les deux indices ne portent pas sur le même objet. La sévérité PRC n'est pas observée : elle est une puissance du nombre d'enregistrements, de pente 0,76 en logarithme, et une puissance multiplie l'indice de queue par son exposant, si bien que $\hat{\xi}_{\mathrm{PRC}}$ décrit la queue des enregistrements transportée en euros. Le biais de taille d'OpRisk, mesuré faible au §3.5, n'en rend pas compte. Les deux sources confirment néanmoins le même régime qualitatif de queue lourde ($\xi > 0$). Il n'existe donc pas de hiérarchie « source primaire » en sévérité : OpRisk fournit des montants réels, la PRC un spectre de tailles plus large via la conversion Jacobs : deux estimations indépendantes et complémentaires, dont l'écart constitue lui-même une information sur l'incertitude du modèle.

La décomposition par sous-catégorie révèle en outre deux profils de risque distincts : les pannes (« Business Disruption ») sont moins fréquentes (19 % des incidents) mais nettement plus coûteuses, avec une médiane cinq fois supérieure à celle des intrusions (« Systems Security »), suggérant que les multiplicateurs DORA pourraient à terme être différenciés non seulement en fréquence mais aussi en sévérité, sous réserve de la taille réduite de l'échantillon « pannes » (28 excès), qui rend cette calibration indicative.

S4.15 ANALYSE EXPLORATOIRE, TESTS STATISTIQUES ET PROFILAGE DES VARIABLES

Les deux sources viennent d'être décrites par leur périmètre et par leurs biais. Elles ne l'ont pas été par leurs *variables* : ni le type de chacune, ni son taux de renseignement, ni la moindre mesure d'association entre elles. Cette section comble ce manque, et elle le fait dans l'ordre où la question se pose à un lecteur prudentiel. Quelle information chaque base porte-t-elle réellement ? Sur quelle part de ses lignes ? Et cette information segmente-t-elle la perte assez nettement pour qu'un modèle ait intérêt à en tenir compte ?

La réponse à la troisième question commande un choix de modélisation qui engage tout le document, celui d'ajuster une queue *commune* plutôt qu'une queue par catégorie d'organisation ou par type d'incident.

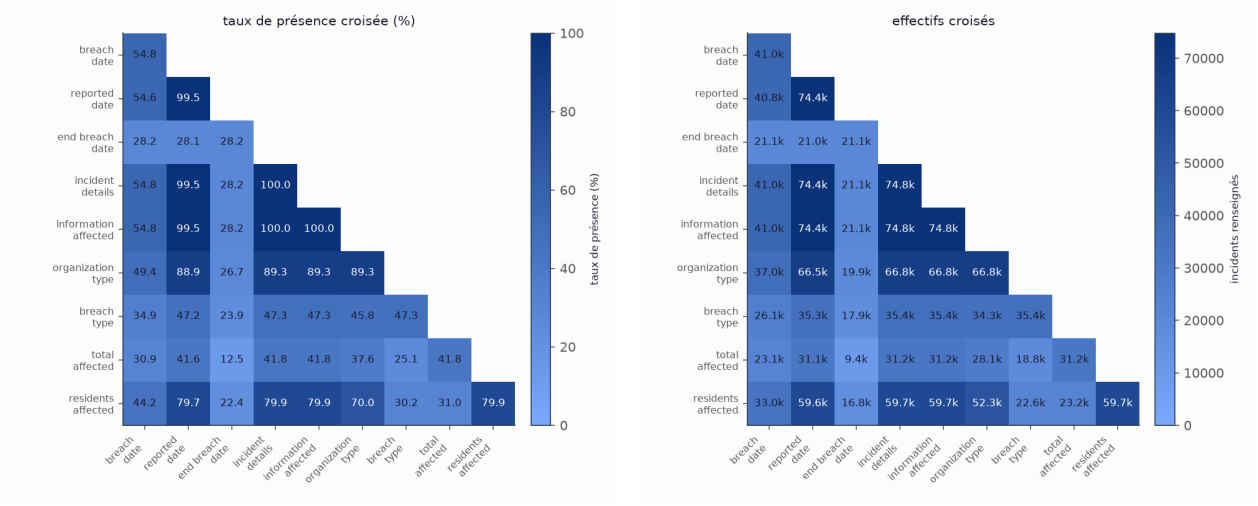
S4.15.1 Les variables retenues et leur taux de renseignement

Un piège de complétude, et il fausse la lecture dans le bon sens pour qui ne le voit pas. Dans l'export de la chronologie PRC, un champ non renseigné ne vaut pas vide : il vaut la chaîne `UNKN`. Un contrôle de complétude ordinaire, qui teste l'absence de valeur, rend donc 100 % de présence sur les trente-sept colonnes, y compris sur celles qui ne sont documentées que dans un cas sur quatre. Les taux ci-dessous comptent `UNKN` comme un manquant, ce qui est le seul comptage défendable, et le script imprime les deux mesures côte à côte pour que l'écart soit visible plutôt que supposé.

Variable	Type	Rôle dans le modèle	Base	Renseignée
`total_affected`	quantitative	volume d'enregistrements touchés, seule mesure d'impact de la base	PRC	41,77 %
`residents_affected`	quantitative	sous-ensemble territorialisé du précédent	PRC	79,88 %
`breach_date`	temporelle	date de survenance, support de la fréquence annuelle	PRC	54,82 %
`reported_date`	temporelle	date de notification, support du délai de détection	PRC	99,54 %
`end_breach_date`	temporelle	fin d'exposition, support de la durée d'incident	PRC	28,18 %
`organization_type`	qualitative	classe d'organisation, huit modalités	PRC	89,29 %
`breach_type`	qualitative	vecteur de la brèche, huit modalités	PRC	47,31 %
`Loss Amount`	quantitative	montant de perte avérée, source de la sévérité	SAS	100 %
`Event Risk Category`	qualitative	catégorie bâloise de niveau 1, sept modalités	SAS	100 %
`Sub Risk Category`	qualitative	sous-catégorie, définit le périmètre TIC	SAS	100 %
`Basel Business Line`	qualitative	ligne métier, dix modalités	SAS	100 %
`Industry Sector Name`	qualitative	secteur, définit le périmètre financier	SAS	100 %
`Revenue`	quantitative	chiffre d'affaires, mesure de taille	SAS	87,82 %
`Assets`	quantitative	actif total, mesure de taille prudentielle	SAS	83,51 %

Lecture. La chronologie PRC porte 74 783 incidents, dont 31 217 seulement documentent un volume touché strictement positif. Après restriction à la période retenue, 15 053 incidents subsistent, effectif que ce recomptage indépendant retrouve à l'unité près sur les sorties déjà versionnées du projet. La base SAS porte 41 976 lignes, dont 41 975 pertes exploitables ; le périmètre TIC en compte 1 099 et son intersection avec le secteur financier 582.

> **La variable d'impact est la moins bien renseignée des deux bases, sans que ce soit un hasard de collecte.** Les champs qu'une obligation de notification impose, la date de déclaration et la nature de l'organisation, sont documentés ; ceux qui demandent une investigation, le volume touché et la date réelle de survenance, ne le sont pas. Le manquant n'est donc pas aléatoire : il est corrélé à la difficulté de l'enquête, donc plausiblement à la gravité.
> **Ce mécanisme n'est aucun des trois biais de la section 3.2, et il se distingue du deuxième.** Le biais de déclaration porte sur les incidents qui *entrent* dans la base, selon que la loi impose ou non de les notifier ; celui-ci porte sur les champs *renseignés* au sein des incidents déjà entrés. Les deux vont dans le même sens et s'ajoutent, mais ils opèrent à deux niveaux distincts, et seul le second se mesure sur les variables au lieu de s'argumenter.



(a) (b)

FIGURE S4.7. Présence croisée des variables de la chronologie PRC, en taux (a) et en effectifs (b). La lecture utile est la ligne du bas du panneau (a) : le volume touché n'est simultanément renseigné avec le type de brèche que dans 25,1 % des cas, et avec la date de fin d'exposition dans 12,5 %. Le panneau (b) donne l'effectif derrière chaque taux.

Les deux panneaux de la figure S4.7 ne disent pas la même chose et il faut les lire ensemble : un taux ne dit pas sur quel effectif il porte. Les 12,5 % du croisement le plus pauvre représentent encore plus de neuf mille incidents, ce qui n'a pas la même portée qu'un taux identique sur une base de quelques centaines. La matrice dit surtout ce qu'une colonne de taux isolés ne dit pas : les lacunes se *cumulent*. Une analyse qui croiserait le volume touché, le type de brèche et la durée d'exposition ne disposerait plus que de 10,9 % de la base, et cette fraction n'aurait aucune raison d'en être représentative, les trois manques ayant la même origine. C'est le motif pour lequel le modèle ne conditionne la sévérité sur aucune de ces variables.

S4.15.2 Description des variables d'impact

Le mémoire publie des quantiles de sévérité dans plusieurs chapitres sans les avoir jamais rassemblés : un lecteur qui veut juger la queue avant de lire l'ajustement devait les reconstituer de proche en proche. La table ci-dessous les réunit sur les quatre variables d'impact du dispositif.

	PRC		SAS OpRisk	
	enregistrements (nombre)	**sévérité dérivée** (M€)	**toutes catég.** (M€)	**cyber × finance** (M€)
n	15 053	15 053	41 975	582
moyenne	102 646	6,07	69,98	24,32
écart-type	1 235 098	41,59	647,26	97,71
minimum	1	0,0020	0,0920	0,0920
q_{25}	69	0,0497	1,012	0,352
médiane	1 104	0,409	3,763	1,380
q_{75}	8 330	1,901	18,40	8,625
q_{85}	23 467	4,176	45,40	22,03
q_{90}	49 000	7,307	82,90	47,42
q_{95}	164 673	18,36	202,4	105,4
q_{99}	1 719 753	109,2	1 012	369,7
maximum	60 000 000	1 624	53 360	1 380
q_{99}/médiane	1 558	267	269	268
maximum/q_{99}	34,9	14,9	52,7	3,7
coef. de variation	12,03	6,85	9,25	4,02

Lecture. Les deux premières colonnes comptent des enregistrements, les deux dernières des euros : elles ne se comparent ni en niveau ni en quantile. La quatrième est celle qui porte la calibration publiée. Trois traits s'y lisent d'un coup.

- **La moyenne dépasse le troisième quartile sur les quatre colonnes.** Une distribution dont la moyenne tombe au-dessus du q_{75} n'est pas décrite par sa moyenne : son niveau est porté par une minorité d'observations.
- **Le rapport du q_{99} à la médiane** vaut près de 270 sur les trois colonnes monétaires et monte à 1 558 sur les enregistrements. Ce n'est pas une queue qui se prolonge, c'est une queue qui change d'échelle.
- **Le coefficient de variation** vaut 4,02 sur le périmètre calibré et jusqu'à 12,03 sur les enregistrements. Une loi exponentielle le vaut exactement un.

> **Une asymétrie entre les deux dernières colonnes, à ne pas lire de travers.** Le rapport du maximum au q_{99} vaut 3,7 sur le périmètre cyber × finance contre 52,7 sur la base entière. Le périmètre retenu est donc le *moins* extrême des deux en ce sens, et non le plus : le sinistre le plus lourd du fichier ne relève pas du risque informatique. La queue calibrée n'est pas celle de l'événement le plus spectaculaire de la base, ce qui écarte le soupçon d'un ajustement tiré par un cas isolé.

Un repère de seuil, et le contrôle qu'il permet. Le q_{85} du périmètre calibré vaut 22,03 M€ sur la donnée courante, quand le seuil publié et gelé vaut 20,03 M€, soit le percentile 84,4. L'écart est attendu et il est la trace du gel : il avait fait diverger trois scripts de validation tant qu'ils redérivaient

leur propre seuil au lieu de le lire dans la configuration. Le contrôle qui vaut porte donc sur le *nombre d'excès* au-dessus du seuil publié, et il en compte 91, exactement l'effectif que la calibration déclare.

S4.15.3 Les plus gros incidents

Une queue lourde reste une abstraction tant qu'on ne voit pas les événements qui la forment. La table ci-dessous montre les plus gros incidents de la chronologie PRC, comptés en enregistrements : elle illustre la forme d'une telle queue, non le quantile publié, calibré en euros sur OpRisk.

Organisation	Secteur	Survenance	Enregistrements
Progress Software, Ipswitch, Inc.	services	2023-05-27	60 000 000
T-Mobile USA, Inc.	services	2021-08-13	53 700 000
AT&T Inc.	services	2024-03-26	51 226 382
Logan Health Medical Center	santé	2021-11-22	40 000 000
T-Mobile	services	2022-11-25	37 000 000
Comcast Cable Communications LLC	services	2023-10-16	35 879 455
Zoosk, Inc.	services	2020-01-12	24 200 000
CafePress, Inc.	détail	2019-02-19	23 000 000
Texas Dow Employees Credit Union	finance	2023-05-29	20 000 000
Evite, Inc.	services	2019-02-22	18 571 486
loanDepot.com, LLC	finance	2024-01-03	16 924 071
ClearVoiceResearch.com, LLC	services	2021-04-16	15 700 000

Lecture. Le premier incident est la compromission du logiciel de transfert de fichiers évoquée au chapitre 1 comme choc de cause commune : il figure ici sous le nom de l'éditeur du logiciel, et non sous ceux des milliers d'organisations atteintes à travers lui. Deux entrées distinctes portent le même opérateur de télécommunications à deux années d'intervalle. Les deux incidents financiers, un établissement de crédit et un prêteur hypothécaire, dépassent chacun quinze millions d'enregistrements.

La concentration, mesurée : l'argument de queue rendu concret. La moitié du volume de sept années tient dans 31 incidents sur 13 410, soit 0,23 % de la base. Quatre-vingts pour cent tiennent dans 209 incidents et quatre-vingt-dix pour cent dans 491. Un modèle qui décrirait cette distribution par son centre manquerait donc son objet : le niveau n'est pas produit par le régime courant, il est produit par une poignée d'événements. C'est ce que l'ajustement par dépassement de seuil formalise, et c'est aussi pourquoi le quantile qui porte le besoin de capital est porté par un sinistre unique plutôt que par une accumulation.

> **Un défaut de la base, trouvé en regardant cette table et non en relisant une documentation.** La chronologie PRC n'agrège pas les notifications : un même incident déclaré à plusieurs autorités y figure autant de fois, avec le même volume. La table brute affichait ainsi un même établissement de crédit *quatre* fois. Une déduplication sur le triplet organisation, volume et date de survenance retire 1 643 lignes, soit 10,9 % de la période retenue.
> Ce chiffre est une *borne basse* : la déduplication exige une égalité exacte, donc elle ne rapproche ni deux graphies d'une même raison sociale, ni deux notifications décalées d'un jour. Des dou-

> blons résiduels subsistent et restent visibles ci-dessus. Les traiter demanderait un appariement approximatif dont le taux d'erreur serait lui-même à estimer.
> **Le mémoire n'est pas affecté**, et le motif est précis : il n'additionne jamais ces volumes pour produire un montant. Il les utilise comme un échantillon de sévérité, où chaque ligne est une observation. La réserve vaut pour qui reprendrait la base à d'autres fins, et elle est déclarée ici plutôt que laissée à découvrir.

La profondeur de collecte, montrée plutôt que déclarée. Le mémoire borne sa fenêtre d'observation au motif que la base ne couvre pas les années anciennes. L'affirmation était écrite, elle n'était pas visible. Elle l'est ici : avant 2015, la chronologie ne porte que 2 152 incidents, soit 6,5 % de la période 2005–2025. Le maximum est atteint en 2023 avec 5 866 incidents, et l'exercice 2025 n'en compte que 174, soit 3,0 % du pic, faute de notifications déjà enregistrées (figure S4.8).

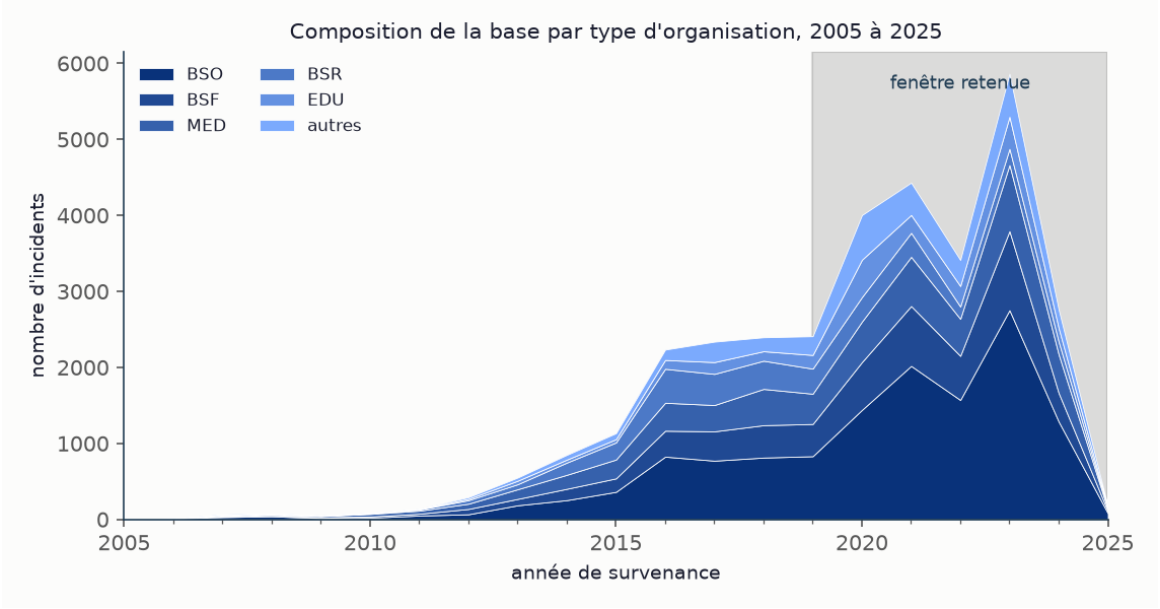


Figure S4.8. Composition de la chronologie PRC par type d'organisation et par année. La zone grisée est la fenêtre retenue. La montée d'avant 2019 est une montée de la *collecte*, pas du risque ; la chute de 2025 est un défaut de recul, pas une accalmie.

Ces deux déformations vont en sens contraire et aucune n'est un signal de risque. Une fenêtre plus large fabriquerait un régime calme au début et un effondrement à la fin, et un modèle de tendance ajusté dessus mesurerait la maturation d'une base de données. C'est le motif, déjà retenu pour la validation hors échantillon, de s'en tenir à la fenêtre grisée.

Compter et sommer ne classent pas les mêmes catégories. La figure S4.9 met en regard le nombre d'incidents et le volume touché par type d'organisation. Les deux ordres divergent sur quatre types sur sept : le commerce de détail est sixième en nombre et quatrième en volume, l'enseignement quatrième en nombre et cinquième en volume.

C'est la traduction visuelle du résultat de la sous-section S4.15.4 : la classe d'organisation informe la sévérité sans la déterminer. Un indicateur qui mêlerait fréquence et volume classerait donc les catégories dans un ordre qu'aucune des deux mesures ne soutient seule.

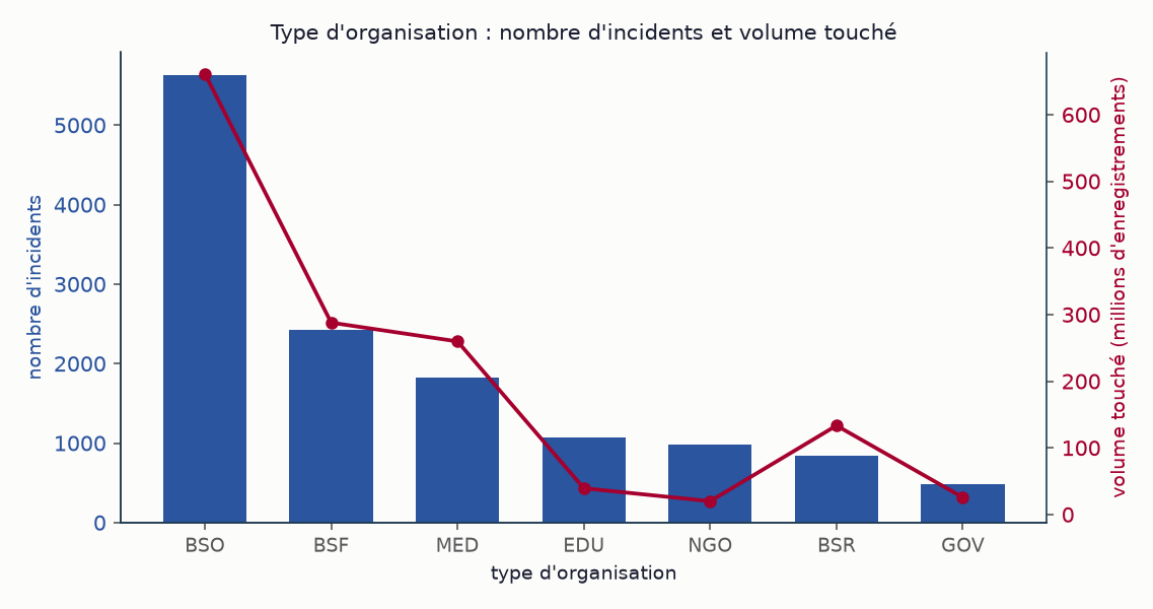


Figure S4.9. Nombre d'incidents en barres et volume touché en courbe, par type d'organisation. Les deux classements ne coïncident pas.

S4.15.4 Association des variables qualitatives au dépassement du seuil

La question posée est celle d'un actuaire qui envisage de segmenter : le type d'incident ou la classe d'organisation prédisent-ils qu'une perte dépasse un seuil élevé ? On binarise donc l'impact au troisième quartile de chaque base, 8 330 enregistrements pour la PRC et 20,00 M$ pour SAS, puis l'on teste l'indépendance par un χ^2 et l'on mesure la force du lien par un V de Cramér à correction de Bergsma.

Base	Variable croisée au dépassement	χ^2	ddl	V de Cramér
PRC	type de brèche	43,1	6	0,068
PRC	type d'organisation	296,4	6	0,148
SAS	catégorie bâloise	1 301,9	6	0,176
SAS	ligne métier bâloise	1 238,5	9	0,171
SAS	secteur d'activité	711,9	20	0,128

Lecture. Les cinq tests rejettent l'indépendance, et ce rejet n'apprend rien. À quinze mille et quarante mille observations, le χ^2 détecte des écarts sans portée pratique : sa p-valeur mesure l'effectif autant que l'association. Le renseignement est dans le V, qui est une taille d'effet bornée par un et ne croît pas avec n. Aucune des cinq associations n'atteint 0,20, quand 0,30 marque conventionnellement le seuil d'une association moyenne. La plus forte, la catégorie bâloise dans SAS, vaut 0,176.

Ce que ces cinq nombres autorisent, et ce qu'ils interdisent. Ils autorisent à dire que la catégorie d'un incident *informe* la probabilité qu'il soit lourd. Ils interdisent d'en faire une variable de segmentation : une association de 0,18 ne porte pas un ajustement de queue par modalité : segmenter par la catégorie bâloise, qui compte sept modalités, ramènerait les 91 excès de la calibration

à une douzaine par modalité, effectif sur lequel aucune loi de queue ne s'ajuste. C'est le premier des deux arguments qui fondent le choix d'une queue commune.

S4.15.5 Forme, dépendance de rang et hétérogénéité des variables quantitatives

La normalité, chiffrée plutôt qu'écartée d'un mot. Le test de Shapiro-Wilk est appliqué à l'échelle brute puis à l'échelle logarithmique, sur un tirage plafonné à 5 000 observations, graine fixée, la statistique n'étant pas fiable au-delà. À l'échelle brute, la statistique W vaut 0,037 sur la PRC et 0,071 sur SAS, pour une valeur de référence de un : le rejet est total. Les moments le confirment, avec une asymétrie de 29,4 et un aplatissement de 1 083 sur la PRC, contre trois pour une loi normale.

Le passage au logarithme améliore nettement la statistique sans la sauver, W montant à 0,970 et 0,986. C'est exactement le diagnostic attendu : la perte n'est ni normale ni tout à fait log-normale, sa queue restant plus lourde qu'une log-normale ne l'admet. Cette mesure justifie le recours à une loi de Pareto généralisée *au-delà d'un seuil* plutôt qu'à un ajustement paramétrique global, choix que la section de calibration met en œuvre.

La perte suit mal la taille : un second chemin le mesure. Les corrélations de rang de Spearman entre le montant de perte et les trois mesures de taille disponibles valent 0,159 pour le chiffre d'affaires, 0,139 pour l'effectif et 0,068 pour l'actif total, sur 33 769 pertes à profil financier complet. Une perte proportionnelle à la taille donnerait un coefficient proche de un.

> **La mesure de taille la moins liée à la perte est celle qui sert à l'échelle prudentielle.** L'actif total arrive dernier des trois prédicteurs, derrière le chiffre d'affaires et derrière l'effectif. Or c'est le bilan qui porte la mise à l'échelle du besoin de capital. Ce constat, obtenu sans hypothèse de forme et sur un effectif dix fois supérieur à celui de la descente d'échelle, va dans le même sens que l'élasticité de 0,087 mesurée par ailleurs : il ne la confirme pas au sens statistique, les deux grandeurs n'étant pas la même, mais il rend cette faible élasticité moins surprenante. Elle corrobore par un chemin indépendant la limite *sévérité non plafonnée à l'échelle d'entité*, inscrite au registre des limites du chapitre 10, et c'est cette limite qui fait lire le besoin de capital de l'entité notionnelle comme une borne supérieure d'ordre de grandeur plutôt que comme une mesure.

L'hétérogénéité entre classes existe, mais elle est petite. Le test de Kruskal-Wallis, non paramétrique donc insensible à la non-normalité qui vient d'être établie, rejette l'égalité des distributions de sévérité entre classes dans les quatre configurations testées. La taille d'effet ε^2 dit de combien : 0,0100 pour le type d'organisation et 0,0123 pour le type de brèche dans la PRC, 0,0720 pour la catégorie bâloise et 0,0785 pour la ligne métier dans SAS. La classe explique donc entre un et huit pour cent de la dispersion des sévérités.

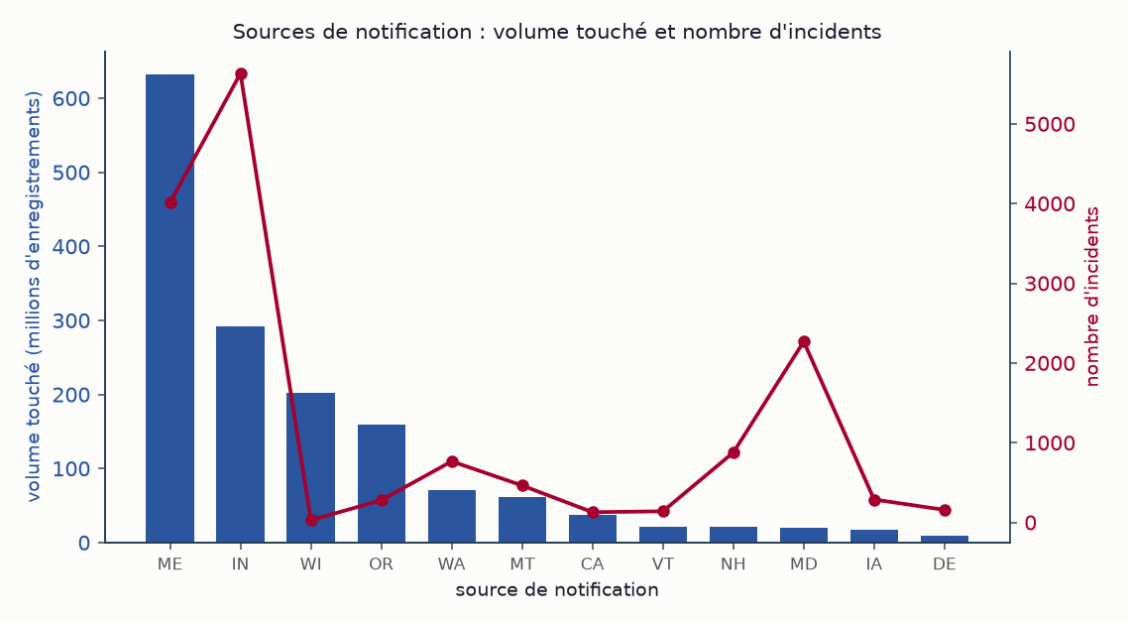


Figure S4.10. Sources de notification de la chronologie PRC : volume touché en barres, nombre d'incidents en courbe. Les deux ordres ne coïncident pas.

La figure S4.10 porte un avertissement de méthode plus qu'un résultat. Les deux axes se contredisent : la source la plus prolixe en nombre d'incidents n'est pas celle qui porte le plus gros volume, et une source ne déclarant que vingt-sept incidents en concentre plus de deux cents millions d'enregistrements. Compter les incidents et sommer les volumes répondent donc à deux questions différentes, et un indicateur agrégé qui mêlerait les deux serait dominé par le régime déclaratif de quelques juridictions.

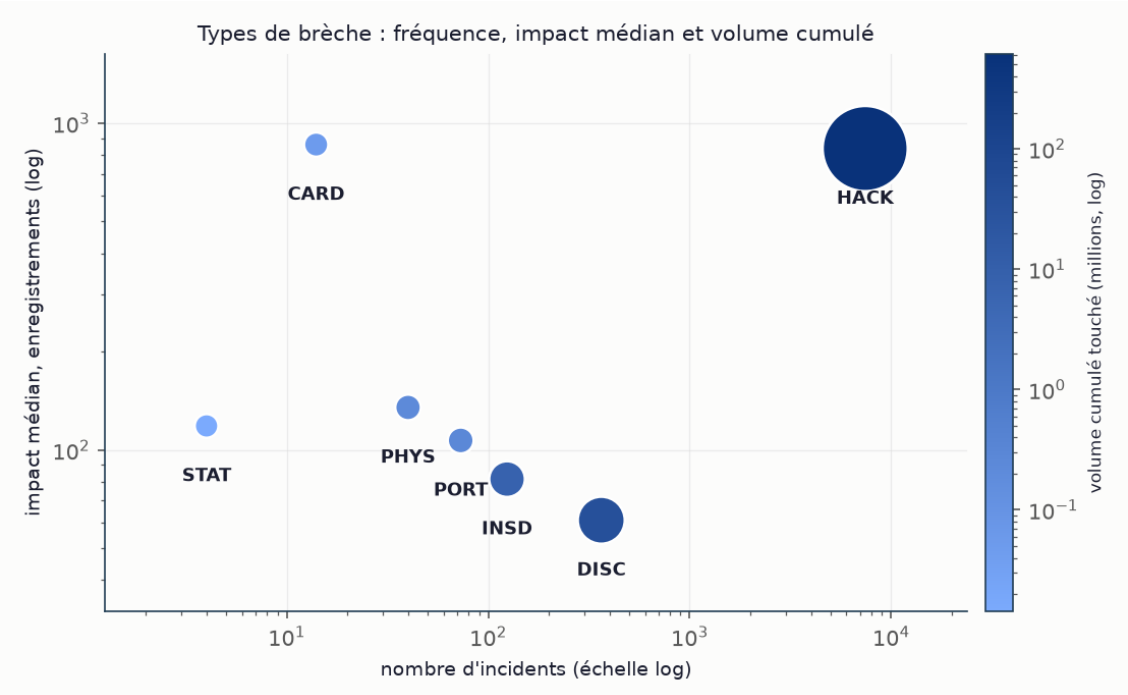


Figure S4.11. Types de brèche dans le plan fréquence contre impact médian, la taille et la teinte des disques portant le volume cumulé. Les deux axes sont logarithmiques.

La figure S4.11 sépare ce que le seul comptage confond. Le piratage domine les deux dimensions à la fois, avec 7 430 incidents et un impact médian de 836 enregistrements, ce qui en fait le seul type simultanément fréquent et lourd. La divulgation involontaire est le deuxième en fréquence mais le plus léger en médiane, à 61 enregistrements. À l'opposé, la fraude à la carte ne compte que quatorze incidents pour une médiane de 860, la plus haute de la table : un type rare peut porter une sévérité unitaire élevée sans peser sur la charge, et l'inverse est vrai.

Ce que cette section change au modèle. Trois mesures convergent vers la même conclusion, obtenues par trois instruments indépendants : le V de Cramér sous 0,20, le ε^2 sous 0,08 et les corrélations de rang sous 0,16. La catégorie d'un incident et la taille de l'entité qui le subit informent faiblement sa sévérité. Segmenter la queue sur l'une ou l'autre coûterait des degrés de liberté sans acheter de pouvoir explicatif. Le mémoire ajuste donc une queue commune, et cette décision est ici une *mesure* plutôt qu'une commodité : elle est adossée à des tailles d'effet publiées, pas à une hypothèse de simplicité.

S4.16 PORTÉE ET LIMITES DU DISPOSITIF DE DONNÉES

La discipline méthodologique retenue dans ce mémoire consiste à ne jamais prétendre inférer davantage que ce que les données permettent réellement, ce qui impose d'expliciter aussi bien les capacités que les limites du dispositif.

Ce que l'on sait faire. On sait lire une fréquence d'incidents matériels sur des pertes observées (OpRisk Global), et la moduler entre états de conformité selon une structure d'attaque citée (Hackmageddon). On sait calibrer une sévérité de queue lourde par la théorie des valeurs extrêmes à partir de pertes réellement observées (OpRisk Global), et confronter cette calibration à une source indépendante pour objectiver l'incertitude. On sait enfin traiter l'écart entre sources non comme un bruit à éliminer, mais comme une dimension d'incertitude à part entière, qui s'ajoute à l'incertitude de paramètre estimée par bootstrap.

Ce que l'on ne sait pas faire. On ne sait pas mesurer directement le niveau de conformité DORA d'une entité donnée ; c'est précisément la raison d'être de l'état de conformité par pilier introduit au chapitre 6. On ne sait pas disposer d'une base d'incidents harmonisée à l'échelle européenne, exhaustive et non biaisée par la visibilité médiatique. On ne sait pas non plus estimer avec précision la corrélation entre les différentes briques de perte, faute d'historique suffisant sur les événements joints ; cette incertitude est traitée au chapitre 5 par une structure de dépendance explicite plutôt que par une hypothèse d'indépendance non fondée.

Deux règles du moteur de simulation, le plafond de sévérité propre à la source PRC et la sévérité nulle sous le seuil, ainsi que la suffisance des trois sources pour un exercice d'ORSA, sont précisées *(voir le Matériel Complémentaire en ligne)*.

S4.17 LE CHOIX D'UN NOMBRE RESTREINT DE SOURCES

Des bases supplémentaires existent (bases commerciales de sinistres cyber assurantiels, enquêtes sectorielles européennes) et pourraient, en principe, enrichir le dispositif. Mais chacune porterait ses propres biais de sélection et de représentativité, sans lever la limite structurelle identifiée plus haut : l'absence, à ce jour, d'un registre harmonisé et exhaustif à l'échelle du marché. Multiplier les sources déplacerait la difficulté sans la résoudre, et complexifierait un dispositif dont les rôles sont aujourd'hui distincts (trois sources, trois rôles, aucune hiérarchie de « source primaire »). L'analyse de sensibilité menée au chapitre 9 confirme d'ailleurs, *a posteriori*, la pertinence de ce choix : c'est l'incertitude sur l'indice de queue ξ de la sévérité, estimé sur les sources déjà mobilisées, qui domine très largement toute autre source de variation du modèle, multipliers de fréquence et paramètres de dépendance compris. Approfondir l'exploitation des trois sources retenues (bootstrap, validation croisée, diagnostics de stabilité) réduit donc l'incertitude du capital de façon bien plus significative que l'ajout d'une quatrième base de sinistralité.

La structure tirée de Hackmageddon est confrontée au rapport *ENISA Threat Landscape 2025* (ENISA, 2025), de méthodologie de collecte distincte, qui confirme la même hiérarchie des vecteurs d'attaque par leur taux de conversion en intrusion *(voir le Matériel Complémentaire en ligne)*.

Ce que ces données permettent, et ce qu'elles interdisent. Elles fixent la queue de sévérité ($\hat{\xi} = 0{,}595$ sur OpRisk), la fréquence d'entrée et l'accumulation par cause commune. Elles ne fixent *pas* la direction de la contagion : le chapitre 7 le montre sur trois sources qui échouent pour des raisons distinctes, et le chapitre 8 en tire les conséquences en bornes de capital. Cette frontière est un résultat produit par le dispositif de données, non une lacune de celui-ci.

S4.18 LIMITES DU DOMAINE ET LIMITES DE CE TRAVAIL

Les trois dernières lignes de la table, et le registre de la section 10.8, mêlent deux natures de limites que rien ne distingue à la lecture. Les unes tiennent à ce qu'aucune source disponible aujourd'hui ne permet de calibrer, à quiconque et non au seul présent travail. Les autres tiennent à ce que ce travail a choisi de ne pas faire. Les confondre fait lire les premières comme des insuffisances, alors qu'elles sont le fait qui commande la méthode.

Ce que la donnée cyber interdit aujourd'hui. La direction de la contagion entre domaines de contrôle n'est enregistrée par aucune source, et ce constat est mesuré plutôt qu'affirmé : le schéma VERIS porte le champ qui l'identifierait, renseigné dans 0,12 % des incidents de sa base publique, et la chronologie qui porterait l'antériorité dans 1,19 % ; leur intersection compte un incident, aucun en secteur financier (section 10.8). La non-identifiabilité n'est donc pas une propriété des sources retenues ici, c'est une propriété du reporting d'incidents tel qu'il existe. Le coût d'un sinistre touchant plusieurs piliers n'est davantage observé par aucune source, et la sévérité d'une perte cyber en euros n'est disponible à cette profondeur que sur des bases de risque opérationnel

bancaire, ce qui fixe le périmètre de calibration du chapitre 4 et la borne inférieure de validité du chapitre 9.

Ce que le mémoire en fait. Devant une grandeur que la donnée ne détermine pas, deux conduites sont possibles : en poser une valeur et la présenter comme une estimation, ou établir la non-identifiabilité, énumérer l'ensemble admissible et publier des bornes. La seconde est retenue partout, et elle s'accompagne d'une exigence : vérifier que la conclusion survit à l'ensemble entier et non à un point choisi, ce que portent le lemme de monotonie en g et l'invariance de l'ordre de remédiation. Il en résulte une lecture qui vaut pour tout le mémoire : l'*amplitude* du surcoût est un scénario, son *signe* et son *ordre* sont des résultats. Un paramètre posé n'est alors pas une faiblesse, c'est un périmètre déclaré.

Ce qui relève de ce travail. Le reste du registre est d'une autre nature et s'arbitre. L'élicitation structurée a été préparée et diffusée, et elle est restée sans réponse (annexe S4.63) ; la calibration est gelée, et les corrections d'erreur seules y restent admises ; une source de structure est citée sans être recalculable, sous un statut déclaré ; deux écarts d'estimation involontaires sont publiés avec leur sens plutôt que corrigés. Ces décisions appartiennent à l'auteur et auraient pu être prises autrement : c'est ce qui les sépare des précédentes. Une limite du domaine ne se corrige pas en travaillant davantage sur ce mémoire, mais par le registre d'incidents spécifié à la section 10.8 ; une limite de ce travail se corrigerait en y revenant.

S4.19 Les trois étages de l'incertitude du SCR

L'incertitude sur le SCR ne se réduit pas au paramètre. Elle se répartit sur trois étages, qu'il faut nommer plutôt que confondre (figure S4.12). Le premier est l'incertitude de paramètre : l'intervalle de confiance de ξ à lui seul dilate la VaR d'un facteur 2,5 sur la calibration figée, valeur que le bootstrap retrouve à la précision près. Le deuxième est l'incertitude d'identification : la direction de W n'étant pas identifiable, la contagion se lit en bande (chapitre 8). Le troisième, le plus souvent passé sous silence, est l'incertitude de modèle : le choix de la *famille* elle-même.

On la chiffre en recalculant le SCR sous des familles concurrentes. Sur l'axe de la *dépendance*, à marges par pilier fixées, le SCR va de 5 322 M€ (indépendance) à 9 806 M€ (comonotone, borne de Fréchet), soit un facteur 1,8, la formule standard Solvabilité II et les copules gaussienne et de Gumbel se plaçant entre les deux ; la cascade dirigée (8 318 M€) tombe dans cette bande, entre une dépendance gaussienne et une dépendance de Gumbel. Sur l'axe de la famille de queue, l'écart est bien plus large : d'une lognormale (4 330 M€) à une GPD à queue lourde ($\xi = 0{,}90$; 24 016 M€), un facteur 5,5. C'est le choix de la loi de queue qui domine, de loin, l'incertitude de modèle, et c'est précisément pourquoi le plafond de réassurance (40 M€) est un levier distinct, qui ramène la famille lourde à 495 M€ : une réponse au risque de queue, non le risque lui-même.

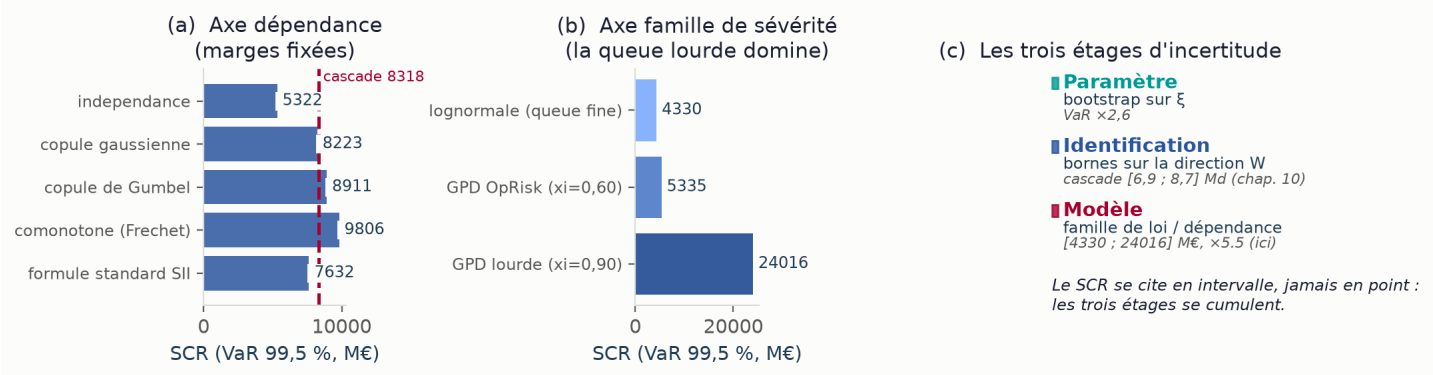


FIGURE S4.12. La bande de modèle, troisième étage d'incertitude. (a) axe dépendance, à marges fixées : la cascade se place entre les copules gaussienne et de Gumbel, dans une bande [5,3 ; 9,8] Md€. (b) axe famille de queue : la queue lourde domine l'incertitude (×5,5). (c) les trois étages (paramètre, identification, modèle) tels que le script les cumule ; la bande *reportée* par le mémoire n'en retient que les deux premiers, le troisième étant publié comme axe de sensibilité (§10.3).

S4.19.1 Deux étages dans la bande reportée, le troisième hors bande

Les trois étages ne peuvent pas tous entrer dans un intervalle unique. La bande reportée par ce mémoire ne cumule que les deux premiers, paramètre et identification. L'étage de modèle est publié, mais comme axe de sensibilité déclaré et non comme composante de la bande.

Les trois étages, mis sur une seule échelle avant toute comparaison. Comparer les étages exige de les lire sur la *même* grandeur, première chose à faire ici : l'étage de paramètre est publié sur le quantile d'*un sinistre* (facteur 2,5) tandis que les deux autres vivent sur la *charge annuelle agrégée*. Les rapprocher tels quels comparerait deux échelles, ce qui est précisément l'erreur que ce mémoire s'interdit ailleurs. Porté sur l'agrégat, l'intervalle bootstrap de ξ donne [3 042 ; 27 152] M€, soit un facteur 8,93 : le quantile annuel amplifie l'incertitude de paramètre, et le facteur 2,5 ne mesure donc pas ce que le paramètre fait au *capital*.

Étage, lu sur la charge annuelle	**Bande**	**Facteur**
Paramètre (ξ sur son IC_{90})	[3 042 ; 27 152]	8,93
Identification (direction de W)	[6 858 ; 8 697]	1,27
Modèle, axe dépendance	[5 322 ; 9 806]	1,84
Modèle, axe famille de queue	[4 330 ; 39 901]	9,21

En M€. La hiérarchie ainsi rétablie n'est pas celle qu'on annonce d'ordinaire : **l'étage de modèle n'écrase pas les autres**, il est du même ordre que l'étage de paramètre, et les deux dominent largement l'identification. Le retirer ne peut donc pas se justifier par sa taille, et l'argument qui suit est d'une autre nature. Réserve à garder : ces largeurs de paramètre font varier ξ seul, σ restant à sa valeur publiée, alors que le bootstrap estime le couple conjointement ; ce sont donc des *majorants*.

Pourquoi l'étage de modèle sort de la bande. Les deux étages retenus sont statistiques, portables par un intervalle ; le troisième est épistémique, un choix de famille ne se moyennant pas. Sur l'axe de la famille de queue, il pousse l'indice de queue à une valeur posée hors de l'intervalle bootstrap,

et le cumuler mettrait un scénario et une borne de confiance dans le même objet. Il reste publié deux fois, comme pire cas de modèle dans l'échelle des postures et comme bande de dépendance ci-dessus, et l'ordre d'amorce des piliers ne bouge pas *(voir le Matériel Complémentaire en ligne)*.

Sur l'auto-excitation : une équivalence observationnelle. Une cascade sans aucune auto-excitation, simulée puis ajustée comme une chronologie réelle, donne au jour un ratio de branchement de 0,480, à comparer au 0,551 mesuré. Le processus de Hawkes n'est donc pas distinguable de la cascade à la résolution disponible, et la cascade est retenue par parcimonie interprétative, puisqu'elle porte en outre la structure entre piliers. Dégrader la résolution fait monter le ratio estimé, et le préprint de cascade climatique converge sur ce choix sans le tester. Le détail est déporté *(voir le Matériel Complémentaire en ligne)*.

Oui, chaque brique a des alternatives. Fréquence (Poisson, Hawkes, Cox), sévérité (lognormale, splicing, EVT bayésienne), dépendance (copules, réseaux, Hawkes multivarié), mesure (TVaR, spectrale, robuste), agrégation (formule standard, Panjer) : on ne prétend pas détenir *la* méthode. La discipline est ailleurs : on a testé les concurrents les plus sérieux, on borne l'effet du choix, et surtout le niveau bouge dans la bande mais l'ordre d'amorce des piliers ne bouge pas ($P1 > P4 > P2 > P3 > P5$, invariant à la famille). Le niveau est illustratif, l'ordre résiste : c'est, chiffrée sur un troisième axe, la thèse du mémoire, et la réponse à qui demanderait « et si vous aviez pris une autre méthode ? ».

S4.20 Contrôle du moteur d'agrégation par trois chemins indépendants

Tout ce que les sections précédentes valident, elles le valident *contre la donnée* : adéquation, balayage de seuil, bootstrap, transformation intégrale de probabilité, test hors échantillon. Aucun de ces contrôles ne regarde le moteur qui transforme une loi de fréquence et une loi de sévérité en un quantile annuel. Un diagnostic de convergence de Monte-Carlo n'y supplée pas : il établit que l'estimateur est *stable*, jamais qu'il est *juste*, et un biais systématique de l'agrégation lui resterait invisible. La charge annuelle du modèle étant exactement une somme composée, $S = X_1 + \cdots + X_K$ avec $X_i = u + \mathrm{GPD}(\xi, \sigma)$, elle se calcule aussi sans simuler, ce que fait cette section.

Le nombre K de pertes non nulles d'une année se construit en trois étages tous exacts : les amorces suivent la binomiale négative, chaque amorce touche un ensemble de piliers dont les tables de cascade énumèrent la loi, et chaque pilier touché ne produit une perte qu'avec la probabilité de dépassement du seuil. Sa fonction génératrice s'écrit donc en forme fermée, ce qui ouvre deux voies étrangères au Monte-Carlo. L'inversion par transformée de Fourier donne la loi agrégée sans aucun aléa : c'est la réalisation numériquement stable de la récursion de Panjer (1981) (Embrechts et Frei, 2009), laquelle est inexploitable telle quelle à l'indice de queue publié, où elle demanderait une grille de plusieurs millions de points parcourue de proche en proche. L'*approximation par perte unique* (Böcker et Klüppelberg, 2005) exploite la sous-exponentialité de la sévérité, sous laquelle

la survie de la somme vaut asymptotiquement $\mathbb{E}[K]$ fois celle d'une perte isolée : elle donne une forme fermée, raffinée au second ordre par une correction de moyenne.

Méthode	Nature	Conforme	Non conforme
Monte-Carlo (moteur publié)	stochastique	6 049	20 188
Inversion par Fourier	numérique exacte	5 945	19 890
Perte unique, second ordre	analytique	5 448	18 632
Perte unique, premier ordre	analytique	4 989	14 933

En M€, VaR à 99,5 % de la charge annuelle. Écarts à la référence Monte-Carlo : −1,7 et −1,5 % pour l'inversion, −9,9 et −7,7 % au second ordre analytique, −17,5 et −26,0 % au premier.

Lecture, et elle ne se fait pas contre zéro. La référence est elle-même une grandeur simulée : sa moyenne sur quatre graines porte une erreur type de 139 et 500 M€ selon l'état. L'écart de l'inversion vaut 0,75 et 0,59 erreur type, donc il n'est pas résolu. Deux chemins qui ne partagent ni code ni aléa, l'un tirant des années et l'autre composant des transformées, ne se séparent pas à la résolution disponible : c'est le meilleur résultat que ce contrôle pouvait rendre ; c'est aussi la raison de ne pas citer le −1,7 % seul, qui se lirait comme un désaccord. L'approximation analytique, qui n'utilise ni simulation ni inversion, reste à moins de dix pour cent au second ordre contre plus du double au premier : la correction de moyenne rattrape l'essentiel, comportement que la théorie annonce pour une approximation asymptotique lue à un niveau fini.

Deux garde-fous numériques sont mesurés plutôt que supposés, parce qu'ils décideraient du résultat. La transformée discrète étant circulaire, la masse qui dépasse la grille revient dans les petits montants et gonfle le quantile : elle vaut ici $1{,}65 \cdot 10^{-8}$, soit quatre ordres de grandeur sous le niveau de dépassement. Et la sévérité est discrétisée par les masses et non par la densité, ce qui laisse un écart de 0,063 % sur sa moyenne.

Ce que ce contrôle établit, et ce qu'il n'établit pas. Les quatre chemins partagent la loi de fréquence, la loi de sévérité et les tables de cascade : ils contrôlent l'*agrégation*, jamais la vérité du modèle. C'est un contrôle d'instrument, du même genre que celui qui impose au test de l'additivité des coûts de redonner les deux capitaux publiés à exposant neutre, et il ne remplace aucun test contre la donnée. Sa portée est précise : le quantile publié n'est pas un artefact du moteur de simulation.

S4.21 VaR prédictive et VaR robuste

Quantifier l'incertitude (les trois étages) ne dit pas encore *quel* nombre reporter. Prendre le quantile 99,5 % d'une loi estimée en un point (*plug-in*) est fragile, car les données sont incertaines : « le quantile d'un objet incertain est mauvais » (C. Hillairet). Deux réponses complémentaires, selon la posture (figure S4.13), le détail étant déporté *(voir le Matériel Complémentaire en ligne)*.

La VaR prédictive intègre l'incertitude de paramètre *avant* de prendre le quantile : on prend le quantile de la loi *prédictive*, mélange des GPD sur la distribution bootstrap de (ξ, σ). Le résultat est

instructif : à 99,5 % elle est *quasi égale* au *plug-in* (645 contre 657 M€, pour un bruit de simulation de 7 M€, donc un écart qui n'excède pas deux fois ce bruit) : le risque d'estimation n'est pas un biais de point à ce niveau, il ne le devient qu'en profondeur (+4 % à 99,9 %). La fragilité est dans la largeur de la bande, pas dans le point.

La VaR robuste prend au contraire la borne haute de la VaR sur l'ensemble d'ambiguïté (paramètre, puis modèle) : la VaR robuste à 95 % vaut 1 037 M€ (1,6× le *plug-in*), le pire-cas de famille lourde 1 331 M€. C'est la posture prudente, où le niveau de robustesse est un choix prudentiel explicite.

Les six postures, et ce que chacune intègre. La figure S4.13 en affiche six, et les nommer ne suffit pas : une échelle dont les crans ne sont pas définis n'est pas une échelle, c'est une suite de nombres. La table les définit donc une fois, avec la précision que chacune supporte.

Posture	**Ce qu'elle intègre**	**VaR**	**bruit**
Point (*plug-in*)	rien : le quantile d'un ajustement ponctuel $(\hat{\xi}, \hat{\sigma})$	657	—
Prédictive	l'incertitude de paramètre, *avant* le quantile, par mélange sur le bootstrap	645	± 7
Robuste $\beta = 90\,\%$	la borne haute de la VaR sur l'ambiguïté de *paramètre* : le quantile β de la loi bootstrap de la VaR	939	± 13
Robuste $\beta = 95\,\%$	idem, à un niveau de prudence plus élevé	1 037	± 9
Robuste $\beta = 99\,\%$	idem, la plus bruitée des six	1 247	± 24
Pire-cas de modèle	on ajoute l'ambiguïté de *famille*, en poussant la queue à $\xi = 0{,}90$	1 331	—

En M€. Le bruit est l'écart-type de simulation sur quatre rééchantillonnages indépendants, à 3 000 tirages bootstrap chacun. Deux lectures s'imposent, et la seconde n'était pas attendue.

Les deux extrémités de l'échelle sont exactes et tout le bruit est au milieu ; la posture la plus prudente est la moins précise. Les deux valeurs de la VaR prédictive, 648 et 645 M€, sont un seul nombre à la précision du bruit. Le détail est déporté *(voir le Matériel Complémentaire en ligne)*.

Quelle posture le mémoire reporte-t-il. La question mérite une réponse explicite, puisque six valeurs vont de 657 à 1 331 M€. Tous les capitaux publiés dans ce mémoire sont bâtis sur la calibration figée, donc sur le *plug-in*, et ils sont cités avec leur bande d'identification partielle. L'échelle des postures n'est pas une alternative à ce choix : c'est l'axe de sensibilité qui en donne le coût, et le passage du point au robuste 95 % multiplierait le capital par 1,6. Le choix d'une posture reportée relève de la politique prudentielle de l'entité, non du modèle : le mémoire en retient une pour ses propres chiffres, avec ses motifs (§10.5), et fournit la grille qui permet à une entité d'en retenir une autre.

Deux points qui intègrent l'incertitude. La VaR prédictive est le point *central* (il embarque l'incertitude d'estimation) ; la VaR robuste est le point *prudent* (la borne haute sur l'ambiguïté). Le

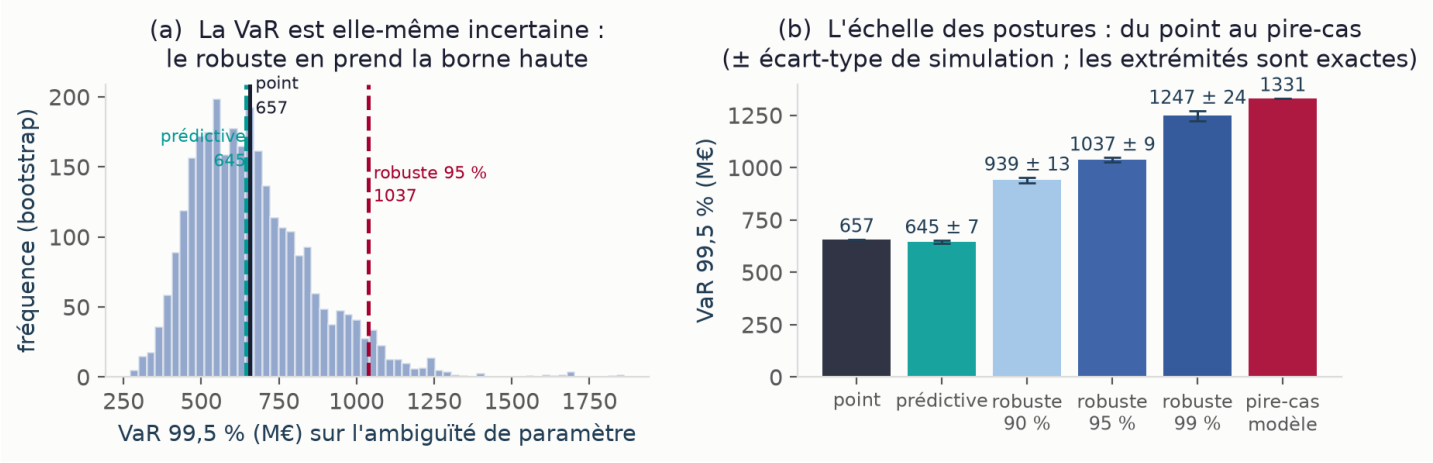


FIGURE S4.13. VaR robuste. (a) la VaR est elle-même incertaine ; le robuste en prend la borne haute. (b) l'échelle des postures, du point (657) au pire-cas de modèle (1 331 M€), chacune avec son écart-type de simulation. Les deux extrémités n'en portent aucun, étant déterministes ; la barre la plus longue est celle de $\beta = 99\,\%$, la posture la plus prudente et la moins précise.

choix entre les deux relève de la politique prudentielle, non du calcul. L'essentiel est de ne jamais reporter le seul *plug-in* : le SCR se cite avec sa bande, ou par un point qui assume l'incertitude, jamais nu.

La posture retenue et ses motifs

Un fait qui rend le choix moins tranché qu'il n'y paraît : la robuste à $\beta = 95\,\%$ est la borne haute de l'intervalle déjà publié. La robuste au niveau β est le quantile β de la loi bootstrap de la VaR ; l'intervalle publié à 90 % est délimité par les quantiles 5 et 95 de cette même loi. Les deux valent donc 1 037 M€, et ce n'est pas une coïncidence numérique mais la même quantité sous deux noms. Reporter le *plug-in* avec sa bande publie donc déjà le chiffre robuste, comme une *borne* et non comme un point. Le désaccord entre les deux postures ne porte pas sur l'information mise à disposition du lecteur, il porte sur ce qu'on appelle « le » capital. La question se tranche pour cela par la définition réglementaire plutôt que par la prudence.

Le paragraphe qui précède donne la grille ; il faut maintenant trancher, sans quoi le mémoire laisserait son résultat central sans convention de report. La posture retenue est le *plug-in* accompagné de sa bande, la robuste restant publiée comme axe prudentiel déclaré. Trois raisons convergent, et elles ne sont pas de même nature.

La première est réglementaire, et elle vient en premier. Le régime applicable définit le capital de solvabilité requis comme une valeur en risque à 99,5 % de la variation des fonds propres à un an. Une borne haute prise sur un ensemble d'ambiguïté n'est pas un quantile de la loi de perte : c'est un supremum sur une famille de lois. La substituer répondrait à une autre question que celle posée. Le risque d'estimation se traite dans le régime par la validation du modèle et par le récit de l'ORSA, non en gonflant le quantile, et pour une raison de cohérence d'ensemble : appliquée à chaque module, la même logique empilerait des marges dont le niveau de confiance global ne serait plus énonçable.

La deuxième est une mesure, celle qui rend le choix confortable. La prédictive, qui est la

réponse théoriquement préférable puisqu'elle intègre l'incertitude *avant* le quantile, vaut 645 M€ contre 657 pour le *plug-in*, soit un écart de deux fois le bruit de simulation. La bonne réponse ne déplace donc pas le point. Reporter la prédictive remplacerait un nombre publié partout par un nombre indiscernable, au prix de la piste d'audit et contre le gel de la calibration : le gain serait nul et le coût réel. Cette coïncidence n'est pas générale et cesse en profondeur, l'écart passant à +4 % à 99,9 % : c'est en profondeur de queue, non au niveau réglementaire, que le choix de posture commencerait à compter.

La troisième est une question de précision, et elle va contre l'intuition. Les postures robustes sont les moins reproductibles des six, avec des écarts-types de simulation de 13, 9 et 24 M€ quand les deux extrémités de l'échelle n'en portent aucun. Reporter comme chiffre de tête la valeur la moins précise contredirait la convention que ce mémoire s'impose par ailleurs, à savoir que toute grandeur simulée se publie avec son bruit.

> **Ce que cette décision ne dit pas.** La robuste n'est pas écartée : elle reste publiée, et elle est le bon nombre pour un *autre* usage. Dimensionner une couverture ou fixer une limite de rétention est une décision sous ambiguïté, où l'on veut précisément la borne haute et non le quantile central ; le §9.13 en est l'exemple. Une même grandeur peut donc être reportée sous une convention et utilisée sous une autre, à condition de dire laquelle et pourquoi, ce qui est fait ici.
> **Et ce qui ferait rouvrir la décision**, énoncé d'avance pour qu'elle ne dépende pas d'une préférence : un écart prédictive contre *plug-in* qui dépasserait durablement quelques unités de bruit au niveau réglementaire, ou un déplacement de l'objet du travail, du capital *reporté* vers une décision sous ambiguïté. Aucun des deux n'est le cas aujourd'hui.

S4.22 Un défaut de calibration chiffré

Un inventaire qui ne porterait que les hypothèses choisies serait incomplet : il doit aussi porter les défauts connus. Il en reste un, de nature différente des précédents, car ce n'est pas une hypothèse discutable mais une incohérence arithmétique.

La formule des dépassements de seuil prend trois entrées, le seuil u, le taux de dépassement p_u et le couple (ξ, σ), pour deux degrés de liberté seulement : le seuil et l'échantillon une fois fixés, p_u se *compte*, il ne se choisit pas. Or la calibration figée publie $u = 20{,}03$ M€ et $p_u = 0{,}1509$, quand ce seuil laisse 91 excès sur 582 pertes, soit 0,1564. Le 0,1509 vaut $88/583$, le taux du percentile 85 d'un filtrage antérieur resté dans la configuration après que le seuil eut bougé. Aucun état du monde ne rend les deux valeurs vraies ensemble, et un lecteur qui pose la division le voit en trente secondes.

L'effet se chiffre exactement. Au taux cohérent, le quantile de sévérité à 99,5 % passerait de 662,78 à 678,60 M€, soit +2,4 %, ou 15,8 M€. Deux lectures de ce signe doivent être distinguées, parce qu'on les confond volontiers. Du côté de la solvabilité, l'écart est anti-conservateur : il sous-estime le besoin de capital, et une sous-estimation ne s'excuse pas par la prudence, elle se déclare. Du côté de la thèse, il va dans l'autre sens, puisque le chiffre avancé n'est pas gonflé par ce défaut

mais minoré. Les deux sont vrais, ils ne portent pas sur la même chose, et seul le premier engage.

La valeur est néanmoins gelée et l'écart inscrit au registre des limites : rejouer le pipeline déplacerait des centaines de nombres publiés sans qu'aucun déplacement soit attribuable à la correction *(voir le Matériel Complémentaire en ligne)*.

Le sens des écarts, en deux colonnes. Un défaut isolé se pardonne ; une série de défauts qui vont tous du même côté est un biais. Il vaut donc mieux mettre les deux colonnes en regard une fois pour toutes, plutôt que de laisser le lecteur les rassembler lui-même.

Écart	Sens	Taille
Défauts d'estimation, tous trois anti-conservateurs		
Taux de dépassement gelé (p_u)	sous-estime	+2,4 % de VaR manquante
Couverture réelle de l'IC_{90} de ξ	sous-estime	86 % au lieu de 90 % ; demi-largeur à élargir d'environ 10 %
Échelle de sévérité non stationnaire	sous-estime	dérive de 4,00 % par an dans la queue ($p = 0{,}0386$), dont la moitié d'inflation monétaire ; au moins +24,7 % sur le quantile, borne basse (§4.7)
Choix posés, tous deux prudents		
Charge systémique a	majore	0,60 posé, au-delà de la borne haute empirique 0,22
Sur-dispersion du moteur φ	majore	9,20 posé contre 2,24 mesuré
Limites de périmètre et de transposition, de sens opposés		
Attritionnel absent de la donnée	sous-estime	non chiffrable : la base est tronquée à son seuil de collecte, les petits sinistres n'y figurent pas
Sévérité non plafonnée à l'échelle d'entité	majore	élasticité sévérité/taille 0,087 [0,026 ; 0,148], presque nulle ; affecte le *niveau* d'entité, et peut modifier les écarts entre états
Hypothèse dont le sens n'est pas déterminable		
Additivité des coûts au sein d'un sinistre multi-piliers	**indéterminé**	élasticité de l'écart 1,20 ; [9 706 ; 20 487] M€ pour $\theta \in [0{,}70 ; 1{,}30]$, soit 76 % de l'écart publié (§10.7)

La lecture est nette sur les cinq premières lignes. Les trois écarts *involontaires* d'estimation sous-estiment tous le capital ; les deux choix *délibérés* le majorent. La prudence du capital publié vient donc de choix déclarés, non de ses écarts d'estimation. L'indice de queue n'est pas de ces choix : le chiffre de tête repose sur la valeur estimée, et la valeur posée plus lourde n'intervient que comme pire cas de modèle dans l'échelle des postures (§10.5), hors du capital reporté.

La troisième ligne pèse un quart quand les deux premières pèsent quelques pour cent. Son effet sur l'écart entre états est mesuré, $-1{,}9$ % et non résolu, et la moitié de la dérive de queue est monétaire. Les deux lignes de périmètre bornent le niveau en sens contraire : l'attritionnel absent de la donnée pèse peu au quantile d'entité, et le plafond de sévérité qui amputerait le besoin de moitié ne va que

de 53 à 74 M€ sur des entités dont la taille varie d'un facteur 134. La dernière ligne, l'additivité des coûts, est la seule dont le sens ne se déclare pas (§10.7). Le motif du gel, la lecture de chaque ligne et le plafond chiffré sont déportés *(voir le Matériel Complémentaire en ligne)*.

S4.23 Défaillances simultanées et additivité des coûts

La cascade produit, pour chaque sinistre, un *ensemble* de piliers touchés, si bien que la défaillance simultanée n'est pas un cas particulier resté de côté mais la sortie même du modèle. La loi exacte de ce nombre est donnée *(voir le Matériel Complémentaire en ligne)* : à l'état non conforme, la défaillance multiple est majoritaire, 62,31 % des sinistres touchant plus d'un pilier contre 31,15 % à l'état conforme. Reste la question de l'agrégation des coûts, et elle demande de distinguer trois énoncés que le seul mot d'additivité recouvre.

1. **Au sein d'un sinistre**, les coûts des piliers touchés *s'additionnent* : c'est une hypothèse de construction, non testée, seul des trois que la question met en cause.
2. **En fonction des piliers non conformes**, le capital est *presque additif*, $R^2 = 0{,}9945$ sur les 32 configurations : c'est une mesure, et elle explique qu'une structure de dépendance entre états ne déplace pas le capital espéré *(voir le Matériel Complémentaire en ligne)*.
3. **En fonction des quatre canaux**, il est *franchement super-additif* en euros, +5 001 M€ d'interaction sur 14 139, soit +35 % (chapitre 9) : c'est également une mesure, et elle traduit une composition quasi *multiplicative* des canaux, le logarithme du capital étant, lui, presque additif (§S1.4.1).

Répondre « le modèle est super-additif » serait donc faux : il l'est sur les canaux et en euros, parce que leurs effets se multiplient, pas sur les piliers, et l'hypothèse sur les coûts d'un incident est un troisième objet.

Sensibilité à l'additivité des coûts. On fait varier cette hypothèse par un exposant, la perte d'un sinistre touchant k piliers valant $\left(\sum_j X_j\right) k^{\,\theta-1}$, de sorte que $\theta = 1$ redonne exactement le modèle publié et que les sinistres mono-pilier restent intouchés. Pour θ parcourant $[0{,}70\,;\,1{,}30]$, l'écart entre états parcourt $[9\,706\,;\,20\,487]$ M€, soit 76 % de l'écart publié et 15 fois l'écart-type de 734 M€ entre quatre graines. Cette sensibilité dépasse le bruit de simulation et fait de l'additivité des coûts l'hypothèse structurelle non testée la plus influente sur l'*écart*.

La queue de sévérité domine, elle, l'incertitude sur le *niveau* (§10.3). L'additivité est une hypothèse de structure et non un choix de prudence, les trois choix posés du §10.6 déplaçant davantage mais dans une direction connue.

Elle n'est pas neutre entre les deux états, ce qui n'était pas attendu. Les élasticités valent 0,95 à l'état non conforme contre 0,39 à l'état conforme, un facteur 2,42, parce que l'exposant ne mord que sur les sinistres multi-piliers, majoritaires au seul état non conforme. L'hypothèse interagit donc avec le canal de propagation au lieu de s'ajouter à côté de lui, et atteint de ce fait la grandeur centrale du mémoire et non un simple niveau. Ce qui tient malgré tout : sur toute l'amplitude examinée l'écart

garde son signe et son ordre de grandeur, jamais proche de zéro, si bien que la thèse ne dépend pas de l'hypothèse d'additivité et que seule son amplitude en dépend. C'est la structure d'argument déjà employée pour les valeurs de g.

Le *sens* de la non-additivité, lui, n'est pas déterminable : mutualisation de la remédiation et saturation de la capacité de réponse tirent en sens contraire, et aucune source ne les sépare. Le détail, la loi du nombre de piliers, la table complète des exposants et la raison pour laquelle l'amplitude est posée plutôt qu'estimée sont déportés *(voir le Matériel Complémentaire en ligne)*.

Croisée avec le plafond de sévérité, elle s'efface là où il mord. La limite de périmètre du §10.6 tire en sens inverse : un plafond de sévérité adossé à l'exposition E de l'entité, à une fraction κ de celle-ci, abaisserait le besoin quand un exposant $\theta > 1$ le relève. Les deux réserves sont mesurées ensemble sur l'entité notionnelle, la perte d'un sinistre valant $\min\big(\kappa E,\ (\sum_j X_j)\, k^{\,\theta-1}\big)$ (figure S4.14). Elles ne se compensent pas : le terme d'interaction est positif sous $\theta = 1$ et négatif au-delà, le plafond atténuant la saturation dans les deux sens, jusqu'à l'effacer à $\kappa = 0{,}5\,\%$, où le besoin vaut 96,2 M€ pour les cinq exposants. Aucun couple où le plafond mord ne ramène le besoin à sa valeur libre, 179,1 M€ dans ce moteur simulé au niveau du sinistre, du même ordre que les 169 publiés. Les deux réserves sont donc hiérarchisées et non confondues, et la bande conjointe, 177,8 M€, reste sous la somme des deux bandes marginales, 203,7 : les additionner surestimerait l'incertitude.

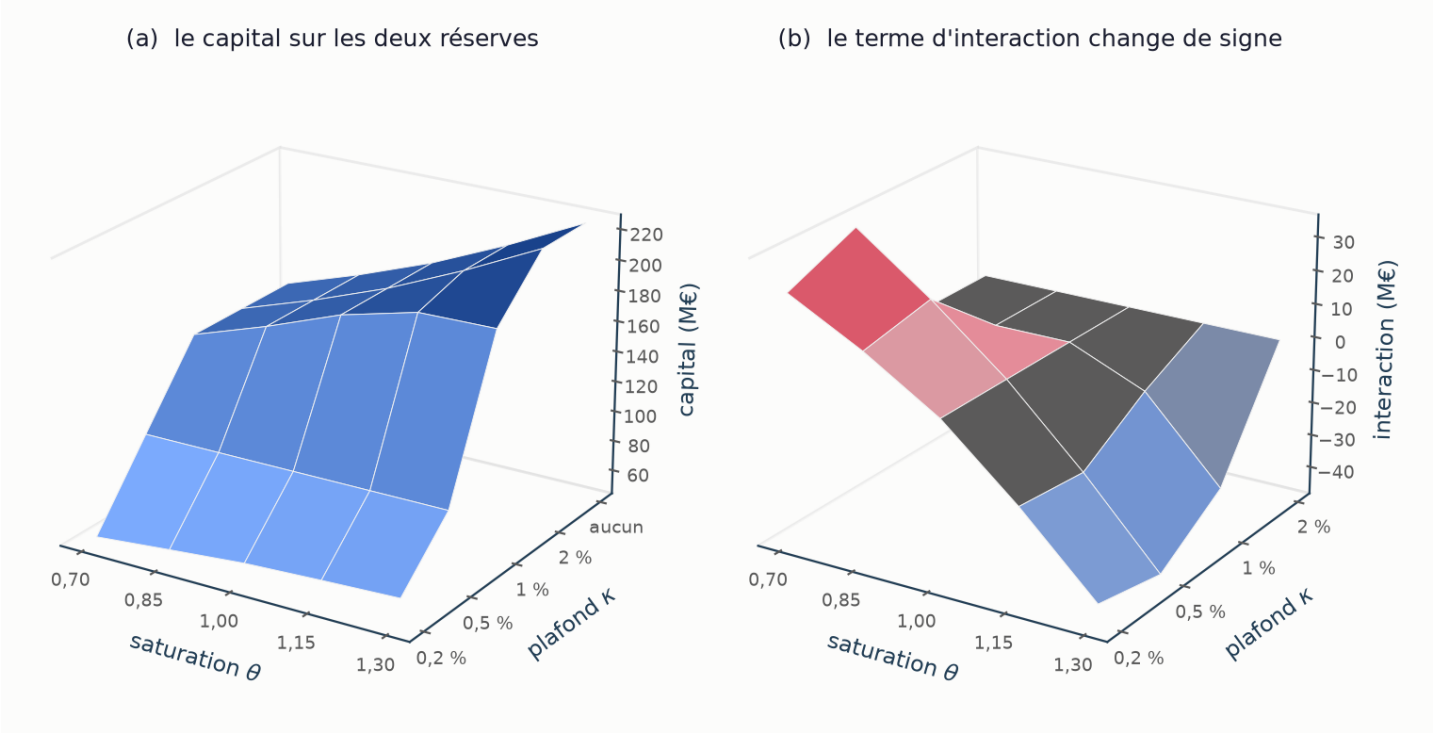


Figure S4.14. La saturation et le plafond croisés sur l'entité notionnelle. (a) le besoin de capital, avec la ligne plate à $\kappa = 0{,}5\,\%$ où la sensibilité à θ est nulle. (b) le terme d'interaction, nul à $\theta = 1$, positif en deçà et négatif au-delà : le plafond est un amortisseur et non un contrepoids. L'axe des plafonds est ordinal, son dernier cran étant l'absence de plafond.

La double lecture. « Insensible aux choix innocents, sensible aux leviers réels » : le modèle n'est ni sur-ajusté ni fragile, il est piloté par ce qui doit le piloter. Et la seule grande incertitude, la queue, est nommée et bornée, pas cachée. C'est ce qui sépare un modèle dont tout n'est pas calibré d'un modèle dont on ignore de quoi il dépend : ici, la dépendance du capital est établie levier par levier, et son absence aussi.

S4.24 RECOMMANDATIONS SUR LA DONNÉE MANQUANTE

Idée directrice. Le chapitre 7 a montré que la direction de la contagion n'est pas identifiable sur les sources agrégées. Cette limite n'est pas un point final : elle se retourne en spécification de reporting, et cette spécification se chiffre puis se hiérarchise. C'est la contribution réglementaire du travail, et elle ne dépend d'aucun prior.

S4.24.1 Contenu d'un registre d'incidents

Puisque les trois sources agrégées échouent pour des raisons *distinctes* (la première manque de taxonomie et de volume informatif, la deuxième de résolution temporelle, la troisième possède les bons champs mais ne les renseigne pas), la donnée qui identifierait W se déduit par complémentarité, et la proposition 5.7 y ajoute une exigence. Un registre d'incidents TIC l'identifiant devrait :

1. horodater la survenance (et non la seule déclaration) au mois ou à la semaine, afin de porter une antériorité que le pas annuel efface ;
2. catégoriser par domaine de contrôle (les piliers DORA), et non par vecteur d'attaque, afin qu'une transition soit interprétable comme un lien $k \to j$;
3. consolider une cause commune comme *un* événement à N victimes, pour ne pas confondre un lot de déclaration avec une contagion séquentielle ;
4. consigner, pour chaque incident, l'ensemble des piliers qui ont cédé, y compris ceux qui n'ont rien entraîné. Même sans horodatage, la loi jointe des piliers touchés distingue une matrice de sa transposée : sur la matrice publiée, la part des sinistres touchant plus d'un pilier vaut 62,31 % sous W et 50,77 % sous $W^\top$.

Ces exigences ne sont pas hors d'atteinte, mais elles ne relèvent pas du même instrument. Le registre d'information du règlement d'exécution (Commission européenne, 2024) porte sur les accords contractuels avec les prestataires : il identifie les prestataires, la chaîne de sous-traitance et la criticité des fonctions, ce qui sert la troisième exigence en permettant de rattacher des incidents à un même prestataire. Les trois autres relèvent de la notification des incidents majeurs, dont il s'agit de fixer le *format* de l'horodatage et le *choix de la taxonomie* plutôt que d'organiser une collecte nouvelle.

La spécification n'est même pas à écrire : elle existe et n'est pas remplie. Les deux premières exigences ci-dessus sont déjà des champs du schéma VERIS, standard ouvert de description d'incidents et support du *Data Breach Investigations Report* : le champ `control_failure` porte le domaine de contrôle défaillant, et une chronologie en quatre étapes (compromission, exfiltration, découverte, confinement) porte l'antériorité. Sur les 10 591 incidents de la base publique associée, le premier est renseigné dans 0,12 % des cas et la seconde, sur au moins deux étapes, dans 1,19 % ; leur intersection ne compte qu'un seul incident, et aucun en secteur financier (chapitre 7). La recommandation change alors de nature. Elle ne demande pas d'inventer une taxonomie, ce qui serait long et contestable, mais de rendre obligatoires deux champs déjà normalisés dans un dispositif, la notification d'incident majeur sous DORA, qui a précisément le pouvoir de l'imposer là où une base déclarative volontaire ne l'a pas. C'est un coût de conception nul et un gain d'identification chiffré à la section suivante.

S4.24.2 Valeur en capital de l'information

Une recommandation de reporting reste un vœu tant qu'elle n'est pas chiffrée. On la chiffre en restreignant l'ensemble admissible du chapitre 8 aux configurations compatibles avec l'information acquise, puis en mesurant le rétrécissement de la bande de capital.

Définition S4.1 (Valeur d'information d'une contrainte)**.** Soit $\mathcal{W}$ l'ensemble admissible et $\mathrm{SCR} : \mathcal{W} \to \mathbb{R}_+$ la fonctionnelle de capital. La largeur de bande associée à un sous-ensemble $\mathcal{V} \subseteq \mathcal{W}$ est

$$L(\mathcal{V}) \;=\; \sup_{W \in \mathcal{V}} \mathrm{SCR}(W) \;-\; \inf_{W \in \mathcal{V}} \mathrm{SCR}(W). \tag{S4.2}$$

Une information $\mathcal{I}$ qui restreint l'ensemble à $\mathcal{W}_{\mathcal{I}} \subseteq \mathcal{W}$ a pour valeur le rétrécissement relatif qu'elle produit :

$$V(\mathcal{I}) \;=\; 1 - \frac{L(\mathcal{W}_{\mathcal{I}})}{L(\mathcal{W})} \;\in\; [0, 1]. \tag{S4.3}$$

Cette définition a deux propriétés utiles. Elle est monotone : si $\mathcal{I}'$ implique $\mathcal{I}$, alors $\mathcal{W}_{\mathcal{I}'} \subseteq \mathcal{W}_{\mathcal{I}}$ et donc $V(\mathcal{I}') \geq V(\mathcal{I})$, une information plus riche ne pouvant pas valoir moins. Et elle est sans dimension, donc indépendante du niveau de capital, ce qui la rend comparable d'une source de sévérité à l'autre alors même que ce niveau, lui, varie d'un facteur quarante.

Les sept premiers rapports post-incident du corpus du chapitre 7 documentent le *sens* de six des dix dépendances entre piliers, sens que le §7.8 ne revendique paire par paire que sur deux d'entre elles. Retenu sur les six, il ferait tomber la largeur de la bande de 66 %. Ce chiffre est donc la valeur, en capital, d'une information de sens de cette étendue, non un acquis du mémoire, et il donne l'ordre de grandeur de ce qu'un registre correctement spécifié apporterait.

> **Ce qu'aucune information de sens ne donnera.** Même les dix directions établies, une bande subsisterait, imputable à la seule amplitude des coefficients : connaître le sens d'un lien ne donne pas sa force. L'identification partielle n'est donc pas un état provisoire que la donnée

> finirait par lever, elle est structurelle. C'est une raison de plus de lire le capital en bande, et de ne pas promettre à un superviseur davantage que ce qu'un registre peut tenir.

S4.24.3 Priorités de documentation des dépendances

L'apport le plus actionnable est ailleurs que dans le total. En fixant le sens d'*une seule* dépendance à la fois, on obtient un classement des données manquantes par valeur d'information (figure 10.1). Le classement est très inégal : documenter la seule dépendance entre gouvernance et gestion des incidents lèverait 28,9 % de l'ambiguïté de capital, tandis que documenter le lien entre tests et tiers n'en lèverait *rien*.

Deux conséquences pratiques. D'abord, un superviseur qui ne pourrait exiger qu'une seule dépendance sait désormais laquelle demander, et une entité qui ne pourrait instrumenter qu'un seul lien sait lequel instrumenter. Ensuite, un fait qui oriente la recommandation : la dépendance la plus précieuse est précisément celle que le corpus documentaire ne couvre pas. La lecture de rapports publics a livré ce qu'elle pouvait livrer ; le reste exige la donnée d'entité.

La limite devenue contribution. Un mémoire qui se contenterait de constater qu'il ne peut pas calibrer W laisserait le lecteur sans suite. En spécifiant la donnée qui manque, en chiffrant ce qu'elle vaut et en la hiérarchisant, on transforme une frontière d'identification en *recommandation opposable*, adressée au cadre de reporting que DORA met précisément en place. C'est le seul endroit du mémoire où une limite produit un livrable.

S4.25 SCR PAR ÉTAT DE CONFORMITÉ

Le SCR croît de façon monotone de l'état conforme à l'état non conforme (figure S4.16). Le tableau 9.1 donne les trois lectures emboîtées : la lecture A porte sur la fréquence seule ; la lecture B ajoute la propagation de la cascade ; la lecture C ajoute le canal détection.

	OpRisk (M€)			**PRC** (M€)		
État	A	B	C	A	B	C
Conforme	8301	6664	5932	2589	1903	1642
Partiellement conforme	11059	9625	9625	3653	3118	3118
Non conforme	15074	15074	16595	5520	5520	6577

TABLEAU S4.1. SCR par état, trois lectures (A : fréquence ; B : + propagation ; C : + détection). Le canal détection ne joue qu'aux extrêmes (il abaisse l'état conforme et relève le non conforme), l'état partiel n'étant pas modulé.

Quatre lectures emboîtées de l'écart et lecture publiée

Le tableau qui précède n'est pas le seul protocole du mémoire à chiffrer « l'écart entre l'état conforme et l'état non conforme ». Quatre le font, et ils donnent quatre résultats. Aucun n'est faux : ils ne relâchent pas le même nombre de canaux entre les deux états, et rien d'autre ne les sépare. Les publier sans le dire reviendrait à laisser le lecteur trancher sans les éléments.

Lecture	canaux	conforme	non conf.	facteur
Score de conformité seul, g figé au niveau NC	1	7987	16 847	2,11
Fréquence + propagation (lecture B)	2	6664	15 074	2,26
+ détection (lecture C)	3	5932	16 595	2,80
+ accumulation P4 (les quatre canaux)	**4**	**6049**	**20 188**	**3,34**

En M€, périmètre OpRisk. Les niveaux sont ceux des sorties versionnées ; les *rapports*, eux, sont recalculés à chaque exécution plutôt que calculés à la lecture, faute de quoi un niveau amont pourrait bouger sans que le facteur suive.

Le mémoire publie la lecture à quatre canaux : 6 049 → 20 188 **M€, soit un facteur** 3,34 **et un écart de** 14 139 **M€.** Le motif n'est pas qu'elle donne le chiffre le plus grand, c'est qu'elle est la seule où l'état conforme est conforme sur tous les canaux que le modèle possède. Dans la première lecture, l'entité dite conforme propage encore comme une entité défaillante ; dans les deux suivantes, sa détection ou son accumulation tiers restent au niveau non conforme. Une entité conforme sur un canal et non conforme sur trois autres n'est pas un état conforme, c'est une *remédiation partielle*, et la nommer conforme sous-estime l'écart par construction.
Le canal de détection y est inclus parce que son effet est résolu : il pèse 2 928 ± 343 M€ en valeur de Shapley et 4 562 ± 819 en marginal de fermeture, signe résolu sur seize graines.
Les trois autres lectures ne sont pas retirées, délibérément : ce sont des remédiations *partielles*, ce qui est un objet utile en soi, et leur emboîtement chiffre ce que coûte de ne fermer qu'une partie des canaux.

> **Le facteur se compare d'une lecture à l'autre, l'écart en euros non** : l'écart passe de 8 860 à 8 410 M€ entre les deux premières lignes alors que le facteur monte. La cause n'est pas un effet de modèle mais un changement de base, l'état conforme passant de 7 987 à 6 664 M€ d'un protocole à l'autre. Un écart en euros ne se compare qu'à base égale ; un rapport est sans dimension. C'est le même motif qui fait publier des élasticités plutôt que des plages au §9.7.
> **Et la monotonie du facteur s'observe, elle ne se teste pas ici.** Les quatre lignes ne forment pas une expérience contrôlée, leurs protocoles différant aussi par la graine et par la base. Elle est *cohérente* avec la composition des canaux mesurée sur les seize configurations (figure S4.15), qui partagent le même moteur et les mêmes graines : les canaux s'y multiplient presque exactement, le produit des quatre facteurs isolés valant 3,47 pour un facteur publié de 3,34, si bien que l'interaction de 5 001 M€ en euros est l'arithmétique d'un produit plus qu'un effet propre de la cascade (§S1.4.1).

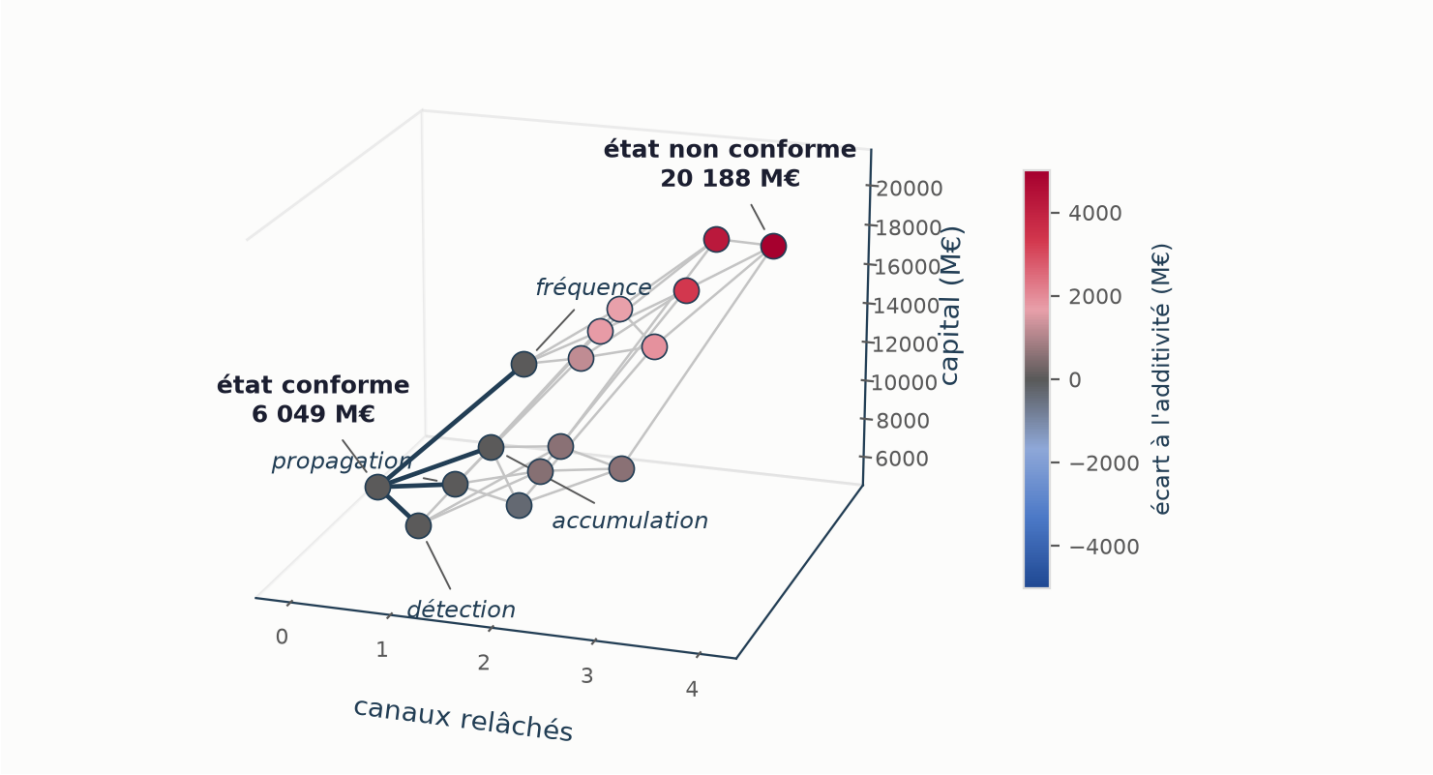


FIGURE S4.15. Les seize configurations de canaux, rangées par nombre de canaux relâchés. La hauteur est le capital, les deux extrémités étant les deux états publiés, 6 049 et 20 188 M€ ; tout sommet intermédiaire est une remédiation partielle. Chaque arête monte, ce qui est la monotonie du §S1.4.1 lue d'un coup d'œil. La couleur est l'écart à l'additivité, c'est-à-dire le capital observé moins la somme des quatre effets isolés : elle vaut +5 001 au sommet complet et −330 sur la seule paire négative du dossier, propagation et accumulation. Le troisième axe sépare les configurations de même rang et ne porte aucune grandeur.

Où chaque lecture continue de servir. Les trajectoires du §9.4 et la priorisation du §9.5 restent conduites en *lecture B*. Ce n'est pas une indécision résiduelle mais un choix d'objet : elles portent sur l'*ordre* de remédiation, dont le chapitre 10 montre qu'il est invariant aux leviers testés, de sorte que le canal ajouté déplacerait leurs niveaux sans déplacer leur conclusion. Les rejouer relèverait par ailleurs de la recalibration, que le gel interdit.

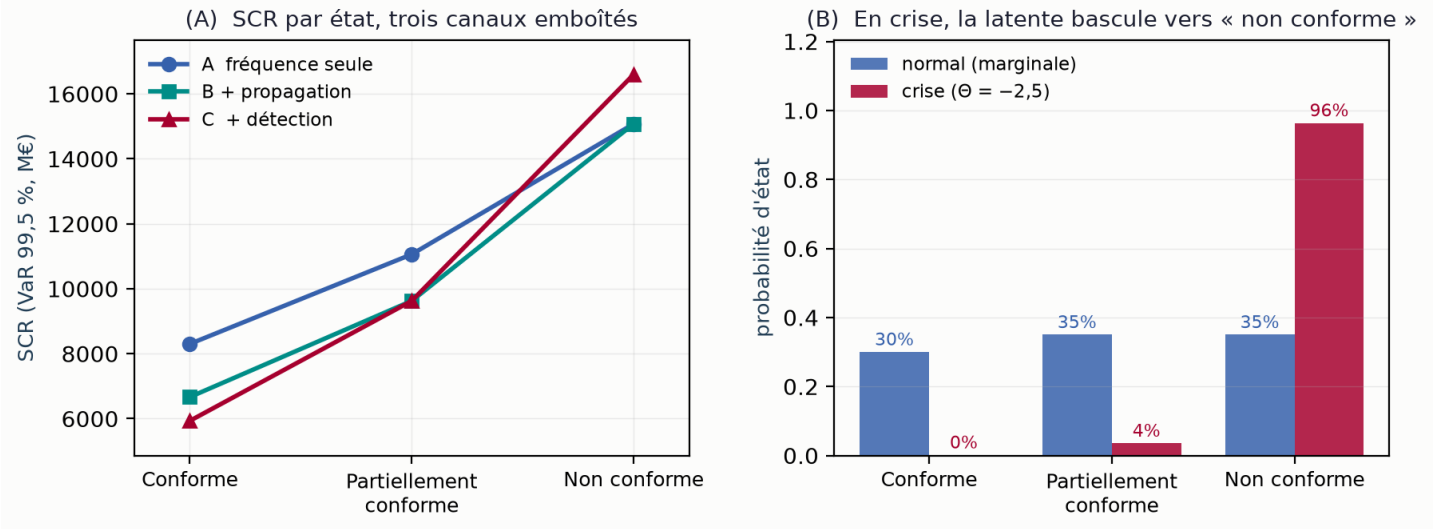


FIGURE S4.16. SCR par état de conformité (trois canaux emboîtés) et bascule des états en crise systémique.

Le surcoût de non-conformité $\Delta_{\text{DORA}} = \text{SCR(NC)} - \text{SCR(C)}$, à graine Monte-Carlo commune (l'écart ne vient que du changement d'état, non du bruit), s'obtient par bootstrap deux niveaux (multiplicateurs + sévérité), et 100 % des tirages sont positifs.

	médiane	IC90 %
Δ_{DORA} NC vs C (OpRisk)	7401	[2830 ; 38793]
Δ_{DORA} PC vs C (OpRisk)	2556	[963 ; 12768]
Δ_{DORA} NC vs C (PRC)	3668	[3201 ; 4094]
Δ_{DORA} PC vs C (PRC)	1257	[1077 ; 1466]

TABLEAU S4.2. Surcoût de non-conformité en euros (M€), lecture B (fréquence + propagation), bootstrap deux niveaux. Côté OpRisk la sévérité de queue est ré-échantillonnée sur les 91 excès réels, non tirée dans une approximation normale ; l'intervalle reste large parce que la queue l'est, non par artefact de méthode.

Lecture actuarielle. L'intervalle très large côté OpRisk du tableau 9.2 n'est pas un défaut du modèle : c'est la signature d'une queue d'indice 0,60, où le niveau du capital est intrinsèquement imprécis. L'écart typique (interquartile) est bien plus resserré que l'intervalle à 90 %, et le *signe* du surcoût, lui, est certain. On retrouve la thèse du mémoire : le SCR est une distribution, pas un point.

L'intervalle PRC est étroit, et il le reste quand on cesse de croire la conversion exacte. La sévérité PRC est dérivée du nombre d'enregistrements compromis par la relation log-log de Jacobs (2014), dont le résidu vaut 0,523 en logarithme naturel : à volume donné, le coût réel varie d'un facteur 2,4 autour de la droite à 90 %. Réinjecter ce résidu enregistrement par enregistrement ne rouvre pourtant presque pas l'intervalle, le bruit se moyennant dans l'ajustement GPD ; il déplace le *niveau* du surcoût de 7 %, sans l'élargir *(voir le Matériel Complémentaire en ligne)*. L'étroitesse de l'intervalle PRC n'est donc pas un artefact de la conversion déterministe.

S4.26 DÉCOMPOSITION PAR PILIER

En basculant un pilier à la fois de conforme à non conforme, le surcoût se décompose (figure S4.17). Le classement obtenu, $P1 > P4 > P2 > P3 > P5$, reproduit exactement le classement ROOT du modèle qualitatif. La convergence n'est pas une validation indépendante : les amorces de la cascade sont semées selon ROOT (§9.3), et ROOT se déduit de la même matrice d'expert que W (§5.5). Elle atteste la cohérence du modèle avec son jugement d'origine.

Une interaction super-additive, établie là où l'estimateur est fiable. Les surcoûts isolés ne somment pas au surcoût total : il reste un terme d'*interaction*, signature de la cascade (un pilier non conforme amplifie aussi les contagions amorcées ailleurs qui le traversent), qu'un modèle sans propagation (un LDA à copule) ne peut pas produire. Sa mesure exige toutefois de la prudence : une interaction est une différence de différences, l'estimateur Monte-Carlo le plus fragile qui soit en queue lourde. Sur la VaR à 99,5 % OpRisk, son *signe n'est pas résolu* : sur six graines à résolution égale (60 000 années chacune), il va de −137 à +1 395 M€ et n'est positif que dans quatre cas sur

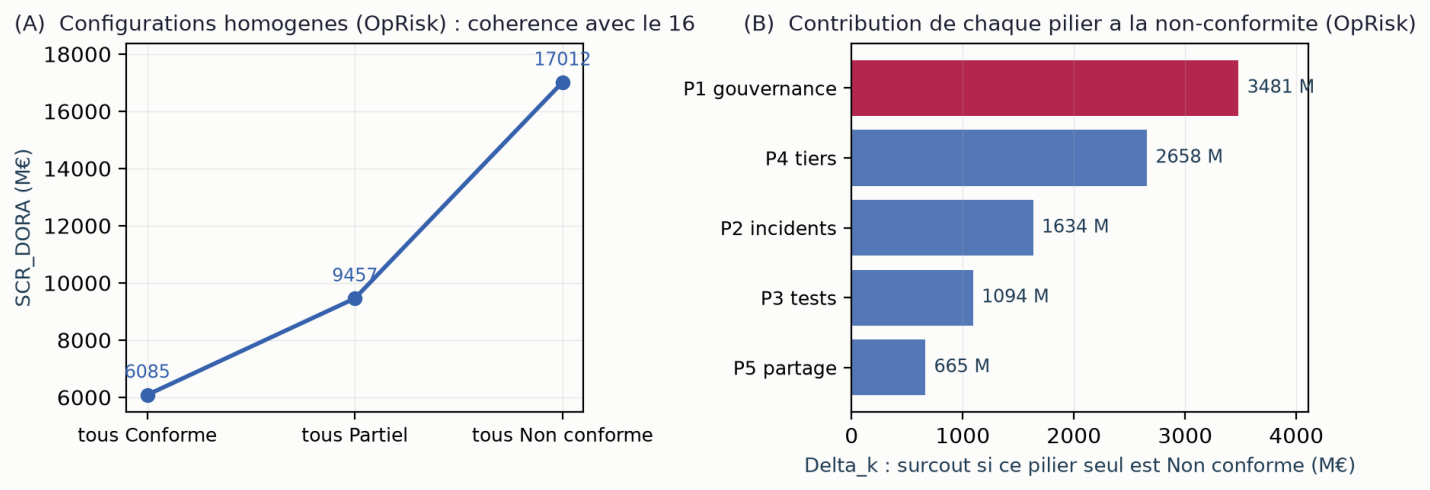


FIGURE S4.17. Décomposition du Δ_{DORA} par pilier et validation croisée avec ROOT.

six, la graine de référence donnant +1 395 M€. Un estimateur qui change de signe avec la graine interdit d'en tirer quoi que ce soit. La super-additivité est en revanche robuste partout où le bruit de queue ne domine pas : en *perte moyenne* elle est positive sur les six graines (+532 à +659 M€ OpRisk, +827 côté PRC, soit environ un cinquième du surcoût moyen), et jusque dans la VaR du périmètre PRC, dont le plafond de sévérité tronque la queue (+905 M€). Conséquence pratique : puisque les marginaux ne somment pas au total, l'attribution du surcoût aux piliers exige une règle principielle qui somme exactement : c'est l'objet de la valeur de Shapley (section 9.3). À ne pas confondre avec l'interaction entre les quatre *canaux* de la non-conformité, qui décompose le même écart sur une autre partition, vaut +5 001 M€ et dont le signe, lui, *est* résolu : elle est reprise terme par terme au §S1.4. Les deux ne s'additionnent pas.

S4.27 ALLOCATION DU CAPITAL PAR SHAPLEY ET EULER

La décomposition qui précède pose deux questions d'allocation distinctes. *Qui porte le surcoût ?* appelle une attribution par pilier *source* de la non-conformité, qui doit composer avec l'interaction (les marginaux ne somment pas au total). *Où loge le capital ?* appelle une allocation du niveau SCR(NC) par pilier *touché*, cohérente au sens où les parts somment au total. La valeur de Shapley répond à la première, la règle d'Euler à la seconde (figure S4.18).

S4.27.1 Attribution du surcoût par Shapley, interaction comprise

On munit les piliers d'une fonction caractéristique

$$v(S) \;=\; \text{SCR}\big(S \text{ en NC},\ \text{reste C}\big) - \text{SCR}(\text{tous C}), \qquad S \subseteq \{P1, \ldots, P5\},$$

calculée par la cascade sur les 2^5 configurations à graine Monte-Carlo commune. Le marginal de la section précédente est $v(\{k\})$; la valeur de Shapley

$$\varphi_j \;=\; \sum_{S \subseteq \{P1,\dots,P5\} \setminus \{j\}} \frac{|S|!\,\big(5-|S|-1\big)!}{5!}\,\big[v(S\cup\{j\}) - v(S)\big]$$

moyenne la contribution de j sur tous les ordres d'arrivée. Par efficience, $\sum_j \varphi_j = v(\text{tous}) = \Delta_{\text{DORA}}$ *exactement* : la règle redistribue l'interaction que les marginaux isolés laissent de côté, quel que soit son signe.

La construction est celle de Shapley (1953), dont l'efficience est la propriété axiomatique ; son emploi en allocation de capital remonte à Denault (2001), et son usage actuariel sous Solvabilité II est documenté (Decupère, 2011). Les cinq piliers autorisent l'énumération exacte des 5! ordres d'arrivée ; les algorithmes par échantillonnage des permutations (Castro et al., 2009 ; Song et al., 2016), indispensables en grande dimension, ne sont donc pas nécessaires ici, et aucune approximation n'entre dans le tableau qui suit.

Le classement de Shapley reproduit le classement ROOT sur les deux périmètres. Une part de cette convergence est mécanique : les amorces de la cascade sont semées proportionnellement à ROOT (parts 30/27/18/15/9 %), et le canal fréquence d'un pilier module sa propre part d'amorce. Le test non trivial est la *déformation* : la part de Shapley de P1 (34 %) excède sa part d'amorce (30 %), effet propre de la propagation (P1 est l'émetteur le plus fort de W), et l'interaction redistribuée (+1 395 M€ OpRisk, +905 PRC à cette graine) est intégralement un produit de la cascade, absent d'un modèle additif.

S4.27.2 Allocation du niveau par Euler et limite d'estimation

La règle d'Euler (Tasche, 1999) alloue SCR(NC) par $C_j = \mathbb{E}\big[L_j \mid L \geq \text{VaR}_{99{,}5\,\%}\big]$ (version TVaR, exacte par construction), où L_j est la perte du pilier *touché* j dans la cascade. Côté PRC, l'allocation est stable et presque plate : P2 23 %, P4 23 %, P1 20 %, P3 18 %, P5 17 %, et les parts de capital coïncident avec les parts de perte moyenne parce que le plafond de sévérité tronque la queue (TVaR = 6 795 ≈ VaR = 6 573 M€). Côté OpRisk, les parts *moyennes* sont stables (P2 23 %, P4 22 %, P1 20 %, P3 18 %, P5 16 %), mais l'allocation de la queue extrême ne l'est pas, et la cause en est théorique : avec $\xi \approx 0{,}6 > 0{,}5$, la sévérité est de variance infinie, l'estimateur Monte-Carlo de la TVaR converge en régime de loi stable, et le classement conditionnel bascule d'une résolution à l'autre (vérifié à 150 et 240 mille années simulées). On rapporte donc l'allocation de queue du périmètre PRC, régularisée par le cap, et l'on tient celle d'OpRisk pour indicative.

	OpRisk			PRC		
pilier	marginal	φ_j	part	marginal	φ_j	part
P1 gouvernance	3481	3717	34,0 %	1375	1608	32,4 %
P4 tiers	2658	2810	25,7 %	1075	1252	25,3 %
P2 incidents	1634	1867	17,1 %	721	920	18,6 %
P3 tests	1094	1484	13,6 %	571	738	14,9 %
P5 partage	665	1048	9,6 %	311	438	8,8 %
somme	9531	10 927	100,0 %	4052	4957	100,0 %

TABLEAU S4.3. Valeur de Shapley du surcoût Δ_{DORA} (M€, NC vs C, trois canaux, protocole des trois canaux). Les marginaux somment à 9 531 (OpRisk), la valeur de Shapley à 10 927, le surcoût total exactement. Cellules arrondies au million et parts au dixième de point, échelle à laquelle la colonne somme exactement à cent : c'est la propriété d'efficacité de la valeur de Shapley, et elle se lit dans le tableau plutôt que de s'y excuser en note.

La mesure de queue sert ici à mesurer, jamais à couvrir. Le besoin de capital publié dans ce mémoire est partout le quantile $\text{VaR}_{99,5\,\%}(L)$ non centré, au niveau de Solvabilité II : la perte attendue d'une non-conformité n'étant couverte par aucune provision, elle n'en est pas déduite ; aucune grandeur de couverture n'est une TVaR, ni une CTE, ni un Expected Shortfall. La mesure de queue intervient à deux titres, et tous deux sont des titres de *diagnostic*. Comme noyau d'allocation d'abord, dans la règle d'Euler ci-dessus, où elle répartit un niveau déjà fixé sans le modifier. Comme *indicateur de forme de queue* ensuite : le rapport $\text{TVaR}_{99,5\,\%}(L)/\text{VaR}_{99,5\,\%}(L) \approx 2{,}1$ se compare à son asymptote théorique $1/(1-\xi) = 2{,}5$. L'information est portée par ce rapport, non par les deux montants. Ce rapport dépend de l'état et il faut donc dire lequel : 2,10 vaut à l'état *tous non conforme*, celui de cette section, tandis qu'il vaut 2,17 sur la calibration de référence *(voir le Matériel Complémentaire en ligne)*. Les deux valeurs sont justes, elles ne portent pas sur la même loi de perte, et l'écart entre elles est sans signification en soi.

Deux raisons de ne pas en faire un niveau de couverture, dont la seconde est décisive. La première est de proportion : sur un risque aussi large, dont les queues sont plurielles selon la catégorie d'événement (annexe S1), adosser la couverture à une moyenne de queue déformerait la distribution et immobiliserait un capital sans commune mesure avec le niveau réglementaire de référence. La seconde est d'existence : sous la calibration PRC, $\hat{\xi} = 1{,}033 > 1$ place la sévérité en régime d'espérance infinie, et la mesure n'existe alors pas au sens mathématique. Une mesure de couverture qui cesse d'être définie selon la source de sévérité retenue ne peut pas porter un besoin de capital ; le même objet, lu comme un diagnostic de queue, reste au contraire parfaitement informatif, puisque sa divergence *est* l'information.

Sources et réceptacles. Les deux allocations ne racontent pas la même chose, et c'est le résultat : Shapley, vue *source*, concentre le surcoût sur P1 (34 %), là où naît la non-conformité ; Euler, vue *réceptacle*, répartit le capital presque uniformément sur les piliers touchés (P2 et P4 en tête légère). La remédiation se décide côté source ; le capital, lui, se loge là où les cascades atterrissent.

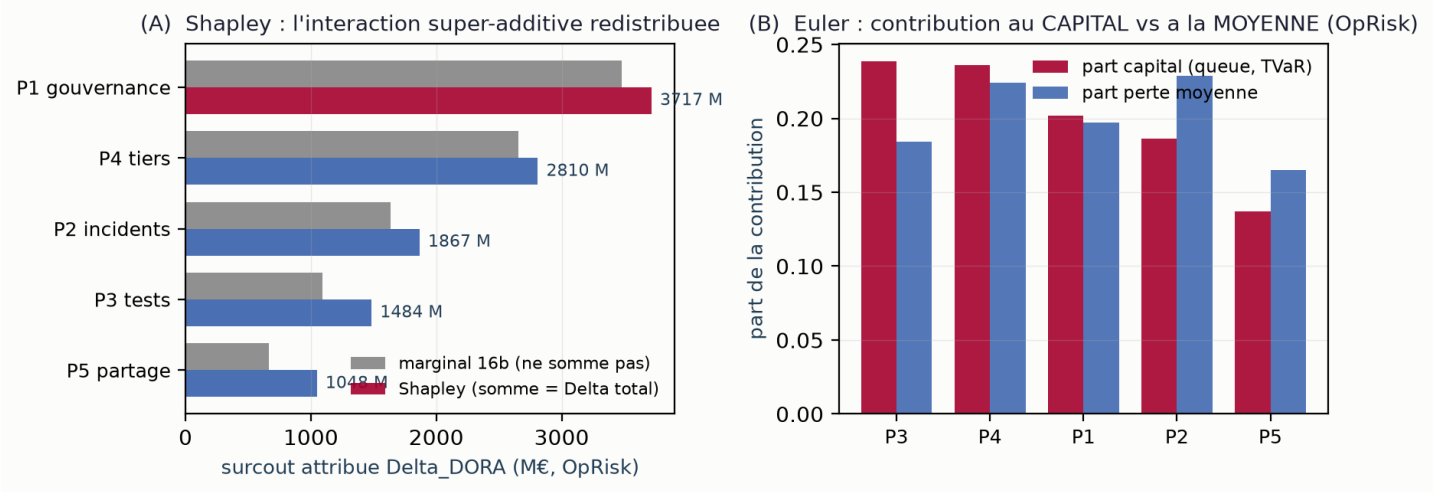


FIGURE S4.18. Allocation du capital DORA (OpRisk). (a) Shapley contre marginaux : l'interaction redistribuée. (b) Euler : parts de capital (queue) contre parts de perte moyenne ; sur ce périmètre non plafonné, l'allocation fine de la queue extrême reste indicative ($\xi \approx 0{,}6$, variance de sévérité infinie).

S4.28 TRAJECTOIRE DU CAPITAL

Le long de la mise en conformité, le capital décroît de l'état initial vers le SCR conforme, et le surcoût résiduel $\Delta_{\text{DORA}}(t)$ tend vers zéro (tableau S4.4, figure S4.19). Partant de l'état marginal actuel (NC 35 %, PC 35 %, C 30 %), le capital OpRisk passe de $\sim$ 10 750 à $\sim$ 7 040 M€ sur cinq ans, vers le SCR conforme ($\sim$ 6 925).

t (ans)	SCR(t) médiane	bande 90 %	$\Delta_{\text{DORA}}(t)$
0	10752	[9092 ; 12654]	3827
1	9576	[7205 ; 12040]	2652
2	8310	[6194 ; 11042]	1385
3	7575	[5924 ; 10164]	650
5	7041	[5857 ; 9028]	116

TABLEAU S4.4. Trajectoire du capital DORA (M€, OpRisk).

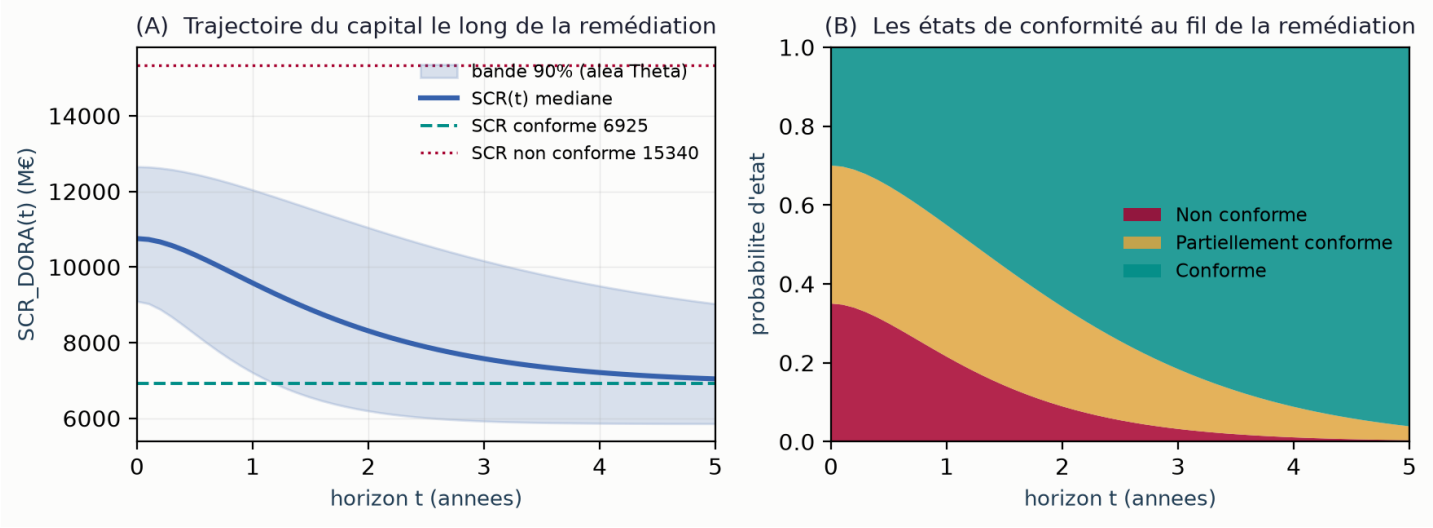


FIGURE S4.19. Trajectoire SCR(t) et évolution des états de conformité.

Lecture actuarielle. L'intégrale de la trajectoire, à un coût de capital près, est le *coût de portage* de la non-conformité pendant la remédiation. La bande reste large et surtout haute en environnement dégradé : la vraie exposition n'est pas le capital médian, c'est le risque que la remédiation traîne quand la menace monte, précisément le scénario où le capital importe le plus.

S4.29 PRIORISATION DE LA REMÉDIATION

Sous budget contraint (un pilier remédié à la fois), l'énumération des 120 ordres donne l'ordre optimal $P1 \to P4 \to P2 \to P3 \to P5$, égal à l'ordre ROOT et distinct de l'ordre glouton par valeur d'accélération (figure S4.20). L'écart de capital intégré entre le pire ordre et l'optimal atteint 21 %.

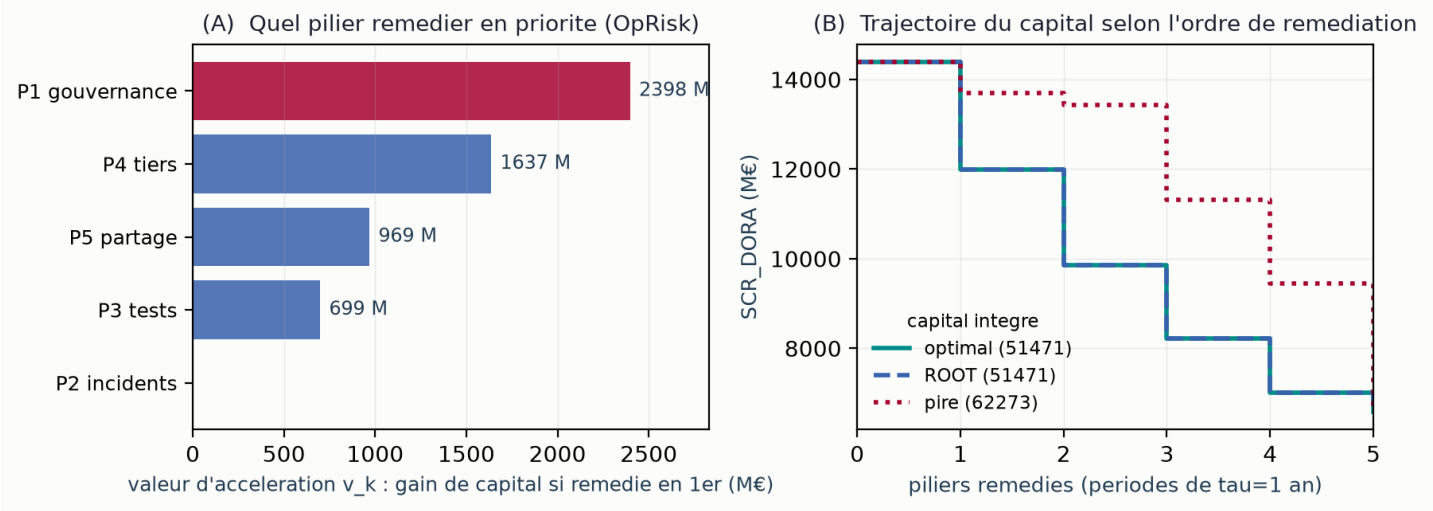


FIGURE S4.20. Valeur d'accélération par pilier et ordre de remédiation optimal.

Le myope n'est pas l'optimal. Remédier au coup par coup le pilier au plus fort gain immédiat (l'ordre glouton) coûte plus cher que l'ordre optimal, parce que les interactions de cascade im-

posent de raisonner sur l'horizon entier. L'optimum coïncide avec le classement ROOT, comme la progéniture (§5.5) et la décomposition par pilier ; ces trois convergences attestent la cohérence du modèle avec le jugement dont il procède, non une validation indépendante, ROOT entrant dans les amorces.

La question réciproque donne le classement qu'un plan de remédiation utilise. Tout ce qui précède fixe un état et lit un capital. L'exercice de résistance *inverse* fixe le capital et cherche les états qui le produisent. Un dispositif ORSA emploie un modèle sous cette forme. La monotonie établie au §S1.4 le rend court : l'ensemble des configurations atteignant une cible est croissant, donc entièrement décrit par ses éléments minimaux, et il n'en compte jamais plus de quatre sur seize. Deux nombres résument alors tout le treillis. Le canal de fréquence seul atteint 10 377 M€, soit 1,72 fois l'état conforme, tandis que les trois autres canaux *réunis* n'atteignent que 11 413, soit 1,89 fois. Toute cible sous le premier seuil se produit donc par un canal unique, et toute cible au-dessus du second exige la fréquence. Aucun autre canal, seul et dans sa plage déclarée, n'atteint même 8 000 M€. La lecture directe hiérarchise les canaux par leur contribution ; la lecture inverse désigne celui dont la maîtrise *interdit* les scénarios sévères. L'information n'est pas la même. Détail, frontières par cible et réserves au §S1.4.1.

S4.30 ROBUSTESSE

Le niveau du capital bouge fortement selon les leviers non calibrés (l'indice de queue ξ domine, facteur ~ 6), mais la direction ($\Delta_{\text{DORA}} > 0$) et la *priorité* (P1 en tête) tiennent sur tous les réglages testés (figure S4.21).

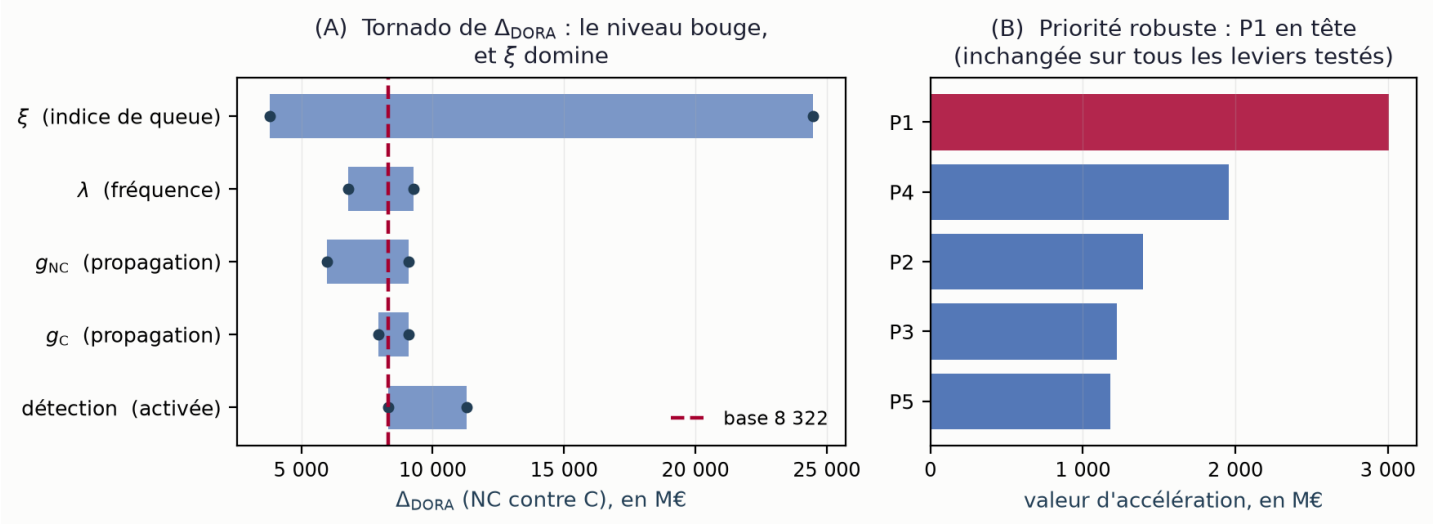


FIGURE S4.21. Robustesse : le classement tient, le niveau non.

La recommandation ne dépend d'aucun paramètre non mesurable. L'ordre de remédiation optimal ne dépend que des SCR par configuration, donc il est invariant aux taux de transition de

la chaîne de Markov, pourtant les paramètres les moins calibrables. Ces taux fixent le calendrier de la trajectoire, jamais la séquence recommandée. Le verdict d'ensemble rejoint celui de toute la démarche : le classement est robuste là où le niveau ne l'est pas.

> **Le périmètre exact de cette robustesse.** Les tests ci-dessus font varier les paramètres du modèle *à matrice W fixée*, celle du classeur qualitatif. Ils établissent donc que P1 arrive en tête *si l'on admet cette direction*. Dès lors que l'on admet ne pas connaître la direction et que l'on balaie l'ensemble admissible (chapitre 8), P1 et P4 deviennent pratiquement à égalité : P1 arrive premier dans 43,6 % des configurations, P4 dans 37,7 %, et l'écart de regret maximal entre les deux n'est que de 1,5 %. Les deux énoncés ne se contredisent pas, ils portent sur des sources d'incertitude différentes. Ce qui est robuste dans les deux cadres, c'est que P1 et P4 devancent nettement P2, P3 et P5, et que P5 n'arrive *jamais* en tête.
>
> **Une troisième source d'incertitude, et elle vise directement le corpus.** Les rapports post-incident sont des enquêtes officielles, mandatées pour établir une cause racine ; elles sur-attribuent donc structurellement à la gouvernance, ce que le chapitre 7 déclare sans pouvoir le lever. On peut néanmoins en chiffrer la conséquence, en dégradant l'émission de P1 par $W_{1k} \to (1-a)W_{1k}$ et en recalculant l'ensemble admissible à chaque degré. Le classement tient jusqu'à $a = 0{,}25$ et bascule vers P4 à $a = 0{,}50$: il faut donc supposer la moitié des arêtes issues de la gouvernance artefactuelles pour renverser la priorité. Le niveau, lui, ne perd que 24,8 % même à $a = 1$, soit 0,81 fois la largeur de la bande d'identification. Le niveau résiste, le classement non, le seuil est connu.

Les hypothèses restantes ont leur axe de stress. Trois entrées ne figuraient pas au tornado : les coefficients de la conversion Jacobs, la charge systémique γ et l'ancrage des probabilités d'état. Stressées à ±1,645 écart-type, elles déplacent des niveaux sans jamais toucher la direction ni le classement : le surcoût PRC reste contenu entre 3 125 et 3 977 M€ autour du central, γ ne commande que la sévérité de la bascule en crise, et l'ancrage des probabilités d'état déplace le capital espéré actuel mais laisse inchangés le SCR par état et le surcoût NC contre C, qui lui sont conditionnels. Le détail du protocole de stress est déporté *(voir le Matériel Complémentaire en ligne)*.

S4.31 SENSIBILITÉ AUX PROBABILITÉS DE PROPAGATION

Le modèle repose sur des probabilités de propagation qui ne sont pas observées. Cette section leur consacre un examen séparé, en distinguant deux questions que l'on confond volontiers : la sensibilité au *niveau* de la propagation, qui est un facteur d'échelle posé, et la sensibilité à sa *direction*, qui n'est pas identifiable. La première se stresse, la seconde se borne.

Le niveau de propagation est le levier le moins sensible. Mesurée en élasticités, à perturbation relative de 10 % appliquée à un paramètre à la fois, la sensibilité classe les leviers comme suit.

Levier	Statut	Élasticité
Indice de queue ξ	estimé	3,79
Échelle σ	estimé	0,97
Taux de dépassement p_u	estimé	0,82
Fréquence λ	estimé	0,45
Sur-dispersion φ	posé	−0,44
Gain de propagation g	**posé**	**0,37**
Seuil u seul	choix de méthode	0,03

La propagation a l'élasticité la plus faible des leviers substantiels, 0,37 contre 3,79 pour l'indice de queue. L'ablation le confirme par un autre chemin : retirer la propagation fait tomber la VaR de 20 %, retirer la queue lourde de 76 %. La thèse ne dépend pas des trois valeurs posées de g, le capital étant croissant en g (§6.4). La direction, elle, ne se stresse pas, elle se borne : à ignorance totale la largeur de l'ensemble admissible vaut 1 839 M€, soit 34,9 % du socle, et elle se paye linéairement avec le degré d'ignorance. Le motif qui écarte les indices de Sobol, la variance de la charge annuelle n'existant pas, le tornado brut et ses deux défauts, la gradation de l'ignorance, l'ablation et la comparaison avec le préprint de cascade climatique, qui classe les leviers à l'inverse parce que sa sévérité est bornée, sont déportés *(voir le Matériel Complémentaire en ligne)*.

Ce que cette section établit. La sensibilité aux probabilités de propagation est *bornée par construction* et non estimée : c'est la différence entre un modèle qui pose une direction et un modèle qui assume ne pas la connaître. Et elle n'est pas le point faible du dispositif : le niveau de propagation déplace le capital moins que tout autre levier, tandis que le seuil de la loi de queue le fait passer à lui seul de 4 862 à 12 944 M€. Toute vigilance sur les valeurs numériques du modèle doit donc se porter d'abord sur l'ajustement de valeurs extrêmes, et c'est là que le mémoire concentre ses réserves déclarées.

S4.32 COMPARAISON DE MODÈLES DE DÉPENDANCE

La cascade dirigée remplace ici l'agrégation par copule d'un modèle LDA. Ce que ce remplacement apporte se mesure en confrontant la cascade à des jumeaux copule construits pour lui ressembler (figure S4.22, périmètre OpRisk, graines Monte-Carlo communes). Cette section compare les modèles sur l'axe de la *structure de dépendance*, à marges fixées ; la comparaison sur l'axe de la *famille de loi* (la bande de modèle) est conduite au chapitre 10, section 10.3, et les deux se complètent.

La photo. À marges par pilier *identiques* (celles de la cascade, état conforme) et corrélation calée, la copule gaussienne retombe sur le SCR de la cascade (+0,1 %) : en queue lourde ($\xi \approx 0{,}6$), la queue annuelle obéit au principe de la perte unique dominante et le *niveau* de base n'identifie pas la dépendance. La Student ($\nu = 4$) le surestime de 17 % en forçant des co-extrêmes que le mécanisme ne produit pas (2,28 piliers extrêmes par année de queue contre 1,12). Le choix de copule est donc à la fois non identifiable et conséquent ; la cascade n'a pas ce degré de liberté : sa dépendance est produite par le mécanisme, pas choisie.

Et ce résultat a été répliqué ailleurs, sans lien avec ce travail. L'objection naturelle serait qu'une coïncidence à +0,1 % entre une copule gaussienne et un mécanisme de cascade tient à un réglage particulier du protocole. Le préprint de cascade climatique cité au chapitre 2 (Karimi et al., 2026) conduit la même expérience, à marges appariées, entre une gaussienne, une Student et sa propre cascade : il obtient des primes centrales pratiquement indiscernables et ne voit la séparation apparaître qu'en *queue*. Même protocole, même conclusion, sur un autre péril et par une autre équipe. Ce n'est donc pas un artefact du réglage retenu ici, mais une propriété du principe de la perte unique dominante, qui rend le niveau central aveugle à la structure de dépendance.

Le +0,1 % est cependant un tirage : sur quatre graines, l'écart moyen vaut +4,8 % et reste sous son propre bruit, et au-delà de 99 % seule la Student sort du sien. Le détail est déporté *(voir le Matériel Complémentaire en ligne)*.

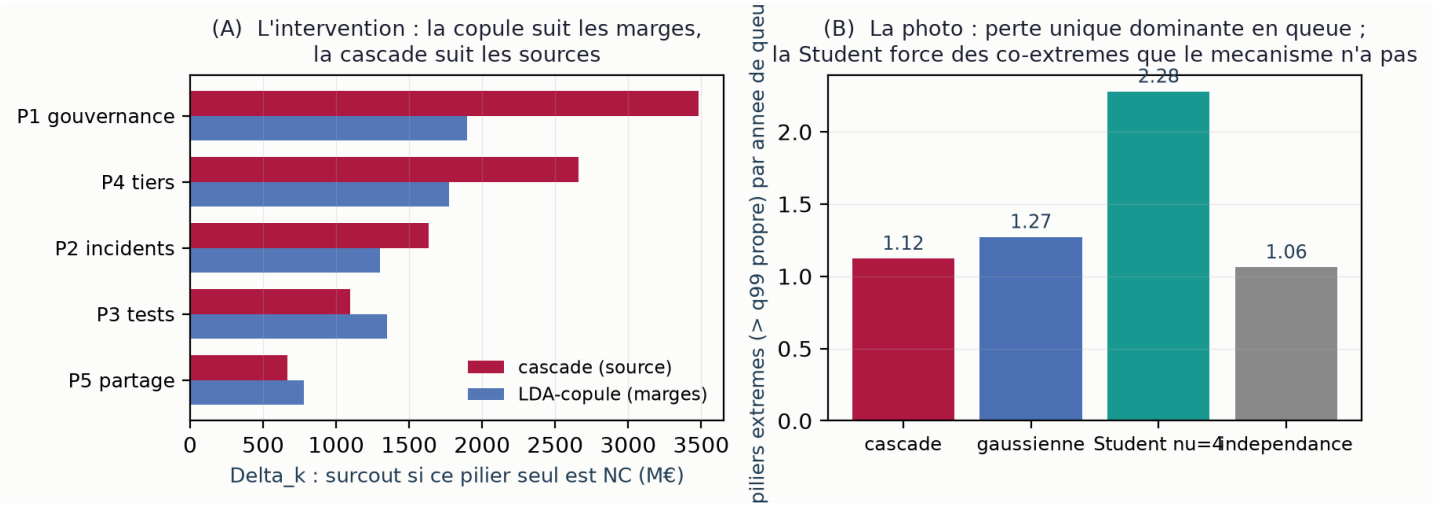


FIGURE S4.22. Benchmark copule (OpRisk). (a) Intervention : le jumeau copule suit les marges et sous-estime le surcoût, la cascade suit les sources. (b) Photo : perte unique dominante en queue ; la Student force des co-extrêmes que le mécanisme n'a pas.

L'intervention. Basculer un pilier en non-conformité est une intervention, pas un conditionnement. Le jumeau LDA-copule exprime les canaux fréquence et détection (les marges dépendent de l'état de leur pilier), mais trois manques sont structurels. *(i)* La propagation n'a nulle part où vivre : le surcoût total ressort à 6 760 M€ contre 10 927 pour la cascade, une sous-estimation de 38 %. *(ii)* Les marges ne dépendant que de l'état de leur propre pilier et la copule étant figée, la perte moyenne totale est *exactement* additive : interaction moyenne nulle par construction (+0 M€ mesuré), là où la cascade en produit +560 M€ : l'interaction moyenne mesurée plus haut est une signature falsifiable qu'aucun modèle copule-marges ne peut reproduire. *(iii)* La priorité de remédiation impliquée s'inverse sur P2/P3, et la dépendance ne durcit pas quand la conformité se dégrade, alors que c'est précisément le canal que DORA fait bouger (g de 0,45 à 0,90).

Le verdict du benchmark. La copule peut imiter la photo d'un état ; elle ne peut imiter ni le surcoût (propagation), ni l'interaction (additivité en moyenne), ni le durcissement de la dépendance avec la non-conformité. La dépendance n'est pas le mécanisme : c'en est l'ombre portée.

S4.33 Mise en regard réglementaire

La question finale est celle de la portée : de l'effet de la conformité que le modèle mesure, quelle fraction les cadres existants savent-ils exprimer ? On confronte donc, sur le même écart de capital entre profil conforme et non conforme, trois dispositifs.

Cadre	**Δ capital C→NC**	**part de l'effet cascade**
Formule Standard (Solvabilité II)	0 M€	0 %
LDA-copule (dépendance symétrique)	6 760 M€	62 %
Cascade dirigée	10 927 M€	100 % (référence)

Tableau S4.5. Fraction de l'effet DORA que chaque cadre sait exprimer.

La Formule Standard est structurellement aveugle, et le tableau 9.4 chiffre ce que chaque cadre sait en exprimer. La charge de risque opérationnel de l'équation (1.1), maximum d'une branche assise sur les primes et d'une branche assise sur les provisions, à coefficients distincts en vie et en non-vie, dans la limite d'un plafond assis sur le BSCR, ne dépend que du volume : elle est *identique* pour une entité exemplaire et pour une entité défaillante sur DORA. Sa réponse à la conformité est nulle par construction. La copule en capte 62 % (les canaux fréquence et détection) mais rate la propagation, faute de direction. Seule la cascade exprime l'effet complet. La valeur du modèle se lit donc en effet DORA rendu visible, non en un niveau de SCR à interpréter dans l'absolu.

Sur donnée ouverte, le pilotage descend jusqu'aux sous-piliers de P2 et, plus grossièrement, à la détection de P3, mais pas jusqu'au pilier des tiers, que seul un registre d'externalisation peut renseigner *(voir le Matériel Complémentaire en ligne)*.

S4.34 Un ordre de grandeur à l'épreuve du réel

Le niveau absolu n'ayant jamais été présenté comme une mesure, il reste à le confronter au réel, non pour le valider mais pour vérifier qu'il ne *peut* pas l'être. Deux confrontations suffisent.

Contre la Formule Standard, sur la même entité notionnelle, le repère forfaitaire vaut environ 450 M€ quand le socle de la cascade au niveau du secteur en vaut 5 275 ; contre le marché, un capital de cet ordre pour une seule entité serait invraisemblable. Au niveau du sinistre unique, en revanche, le quantile de sévérité (663 M€) et sa moyenne de queue (1 752 M€) encadrent les grandes pertes cyber réelles. Le niveau sectoriel tient donc à la fréquence d'amorce, et la descente d'échelle le vérifie. À matrice W et moteur inchangés, une entité d'actifs A reçoit une fréquence et une sévérité lues à sa taille :

$$\lambda(A) = \lambda_c \Big(\frac{A}{A_c}\Big)^{b_\lambda}, \qquad m(A) = \Big(\frac{A}{A_m}\Big)^{b}, \\ X = m(A) \sum_{k \in S_a} Y_k, \qquad \mathcal{B}(A) = \mathrm{VaR}_{99{,}5\,\%}\Big(\sum_{n=1}^{N} X_n\Big), \tag{S4.4}$$

où N suit la binomiale négative de moyenne $\lambda(A)$ et de surdispersion φ, S_a est l'ensemble des piliers touchés depuis l'amorce a, et les Y_k sont les sévérités GPD calibrées. Les deux élasticités sont estimées, $b_\lambda = 0{,}074$ par une binomiale négative à lien logarithmique, $b = 0{,}087$ sur la sévérité, d'où un multiplicateur $m = 0{,}854$ à la taille de l'entité notionnelle ; λ_c, A_c et A_m sont la fréquence et les tailles de référence du panel.

Lecture	λ (an^{-1})	sévérité	SCR 99,5 %	Perte moyenne
Secteur financier mondial	21,56	×1	8 123 M€	983 M€
Seuil « ≥ 10 événements »	0,210	×1	488 M€	9,7 M€
Seuil « toutes firmes »	0,100	×1	229 M€	4,6 M€
λ lu à la taille de la cible	0,092	×1	198 M€	4,3 M€
Les deux canaux composés	**0,092**	**×0,854**	**169** M€	**3,6** M€

TABLEAU S4.6. Le même modèle lu à plusieurs échelles. La matrice W et le moteur de cascade sont identiques partout ; seules la fréquence d'amorce et l'échelle de sévérité changent. Les deux dernières lignes sont la lecture cohérente, où la fréquence *et* la sévérité sont prises à la taille de l'entité visée.

Diviser λ par 235 divise la perte moyenne par 270 mais le capital par 48 seulement : le quantile extrême est porté par le plus grand sinistre, non par le nombre. La coïncidence apparente avec le repère forfaitaire au seuil de dix événements (488 contre 450 M€) ne survit pas à la correction, et le chiffre d'entité est une bande, [131,5 ; 183,3] M€ sur les 1 024 sommets admissibles. Ce 169 M€ est une borne supérieure d'ordre de grandeur (§9.11).

À l'échelle d'entité, ignorer la direction coûte autant qu'ignorer la queue. La bande d'identification mesure 51,7 M€ de large. En faisant varier le seul indice de queue sur son intervalle de confiance à 90 % ($\xi \in [0{,}304\,;0{,}831]$), le SCR d'entité va de 140,9 à 191,6 M€, soit 51,5 M€ de large. Les deux incertitudes sont du même ordre, et aucune ne domine l'autre. C'est un argument supplémentaire pour la spécification de reporting : réduire l'ignorance directionnelle vaut, en euros de capital, autant qu'affiner l'estimation de la queue.

Ce que le forfait ne voit pas, à l'échelle d'entité. En balayant le gain de propagation sur ses trois valeurs d'état (0,45, 0,68, 0,90) à fréquence et taille cibles, le SCR d'entité passe de 116 à 143 puis 169 M€, soit +45 % entre le profil conforme et le profil défaillant, et ce par le seul canal de contagion, les canaux fréquence et détection n'étant pas mobilisés ici : l'écart lu est donc un plancher. Sur les mêmes trois profils, le repère forfaitaire vaut 450 M€ et ne bouge pas d'un euro, pas plus que la charge réglementaire elle-même, qui ne dépend d'aucun état. C'est la thèse du mémoire, lue à l'échelle où une entité la vit.

Ces trois nombres sont un scénario d'écartement, non une mesure : la correspondance état $\to g$ est posée et non calibrée, faute d'entité publiant son état de conformité. Ce qui est établi, et démontré au §6.4, est plus fort et plus modeste à la fois : le capital étant croissant en g, l'écart existe et garde son signe pour *toute* correspondance respectant l'ordre, y compris la plus étroite, quand le forfait reste plat dans tous les cas. Seule l'amplitude dépend de l'écartement retenu.

Les deux canaux de la descente, ce que la correction d'échelle déplace, le rejet d'une mise à

l'échelle proportionnelle et les figures sont déportés *(voir le Matériel Complémentaire en ligne)*.

S4.35 Quatre entités réelles et borne inférieure de la méthode

Tout ce qui précède porte sur une entité *notionnelle*, posée à 20 000 M$ d'actifs et 15 000 M€ de provisions. La méthode est complète, l'objet est fictif : le mémoire démontre une faisabilité, il ne mesure pas une entité. C'est la première objection qu'un rapporteur formule. Elle est juste. On la lève avec la seule donnée disponible sans accès interne, les rapports SFCR de l'exercice 2024, qui sont des publications réglementaires.

Trois grandeurs suffisent par entité : provisions techniques, fonds propres éligibles, SCR. Chaque champ porte sa provenance, *publié* quand il est lu tel quel, *déduit* quand il résulte d'une identité comptable ou d'un ratio de couverture publié. Aucun n'est estimé. La conversion en dollars, nécessaire parce que le panel de calibration exprime les actifs en $, n'est pas un paramètre sensible : l'élasticité valant 0,074, une erreur de 10 % sur le cours déplace λ de 0,7 %. Le besoin de chaque entité est $\mathcal{B}(A)$ de l'équation (9.1) : en point à la matrice d'expert, donc au gain de propagation non conforme, les autres canaux restant à leur calibration de référence, et en bande sur les sommets admissibles. Le rapport est $\mathcal{B}(A)/\mathrm{SCR}_{\text{publié}}$.

> **Deux précautions de vocabulaire, avant tout chiffre.** D'abord, il n'existe *aucun* module DORA dans la Formule Standard : la grandeur calculée ici est un besoin de capital ORSA, donc de pilier 2, conformément à ce que pose la section 1.6. Écrire « le SCR DORA de telle entité » ferait croire à un objet réglementaire qui n'existe pas. Ensuite, le rapport de ce besoin au SCR publié est une mise à l'échelle et non une part : diviser un besoin de pilier 2 par le SCR réglementaire ne fait pas du premier une composante du second. Le rapport répond à « est-ce gros ou petit pour cette entité », et à rien d'autre. Enfin les entités sont désignées par leur classe de taille, non par leur nom : le modèle n'utilise que le total de bilan et les provisions, jamais l'identité, et il serait donc gratuit d'accoler un nom de société à un état de conformité *supposé*. Les identités et les références SFCR exactes sont tenues hors du mémoire, dans le code de calcul, qui en imprime la table de correspondance à chaque exécution.

Entité	Actifs M€	SCR publié M€	Besoin ORSA M€	Bande M€	Rapport
Assureur non-vie A	2 319	425	112	[88 ; 122]	26,4 %
Assureur non-vie B	5 305	812	136	[104 ; 146]	16,7 %
Assureur vie C	37 845	1 587	196	[149 ; 213]	12,3 %
Assureur vie D	**309 800**	**14 800**	**294**	[**233** ; **316**]	**2,0** %
Entité notionnelle	19 231	—	169	[132 ; 183]	—

Les quatre SCR du dénominateur sont publiés, et cela a été vérifié pièce par pièce. Les deux assureurs vie donnent leur SCR en synthèse ; les deux assureurs non-vie le donnent dans leur état quantitatif S.25.01, à 425 et 812,5 M€. Aucun n'est reconstitué à partir d'un taux de couverture, si bien que la colonne des rapports repose entièrement sur des grandeurs lues. Ce qui reste *déduit* est le total d'actif de trois entités, obtenu par l'identité comptable provisions plus fonds propres, et l'approximation y est conservatrice : les autres passifs manquants minorent l'actif, donc λ, donc le capital. Sur la quatrième entité, où le total d'actif est publié, l'identité se vérifie au million près.

Un résultat en sort, sur le repère forfaitaire lui-même. Les deux états S.25.01 publient le module de risque *opérationnel* de Formule Standard, ce qui permet de confronter le repère de 3 % des provisions employé dans ce chapitre à la charge effectivement calculée : il vaut 54,1 contre un module publié de 59 sur la première entité non-vie, et 62,1 contre 39,7 sur la seconde, soit des écarts de -8 % et de +56 %. L'écart ne vient pas du règlement mais de l'approximation : le repère ne retient que la branche provisions de l'équation (1.1), sans la branche primes dont la formule prend le maximum, sans le plafond assis sur le BSCR, et sur une assiette qui mêle parfois provisions et autres passifs. Il ne se cite donc que comme un ordre de grandeur de comparaison, jamais comme la charge réglementaire ni comme l'une de ses bornes, et le module publié lui est préféré chaque fois qu'il existe.

La première lecture est celle qu'on attendait. Sur la plus grande entité du panel, un assureur vie de 310 Md€ d'actifs, le besoin de capital associé à la non-conformité vaut 294 M€ en point et [233 ; 316] en bande, soit 2,0 % de son SCR publié : un ordre de grandeur défendable, obtenu sans aucune donnée interne. Et l'écart entre états de conformité subsiste à toutes les tailles, de +41 % à +49 %, face à une charge forfaitaire qui n'en distingue aucune. La thèse ne dépendait donc pas de l'entité fictive.

> **La seconde lecture n'était pas attendue, et elle contraint le mémoire.** La charge décroît beaucoup moins vite que la taille : un facteur 134 sur les actifs ne divise la sévérité que par 1,53 et la fréquence que par 1,44. Rapportée au SCR publié, la charge passe donc de 2,0 % pour une grande entité à 26,4 % pour une petite. En posant qu'un seul risque de non-conformité réglementaire ne peut raisonnablement peser plus de 10 % du SCR total d'une entité, tous risques confondus, la bascule se situe entre 37 845 et 309 800 M€ d'actifs. Ce n'est pas un seuil fin, quatre entités ne le déterminent pas, et il dépend aussi du levier propre de l'entité, dont le rapport SCR sur actifs va ici de 4,2 à 18,3 %. C'est un ordre de grandeur, pour la cause que le §9.10 nommait sans la chiffrer : l'élasticité corrige l'*échelle* de la sévérité, jamais sa *forme*, qui reste celle de grandes institutions financières.

Conséquence directe sur le chiffre central, qu'il faut assumer. L'entité notionnelle pèse 19 231 M€ d'actifs et se trouve donc *dans* la zone que la ligne précédente déclare hors domaine, ce qui suffit à en tirer la conséquence : le 169 M€ doit être lu comme une borne supérieure d'ordre de grandeur, non comme une charge plausible. Un second test, celui du levier, ne l'accable pas :

en imputant à cette entité le levier médian des quatre entités réelles (10,0 %), soit 1 932 M€ de SCR, la charge en représenterait 9 %, donc juste *sous* le critère de 10 %. La requalification repose ainsi sur le seul argument de taille. Ce que le mémoire établit n'en est pas affaibli, parce que sa thèse porte sur l'*écart* entre états de conformité face à un forfait insensible, et qu'un écart est un rapport : il survit à une erreur de niveau commune aux trois états. Mais le *niveau*, lui, cesse ici d'être présenté comme une mesure. Le lever demanderait une sévérité calibrée sur des incidents d'entités de cette taille, c'est-à-dire exactement la donnée que le chapitre 3 déclare absente.

Deux réserves enfin, à ne pas reléguer en note. Aucune de ces entités ne publie son état de conformité DORA : on mesure une *exposition* sous un état supposé, jamais une non-conformité constatée : les trois états sont donc donnés côte à côte sans qu'aucun soit désigné. Et deux des quatre entités publient « provisions techniques et autres passifs » sans les séparer, ce qui surestime l'assiette du repère forfaitaire pour elles ; pour les deux assureurs vie, la branche provisions de la formule applique de surcroît un coefficient plus faible que celui du repère, qui ne vaut donc pas pour elles. Le rapport au SCR publié, lui, n'est pas concerné.

S4.36 L'écart dans l'agrégation réglementaire

Il reste à dire ce que le capital total de l'entité retient d'un écart D entre états. Sous Solvabilité II, le risque opérationnel n'entre pas dans la matrice de corrélation du BSCR, selon l'identité $\mathrm{SCR} = \mathrm{BSCR} + \mathrm{Adj} + \mathrm{SCR}_{Op}$ de la section 1.6. On la compare au traitement où D serait un module de plus, corrélé à ρ avec le BSCR :

$$\Delta\mathrm{SCR}_{\text{additif}} = D, \qquad \Delta\mathrm{SCR}_{\rho} = \sqrt{\mathrm{BSCR}^2 + 2\rho\,\mathrm{BSCR}\,D + D^2} - \mathrm{BSCR} = \tau(\rho, d)\,D, \tag{S4.5}$$

$$\tau(\rho, d) = \frac{\sqrt{1 + 2\rho d + d^2} - 1}{d} = \rho + \frac{d}{2}\left(1 - \rho^2\right) + O(d^2), \qquad d = \frac{D}{\mathrm{BSCR}}. \tag{S4.6}$$

Un montant petit devant le BSCR n'est donc reconnu qu'à hauteur de ρ sous agrégation corrélée, et en entier sous la convention additive : un euro d'écart DORA coûte un euro de capital. Le BSCR n'étant pas publié, $\mathrm{Adj} \le 0$ et le plafond $\mathrm{SCR}_{Op} \le 0{,}3\,\mathrm{BSCR}$ le minorent par $\mathrm{BSCR} \ge \max\left(\mathrm{SCR}/1{,}3\,;\ \mathrm{SCR} - \mathrm{SCR}_{Op}\right)$; τ croissant en d, les taux lus ci-dessous sont des majorants *(voir le Matériel Complémentaire en ligne)*.

Entité	**Écart D, contagion** M€	$d = D/\mathrm{BSCR}$	τ **à** $\rho = 0{,}25$	**additif / corrélé**
Assureur non-vie A	34,9	0,0954	29,4 %	3,41
Assureur non-vie B	44,4	0,0575	27,7 %	3,62
Assureur vie C	62,7	0,0514	27,4 %	3,65
Assureur vie D	86,0	0,0076	25,4 %	3,94

L'écart D est celui du seul canal de contagion, donc un plancher (§9.11), et non l'écart à quatre

canaux du chiffre de tête. À $\rho = 0{,}25$, le facteur $1/\tau$ va de 3,4 à 3,9, et reste dans cette bande étroite sur un facteur 134 de taille de bilan, précisément parce que τ tend vers ρ. Lu sur le niveau plutôt que sur l'écart, où d est plus grand, le facteur va de 2,6 à 3,8. Rapporté au SCR publié de chaque entité, l'écart entre états pèse de 0,58 % pour la plus grande à 8,21 % pour la plus petite, et ces points de SCR sont acquis en entier.

Le plafond borne en outre ce qu'un forfait saurait exprimer. La charge forfaitaire vaut $\mathrm{SCR}_{Op} = \min(0{,}3\,\mathrm{BSCR}\,;\,\mathrm{Op})$, et la marge restante sous le plafond $0{,}3\,\mathrm{BSCR} - \mathrm{SCR}_{Op}$. Sur l'assureur non-vie A, le besoin calculé en vaut 2,21 fois : même un forfait rendu sensible à la conformité saturerait avant de l'exprimer *(voir le Matériel Complémentaire en ligne)*.

La lecture décisionnelle, et elle renverse une intuition de gestion. Un euro économisé sur la non-conformité DORA vaut, en capital, davantage qu'un euro économisé sur un risque qui se diversifie : le premier est reconnu en entier, le second à hauteur de sa corrélation. Une direction des risques qui classerait ses chantiers de remédiation au seul vu de la sinistralité attendue sous-estimerait donc le rendement en capital de celui-ci, d'un facteur de l'ordre de trois à quatre. Cette conclusion ne dépend d'aucun paramètre du modèle de cascade : elle tient à la place que le règlement assigne au risque opérationnel, et elle survivrait à un changement complet de calibration.

S4.37 Détention du capital ou transfert du risque au prix de marché

Les trois confrontations qui précèdent portent sur le *niveau*. Il en manque une sur le *prix*. Un SCR n'est pas une perte : c'est du capital immobilisé, et le capital coûte. Solvabilité II chiffre ce coût explicitement par le taux de coût du capital de la marge de risque, historiquement 6 % et ramené à 4,75 % par la directive (UE) 2025/2, dont la transposition est due pour janvier 2027. Détenir le risque coûte donc $\mathrm{CoC} \times \mathrm{SCR}$ par an. En face, le *transférer* coûte une prime, que le marché cyber facture avec un chargement : à un ratio de sinistralité LR de l'ordre de 48,5 %, l'assureur encaisse environ 2,1 fois la prime pure. Les deux grandeurs sont homogènes, donc comparables. Un directeur des risques fait cette comparaison.

Le multiple de capital, et ce qu'il coûte. À l'échelle d'entité (tableau 9.5, lecture composée), le modèle donne un SCR de 169 M€ pour une perte attendue de 3,6 M€, soit un multiple $\mathrm{SCR}/\mathbb{E}[L]$ de 47 contre 8,3 à l'échelle du secteur. L'écart est la mutualisation, lue à l'envers : le capital d'une entité isolée est dominé par un sinistre unique, celui d'un secteur par l'accumulation. Le coût annuel de détention vaut alors 8,0 M€ sous le régime révisé et 10,1 M€ sous l'actuel, c'est-à-dire 2,2 à 2,8 fois la sinistralité attendue. Immobiliser coûte plusieurs fois ce que le risque coûte en moyenne : c'est ce rapport qui rend le transfert économiquement pertinent, et il ne se lit sur aucune des comparaisons de niveau.

Dimensionner plutôt que tout céder. Un traité en excès de perte annuel, sans rétention et de portée ℓ, cède $\min(L, \ell)$ de la charge annuelle L. Le coût total de l'entité, prime plus coût du capital résiduel, est

$$C(\ell) = \frac{\mathbb{E}\big[\min(L,\ell)\big]}{\mathrm{LR}} + \mathrm{CoC} \cdot \mathrm{VaR}_{99{,}5\,\%}\big(L - \min(L,\ell)\big), \tag{S4.7}$$

minimal en $\ell^\star = \mathrm{SCR} = 169$ M€ : il passe de 8,0 à 2,9 M€ par an, soit −64 %. Ce gain est une borne supérieure, entamée par la capacité du marché, les exclusions et le risque de contrepartie, mais il faudrait que 78 % de la couverture soit inefficace pour que la détention redevienne préférable. Une entité devenue conforme voit en outre ce coût tomber de 81 %, la conformité déplaçant le point d'équilibre entre rétention et transfert. Le calcul, ses réserves et la figure sont déportés *(voir le Matériel Complémentaire en ligne)*.

La boucle que cette section referme. DORA impose des exigences de *gestion*, Solvabilité II impose du *capital*, et rien n'articule les deux. En passant par le prix, le SCR cesse d'être un chiffre à publier pour devenir un critère de décision entre trois leviers concurrents. C'est la lecture que la thèse du mémoire appelait : le niveau est illustratif, mais le *rapport* entre le coût de détention et le prix de transfert, lui, est une grandeur d'entité, robuste au changement d'échelle puisque ses deux termes se rapportent au même SCR.

Pourquoi le niveau ne peut pas être une mesure. La confrontation ne calibre pas le niveau, elle le disqualifie comme mesure et confirme, par un chemin externe, la lecture que tout le mémoire adopte : ce sont le rapport au socle, la largeur de la bande d'ignorance et la hiérarchie des piliers qui portent les conclusions, jamais le montant en euros.

S4.38 Trois échecs aux raisons distinctes

Source 1 : Data Breach Chronology (notifications d'États américains). La base est volumineuse (74 783 incidents, 25 009 organisations) mais inexploitable pour W, par manque de taxonomie et de volume informatif. La catégorie non déterminée (`UNKN`) pèse 52,7 % des incidents et n'est attribuable à aucun pilier. La date de *survenance* n'est exploitable que dans 49,6 % des cas, et son caractère manquant n'est pas aléatoire : il varie par type d'incident, si bien qu'ordonner par survenance élimine des catégories entières du panel. Ordonner par *déclaration*, l'autre date disponible, ne mesure pas la contagion mais le délai de détection. Résultat : une fois restreint aux types informatifs et aux trimestres consécutifs, il ne reste que 71 transitions $k(t{-}1) \to j(t)$ (soit 3,6 observations par cellule hors-diagonale), et 34 dans le seul secteur financier. La direction n'y est pas estimable, faute de matière.

Source 2 : SAS OpRisk Global Data (pertes opérationnelles, Bâle). Ici le volume est au rendez-vous : 4 329 transitions annuelles entre les 7 catégories de risque, soit environ 103 observations par cellule. Et pourtant la direction reste inidentifiable, pour la raison *opposée* : le pas de temps

est l'année, trop grossier pour porter une antériorité. Un test placebo le montre sans appel. Soit M la matrice des transitions observées, M_{jk} comptant les passages $k(t-1) \to j(t)$. On mesure la direction par la statistique d'asymétrie

$$T(M) \;=\; \tfrac{1}{2}\,\|M - M^{\top}\|_1 \;=\; \tfrac{1}{2}\sum_{j\neq k}\bigl|M_{jk} - M_{kj}\bigr|, \tag{S4.8}$$

nulle si et seulement si M est symétrique. Sous l'hypothèse nulle H_0 d'absence de direction, permuter les années *à l'intérieur de chaque firme* détruit toute antériorité tout en conservant la co-occurrence : si Π désigne une telle permutation et M^{Π} la matrice recalculée, la loi de $T(M^{\Pi})$ est celle de $T(M)$ sous H_0. En notant μ_0 et σ_0 ses moyenne et écart-type empiriques sur les tirages de Π, la statistique centrée réduite

$$z \;=\; \frac{T(M) - \mu_0}{\sigma_0} \tag{S4.9}$$

vaut ici

$$T(M) = 119 \qquad \text{contre} \qquad \mu_0 \pm \sigma_0 = 128 \pm 27 \qquad \Longrightarrow \qquad z = -0{,}33.$$

L'asymétrie observée est *sous* le bruit du placebo : aucun signal directionnel. Le test binomial par paire confirme : sur 18 paires suffisamment peuplées, aucune n'est significative à 5 %, ni avant ni après correction de Bonferroni. Le pas annuel a lessivé la direction.

Précaution de méthode (à afficher). Le test intuitif du « temps inversé » (comparer M à la matrice obtenue en renversant la chronologie) est dégénéré sur un comptage : par construction $M_{\text{inv}} = M^{\top}$, donc la corrélation des asymétries vaut -1 quel que soit le contenu. Il ne prouve rien. Seul le placebo par permutation est valide sur des comptages.

Source 3 : la VERIS Community Database, ou le schéma sans le remplissage. Les deux premiers échecs tiennent à ce que la source ne *prévoit* pas ce que W exige. Restait l'hypothèse la plus favorable : un standard de description d'incidents qui, lui, prévoit exactement les bons champs. C'est le cas du schéma VERIS, référence de la profession et support du *Data Breach Investigations Report*, dont la base publique compte 10 591 incidents (980 en secteur financier, NAICS 52). Son schéma porte littéralement les deux objets manquants : un champ `control_failure`, qui nomme le domaine de contrôle défaillant, et une chronologie en quatre étapes (compromission, exfiltration, découverte, confinement), qui porte l'antériorité.

Le verdict est sans appel, et il porte sur le *remplissage* et non sur la conception. Le champ `control_failure` est renseigné dans 13 incidents sur 10 591 (0,12 %), dont un seul en secteur financier. La chronologie n'est datée sur au moins deux étapes que dans 126 incidents (1,19 %), et sur au moins trois dans 10. Surtout, l'intersection des deux conditions, qui est ce qu'identifier W exigerait simultanément, ne compte que 1 incident sur toute la base, et aucun en secteur financier.

Pourquoi ce troisième échec est le plus utile des trois. Les deux premiers pouvaient se lire comme un défaut de conception des sources : personne n'avait prévu de collecter la direction. Celui-ci interdit cette lecture. La spécification *existe*, elle est publiée, elle est adoptée par la profession, et elle n'est pas remplie. Le problème n'est donc pas de savoir *quoi* collecter, question à laquelle le schéma VERIS répond déjà, mais d'en rendre le remplissage obligatoire. C'est exactement ce qu'un registre d'incidents sous DORA peut imposer et qu'une base déclarative volontaire ne peut pas, et c'est ce qui donne sa portée à la spécification de reporting de la section 10.8 : elle ne demande pas d'inventer des champs, elle demande d'en rendre deux obligatoires.

S4.39 Direction de contagion et réversibilité

Le placebo établit un fait ; la théorie des processus réversibles en donne la raison de principe, sous une hypothèse qu'il faut écrire : que les sauts entre piliers se représentent par une chaîne de Markov stationnaire. Toute matrice se décompose de façon unique en $W = S + A$, part symétrique $S = (W + W^\top)/2$ et antisymétrique $A = (W - W^\top)/2$, et ces deux parts sont *orthogonales* au sens de Frobenius. Sur la chaîne de Markov des sauts inter-piliers construite à partir du jugement dirigé (de loi stationnaire π), S est la partie réversible et A le *courant* de probabilité $J_{jk} = \pi_j P_{jk} - \pi_k P_{kj}$, antisymétrique et nul si et seulement si l'équilibre détaillé est satisfait. Le renversement du temps laisse S invariante et retourne le signe de A.

La décomposition $W = S + A$ est ce qui porte les bornes du chapitre 8 et elle se retient telle quelle. Les trois identités qui suivent ne portent, elles, aucune valeur publiée : elles établissent pourquoi une statistique invariante par renversement du temps ne *pouvait* pas révéler la direction, donc pourquoi l'échec des trois sources tient à la nature de l'observable et non à un défaut de collecte. Elles sont empruntées à la théorie des chaînes de Markov et non à l'outillage actuariel, et les sauter ne coûte rien à la suite du mémoire.

Formellement, en notant P le noyau de transition et π sa loi stationnaire, on décompose $P = S_\pi + A_\pi$ où $S_\pi = \tfrac{1}{2}(P + \tilde{P})$ et $A_\pi = \tfrac{1}{2}(P - \tilde{P})$, avec $\tilde{P}_{jk} = \pi_k P_{kj}/\pi_j$ le noyau *adjoint* (la chaîne renversée dans le temps). Trois identités s'ensuivent, vérifiées numériquement (figure S4.23).

(i) Le courant. La quantité

$$J_{jk} \;=\; \pi_j P_{jk} - \pi_k P_{kj} \tag{S4.10}$$

est antisymétrique, et $J \equiv 0$ caractérise la réversibilité (équilibre détaillé). Elle est ici non nulle : le modèle porte bien une direction.

(ii) La fluctuation ne voit que la partie réversible. Pour toute fonction test $f : \{1, \dots, 5\} \to \mathbb{R}$, la forme de Dirichlet, qui est la variation quadratique de la martingale associée, vaut

$$\mathcal{E}(f, f) \;=\; \tfrac{1}{2} \sum_{j,k} \pi_j P_{jk}\,(f_k - f_j)^2 \;=\; \tfrac{1}{2} \sum_{j,k} \pi_j (S_\pi)_{jk}\,(f_k - f_j)^2, \tag{S4.11}$$

la contribution de A_π s'annulant terme à terme par antisymétrie de A_π et symétrie de $(f_k - f_j)^2$. L'énergie de fluctuation est donc aveugle à la direction.

(iii) L'irréversibilité tient en un scalaire. La production d'entropie

$$\sigma \;=\; \tfrac{1}{2}\sum_{j,k}\big(\pi_j P_{jk} - \pi_k P_{kj}\big)\log\frac{\pi_j P_{jk}}{\pi_k P_{kj}} \;\geq\; 0 \tag{S4.12}$$

est nulle si et seulement si la chaîne est réversible, chaque terme étant du signe de $(x-y)\log(x/y) \geq 0$.

Une précaution de vocabulaire, et elle a été demandée. Les mots *martingale* et *variation quadratique* sont employés ici au sens de la théorie des chaînes de Markov, sous la mesure physique : $\mathcal{E}(f,f)$ est la forme de Dirichlet de la chaîne, c'est-à-dire la variation quadratique de la martingale associée à la fonction test f. Il ne s'agit à aucun moment d'une mesure risque-neutre, d'un actif répliqué, ni d'un « test de martingalité » au sens des générateurs de scénarios économiques. Ce mémoire ne valorise rien : aucune hypothèse de non-arbitrage n'y est faite ni requise, et aucun changement de mesure n'y intervient. La confusion est facile ; elle est écartée ici parce que le même mot désigne, en tarification, un objet qui n'aurait aucun sens. La martingale, sa filtration et sa mesure sont nommées *(voir le Matériel Complémentaire en ligne)*, avec les hypothèses de la chaîne, la distinction entre ce qui est *testé* et ce qui est *décomposé*, et la raison pour laquelle aucun test de martingalité n'est possible sur un facteur latent.

Le placebo, relu, et la portée de cette lecture. Le non-rejet $z = -0{,}33$ est compatible avec $\sigma = 0$ (équilibre détaillé). Pour une chaîne stationnaire, une statistique invariante par renversement du temps a la même loi sous P et sous le noyau renversé $\tilde{P}$: elle ne *peut pas* voir un courant qui change de signe sous ce renversement, et c'est ce qui rend dégénéré le test du « temps inversé ». La statistique T du placebo n'est pas de ce type, puisqu'elle compare les transitions à leur transposée : elle pouvait détecter un courant, et au pas annuel elle n'en détecte aucun. Deux limites bornent cette lecture. W n'est pas littéralement un générateur de Markov, et le produit scalaire propre est pondéré par π, dont le $S = (W + W^{\top})/2$ euclidien est le cas π uniforme. Surtout, l'énoncé ne s'étend pas à la loi complète des ensembles de piliers touchés par un sinistre, qui dépend de la direction (proposition 5.7). La frontière est donc celle des statistiques que les sources fournissent, non une impossibilité de principe.

S4.40 Le choc MOVEit comme expérience naturelle

Avant de conclure, on tente la stratégie la plus ambitieuse que la donnée autorise : une expérience quasi naturelle. En mai 2023, l'exploitation de masse de la faille du logiciel de transfert MOVEit, édité par un tiers, frappe simultanément des centaines d'organisations. C'est un choc exogène, daté, et typé pilier 4. Si la contagion dirigée existe, ce choc doit élever, dans les mois suivants et chez les mêmes organisations, le risque de défaillances relevant d'autres piliers. C'est une prédiction directionnelle testable, par différence de différences (188 organisations financières touchées, groupe

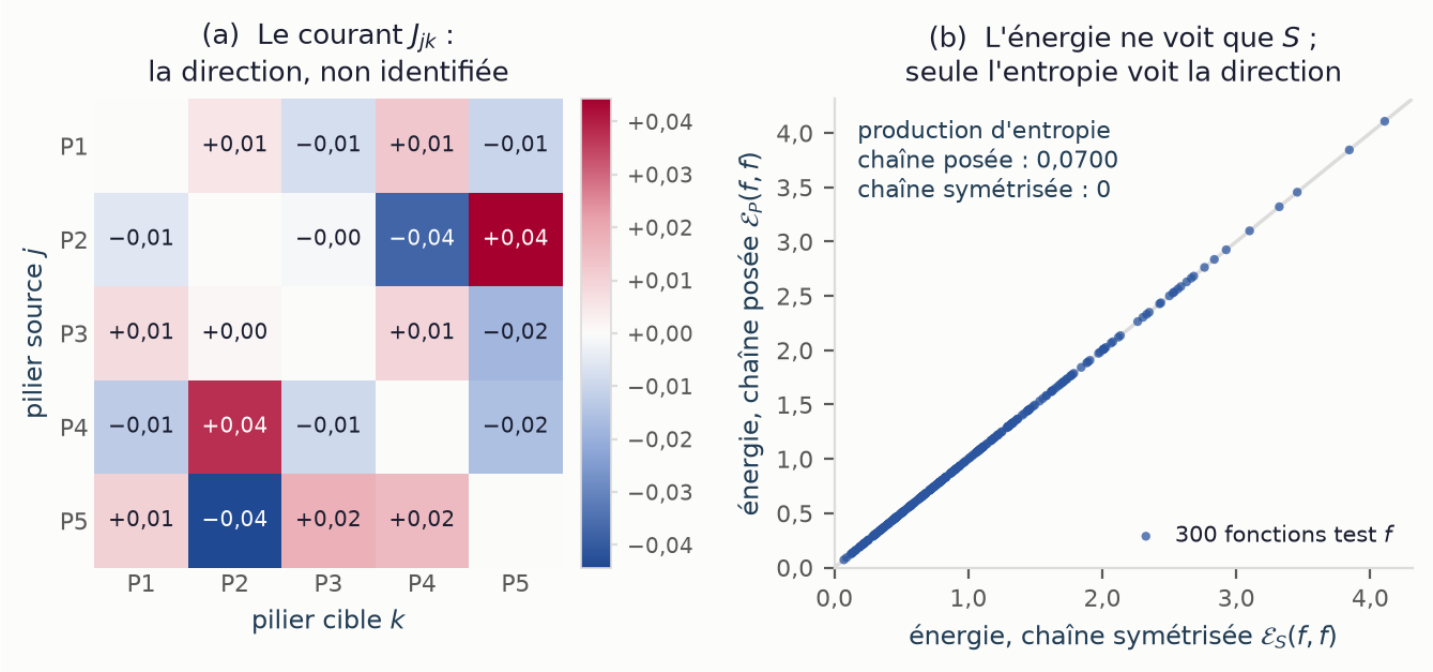


Figure S4.23. La direction A comme courant irréversible, et pourquoi une statistique invariante par renversement ne peut pas la voir. (a) le courant $J_{jk} = \pi_j P_{jk} - \pi_k P_{kj}$ est non nul : le modèle porte bien une direction. (b) pour trois cents fonctions test tirées au hasard, l'énergie de fluctuation, c'est-à-dire la variation quadratique de la martingale, est la même pour la chaîne posée et pour sa symétrisée : les points tombent sur la diagonale, elle ne voit que S. Seule la production d'entropie distingue les deux chaînes, et elle s'annule à la symétrisation.

de contrôle apparié, fenêtres de 180 jours).

> **Le piège, et ce qu'il apprend.** La différence de différences brute est grande et statistiquement significative (+1,17 jour-brèche par organisation, IC bootstrap [+1,07 ; +1,27]). Mais un placebo (le même dispositif calé sur une fausse date un an plus tôt) produit presque le même chiffre (+1,11), alors qu'aucun choc n'a eu lieu. L'effet apparent n'est donc pas causal : il vient de la sélection du groupe de contrôle, qui revient mécaniquement vers sa moyenne. L'effet net, une fois le placebo retranché, tombe à +0,06, indistinguable de zéro. Et quand bien même un signal subsisterait, la cible resterait non attribuable : la taxonomie de la source est un vecteur d'attaque (HACK, DISC…, 32 % non déterminés), pas un domaine de contrôle DORA. Même la meilleure expérience naturelle ne fait donc pas apparaître de propagation dirigée sur donnée agrégée (figure S4.24) : l'échec tient à la donnée, pas à la méthode.

S4.41 Corroboration par un corpus documentaire

Les trois sections précédentes portent sur des bases agrégées. Or la spécification que W exige, horodatage fin, taxonomie par domaine de contrôle, causes communes consolidées, est introuvable dans une base agrégée mais existe *à l'intérieur* d'un autre type de source : le rapport post-incident officiel, où une enquête publique reconstitue la séquence des défaillances de contrôle. On procède

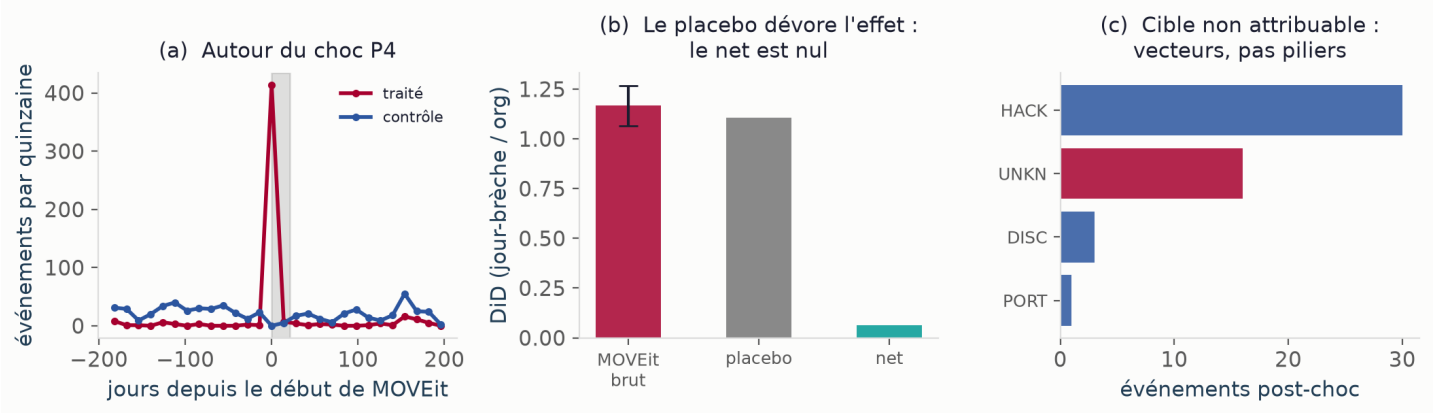


FIGURE S4.24. Event-study du choc MOVEit. (a) Fréquence des brèches, groupe touché contre contrôle, autour du choc. (b) La différence de différences brute est dévorée par le placebo : l'effet net est nul. (c) La cible reste non attribuable, la taxonomie étant un vecteur d'attaque et non un pilier.

donc à une analyse de contenu structurée de sept post-mortems (Cyber Safety Review Board, FCA et PRA, GAO, SEC, OCC), dont deux portent sur des entités financières régulées, en codant chaque rapport en transitions dirigées $k \to j$ telles que le rapport les *établit*. Le protocole de codage est explicite et réplicable, et l'unité de codage est le couple (incident, paire de piliers).

Le résultat est net. Sur 17 transitions codées, l'asymétrie observée vaut 17 contre un placebo par permutation de 8,4 ± 2,2, soit $z = +3{,}93$ ($p = 0{,}0004$), là où le pas annuel d'OpRisk donnait $z = -0{,}33$; aucune transition ne va à contre-sens de la tendance dominante de sa paire. Surtout, une structure apparaît : P1 (gouvernance) n'est jamais une cible (9 sorties, 0 entrée) et P2 (gestion des incidents) est un puits (0 sortie, 7 entrées). C'est exactement la structure que le classeur qualitatif posait par jugement, retrouvée ici sur donnée documentaire et par un chemin indépendant. Le compromis est l'inverse de celui d'OpRisk : peu de volume, mais une direction établie par l'enquête, dont la qualité du codage fait la puissance.

> **Le confondant, qu'aucun de ces chiffres ne lève.** Le placebo teste la *cohérence* du codage, non l'*exogénéité* de la direction. Or une enquête officielle est *mandatée* pour établir une cause racine et des responsabilités, et conclut très souvent à une « défaillance de gouvernance » : que P1 ressorte comme source pure peut donc refléter la convention d'écriture des rapports autant que la causalité opérationnelle. S'y ajoutent un codeur unique, des sources en partie secondaires, et un échantillon raisonné d'incidents notoires. Ce corpus corrobore donc la structure ; il ne la *calibre* pas. Le codage à juge unique est à ce titre une limite déclarée de ce mémoire, et non une étape en attente : son coût est *borné* plutôt que supposé, au §7.7, où la dégradation complète du rôle de P_1 se révèle moins chère que l'ignorance directionnelle que le mémoire assume et publie déjà. Deux dispositifs complètent par ailleurs le dossier, documentés en annexe, et leur exécution renforcerait l'énoncé sans le sauver : une mesure de fiabilité inter-juges par second codeur en aveugle, encore *en attente*, et une relecture par praticiens dont les questions portent précisément sur l'ordre P1 vers P2, à partir de leur expérience de terrain et non de rapports publics, désormais engagée.

Les trois relectures de praticiens reçues vont dans le même sens. Aucune ne distingue un ordre de propagation d'une cause commune, ce qui corrobore la *frontière* et non la matrice ; les deux dernières contestent le sens unique de deux arcs sans déplacer le capital publié, l'ensemble admissible ne fixant aucune direction (§S4.68).

S4.42 Le corpus étendu et la matrice ordonnée complète

Deux objections restaient ouvertes. Le signal directionnel pouvait tenir au *choix* des sept incidents, tous notoires ; et le codage, tel qu'il est exploité ci-dessus, ne compare que $n(j \to k)$ à $n(k \to j)$ *à l'intérieur* d'une paire, ce qui élimine le dénominateur et ne dit donc rien de l'amplitude. On lève les deux ensemble.

Le corpus passe à dix rapports, et le signal se renforce. Trois incidents s'ajoutent, tous documentés par une enquête publique : CrowdStrike Falcon 2024 (analyse technique de cause racine du 6 août 2024, où le validateur de contenu laisse passer un fichier dont le nombre de champs ne correspond pas au modèle), Log4Shell 2021–2022 (premier rapport du CSRB, où l'absence d'inventaire des dépendances logicielles interdit de savoir où la bibliothèque était déployée) et Raphaels Bank 2015 (amende conjointe FCA/PRA pour manquement répété à la gouvernance de l'externalisation). Le corpus compte alors 22 transitions. Le test de direction ne se contente pas de tenir, il se renforce, et il survit aux deux restrictions les plus dures.

Périmètre	**Rapports**	**Transitions**	**Asym. / nul**	z
Corpus initial (chapitre, ci-dessus)	7	17	17 / 8,4 ± 2,2	+3,93
Corpus étendu	10	22	22 / 9,5 ± 2,4	**+5,12**
Sources *primaires* seules	7	18	18 / 8,2 ± 2,4	+4,08
Perspective *entité* seule	6	16	16 / 8,0 ± 2,2	+3,62

Les deux dernières lignes comptent autant que la deuxième. Restreindre aux sources primaires écarte l'hypothèse que le signal viendrait de la couverture de presse ; restreindre à la perspective entité écarte celle qu'il viendrait du mélange des points de vue, une défaillance interne d'un fournisseur n'étant pas un risque tiers pour lui-même alors qu'elle l'est pour ses clients. Le signal survit aux deux.

La matrice ordonnée, enfin estimable. Chaque incident déclare désormais, en plus de ses transitions, l'ensemble des piliers défaillants, y compris ceux qui ont cédé sans rien entraîner. On dispose alors du dénominateur qui manquait, et l'on estime directement

$$p_{jk} \;=\; \mathbb{P}(\text{le pilier } k \text{ cède} \mid \text{le pilier } j \text{ a cédé}), \qquad p_{jk} \mid \text{données} \;\sim\; \mathrm{Beta}\big(1 + m_{jk},\; 1 + N_j - m_{jk}\big), \tag{S4.13}$$

où N_j compte les incidents où j a cédé et m_{jk} ceux où le rapport établit $j \to k$. C'est la matrice *ordonnée complète*, donc S et A, là où la lecture par paire ne donnait que le signe de A.

L'asymétrie du résultat est le point à retenir. Sur les vingt liens ordonnés, douze ont un crédible à 90 % entièrement *sous* 0,5, et *aucun* entièrement au-dessus. Le corpus établit donc très bien *où la contagion ne va pas*, et pas du tout où elle va fort : même les liens les plus élevés, $P_3 \to P_2$ (0,77, crédible $[0{,}48\,;0{,}95]$) et $P_1 \to P_4$ (0,68, $[0{,}40\,;0{,}89]$), recouvrent encore 0,5. Les douze liens faibles comprennent en revanche les *quatre* sorties de P_2, soit toutes, et trois des quatre entrées de P_1 : le puits est donc établi comme tel, la source pure seulement en partie, l'arc $P_5 \to P_1$ n'étant pas établi comme faible. Cette asymétrie résiduelle va contre la convention « cause racine = gouvernance » plutôt qu'en sa faveur, et elle est rapportée ici pour cette raison.

Ce que l'extension confirme, et ce qu'elle ne déplace pas. La corrélation entre la matrice documentaire et le classeur d'expert n'est pas significative, ni sur la matrice complète ($\rho = +0{,}08$) ni sur la seule partie antisymétrique ($\rho = +0{,}31$, $p = 0{,}19$). Le corpus ne reproduit donc pas le classement des coefficients. Ce qu'il reproduit est la structure, et elle seule. Enfin, en ajoutant des défaillances non propagées au dénominateur, pour tenir compte de ce qu'une enquête documente mal les contrôles qui cèdent sans conséquence, le *niveau* de p_{jk} s'effondre (de 0,27 à 0,07 en moyenne) tandis que la part de direction $\|A\|/\|W\|$ ne bouge pas (elle reste à 60 %). Le corpus établit un ordre, pas une magnitude, et l'extension confirme la frontière à trois niveaux sur un objet plus riche au lieu de la déplacer.

S4.43 Mesure du biais de narration

Des trois limites nommées au §7.5, la troisième est la plus sérieuse et la seule qui ne se corrige pas en ajoutant des rapports. Une enquête officielle cherche une *cause racine*, et « défaillance de gouvernance » est une conclusion de convention : le corpus pourrait surreprésenter P_1 comme source non parce que la gouvernance émet, mais parce que les enquêteurs concluent ainsi. L'enjeu n'est pas mince, puisque onze des vingt-deux transitions codées partent de P_1. Jusqu'ici cette limite était écrite et non chiffrée, ce qui est la différence entre une réserve et un résultat. On la chiffre.

On la chiffre par une loi nulle exacte, obtenue par convolution et sans tirage, sur laquelle toutes les décisions se prennent en p-valeur exacte plutôt qu'en z ; un jackknife montre qu'aucun rapport ne porte le signal à lui seul. On cherche ensuite, en borne adverse sur les 2^{11} sous-ensembles d'arêtes partant de P_1, l'ampleur qu'il faudrait à la convention narrative pour renverser la conclusion, en *retirant* ou en *retournant* des arêtes. La construction et le jackknife sont déportés *(voir le Matériel Complémentaire en ligne)*.

Hypothèse sur les 11 arêtes de P_1	**Reste**	**p exacte**
Aucune (corpus tel qu'il est codé)	22 transitions	$1{,}5 \cdot 10^{-5}$
4 arêtes *retournées*, pire configuration	22 transitions	**0,084**
Les 11 arêtes *retirées*	11 transitions	0,0039
Les 7 *rapports* concernés retirés	3 transitions	0,50

La deuxième ligne donne le point de rupture : il faudrait que la convention narrative ait *inversé* quatre des onze arêtes, et dans l'agencement le plus défavorable, pour perdre la significativité. La troisième est plus instructive encore : aucun nombre de retraits ne suffit. En supprimant la totalité du rôle de la gouvernance, donc la moitié du corpus, la direction reste significative, portée par les seules chaînes $P_3 \to P_2$ et $P_4 \to P_2$, les tests qui ne détectent pas et les tiers qui entraînent la gestion d'incident. Ces deux chaînes ne doivent rien à la convention « cause racine = gouvernance », puisque P_1 n'y figure pas.

La quatrième ligne, qui retire les rapports entiers et non les seules arêtes, jette aussi des chaînes que le biais ne concerne pas ; c'est une borne de forme, discutée au même endroit.

Ce que le biais coûte en capital, et ce qu'il ne coûte pas. Un z n'est pas un capital. En dégradant l'émission de P_1 dans la matrice retenue, $W_{1k} \to (1 - a)\, W_{1k}$, et en *recalculant* la bande d'identification pour chaque degré (la dégradation modifie S, donc l'ensemble admissible lui-même), le SCR d'entité passe de 169,0 à 127,1 M€ quand P_1 devient complètement muette, soit −24,8 %. Ce déplacement de 41,9 M€ vaut 0,81 fois la largeur de la bande d'identification déjà publiée, 51,7 M€. Accorder au critique la totalité de son objection coûte donc *moins* cher que l'ignorance directionnelle que le mémoire assume et publie : le biais de narration n'est pas la première source d'incertitude du chiffre d'entité, et il ne faut pas le présenter comme telle. Ce qui bouge, en revanche, est le pilotage : le pilier à remédier en premier passe de P_1 à P_4 dès $a = 0{,}50$. Le niveau de capital résiste au biais, la recommandation opérationnelle en dépend, et les deux ne doivent pas être présentés avec la même assurance.

Enfin, l'écart entre états de conformité, qui est la thèse du mémoire, survit à tous les degrés testés : de +45,2 % à $a = 0$ il descend à +29,1 % à $a = 1$ sans s'annuler, la conformité agissant par le gain g sur *toutes* les arêtes et pas seulement sur celles de P_1. Le second codage en aveugle n'est donc pas le préalable de ce résultat : il en serait le renforcement. Ce que le mémoire publie ici est une *borne adverse*, et le rapport de 0,81 ci-dessus dit pourquoi elle porte : accorder au critique la totalité de son objection déplace le capital d'entité de moins que l'ignorance directionnelle déjà assumée. Ce qu'un second codage ajouterait est une mesure d'*intersubjectivité*, non une correction de niveau, et son absence ne laisse aucun énoncé du mémoire sans borne.

Le dispositif de second codage est préparé et décrit *(voir le Matériel Complémentaire en ligne)*.

S4.44 Exploration des séquences ordonnées

Des marges par paires ne déterminent pas une loi sur les permutations : un triplet ordonné, du type P1 → P3 → P2, porte en général une information qu'aucune paire ne porte. Composer les arêtes d'un même incident donne 9 chemins de longueur deux. Le résultat est négatif pour trois raisons distinctes : la comparaison la plus naturelle a un support vide, P2 n'émettant jamais et P1 n'étant jamais atteint ; le test de dépendance au prédécesseur n'a aucune puissance, aucun pilier n'étant à la fois atteint et doté de deux successeurs ; et l'acyclicité du graphe agrégé s'obtiendrait deux fois

sur trois par hasard, donc ne confirme rien. Un acquis subsiste sur le modèle : l'auto-évitement rend la chaîne des piliers dépendante du prédécesseur, de sorte que les triplets portent une prédiction testable. Le protocole et le volume requis, 158 à 589 chemins par un même pilier, sont déportés *(voir le Matériel Complémentaire en ligne)*.

S4.45 La formalisation bayésienne et sa prudence

Borner à la main traite toutes les configurations admissibles à égalité, y compris celles que les rapports contredisent. Le cadre bayésien fait mieux avec le même matériau, et sans élicitation. Pour chaque paire $\{lo, hi\}$, on pose θ la probabilité qu'une chaîne documentée aille de lo vers hi, et on la relie au coefficient antisymétrique par

$$A_{lo,hi} \;=\; S_{lo,hi}\,(2\theta - 1),$$

transformation affine, croissante et bijective de $[0, 1]$ sur l'intervalle admissible $[-S_{lo,hi}, +S_{lo,hi}]$ du chapitre 8, avec $\theta = 1/2$ donnant $A = 0$, c'est-à-dire W symétrique. Si le corpus documente n_{lo} chaînes allant de lo vers hi et n_{hi} dans l'autre sens, la vraisemblance est binomiale et la conjugaison beta-binomiale donne un posterieur explicite :

$$\begin{aligned} &\theta \sim \mathrm{Beta}(\alpha_0, \beta_0), \qquad n_{lo} \mid \theta \sim \mathcal{B}\mathrm{in}(n_{lo} + n_{hi},\, \theta) \\ \Longrightarrow \qquad &\theta \mid \text{données} \;\sim\; \mathrm{Beta}\big(\alpha_0 + n_{lo},\; \beta_0 + n_{hi}\big). \end{aligned} \tag{S4.14}$$

Aucune simulation par chaînes de Markov n'est nécessaire, et aucun prior d'expert n'intervient. Le cas $n_{lo} = n_{hi} = 0$, celui des paires que le corpus ne documente pas, rend (7.5) égal au prior : sous $\mathrm{Beta}(1, 1)$, θ reste uniforme sur $[0, 1]$ et A balaie donc *tout* l'intervalle admissible.

La propriété qui fait l'intérêt du procédé. Le posterieur reproduit de lui-même la structure d'identification partielle : les quatre paires que le corpus ne documente pas gardent un θ uniforme, donc un coefficient qui couvre *tout* l'intervalle admissible, sans qu'on ait à poser cette ignorance ; les paires documentées, elles, se concentrent. Le bayésien n'ajoute donc pas une hypothèse, il formalise celle qui était déjà là. Le capital devient une loi plutôt qu'un encadrement, et son intervalle de crédibilité à 90 % se révèle 81 % plus resserré que les bornes de pire cas (les niveaux sont établis au chapitre 9). Les deux objets répondent à deux questions distinctes, et le mémoire donne les deux : les bornes sont *opposables* car sans prior, le crédible est *informatif*.

Deux vérifications vont en sens opposés. Sous un prior sceptique, la médiane ne se déplace presque pas, donc la conclusion vient des comptes documentés. Mais par paire, seules deux des six paires documentées ont un intervalle de crédibilité à 90 % qui exclut $\theta = 1/2$: c'est cette lecture, la plus conservatrice, qui est retenue. Le détail et la figure sont déportés *(voir le Matériel Complémentaire en ligne)*.

S4.46 LA FRONTIÈRE D'IDENTIFICATION EN TROIS NIVEAUX

On peut maintenant énoncer précisément ce que la donnée autorise à revendiquer, et c'est un énoncé à trois étages plutôt qu'un verdict unique.

Objet	Ce que la donnée établit	Posture retenue
Structure (P1 amont, P2 aval)	17 transitions sur le corpus initial et 22 sur le corpus étendu, aucune à contre-sens, $z = +3{,}9$ puis $+5{,}1$; convergence avec le jugement d'expert par un chemin indépendant	**revendiquée**, avec son confondant déclaré
Direction paire par paire	2 paires sur 6 seulement ont un crédible concluant	**non revendiquée** ; les bornes restent
Amplitude des coefficients	aucune information ; même les dix sens connus, une bande de 656 M€ subsisterait	**non identifiable** par cette voie

La conséquence de méthode est nette : on revendique un ordre partiel entre piliers, non une matrice. C'est un objet plus faible, donc bien plus difficile à contester, et il *suffit* à porter les conclusions du mémoire, à savoir le classement des piliers et l'ordre de remédiation. Ce que la donnée fixe par ailleurs demeure ce qu'établissent les chapitres empiriques : la fréquence marginale d'entrée, l'accumulation par cause commune, et l'indice de queue de sévérité avec son hétérogénéité par catégorie. Ce qu'elle ne fixe pas relève d'un autre régime de connaissance et se lit en bande, jamais en point.

La spécification du registre qui identifierait W, et la valeur en capital de cette information, sont traitées à la section 10.8, au chapitre 10 : elles relèvent de la portée réglementaire du travail plus que de sa démonstration.

Ce que ce chapitre apporte au mémoire. Démontrer, chiffres à l'appui, qu'une dépendance que tout le monde *postule* n'est pas *mesurable* sur les données agrégées est rare ; en donner la raison théorique l'est davantage ; aller ensuite chercher, dans une source d'un autre genre, de quoi en corroborer la structure sans sur-vendre le résultat est ce qui distingue une limite *assumée* d'une limite *subie*. Il en sort quatre acquis : une *frontière d'identification* à trois niveaux, une discipline sur l'usage de W (ordre partiel revendiqué, coefficients bornés, jamais présentés comme calibrés), une *formalisation* bayésienne qui reproduit cette frontière au lieu de la postuler, et une spécification de reporting hiérarchisée qui donne au travail une portée réglementaire au-delà du modèle.

S4.47 ESTIMATION DE L'INDICE DE QUEUE ET PRÉCISION DE L'ESTIMATEUR

Le Maximum de Vraisemblance (MLE). Pour pallier le biais de l'estimateur de Hill hors du régime asymptotique strict, ce mémoire privilégie l'estimation par Maximum de Vraisemblance (MLE) sur les excès de la GPD. La log-vraisemblance pour un échantillon de N_u excès y_i au-delà du seuil u

s'écrit (pour $\xi \neq 0$) :

$$\ell(\xi, \sigma) = -N_u \ln(\sigma) - \left(1 + \frac{1}{\xi}\right) \sum_{i=1}^{N_u} \ln\left(1 + \frac{\xi y_i}{\sigma}\right) \tag{S4.15}$$

La maximisation numérique de cette fonction fournit des estimateurs $(\hat{\xi}_{MLE}, \hat{\sigma}_{MLE})$ qui, bien que nécessitant des méthodes d'optimisation (algorithme de Nelder-Mead), offrent une robustesse supérieure face à la variance d'échantillonnage des bases de sinistres cyber comme OpRisk ou PRC.
Par la delta-méthode, l'intervalle de confiance asymptotique à 90 % de l'indice de queue vaut $[0{,}320\,;0{,}870]$; il recoupe l'intervalle bootstrap $[0{,}304\,;0{,}831]$. Les lois asymptotiques de cet estimateur et de l'estimateur de Hill sont données *(voir le Matériel Complémentaire en ligne)*.

Quantile de sévérité : formules fermées, et ce qu'elles ne donnent pas. Le passage des paramètres (ξ, σ) au quantile d'*un* sinistre est explicite. Il faut dire tout de suite ce qu'il n'est pas : ce quantile n'est pas un besoin de capital, et l'on n'y accède au capital qu'après agrégation annuelle de la fréquence et de la sévérité, puis propagation dans la cascade (chapitre 5). Notons $\zeta_u = \mathbb{P}(X > u)$ la probabilité de dépassement du seuil. Les formes qui suivent sont classiques (McNeil et al., 2015).

Proposition S4.2 (Quantile et moyenne de queue d'une sévérité GPD)**.** *Sous le modèle POT, pour α tel que $\mathrm{q}_\alpha(X) > u$ et $\xi \in (0, 1)$:*

$$\mathrm{q}_\alpha(X) = \boxed{u + \frac{\sigma}{\xi}\left[\left(\frac{1-\alpha}{\zeta_u}\right)^{-\xi} - 1\right]}, \tag{S4.16}$$

$$\overline{\mathrm{q}}_\alpha(X) = \mathbb{E}[X \mid X > \mathrm{q}_\alpha(X)] = \boxed{\frac{\mathrm{q}_\alpha(X)}{1-\xi} + \frac{\sigma - \xi u}{1-\xi}}. \tag{S4.17}$$

Lorsque $\xi \geq 1$, l'espérance $\mathbb{E}[X]$ est infinie et $\overline{\mathrm{q}}_\alpha$ n'est pas définie.

La démonstration est déportée *(voir le Matériel Complémentaire en ligne)*.
Numériquement, la calibration OpRisk ($u = 20{,}03$, $\sigma = 57{,}97$, $\xi = 0{,}595$, $\zeta_u = 0{,}151$) donne par (4.3) un quantile de sévérité $\mathrm{q}_{99{,}5\%}(X) = 663{,}0$ M€ et par (4.4) une moyenne de queue $\overline{\mathrm{q}}_{99{,}5\%}(X) = 1\,752{,}4$ M€.

> **Ces deux nombres ne sont pas des capitaux, et le mémoire ne les compare jamais à un SCR.** Ils décrivent *un* sinistre. La mesure de capital est $\mathrm{VaR}_{99{,}5\,\%}(L)$, quantile de la charge *annuelle agrégée*, et elle vaut plusieurs milliers de millions d'euros à l'échelle sectorielle : l'écart avec les 663 M€ ci-dessus ne traduit aucune incohérence, il traduit l'agrégation. À $\lambda \simeq 21{,}6$ sinistres matériels par an, atteindre le quantile annuel à 99,5 % demande un quantile *par sinistre* de l'ordre de 99,98 %, bien plus haut dans la queue. Les deux échelles sont confrontées au §9.10. Réserver VaR et TVaR à L, et q et $\overline{\mathrm{q}}$ à X, n'est donc pas une coquetterie de notation : c'est ce qui empêche de lire une différence d'échelle comme une contradiction.

Deux grilles coexistent dans ce chapitre, et elles ne sont pas concurrentes. La première décrit *comment* un incident entre : par vecteur d'attaque (hameçonnage, exploitation de vulnérabilité, chaîne d'approvisionnement). La seconde décrit *quel contrôle* a cédé : par pilier DORA. Un vecteur n'est pas un pilier, et il serait faux de les apparier terme à terme. Leur articulation est de type *entrée puis propagation* : le vecteur gouverne l'amorce, c'est-à-dire la fréquence d'arrivée d'un sinistre et le pilier sur lequel il tombe ; la cascade du chapitre 5 gouverne ensuite la *propagation* entre piliers. Le présent chapitre calibre donc l'amorce et rien d'autre. La grille par vecteur ne réapparaît plus après lui, et aucun résultat de capital ne dépend de son appariement à un pilier.

S4.48 La brique de fréquence

Décomposition par vecteur d'attaque. Une fréquence de référence λ_{ref}, lue sur le périmètre financier de la base PRC ($\lambda_{ref} = 341$ notifications/an), est décomposée en sous-fréquences par vecteur d'attaque, pondérées par la structure observée dans la base Hackmageddon :

$$\lambda_{ref} = \sum_{v} \lambda_v, \qquad \lambda_v = \lambda_{ref} \times \pi_v, \tag{S4.18}$$

où π_v est la part du vecteur v dans la structure Hackmageddon (38,8 % phishing, 33,8 % exploitation de vulnérabilités, 15,8 % supply chain, 6,3 % identifiants compromis, 5,3 % autres). Cette décomposition transforme un constat structurel en levier de modélisation : un défaut de conformité sur une exigence donnée n'agit que sur la sous-fréquence du vecteur qu'elle est censée mitiger, pas sur l'ensemble de λ_{ref}.

λ_{ref} est une clé de répartition, pas le niveau du modèle. Les 341 de la PRC comptent des *notifications de violation de données* déclarées par les organisations financières de la base, sur un périmètre américain et sans seuil de matérialité. Le périmètre importe : la base entière en compte 2 150 par an, six fois plus, et confondre les deux rendrait le nombre incompréhensible à qui le recalcule. Ce nombre sert exclusivement à répartir la sinistralité entre vecteurs, c'est-à-dire à fixer les π_v et à faire jouer les multiplicateurs de conformité. Il n'alimente pas le moteur de cascade. L'entrée du moteur est la fréquence d'incidents TIC *matériels* lue sur OpRisk, $\lambda \simeq 21{,}6$ par an au niveau du secteur financier mondial, dont la table du chapitre 3 donne les trois échelles de lecture. Tout niveau de capital du chapitre 9 repose sur λ, jamais sur λ_{ref}.

Choix de la loi binomiale négative. La fréquence agrégée $\lambda_{S_x} = \sum_v \lambda_{ref}\, \pi_v\, m_{v,S_x}$ obtenue sous un scénario S_x n'est pas simulée par une loi de Poisson, mais par une loi binomiale négative, pour tenir compte de la sur-dispersion observée dans les données ($\sigma^2/\mu > 1$). Le facteur de sur-dispersion $\phi = \sigma^2/\mu = 9{,}2$ est traité comme une propriété structurelle de la sinistralité, supposée indépendante du niveau de fréquence : c'est donc ϕ qui est maintenu constant d'un scénario à l'autre, et non le

paramètre r de la binomiale négative, qui est au contraire recalculé sous chaque scénario :

$$r_{S_x} = \frac{\lambda_{S_x}}{\phi - 1}, \qquad p_{S_x} = \frac{r_{S_x}}{r_{S_x} + \lambda_{S_x}}. \tag{S4.19}$$

Augmenter λ via les multiplicateurs DORA déplace ainsi la fréquence moyenne tout en préservant la *forme* de sur-dispersion de la sinistralité, hypothèse de modélisation explicite, dont la limite est que le comportement de la sur-dispersion en régime de forte dégradation n'est pas lui-même observé, faute d'historique de crise DORA.

Réconciliation des mesures de surdispersion, et effet sur le capital. Quatre nombres de surdispersion apparaissent dans ce chapitre et ils ne sont pas en concurrence : l'indice de dispersion n'est pas invariant d'échelle, valant $1 + \lambda/r$ pour un mélange de Poisson, donc croissant avec le niveau de fréquence auquel il est lu. Sur les 14 944 cellules firme-année du panel, où la fréquence moyenne est de l'ordre de quatre centièmes d'incident par cellule, $\mathrm{Var}/\mathbb{E}$ vaut 1,19 ; sur la série annuelle sectorielle détendancée, où λ vaut 21,6, il vaut 2,24 ; le moteur retient 9,20, choix de prudence posé et non mesure. Une échelle de lecture, une agrégation de cellules corrélées, puis une marge prudentielle assumée : les trois écarts s'expliquent l'un après l'autre.

Les paramètres de *forme* se réconcilient par la même identité : $r = 0{,}63$ pour le mélange Gamma au niveau firme-année, $a = 0{,}60$ pour la charge systémique commune (mélange lognormal du chapitre 6), $\varphi = 9{,}20$ pour le mélange Gamma agrégé, c'est-à-dire la binomiale négative. Un mélange lognormal a pour indice de dispersion $1 + \lambda(e^{a^2} - 1)$ et décrit donc la même surdispersion agrégée que le mélange Gamma dès lors que $a = \sqrt{\ln\!\big(1 + (\varphi - 1)/\lambda\big)}$. À l'échelle du moteur, $\varphi = 9{,}20$ correspond à $a = 0{,}57$, soit cinq pour cent sous la valeur 0,60 posée par ailleurs : les deux calages agrégés coïncident, le $r = 0{,}63$ vivant à une échelle firme-année non comparable directement.

Trois enseignements suivent (figure S4.25). D'abord, à variance égale la queue dépend encore de la loi de mélange : le quantile 99,5 % du nombre annuel vaut 74 (mélange Gamma) contre 82 (lognormal), soit +11 % : appairer la variance n'appaire pas la queue. Ensuite, le choix de la loi de comptage déplace la VaR mais *non* la moyenne (l'espérance $\mathbb{E}[N] = \lambda$ est fixe pour les trois lois) : passer du Poisson à la binomiale négative posée relève le SCR de +9 % seulement, la queue restant portée au 99,5 % par la perte unique dominante ($\xi \simeq 0{,}60$). Enfin, calée sur la série cyber×finance détrendée, le rapport $\mathrm{Var}/\mathbb{E}$ brut confondant la croissance tendancielle avec le choc commun, la dispersion de Pearson résiduelle vaut $\varphi = 2{,}24$ (IC 95 % [1,24 ; 5,18], dix-huit points seulement), soit une charge empirique $a = 0{,}122$ (IC 95 % [0,054 ; 0,223]). La valeur posée $a = 0{,}60$ dépasse donc la *borne haute* de cet intervalle, et le $\varphi = 9{,}20$ retenu au niveau du moteur dépasse de loin le 2,24 mesuré : l'un comme l'autre sont un choix de prudence sur la queue de fréquence, non une calibration, à assumer comme tel. La conclusion « le calage posé est conservateur » résiste ainsi à l'incertitude d'estimation, ce qui est la seule chose que dix-huit points autorisent à affirmer.

La dynamique du facteur systémique. Le moteur tire des comptes annuels indépendants de loi binomiale négative. Le facteur de conformité Θ, centré et réduit, intervient dans la distribution des états du chapitre 6. Une dynamique brownienne avec sauts serait une extension. Préserver les marginales

ne suffirait pas à garantir le même quantile annuel si la dépendance intra-annuelle changeait.

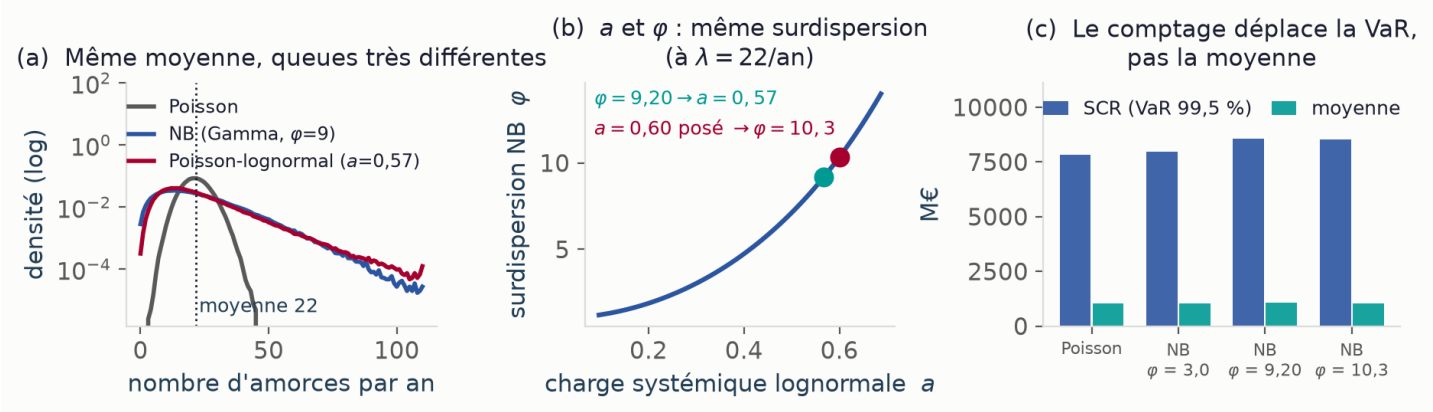


FIGURE S4.25. La loi de comptage négative binomiale, simulée et réconciliée. (a) à moyenne égale, la queue du nombre annuel diffère selon la loi de mélange. (b) la charge lognormale a et le facteur φ tracent la même surdispersion agrégée ; les deux valeurs posées quasi coïncident. (c) le comptage déplace la VaR, pas la moyenne.

De la fréquence par scénario à la fréquence par entité. Le choix d'un scénario $S_x \in \{S_0, S_1, S_2\}$ reste, par construction, discret et appliqué uniformément à l'ensemble du marché. Une extension implémentée utilise la probabilité de non-conformité de l'entité pour interpoler linéairement les multiplicateurs. Ils restent entre leur valeur conforme et le centre de leur intervalle non conforme. L'interpolation utilise une probabilité, et non directement la latente gaussienne. Le résultat principal à quatre canaux utilise les états discrets, sans cette interpolation.

S4.49 LA BRIQUE DE SÉVÉRITÉ, CALIBRÉE SUR OPRISK

Choix de la loi de Pareto généralisée. La sévérité des sinistres cyber présente une signature de queue lourde documentée au chapitre 3 : sur OpRisk Global, sur la population de la fréquence et de la descente d'échelle, les 10 % d'incidents les plus graves concentrent 92,3 % de la perte totale. Cette concentration extrême justifie le recours à la théorie des valeurs extrêmes, et plus précisément à une modélisation de la queue de distribution par une loi de Pareto généralisée (GPD) au-delà d'un seuil u, selon l'approche *peaks-over-threshold*.

Calibration OpRisk. Au seuil du percentile 85 (u = 20,0 M€, 91 excès), la calibration donne :

$$\hat{\xi}_{\text{OpRisk}} = 0{,}595 \quad (\text{IC}_{90\%} = [0{,}30\,;\,0{,}83]), \qquad \hat{\sigma}_{\text{OpRisk}} = 58{,}0\ \text{M€}, \qquad q_{99{,}5\%}(X) = 663\ \text{M€}. \tag{S4.20}$$

Le dernier terme est un quantile de sévérité, c'est-à-dire le montant d'*un* sinistre, et non un besoin de capital. L'intervalle de confiance bootstrap qui l'entoure, [411 ; 1037] M€, matérialise à lui seul un facteur 2,5 entre les bornes, uniquement imputable à l'incertitude de paramètre.

Ce que le seuil doit aux diagnostics, et ce qu'il ne leur doit pas. Le choix de u s'appuie sur deux diagnostics, à condition de ne leur faire dire ni plus ni autre chose que ce qu'ils disent. Le *diagnostic GPD* (figure S4.26) établit un point, et un seul : le seuil retenu se situe à la frontière où le paramètre

de forme quitte la zone instable ($\xi \geq 1$, où l'espérance n'existe pas) pour un régime de moments finis, tout en conservant assez d'excès pour estimer ($n = 91 > 30$). L'argument porte sur le *voisinage* du seuil et ne s'étend pas à toute la plage, où l'indice décroît nettement : écrire que $\hat{\xi}$ est stable quand on fait varier le seuil serait donc inexact, et le balayage qui l'établit est mesuré au §4.6. Le second diagnostic, le *Hill plot (voir le Matériel Complémentaire en ligne)*, ne corrobore pas davantage ce niveau par sa valeur, qui en vaut plus du double ; l'écart fait l'objet de la section suivante, où il devient une corroboration d'un autre genre.

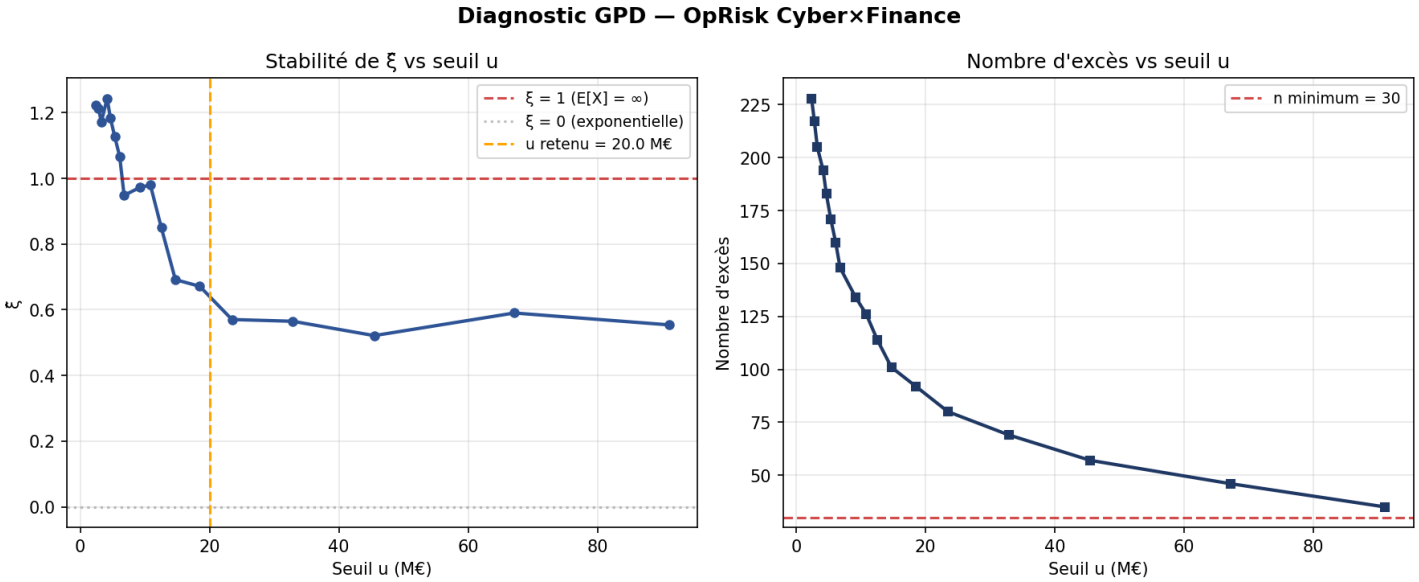


FIGURE S4.26. Diagnostic GPD sur le périmètre cyber×finance d'OpRisk. *Gauche* : $\hat{\xi}$ en fonction du seuil u ; le paramètre passe sous $\xi = 1$ (espérance finie) avant le seuil retenu $u = 20$ M€. La plage tracée s'arrête en deçà des seuils les plus élevés du balayage, où l'indice descend plus bas : la figure atteste le voisinage du seuil, non une stabilité d'ensemble. *Droite* : le nombre d'excès correspondant ($n = 91$) demeure au-dessus du minimum de 30 requis pour une estimation robuste.

S4.50 HILL CONTRE MAXIMUM DE VRAISEMBLANCE

L'estimateur de Hill (Hill, 1975), appliqué au même périmètre, ne corrobore pas l'indice de queue par sa valeur : au seuil retenu ($k = 86$) il vaut 1,32, soit 120,8 % au-dessus du maximum de vraisemblance. L'écart est pourtant exactement ce qu'un indice de 0,595 produit en échantillon fini : sur 2 000 échantillons simulés sous le modèle publié, les six valeurs observées de Hill tombent dans l'intervalle simulé à 90 %. Hill croît en outre avec k quand le balayage de seuil fait décroître $\hat{\xi}$, ce qui serait inversé si la queue valait 1,32. La calibration sur la PRC donne $\hat{\xi} = 1{,}03$, un indice qui ne porte pas sur le même objet, la sévérité PRC étant une puissance du nombre d'enregistrements (§3.7). La définition de l'estimateur, la table des simulations, le tracé et la validation croisée sont déportés *(voir le Matériel Complémentaire en ligne)*.

S4.51 Validation et adéquation du socle

Avant d'agréger, on vérifie que les deux lois posées s'ajustent réellement aux données, faute de quoi tout le reste serait bâti sur du sable (figure 4.2).

Sévérité. La GPD passe les diagnostics sans réserve. Les tracés quantile-quantile et probabilité-probabilité s'alignent sur la diagonale ; la vie résiduelle moyenne est linéaire au-delà du seuil, ce qui est la signature même d'une queue GPD et justifie le choix de u ; et $\hat{\xi}$ est stable dans le *voisinage* du seuil retenu, à 0,5 % près jusqu'au percentile 85 des données courantes. Il ne l'est pas sur toute la plage : en remontant le seuil du percentile 85 au percentile 95, l'indice décroît de 0,60 à 0,38, six seuils comptant chacun au moins trente excès. Cette décroissance reste *entièrement* dans l'intervalle de confiance à 90 % déjà publié pour ξ, $[0{,}30\,;0{,}83]$: la sensibilité au seuil ne crée donc pas d'incertitude nouvelle, elle se lit dans celle qui est déjà déclarée. En descendant au contraire sous le seuil retenu, $\hat{\xi}$ remonte jusqu'à 0,98 et sort de cet intervalle par le haut, ce qui est le biais de seuil attendu lorsqu'on ajuste une loi de queue à des pertes qui n'y appartiennent pas encore, et ce qui justifie de ne pas descendre plus bas.

Les tests formels ne rejettent pas l'ajustement, la p-value étant obtenue par bootstrap paramétrique, les valeurs critiques tabulées ne valant pas lorsque les paramètres sont estimés : Anderson-Darling $p = 0{,}96$, Kolmogorov-Smirnov $p = 0{,}89$. Ces deux tests portent sur la *famille* GPD, paramètres réajustés à chaque tirage. Le couple $(\hat{\xi}, \hat{\sigma})$ *effectivement publié* est testé séparément, paramètres imposés, seule façon d'attester le chiffre plutôt que le choix de loi : Anderson-Darling $p = 0{,}99$, Kolmogorov-Smirnov $p = 0{,}89$, sans rejet non plus.

La couverture réelle de l'intervalle de confiance à 90 % de ξ, mesurée par simulation à n fini, vaut 86 %. Le mot juste n'est pas « proche du nominal » : un intervalle annoncé à 90 % qui n'en couvre que 86 est trop étroit, donc l'incertitude reportée sur ξ est sous-estimée et non l'inverse. Sous l'approximation normale, atteindre le nominal demanderait d'élargir la demi-largeur d'environ 10 %. L'écart est petit, mais son sens compte, et il rejoint celui du taux de dépassement gelé au §10.6 ainsi que celui de la dérive d'échelle mesurée au §4.7 : les trois seuls défauts d'estimation du mémoire vont du même côté, celui de la sous-estimation, quand tous ses choix *posés* vont du côté prudent. C'est aussi ce qui justifie de rapporter les intervalles bootstrap plutôt que les asymptotiques.

Fréquence. Sur les 14 944 cellules firme-année du panel financier, la binomiale négative domine le Poisson sans ambiguïté : le test du rapport de vraisemblance donne $p \approx 10^{-30}$. La surdispersion ($\mathrm{Var}/\mathbb{E} = 1{,}19$) est donc un *fait*, non un artefact, et la NB épouse la queue des comptes là où le Poisson s'effondre.

Le seuil est une règle, pas un choix. Une règle de stabilité écrite, appliquée à dix percentiles candidats, retient 19,87 M€ contre 20,03 publiés, avec un quantile identique, et ce seuil est aussi le mieux ajusté du balayage. La règle la plus permissive descendrait à 12,88 M€ et donnerait un quantile de sévérité supérieur de 16,0 % : le seuil publié n'est pas celui qui maximise le chiffre du mémoire. Les deux règles et l'absence de compromis entre biais et variance sur cette grandeur sont exposées *(voir le Matériel Complémentaire en ligne)*.

Une poignée d'observations porte la queue, et aucune ne la porte seule. Un ajustement conduit sur 91 excès appelle une objection directe : le niveau tient-il à une observation ? Les deux moitiés de la question se traitent séparément et ne reçoivent pas la même réponse. Prises une à une, les observations ne commandent pas l'estimation : en retirant chacun des 91 excès à son tour, le quantile de sévérité balaie une étendue de 111,7 M€, soit 17,9 % de l'amplitude de l'intervalle de confiance déjà publié, et aucun de ces retraits ne l'en fait sortir. L'excès le plus influent est bien le plus gros, 1 380 M€, dont le retrait déplace le quantile de −15,8 %.

Prises ensemble, elles le commandent. Retirer les trois plus grosses pertes suffit à faire passer le quantile sous la borne basse du même intervalle, et en retirer cinq le divise presque par deux, de 657,2 à 327,3 M€, l'indice de queue tombant de 0,60 à 0,22. Le déplacement est monotone, et son sens est celui qu'une queue lourde impose : le quantile à 99,5 % *est* porté par les plus grands sinistres, de sorte que les retirer ne met pas l'ajustement à l'épreuve, cela retire l'objet mesuré. Ce qui se déclare n'est donc pas une fragilité de l'estimateur mais une condition de lecture : le niveau publié vaut tant que ces quelques pertes sont réelles, et une erreur de saisie sur l'une d'elles le majorerait.

> **Ce qui rend la première moitié concluante.** Un retrait observation par observation ne conclut rien si l'une d'elles se détache du nuage, puisqu'il mesurerait alors cette distance et rien d'autre. Sur le périmètre calibré, le maximum ne vaut que 3,7 fois le quantile à 99 %, contre 52,7 sur la base entière : la plus grosse perte appartient à un continuum, et c'est ce qui autorise à lire l'absence de point de levier. La conclusion ne tient pas davantage à la convention de recomptage du taux de dépassement, les deux colonnes s'écartant d'au plus 1,9 %.

Ce que la validation établit, et ce qu'elle n'établit pas. Les tests portent sur la *forme* des lois, pas sur le *niveau* du capital : ils confirment que la GPD et la NB sont les bons objets, mais laissent entière l'incertitude sur ξ et donc sur la VaR (la bande du chapitre 9). Adéquation n'est pas certitude : c'est précisément pourquoi le SCR se lit en intervalle, jamais en point.

S4.52 Backtest hors échantillon à origine glissante

Les diagnostics qui précèdent partagent une limite, et elle est de principe plutôt que de degré : ils interrogent l'ajustement sur les données mêmes qui l'ont produit. Un test d'adéquation demande si une loi décrit son échantillon, jamais si elle prédit une période qu'elle n'a pas vue. C'est pourtant la seconde question qu'un modèle de capital doit affronter.

Le protocole est celui de l'origine glissante. Pour chaque année d'origine, les deux lois sont ajustées sur les seules observations antérieures, la seule année suivante est notée, puis l'origine avance d'un an. La fenêtre retenue va de 2004 à 2025, soit 539 incidents, ce qui donne douze années notées hors échantillon. Deux précautions en conditionnent la lecture. La fenêtre est choisie sur la donnée et non par commodité : avant 2004 la base porte de un à neuf incidents par an contre treize à trente-neuf ensuite, et l'année 2026 n'en porte que cinq, si bien qu'une fenêtre plus large fabriquerait

un faux régime calme au début et un faux effondrement à la fin. Et le seuil est ré-estimé sur chaque échantillon d'apprentissage par la règle du percentile 85, plutôt que lu dans la calibration figée : un seuil calculé sur toute la période ferait passer l'information de test dans l'apprentissage, et le test cesserait de mesurer quoi que ce soit.

Les résultats. La loi de fréquence est validée : un intervalle de prévision annoncé à 90 % en couvre 91,7 % sous la binomiale négative contre 75,0 % sous le Poisson, et le log-score, qui pénalise la largeur, désigne le même gagnant. La forme de la queue survit au test de probabilité intégrale ($p = 0{,}4087$). Les quantiles de sévérité sont en revanche dépassés trois fois trop souvent, parce que l'échelle dérive : 4,00 % par an dans la queue, dont la moitié d'inflation monétaire, les montants de la base étant nominaux, soit au moins +24,7 % sur le quantile de sévérité. Cette dérive ne gonfle pas la thèse : le facteur entre états passe de 3,344 à 3,124 sous la sévérité dérivée, et l'écart en euros ne bouge que de $-1{,}9$ %, par compensation entre forme et échelle. Sur la charge annuelle agrégée le verdict est négatif, pour la même cause, le désalignement n'apparaissant que sur les dernières années notées. L'indépendance entre fréquence et sévérité tient sur les excès. Le détail de ces tests est déporté *(voir le Matériel Complémentaire en ligne)*.

> **Ce que ce dispositif ne peut pas tester, dit en années plutôt qu'en précaution de style.** Détecter un taux de dépassement *double* du nominal avec une puissance de 80 % demanderait 1 811 années au niveau de 99,5 %, 905 à 99 %, et 78 même à 90 %. Le quantile qui porte le capital n'est donc backtestable sur aucun historique de risque opérationnel existant, et sur douze années le test ne renseigne que le centre et le corps de la loi de l'agrégat. Le niveau de capital reste adossé à l'ajustement paramétrique, dont la queue est corroborée par trois chemins indépendants et bornée par l'intervalle de ξ ; aucun de ces chemins n'est un backtest du quantile, et le présenter comme tel serait faux. Un backtest qui ne déclare pas sa puissance laisse croire qu'une absence de rejet vaut validation.

Un seul défaut, derrière trois symptômes. Des quatre objets soumis au test, un seul mécanisme est en défaut, l'échelle de la sévérité, et les trois symptômes qui restent en découlent : les quantiles de sévérité dépassés, la charge agrégée rejetée et le quantile publié anti-conservateur. Aucune limite nouvelle n'entre donc à l'inventaire. La valeur reste gelée et l'écart est inscrit au registre des limites (§10.6), du même traitement que le taux de dépassement. Sur la thèse, la formule à retenir est l'invariance d'*échelle* et non l'invariance à la dérive : le facteur entre états ne bouge pas d'une variation d'échelle, mais il baisse de 6,6 % sous la sévérité dérivée, dont la forme est plus légère.

S4.53 Généralisation A, une structure systémique propre à chaque pilier

On indexe désormais par entité i et pilier $j \in \{1, \dots, 5\}$, et l'on remplace le facteur unique par un facteur systémique par pilier Y_j et une sensibilité propre ρ_{ij} :

$$X_{ij} \;=\; \sqrt{\rho_{ij}}\, Y_j \;+\; \sqrt{1-\rho_{ij}}\, \varepsilon_{ij}. \tag{S4.21}$$

Chaque pilier a sa « météo systémique » propre (l'état de la menace sur la chaîne d'approvisionnement pour P4, l'état réglementaire pour P1), et les Y_j sont corrélés entre eux par une matrice Σ_Y : c'est là que vivent proprement les dépendances croisées, au niveau systémique.

Information sur les sensibilités ρ_{ij}. Le nombre de paramètres ne suffit pas à juger la calibration. L'information disponible dépend des périodes d'observation du panel entité × pilier. Une sensibilité n'apparaît pas sur un taux de conformité : la marge vaut 0,35 quelle que soit sa valeur, de sorte qu'elle ne se lit que sur la co-variation entre cellules qui partagent un facteur. Or une cellule (i, j) ne rend qu'un état binaire par période. En accordant même au test le facteur Y_j exactement connu, ce qu'aucune donnée ne fournit, séparer un écart de 0,10 de la valeur de son pilier demanderait 813 périodes, d'après une approximation locale sous périodes indépendantes.

Sur une coupe transversale, deux fois la divergence de Kullback-Leibler atteint 0,47 pour l'alternative $\rho_{ij} = 0{,}99$. Cette moyenne du double log-rapport ne se compare pas au seuil de 3,84 et ne suffit pas à conclure qu'un écart est indétectable. Le même écart lu au niveau du pilier, où les entités se mettent en commun, demande 474 périodes à quatre entités et encore 81 sur une population entière : élargir sature, une période ne livrant qu'un tirage du facteur. Dans ce cadre, l'information sur la sensibilité vient de la répétition dans le temps. Pour l'asymétrie de W, on pourrait utiliser une chronologie fiable ou la loi complète des ensembles touchés, sous des hypothèses sur la cascade.

Une extension serait le compromis hiérarchique $\rho_{ij} = \rho_j + u_{ij}$, où la sensibilité de chaque entité gravite autour de la moyenne de son pilier ρ_j (*pooling* partiel). Il n'est pas une approximation du ρ_{ij} libre : sur tout panel réaliste, u_{ij} reste à sa valeur *a priori*, et les deux écritures ne diffèrent alors par aucun nombre. Une variante admissible par construction s'écrit sur l'échelle transformée, $\operatorname{logit} \rho_{ij} = \operatorname{logit} \rho_j + u_{ij}$, une sensibilité étant une part qu'un terme additif porté directement sur ρ_{ij} fait sortir de $[0\,;\,1]$ avec une probabilité strictement positive, 1,40 % pour une dispersion de 0,20. Le pipeline posant une sensibilité unique, le choix entre les deux écritures ne déplace aucun chiffre publié.

> **Le sens du regroupement décide de ce qui serait observable.** Ici le facteur est celui du pilier, partagé par les entités, et l'identification passe par le temps. Dans le modèle effectivement publié au chapitre 6, il est celui de l'entité et ses cinq piliers le partagent, de sorte qu'une entité forme un groupe et que deux entités sont indépendantes : le même écart s'y sépare avec 374 entités observées une seule fois, soit l'ordre de grandeur d'un marché national. La même équation sous

> deux regroupements n'appelle pas le même dispositif d'observation.

La partie A n'est pas une contribution. Le Merton-Vasicek multifacteur à matrice de corrélation générale est celui de Li (2000), employé tel quel en risque de crédit de portefeuille. La contribution propre ne commence qu'en partie B, avec la contagion dirigée. Le revendiquer clairement évite de se voir opposer une littérature qu'on aurait ignorée.

S4.54 La cascade comme processus de branchement

Le modèle simultané sur latentes n'est pas celui que les données pourraient identifier. On lui substitue une contagion retardée sur incidents, qui est un processus de branchement multitype : un incident sur le pilier k engendre, à la période suivante, un nombre aléatoire d'incidents sur les autres piliers. Toute la théorie de l'extinction des épidémies s'applique, et l'objet central n'est plus W mais la matrice de génération suivante M, qui compte des incidents et non des écarts-types latents :

$$M_{jk} \;=\; \Phi(\text{base}_j + W_{jk}) - \Phi(\text{base}_j). \tag{S4.22}$$

Deux rayons spectraux, à ne pas confondre. $\rho(W)$ gouverne le système latent simultané (il doit être < 1 pour que $(I-W)^{-1}$ existe) ; $R_0 = \rho(M)$ gouverne la cascade d'incidents, qui s'éteint si et seulement si $R_0 < 1$ (le R_0 des épidémiologistes). Avec une incidence de fond de 4,5 % et $g = 0{,}9$, on obtient $\rho(W) = 0{,}506$ et $R_0 = 0{,}054$: les deux lectures sont stables, mais pas du même ordre.

La figure S4.27 vérifie ces deux seuils numériquement.

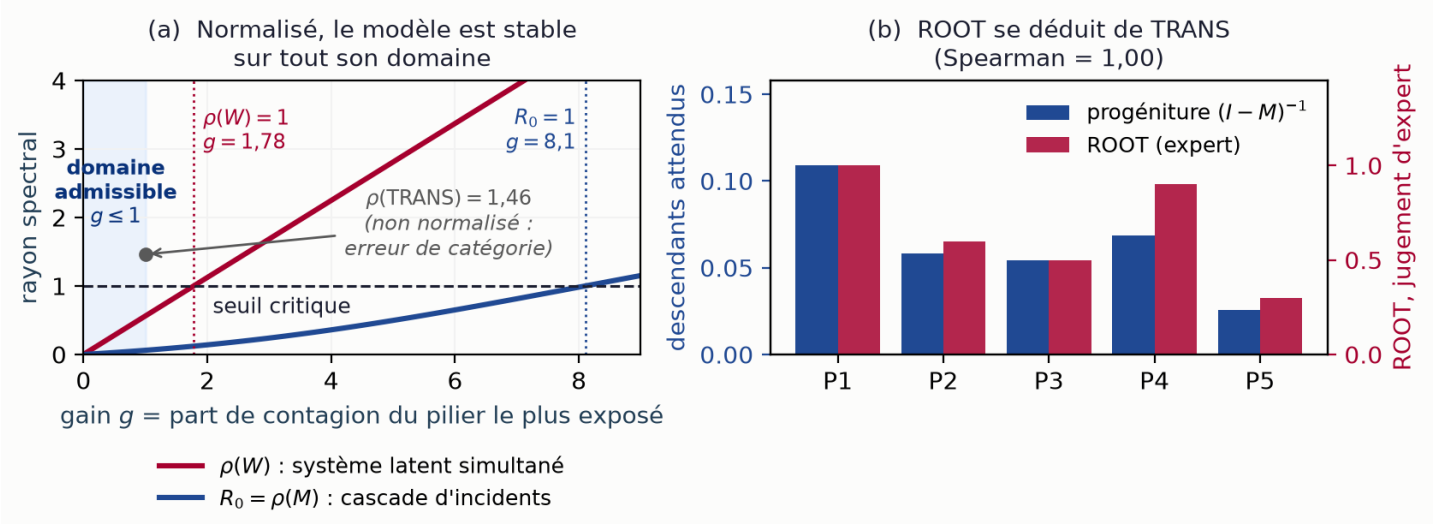


Figure S4.27. (a) Sur le domaine admissible $g \le 1$, les deux rayons spectraux restent < 1 ; les seuils critiques ($\rho(W) = 1$ à $g = 1{,}78$; $R_0 = 1$ à $g = 8{,}1$) sont hors domaine. (b) La progéniture $(I - M)^{-1}$ reproduit exactement le classement ROOT du jugement d'expert.

Deux résultats en découlent. D'une part, la forme simultanée est structurellement alarmiste : même normalisée, elle approche son seuil critique plus de *quatre* fois plus vite que la cascade réelle

($g^\star = 1{,}78$ contre 8,1). Une lecture naïve de TRANS crierait à l'emballement systémique dans un régime où la contagion s'éteint tranquillement. D'autre part, la progéniture $(I - M)^{-1}$ se lit comme le nombre de descendants d'un incident initial : le calcul donne 0,109 (P1), 0,069 (P4), 0,058 (P2), 0,054 (P3), 0,026 (P5), un classement identique à celui du barème ROOT (Spearman = 1,00), et ce pour toute valeur de g.

> **Cohérence interne, et non validation externe.** ROOT et TRANS sont issus du jugement du même expert ; retrouver ROOT à partir de TRANS n'est pas une validation externe mais un test de *cohérence interne* du jugement, réussi. Sa portée réelle est une réduction de paramètres : ROOT se déduit de TRANS au lieu d'être posé, soit cinq paramètres d'expert en moins.

S4.55 Le seuil K_j, substitut de $\Phi^{-1}(\mathrm{PD})$

Il faut distinguer deux seuils vivant dans deux espaces : u_j, le seuil de matérialité (DORA art. 18), dans l'espace des sévérités observables (euros, clients, heures) ; et K_j, le seuil sur la variable latente, sans unité. On ne peut pas prendre l'un pour l'autre : on apparie leurs probabilités, en choisissant K_j pour que l'événement latent $\{X_{ij} \geq K_j\}$ ait la même probabilité que l'incident majeur observable $\{S_{ij} \geq u_j\}$:

$$\boxed{K_j \;=\; F^{-1}(1 - p_j), \qquad p_j = \mathbb{P}(S_{ij} \geq u_j).} \tag{S4.23}$$

La littérature fait déjà exactement cela. Dans la représentation CreditMetrics des matrices de transition (Gupton et al., 1997), le seuil de migration vaut $L = \Phi^{-1}(\text{fréquence cumulée observée})$: on inverse *toujours* une répartition. Ce qu'on reproche à $\Phi^{-1}(\mathrm{PD})$ n'est pas l'inversion, ce sont ses deux entrées : une fréquence non mesurable (remplacée par p_j, définie par le règlement, donc stable et comparable entre entités) et une queue gaussienne trop fine (remplacée par une loi F à queue lourde). La probabilité de dépassement devient alors une sortie du modèle, conditionnelle à l'état systémique.

Le biais sur K_j ne vient pas de la méthode d'estimation de la queue mais de la **sous-déclaration** : en notant $q(s)$ la probabilité qu'un incident de sévérité s soit déclaré, on a l'identité exacte $\hat{p}_j^{\text{naïf}} / p_j = \mathbb{E}[q(S) \mid S \geq u_j] < 1$. On sous-estime p_j, donc on sur-estime K_j, donc on sous-provisionne, et ce biais s'effondre quand la barre monte dans la queue (+0,369 à $u = 0{,}5$; +0,001 à $u = 40$). La barre DORA est défendable parce qu'elle est haute, pas parce qu'elle est réglementaire, et c'est une propriété vérifiable : il suffit d'estimer $q(u_j)$. Le rôle de l'EVT n'est pas de débiaiser cette fréquence (extrapoler le taux depuis un seuil haut n'est pas pilotable), mais de modéliser la sévérité au-dessus de la barre, donc le capital ($-0{,}8\,\%$ de biais contre $-63{,}9\,\%$ pour la lognormale).

S4.56 CALIBRATION ET FAISABILITÉ

Les sources examinées n'identifient pas l'asymétrie de W. Une chronologie fiable ou la loi complète des ensembles touchés pourraient renseigner la direction, sous des hypothèses sur la cascade et les amorces. Nous testons un probit dynamique adapté au bruit gaussien et au seuil du modèle générateur ; un logit gonflerait les magnitudes d'un facteur 2,1. Sur données *simulées* par ce modèle, le probit retrouve W dans ses unités (corrélation 0,92, pente 1,08). Ce contrôle simulé ne valide pas la calibration sur données réelles.

> **Ce que ce protocole donne sur données réelles : rien.** Appliqué aux sources disponibles, il échoue, et il échoue pour des raisons qui tiennent aux *données* et non à la méthode. Le chapitre 7 le démontre sur trois sources qui échouent pour des raisons distinctes et en tire la frontière d'identification ; le chapitre 8 en tire les conséquences sur le capital. Une précision de méthode s'impose dès ici : le test intuitif du « temps inversé » est dégénéré sur des comptages, puisque la matrice obtenue en renversant la chronologie vaut, par construction, la transposée. Il ne prouve rien, et seul le placebo par permutation est valide.

S4.57 VÉRIFICATION NUMÉRIQUE DES TROIS PROPRIÉTÉS CENTRALES

Parmi les six énoncés ci-dessus, trois portent l'argument du mémoire. Chacun est accompagné de sa vérification numérique : l'énoncé dit ce qui doit se produire, le calcul montre que cela se produit.

La criticité dépend de l'ordre (proposition 5.6). Sur les 26 sous-ensembles de taille au moins deux, 22 changent de criticité selon l'ordre, avec un écart atteignant 6 points sur une échelle de 10, soit 60 % de l'échelle, pour un *même* ensemble de piliers. Le contre-exemple minimal suffit à le voir : sur la paire $\{P_1, P_2\}$, le classeur donne TRANS[1][2] = 0,80 et TRANS[2][1] = 0,20, d'où des criticités de 8 et 2 pour le même ensemble.

La contraposée est l'argument utile. Toute mesure de risque qui ne dépend que de l'ensemble touché est invariante par permutation. La proposition 5.6 exhibe donc un objet qu'*aucune* copule et qu'*aucun* score additif ne reproduit, et l'hypothèse requise est minimale : il suffit que TRANS soit asymétrique, sans qu'aucune *valeur* de la direction ne soit revendiquée.

Ce qui n'est pas revendiqué, et pourquoi le dire. Une propriété plus forte, la *non-transitivité* de la dominance entre piliers, a été testée dans trois formulations : la transitivité des corrélations qu'impose un modèle à facteur unique, la positivité de la dépendance symétrisée, et l'existence de cycles de dominance par paire. Aucune ne se vérifie : zéro violation de l'inégalité de transitivité sur 420 triplets, valeur propre minimale +0,405 donc matrice de corrélation parfaitement valide, et zéro cycle. Cette revendication est donc retirée. La dépendance à l'ordre exclut exactement les

mêmes concurrents et, elle, se démontre.

La borne de propagation tient, et son écart se lit (propositions 5.2 et 5.3). Avec le classeur actuel, $\rho(W) = 0{,}506$. La majoration $\mathbb{E}\,|S_a| \le [(I - W)^{-1}\mathbf{1}]_a$ est vérifiée sur les cinq amorces et sur 300 matrices de l'ensemble admissible, sans aucun contre-exemple. L'écart entre la borne et la valeur exacte va de 10,6 % (amorce P5) à 19,9 % (amorce P1). Cet écart n'est pas une imprécision : il mesure exactement les *collisions*, c'est-à-dire les piliers atteints par plusieurs chemins, que la forme linéaire compte plusieurs fois. Sur cinq piliers fortement connectés il n'est pas négligeable, ce qui justifie de conserver le calcul exact par sous-ensembles (proposition 5.4) plutôt que la seule forme close.

La direction échappe aux statistiques disponibles, et cela coûte (proposition 5.7). Le test directionnel ne rejette pas l'hypothèse $A = 0$ (chapitre 7 : asymétrie observée 119 contre un nul de permutation à 128 ± 27, soit $z = -0{,}33$, et aucune arête significative sur 18). Retourner la matrice déplace pourtant le capital de 3,6 % et la perte moyenne de 7,9 % (les niveaux sont établis au chapitre 9 ; seuls les écarts importent ici), et surtout la priorité de remédiation bascule de P1 à P4. Sur l'ensemble admissible, l'écart entre une matrice et sa transposée atteint 1 173 M€.

La loi complète des ensembles touchés, elle, distingue les deux matrices, ce que la partie (ii) de la proposition énonce. Sur la matrice publiée, avec l'amorce et la marche du moteur, un sinistre touche en moyenne 1,931 pilier sous W et 1,746 sous $W^{\top}$, la part des sinistres multi-piliers passe de 62,31 % à 50,77 %, et la probabilité que P2 et P5 cèdent ensemble tombe de 0,127 à 0,066. Sous amorce uniforme, l'écart entre les deux matrices s'efface avec l'intensité de la contagion : il ne vaut plus que 0,86 % quand W est ramenée au cinquantième de sa valeur, ce qui est la partie (i).

L'énoncé à retenir : indiscernables pour les statistiques disponibles, matériellement différentes. C'est la formulation exacte de la frontière d'identification, et elle ne repose sur *aucun* dire d'expert. Elle chiffre en euros de capital, et en inversion de priorité, le prix de ne pas savoir dans quel sens la contagion circule. Elle désigne aussi la donnée qui réduirait cette ignorance : la direction n'est pas inaccessible par principe, elle est absente des sources, et un registre qui consignerait l'ensemble des piliers touchés par chaque incident en porterait une partie. C'est ce qui fonde à la fois le modèle en couches (chapitre 8) et la spécification de reporting adressée au régulateur.

S4.58 LE PRINCIPE DES DEUX ÉCHELLES DE TEMPS

Le moteur du chapitre 5 traite l'état de conformité comme *figé*, et les niveaux qui en découlent ne sont établis qu'au chapitre 9. Or la conformité n'est ni un point ni un instantané : elle est graduelle (trois niveaux au moins) et évolue dans le temps. On distingue donc deux dynamiques. La couche rapide est celle des incidents et de leur cascade à l'intérieur d'une année, chiffrée par le moteur du chapitre précédent, *conditionnellement* à une configuration de conformité. La couche lente est celle de la gouvernance : l'état de conformité de chaque pilier progresse sur des mois et des années. L'état

de la couche lente sert de paramètre à la couche rapide. C'est exactement la structure d'un modèle de risque de crédit à migration de rating, sur laquelle on revient en §6.7.

Cette séparation n'est pas une commodité de calcul, et un précédent le confirme. On pourrait la lire comme un artifice permettant de simuler deux dynamiques sans les coupler. Elle répond en réalité à une exigence de fond : la propagation à l'intérieur d'un sinistre et l'évolution de la conformité d'une année sur l'autre ne vivent pas sur la même horloge, et les confondre reviendrait à laisser une tendance longue expliquer un enchaînement de quelques heures, ou l'inverse. Le préprint de cascade climatique cité au chapitre 2 (Karimi et al., 2026) sépare de la même façon trois indices, un temps calendaire, une position spatiale et un pas de propagation *à l'intérieur* d'un événement, en donnant explicitement pour motif d'empêcher que l'évolution de long terme ne soit confondue avec la propagation de court terme. Une équipe travaillant sur un autre péril aboutit donc à la même séparation pour la même raison, ce qui la déplace d'un choix de modélisation vers une contrainte de construction.

S4.59 Valeurs posées de g et invariance de la conclusion

Le gain de propagation g est l'un des canaux par lesquels la conformité agit, et ses trois valeurs,

$$g = 0{,}45 \text{ (conforme)}, \qquad 0{,}68 \text{ (partiellement conforme)}, \qquad 0{,}90 \text{ (non conforme)},$$

sont posées. Elles ne sont calibrées sur aucune donnée, et pour une raison irréductible : aucune entité ne publie son état de conformité DORA, si bien qu'il n'existe aucun échantillon d'où tirer la correspondance état $\to g$. Un écart énoncé comme « le capital passe de 116 à 169 M€ » hérite donc entièrement de ces trois décimales. Ce qui s'établit sans elles tient en deux temps.

Le lemme, qui n'allait pas de soi. Le capital est croissant en g. Ce n'est pas une évidence : le chapitre 9 établit qu'à indice de queue élevé la VaR annuelle est *peu sensible* à la structure de cascade, par principe du grand saut unique, et peu sensible ne veut pas dire monotone. On le vérifie donc numériquement plutôt que de le supposer, sur une grille de vingt points et à nombres aléatoires communs, condition sans laquelle deux valeurs voisines de g ne différeraient que par le bruit de tirage. Résultat : *aucun pas décroissant* sur les vingt intervalles, et cela sur quatre grandeurs à la fois, le capital et la perte moyenne, à l'échelle d'entité comme à celle du secteur.

L'invariance, qui en découle. Si le capital est croissant en g, alors toute application état $\to g$ respectant l'ordre $g_C < g_{PC} < g_{NC}$ produit $\mathrm{SCR}_C < \mathrm{SCR}_{PC} < \mathrm{SCR}_{NC}$, *quelles que soient les valeurs*. Or la charge forfaitaire de Formule Standard ne dépend pas de l'état. L'existence et le *sens* de l'écart sont donc invariants à la calibration ; seule son amplitude est un scénario.

Application état → g	**Conf.** M€	**Part.** M€	**Non conf.** M€	**Écart**	**Ordre**
étroite (0,70/0,80/0,90)	145,5	156,5	169,0	+16,2 %	oui
retenue (0,45/0,68/0,90)	**116,4**	**143,2**	**169,0**	**+45,2** %	oui
large (0,20/0,55/0,90)	94,4	126,4	169,0	+79,1 %	oui
conformité faible (0,45/0,55/0,65)	116,4	126,4	139,2	+19,5 %	oui
très étroite (0,85/0,875/0,90)	162,6	166,7	169,0	+3,9 %	oui
repère forfaitaire de Formule Standard	450	450	450	0 %	*plat*

La dernière ligne du tableau est la plus instructive. Même en n'accordant à la conformité qu'un déplacement de 0,05 sur g, soit une hypothèse presque nulle, l'écart de capital subsiste (+3,9 %) quand le forfait reste exactement plat. La thèse du mémoire est cet écart de signe, non une valeur de g.

Ce qui reste une hypothèse, et c'est tout ce qui reste. La proposition « se conformer à DORA réduit la propagation entre piliers », soit $g_C < g_{NC}$. C'est une affirmation qualitative, discutable, et sur laquelle le règlement lui-même prend parti puisque ses cinq piliers sont des exigences de maîtrise. Elle est d'un autre ordre de solidité qu'un triplet de valeurs. Ce qui reste un scénario : l'amplitude, qui ne dépend que de l'écartement $g_{NC} - g_C$. L'élasticité d'arc du capital au gain vaut 0,41 sur $g \in [0{,}20\,;0{,}95]$, de sorte qu'un lecteur qui préfère ses propres valeurs recalcule son écart sans relancer le modèle. Et pour que cet écart dépasse 10 %, il suffit que la conformité fasse baisser g de 0,90 à 0,75, soit un écartement de 0,15 : l'exigence porte sur un ordre de grandeur, pas sur une mesure.

Une conséquence de rédaction en découle, et elle est appliquée au chapitre 9 : l'écart entre états n'y est pas présenté comme une mesure mais comme un *scénario d'écartement*, et c'est l'invariance d'ordre qui est mise en avant, puisque c'est elle qui est établie (figure S4.28).

S4.60 L'ÉTAT PAR PILIER

L'apport central est de porter l'état par pilier : chaque pilier a sa propre latente $C_j^\star$, les cinq étant corrélées par le facteur systémique commun Θ. C'est ce qui fait *interagir* la conformité et la cascade : un pilier non conforme propage plus et détecte moins que ses voisins conformes. Les trois canaux deviennent indexés par pilier $(\lambda_j, g_j, p_{u,j})$ et alimentent un moteur d'agrégation qui se réduit exactement à la version globale lorsque tous les piliers partagent un état (contrôle de cohérence). On en déduit la décomposition du surcoût de non-conformité par pilier, en basculant un pilier à la fois, dont les résultats sont au chapitre 9.

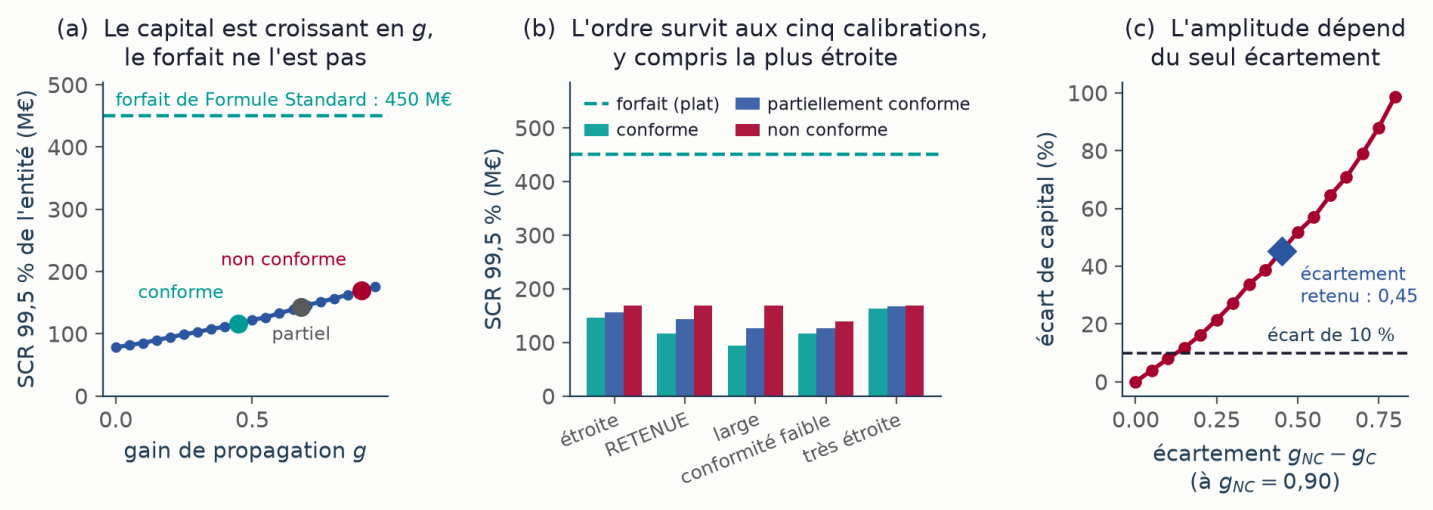


FIGURE S4.28. La thèse ne dépend pas des valeurs de g, seulement de leur ordre. (a) le lemme de monotonie sur vingt points de grille, à nombres aléatoires communs, avec les trois valeurs retenues situées sur la courbe et la charge forfaitaire qui, elle, ne dépend pas de l'état. (b) cinq applications état $\to g$, de très étroite à large : l'ordre du capital est respecté par toutes, le forfait reste plat dans tous les cas. (c) l'amplitude de l'écart en fonction du seul écartement $g_{NC} - g_C$, la valeur retenue étant marquée : c'est la seule grandeur qui soit un scénario.

S4.60.1 Structure portée et structure omise de la dépendance entre états

La conformité aux piliers 1 et 2 pourrait aider à satisfaire les exigences du pilier 3 si les contrôles se recouvrent. Cette hypothèse métier n'est pas observée dans les données. Le diagnostic suivant mesure l'effet d'une dépendance supplémentaire entre ces états.

Ce qu'il porte déjà. Les états ne sont pas indépendants : les cinq latentes partagent le facteur systémique avec une charge de 0,68, soit une corrélation de 0,462 entre deux piliers quelconques. Répondre à l'objection par « la dépendance manque » serait donc faux. Ce qui manque est sa structure : la dépendance est *échangeable*, identique pour toutes les paires, alors que le recouvrement des contrôles est propre à certains triplets.

Ce que l'omission coûte, et la réponse est nulle. On ajoute un surcroît de corrélation δ aux deux seules paires concernées, par une matrice de corrélation dont la diagonale vaut un, ce qui préserve les marges *par construction* et isole donc l'effet de structure. Le surcroît admissible va jusqu'à $\delta = 0{,}38$ avant que la matrice cesse d'être définie positive. Sur ce balayage, la loi des configurations bouge nettement : la probabilité que les cinq piliers soient non conformes passe de 0,068 à 0,088 et celle qu'ils soient tous conformes de 0,291 à 0,330. Le capital espéré, lui, ne bouge que de 2 M€, soit 0,02 %.

Et la raison n'est pas numérique, elle est structurelle. Le capital des 32 configurations s'ajuste presque exactement par une forme *additive* en indicateurs de pilier, $R^2 = 0{,}9945$, avec des contributions de 3 524 (P1), 2 863 (P4), 2 022 (P2), 1 577 (P3) et 897 M€ (P5) au-dessus d'un socle tous conformes. Or l'espérance d'une fonction additive ne dépend que des marges, jamais de la dépendance : les termes croisés sont le seul canal par lequel une structure pourrait agir, et il n'en reste presque rien. L'invariance ne tient donc pas à la valeur de δ retenue, elle vaut pour *toute* structure de dépendance à marges fixées, y compris celles qu'on n'a pas essayées. C'est ce qui rend la conclu-

sion solide alors qu'aucune donnée du projet ne calibre δ. Le détail et la figure sont déportés *(voir le Matériel Complémentaire en ligne)*.

Cette quasi-additivité est par ailleurs le même fait que l'interaction entre piliers déjà publiée, petite devant la somme des marginaux et de signe non résolu (§9.3) : deux lectures d'un seul constat, et l'ordre des contributions additives reproduit celui des marginaux, $P1 > P4 > P2 > P3 > P5$.

L'argument porte sur une espérance, et le capital est un quantile. Il ne transporte ni au quantile de la loi de perte mélangée sur les configurations, ni au quantile de la loi des configurations elle-même. Sur le premier, l'invariance est seulement non détectée ; sur le second, l'effet est de quelques pour cent, porté par une polarisation des configurations extrêmes. Les deux calculs et leurs limites sont déportés *(voir le Matériel Complémentaire en ligne)*.

S4.61 La chaîne de Markov et les séjours de type phase

À l'échelle lente, l'état de conformité suit une chaîne de Markov à temps continu NC $\to$ PC $\to$ C, l'état Conforme étant absorbant en cas de base (une fois conforme, on le reste ; la régression est un axe de sensibilité). Les séjours ne sont pas exponentiels mais de type phase (Erlang-k). Nous posons $k = 2$ phases et une durée moyenne de 1,5 an pour chacun des deux états transitoires. Chaque phase a donc un taux $\mu_0 = k/(1{,}5\text{ an})$. Cette loi réduit la probabilité de séjours très courts sans imposer de durée minimale strictement positive.

> **Deux Erlang, deux objets sans rapport.** Le mot désigne ici la loi des *durées de séjour* dans la chaîne de conformité, où k est un choix de modélisation assumé. Il désigne ailleurs, au chapitre 4, la loi *mélangeante* de la fréquence, dont la forme ajustée vaut 0,63 et n'est donc pas une Erlang, celle-ci exigeant une forme entière supérieure ou égale à un. Les deux usages n'ont ni le même support, ni le même statut : le premier est posé, le second est estimé et rejeté comme tel.

On développe chaque macro-état transitoire en k phases et l'on résout le générateur Q sur l'espace de phases par exponentielle de matrice :

$$\big(\mathbb{P}(\mathrm{NC},t),\mathbb{P}(\mathrm{PC},t),\mathbb{P}(\mathrm{C},t)\big) \;=\; (\text{sommes de phases de})\;\; v_0\,\exp(Qt), \tag{S4.24}$$

où v_0 place les masses 0,35, 0,35 et 0,30 en première phase de NC, PC et en C. À chaque horizon t, cette distribution pondère les besoins de capital par état du Vasicek multi-états :

$$\overline{\mathrm{SCR}}(t) \;=\; \sum_{e\in\{\mathrm{NC},\mathrm{PC},\mathrm{C}\}} \mathbb{P}(e,t)\,\mathrm{SCR}_e. \tag{S4.25}$$

Cette grandeur est une *moyenne de quantiles*, pondérée par la loi de l'état à l'horizon t. Quand l'état est incertain, le quantile à 99,5 % de la perte se calcule sur la loi mélangée. Sa queue dépend des composantes les plus lourdes ; les deux objets ne coïncident pas. Sur le mélange des 32 configurations de piliers, le quantile du mélange dépasse la moyenne des quantiles de 9,3 % *(voir le Matériel*

Complémentaire en ligne). La trajectoire se lit donc comme l'espérance du besoin de capital sous l'incertitude d'état, qui est la convention retenue dans tout le mémoire.

S4.62 LE COUPLAGE SYSTÉMIQUE ET L'ANALOGIE DE CRÉDIT

Un seul facteur couple les deux couches. Le même facteur systémique Θ agit à la fois sur la couche lente et sur la couche rapide. Un environnement dégradé ($\Theta < 0$) fait deux choses avec le *même* tirage : il ralentit la remédiation, via des taux de transition $\mu(\Theta) = \mu_0\, e^{\beta_{\text{rem}}\Theta}$, et il durcit la cascade, via $\text{SCR}_e(\Theta) = \text{SCR}_e\, e^{-\beta_{\text{casc}}\Theta}$. Les deux poussent le capital dans le même sens : la corrélation entre conformité et sinistralité, qu'auraient perdue des couches indépendantes, est restaurée. La dispersion de Θ engendre la bande d'incertitude de la trajectoire.

Cette architecture est celle, éprouvée, du risque de crédit à migration de rating : la chaîne de Markov joue le rôle de la migration d'un « rating de conformité DORA » (la qualité change lentement, d'année en année), et le Vasicek multi-états celui du modèle de défaut conditionnel au rating (rapide, dans l'année, pour un rating donné). Transposer cette structure à deux étages au risque cyber n'est pas une invention fragile mais l'application d'un cadre reconnu, ce qui en fait un argument de robustesse et non un pari.

Ce chapitre en donne la méthodologie complète ; les résultats chiffrés et les figures qui en découlent sont rassemblés au chapitre 9.

S4.63 LA MÉTHODE DE COOKE EN QUATRE TEMPS

Le *modèle classique* de Cooke ne traite pas les experts comme interchangeables : il les *note*, sur des questions dont l'analyste connaît la réponse, puis pondère leurs avis par cette note. Il se déroule en quatre temps.

1. **Élicitation en quantiles.** Chaque expert ne donne pas un point mais trois quantiles, à 5, 50 et 95 %, ce qui rend son incertitude déclarée mesurable.
2. **Calibration.** Sur les *questions-graines*, dont la réponse est connue de l'analyste et masquée à l'expert, on compare la fréquence empirique des réalisations dans les intervalles déclarés à la fréquence théorique. L'écart se lit comme une statistique d'information de Kullback-Leibler, et son niveau de signification devient le score de calibration.
3. **Information.** Un expert bien calibré mais qui déclare des intervalles très larges n'apporte rien. Le score d'information mesure la concentration de ses distributions relativement à une loi de référence.
4. **Poids et agrégation.** Le poids d'un expert est le produit des deux scores, et il est nul sous un seuil de calibration. L'avis agrégé est la combinaison linéaire pondérée des distributions individuelles.

C'est le quatrième point qui fait la force et la fragilité de la méthode : un expert mal calibré est écarté, ce qui protège des dires péremptoires, mais réduit d'autant la taille effective du panel.

S4.64 Le protocole construit pour la matrice de contagion

Le questionnaire préparé comporte deux parties. La partie d'étalonnage pose des questions à réponse connue, tirées de sources publiques vérifiables, sur des grandeurs du même domaine que les cibles. La partie cible interroge les liens dirigés entre piliers, un par un, sous la forme d'une probabilité conditionnelle : sachant que le pilier source est défaillant, quelle est la probabilité que le pilier cible le devienne.

Le dispositif complet demande seize questions par expert, dont dix questions-graines. Ce ratio n'est pas un excès de prudence : c'est le minimum qui permette de distinguer un expert calibré d'un expert chanceux, et le réduire viderait la méthode de ce qui la distingue d'une moyenne d'opinions. Le protocole, le questionnaire et le gabarit de réponses sont versionnés dans le dépôt du mémoire, et deux scripts implémentent l'agrégation, l'un sur réponses fictives pour valider la chaîne de traitement, l'autre prêt à recevoir des réponses réelles.

Une dixième graine a été retirée, et le dire fait partie du protocole. La première version de l'étalonnage portait une question sur l'indice de queue de sévérité ξ, de valeur vraie annoncée 0,90. Deux défauts s'y cumulaient. D'abord 0,90 n'est pas la calibration mais la valeur *posée* du scénario de pire cas, la calibration figée donnant $\hat{\xi} = 0{,}5954$: or dans la méthode de Cooke une graine fausse n'ajoute pas du bruit, elle *inverse* les poids, en pénalisant le répondant qui vise juste. Ensuite, et c'est ce qui justifie le retrait plutôt que la correction, ξ est une *estimation* d'intervalle $[0{,}30\,;\,0{,}83]$, plus large que la valeur elle-même : une graine doit être une grandeur réalisée, pas un paramètre estimé. Les dix graines de l'instrument révisé sont toutes reproductibles par une sortie de script versionnée, ce qui est la condition pour qu'une notation d'expert soit opposable.

S4.65 Documents produits et diffusés

Le dispositif n'est pas resté à l'état d'intention, et le distinguer importe : un protocole qu'on décrit sans l'avoir soumis n'engage rien, un protocole soumis et resté sans réponse documente un état du terrain. Quatre pièces ont été produites et sont versionnées au dépôt du mémoire.

- **Le protocole**, qui fixe la méthode, les seuils et la règle d'agrégation.
- **Le questionnaire**, dans sa troisième version, avec ses seize questions dont dix graines d'étalonnage, reproduit à la section précédente.
- **Un formulaire en ligne** reprenant ces questions, pour que le répondant saisisse ses trois quantiles sans manipuler de fichier.
- **Le gabarit de réponses**, qui alimente la chaîne d'agrégation.

Deux scripts complètent l'ensemble, l'un validant la chaîne de traitement sur des réponses fictives, l'autre prêt à recevoir des réponses réelles.

L'appel a été adressé par deux canaux. Le premier est une commission de l'Institut des Actuaires, sollicitée pour atteindre des praticiens qualifiés sur le risque lié aux technologies ; les destinataires ne sont pas nommés ici, la même règle valant pour eux que pour les répondants du formulaire de relecture rapporté plus bas. Le second est un ensemble de praticiens du cabinet, déjà sollicités par ailleurs sur cette relecture.

L'appel est resté sans réponse, et aucun panel n'a pu être constitué. Du côté de l'Institut, aucune réponse n'est parvenue. C'est un fait de démarche et il se publie comme tel, sans être présenté comme un résultat : il dit la difficulté d'obtenir un jugement quantitatif structuré sur un objet aussi récent, il ne dit rien de la disposition des personnes sollicitées. La conséquence pour le mémoire est en revanche nette, et la section suivante la tire.

S4.66 PORTÉE DE L'ABSENCE DE PANEL

La première raison est de fait : l'appel n'a pas abouti. Les deux suivantes disent pourquoi cette absence ne fragilise pas la conclusion, et elles étaient établies *avant* qu'on la constate, ce qui est la seule façon honnête de les présenter.

Un panel de un ou deux experts n'aurait eu aucun pouvoir de calibration. À supposer même que l'appel eût trouvé des répondants, le calendrier du mémoire et un taux de retour réaliste sur un questionnaire de seize questions quantitatives auraient donné un nombre de réponses exploitables, c'est-à-dire complètes et passant le seuil de calibration, de l'ordre de une à deux. Or à deux experts la pondération de Cooke dégénère : soit un seul survit au seuil et l'on obtient un avis unique déguisé en agrégation, soit les deux survivent et le poids relatif est estimé sur dix graines, ce qui ne le distingue pas d'une moyenne simple. Dans les deux cas la méthode ne fait plus ce pour quoi elle est choisie.

Et une élicitation faible ne serait pas neutre, elle serait trompeuse. C'est l'argument décisif, chiffré. Le chapitre 8 mesure l'effet d'un panel biaisé sur le capital : il déplace le SCR de 777 M€ sans qu'aucun signal ne l'indique au lecteur, là où l'approche par bornes reste *invariante* à ce biais. Un jugement d'expert faiblement calibré introduirait donc dans le résultat une incertitude *non déclarable*, alors que la non-identifiabilité, elle, se déclare et se borne. En termes de qualité de la conclusion, l'échange serait défavorable : on remplacerait une ignorance mesurée par une erreur invisible.

Une asymétrie à assumer, car un relecteur la trouvera. Cet argument condamne le jugement d'expert non vérifiable, or ce mémoire *utilise* du jugement d'expert ailleurs : la direction de la contagion s'appuie sur un corpus de dix rapports codés, et par un seul codeur à ce jour. Refuser l'élicitation au nom du biais d'expert tout en s'appuyant sur un codage d'expert demande donc une justification, et non un silence.

Elle tient en trois différences dont le cumul compte. Le codage est *auditable* : le protocole est écrit, les dix récits sont publics, et n'importe qui peut recoder le corpus et confronter ses réponses

aux nôtres, ce qu'une élicitation quantitative en séance ne permet pas. Son biais principal est mesuré plutôt que redouté : le biais de narration fait l'objet d'un test contre une loi nulle exacte, dont le résultat est publié *et négatif* (§7.7). Et son produit est un ordre partiel, un objet qualitatif que la suite du raisonnement borne, là où une élicitation produirait des coefficients numériques entrant directement dans le capital. Un dire d'expert qui alimente une borne et un dire d'expert qui alimente un nombre n'engagent pas le même risque.

Reste que la comparaison n'est pas entièrement favorable : le codage demeure à juge unique, et cela se lit comme une limite déclarée et non comme une étape en attente. Ce qui la distingue du défaut reproché à l'élicitation est qu'elle est *bornée* : la dégradation complète de la source contestée coûte moins que l'ignorance directionnelle déjà publiée (§7.7), là où un panel faiblement calibré introduirait une incertitude non déclarable. Un second codage en aveugle renforcerait l'énoncé, et le dispositif reste préparé à cette fin.

S4.67 LES DISPOSITIFS DE SUBSTITUTION

Trois dispositifs, tous en place et tous sans prior d'expert.

Le corpus documentaire. Dix rapports post-mortem officiels sont codés selon un protocole écrit, et le sens des transitions y est testé contre une loi nulle exacte de permutation : $z = +5{,}12$ sur le corpus étendu. La direction n'est donc pas seulement posée, elle est *corroborée* par une source indépendante du classeur qualitatif.

L'échelle de repli sur la direction. Plutôt que de connaître la direction, on peut supposer qu'elle est de rang faible. Le premier cran de cette échelle capte 74,1 % de la variance de la direction posée et resserre le capital dans [7 761 ; 8 316] M€, soit une largeur de 555 M€ contre 1 839 sous ignorance totale. C'est une hypothèse structurelle, déclarée comme telle, et bien plus modeste qu'un dire d'expert.

Les ancrages réglementaires. Les niveaux d'exigence des textes et les publications des autorités fournissent des repères externes sur les états de conformité, sans passer par un panel.

S4.68 LA RELECTURE DE PRATICIEN ET SON RÉSULTAT

Pourquoi ce dispositif est nécessaire, et il l'est pour une raison qui n'a rien de conjoncturel. La direction de W n'est pas identifiable sur les données disponibles, et le chapitre 7 le démontre plutôt que de le déplorer : les statistiques que les sources permettent de construire sont aveugles à la partie antisymétrique, donc une matrice et sa transposée y sont indiscernables. Il en résulte que W n'est pas calibrée au sens où le sont la fréquence et la sévérité. Sa structure est *déduite* d'un corpus de rapports post-mortem, source qui porte son propre confondant, le biais de narration d'une enquête officielle, borné au §7.7 mais non levé.

Sur une structure ainsi posée, il ne reste qu'un seul contrôle externe possible : le jugement de praticiens qui ont vu des défaillances réelles, et qui n'ont lu ni le corpus ni le mémoire. Ce dispositif

est donc nécessaire et non facultatif. Mais il faut voir ce qu'il peut et ce qu'il ne peut pas : un praticien peut corroborer ou contredire une structure, il ne peut pas la calibrer, faute de quoi on retomberait sur l'élicitation que ce chapitre vient d'écarter, avec son déplacement de capital non déclarable. C'est exactement la différence entre une relecture et une élicitation, et elle commande la forme de l'instrument.

Le dispositif est donc de nature différente des trois précédents : non pas recueillir des probabilités, mais soumettre à des praticiens du secteur les affirmations *qualitatives* sur lesquelles le modèle repose, en leur demandant de les contredire. L'instrument est un questionnaire de sept phrases, sans lecture préalable du mémoire, dont deux portent explicitement sur l'ordre P1 vers P2. Le choix de demander des désaccords plutôt que des accords est délibéré : un accord ne discrimine rien, alors qu'un désaccord argumenté désigne l'endroit exact où le modèle s'écarte de ce que le terrain observe.

La première réponse ne contredit rien. Une consultante de Nexialog, exerçant en gestion des risques et du contrôle depuis une dizaine d'années, n'a contredit aucune des sept phrases : deux accords pleins, cinq accords assortis d'une nuance. Un instrument construit pour recueillir des désaccords et qui n'en recueille aucun renseigne d'abord sur lui-même, et cette information vaut d'être écrite plutôt que passée sous silence.

Ce que la réponse corrobore, la direction exceptée. Deux affirmations reçoivent un accord franc et argumenté, et toutes deux portent sur la *faisabilité* des recommandations plutôt que sur la structure du modèle. Sur les trois indicateurs pilotables, la répondante les juge cohérents et produisibles, et suggère de les compléter par une fréquence d'occurrence. Sur le registre d'incidents mieux spécifié, qui est le prolongement le plus utile identifié par ce mémoire, elle va plus loin que l'accord : elle décrit un usage professionnel établi, un tableau de bord des incidents par prestataire servant, dans une analyse de risque conduite au titre de DORA, à évaluer la fréquence du risque de défaillance système et le taux d'indisponibilité sur douze mois. La recommandation la moins mathématique du mémoire est donc aussi celle que le terrain confirme le plus directement.

Une qualification substantielle, qu'il faut déclarer sans la traiter. La nuance la plus utile porte sur l'arc de la gouvernance vers la gestion des prestataires tiers. La répondante distingue l'occurrence et la maîtrise : une gouvernance solide ou fragile ne change pas, selon elle, le fait qu'un prestataire critique tombe, mais elle change la capacité de l'entité à en limiter les conséquences. Traduite dans les termes du modèle, cette distinction déplacerait cet arc de la matrice de propagation vers le canal de détection, ce qui n'est pas la même chose et ne donne pas le même chiffre. La réserve est donc déclarée et non traitée : la traiter reviendrait à recalibrer, ce que le gel interdit, et cette qualification, portée par une seule des trois réponses, ne justifie pas de rouvrir la calibration.

Et un argument d'antériorité, le seul de la réponse qui soutienne vraiment un ordre. Sur la phrase qui fait de la gestion des incidents un puits, la répondante avance un argument temporel plutôt qu'une intuition : les tests sont conduits en amont de la mise en service, donc un incident postérieur ne peut pas dégrader les tests. C'est de la précédence, et c'est précisément ce que le corpus documentaire code. Elle ajoute une critique de la définition du pilier lui-même, en séparant l'incident de sa gestion,

deux objets que la nomenclature réglementaire réunit.

Ce que l'instrument devient. Deux défauts du questionnaire ont été identifiés par cette première réponse, tous deux dans les phrases et non chez la répondante. La phrase sur la gouvernance source pure *empaquetait* deux affirmations, et la répondante a nuancé la première sans se prononcer sur la seconde, qui est celle qui compte. Et la phrase opposant la contagion à la cause commune ne discriminait pas ce qu'elle prétendait discriminer, pour la raison exposée au chapitre 7. Trois questions à choix forcé ont été ajoutées, qui séparent les deux affirmations empaquetées, demandent au répondant de choisir entre contagion et cause commune, et font trancher la distinction occurrence contre maîtrise. La modalité *je ne peux pas trancher* y est offerte explicitement ; c'est la modalité la plus intéressante : un praticien qui la choisit corrobore la frontière d'identifiabilité sur le terrain, ce qui vaut davantage qu'un accord sur la matrice.

La seconde réponse contredit deux phrases, ce que l'instrument cherchait. Un consultant de Nexialog, expert de la résilience et de la continuité d'activité dans les services financiers depuis sept ans, a répondu à la même version du questionnaire, sans les questions à choix forcé ajoutées depuis. Il ne se prononce pas sur la première phrase tout en la commentant, donne quatre accords assortis d'une nuance, et exprime deux désaccords argumentés, sur les deux phrases que le questionnaire désignait comme les plus importantes.

La cause commune, avancée sans y être invité. Sur la phrase qui oppose la contagion à la cause extérieure commune, il reconnaît des chaînes de causalité, une gouvernance peu structurée conduisant à des tests insuffisants puis à des incidents, mais ajoute que plusieurs domaines peuvent céder ensemble parce qu'ils partagent une cause : un manque de ressources, une transformation mal pilotée, une architecture vieillissante. Il conclut qu'il parlerait de dépendances entre domaines plutôt que de causalité systématique. Là où la première réponse illustrait la frontière d'identifiabilité sans la nommer, celle-ci la formule : c'est la corroboration la plus nette que le dispositif ait produite, et elle porte sur la frontière, non sur la matrice.

Deux désaccords sur le sens des arcs, déclarés. Il conteste que la gouvernance soit une source pure : un incident significatif peut conduire à changer les responsabilités, à renforcer les comités de suivi ou à augmenter les budgets, si bien que la gouvernance est aussi une conséquence des défaillances. Il conteste de même que la gestion des incidents soit un puits : un incident mal géré révèle des tests insuffisants et conduit à les renforcer, un incident impliquant un prestataire fait revoir les contrats et la surveillance, et une escalade défaillante dégrade la circulation de l'information. Deux lectures de ces exemples doivent être tenues ensemble. La plupart décrivent une rétroaction corrective, l'incident conduisant à renforcer un domaine : elle relève de l'évolution des états de conformité modélisée au chapitre 6, non de la propagation d'une perte que porte la matrice. Un seul décrit une dégradation en retour, de la gestion des incidents vers le partage d'information, sens qu'aucun rapport du corpus ne code. Ce désaccord ne déplace pas le capital publié : l'ensemble admissible du chapitre 8 ne fixe aucune direction et contient aussi bien les matrices à dépendance réciproque que celles où l'arc est inversé. Il affaiblit en revanche la structure que le corpus suggère, déjà déclarée corroborée et non

calibrée ; il est enregistré comme tel.

La faisabilité, sous conditions. Il juge les trois indicateurs pertinents et actionnables mais insuffisants à eux seuls, et y ajouterait les incidents récurrents, les vulnérabilités critiques non corrigées, les résultats des tests et la disponibilité des services critiques. Il juge le registre d'incidents réaliste, et la distinction entre date de survenue et date de déclaration particulièrement utile, sous réserve de règles de qualification précises : le classement d'un incident par domaine peut être subjectif, et reconnaître une cause commune à plusieurs victimes suppose de disposer de l'information qui l'établit. Sur le prestataire partagé, il confirme le choc simultané en rappelant que le niveau de dépendance résulte lui-même de choix de gouvernance.

Ce qui manque selon lui. La gestion des changements et celle des vulnérabilités, qu'il désigne comme des déclencheurs fréquents d'une chaîne traversant plusieurs domaines sans qu'aucun ait été défaillant au départ. Le modèle fait naître un incident sur un pilier ; un déclencheur transversal de ce type n'y a pas de place propre. Cette limite de périmètre est à inscrire parmi les prolongements.

La troisième réponse répète le désaccord sans l'élargir. Un consultant en données, exerçant depuis un an, a répondu à la version portant les trois questions à choix forcé. Il conteste les deux mêmes phrases que la réponse précédente, et répond à la question fermée sur la gouvernance qu'un incident, un test raté ou la défaillance d'un prestataire la dégradent *temporairement*. Son seul commentaire juge le registre d'incidents réaliste mais risqué pour la confidentialité. Aucun argument nouveau n'entre donc par cette voie : venant d'un profil plus éloigné du métier de la résilience, elle augmente la fréquence du désaccord et non sa portée. Ce répondant a demandé à n'être cité que par sa fonction.

Statut. Trois réponses ne font pas un panel. Cette relecture n'entre donc dans aucune table de robustesse et ne modifie aucun niveau publié. Elle est citée pour ce qu'elle est, une relecture de praticiens engagée et rendue, et les répondants ne sont pas nommés.

S4.69 LE COÛT DE L'ABSENCE ET SA RÉVERSIBILITÉ

Il faut nommer le coût. L'élicitation avait une fonction précise et une seule : *départager P1 et P4* en tête du classement des piliers sources. Sans elle, les deux restent pratiquement à égalité sur l'ensemble admissible, P1 arrivant premier dans 43,6 % des configurations et P4 dans 37,7 %, pour un écart de regret maximal de 1,5 % (§9.6). Le mémoire conclut donc que P1 et P4 devancent nettement les trois autres piliers, et il s'arrête là où la donnée s'arrête, au lieu de trancher entre eux par un avis.

Un instrument prêt, à qui il ne manque que des répondants. Le protocole est écrit, le questionnaire est prêt et diffusé, le gabarit de réponses et la chaîne d'agrégation sont testés. Ce qui manque n'est pas le dispositif mais un panel de taille suffisante pour que la pondération de Cooke ait un sens. La reprise est donc *sans coût de développement* : si un accès à un panel d'une dizaine de

répondants devient possible, l'élicitation reprend là où elle a été laissée, et son apport attendu est connu d'avance, à savoir le départage de P1 et P4 et un resserrement de la bande d'identification. C'est le seul point du mémoire où une donnée supplémentaire changerait une conclusion plutôt qu'un niveau.

Bibliographie

AMRAE. LUCY 2026 : Lumière sur la cyberassurance. Rapport technique, Association pour le Management des Risques et des Assurances de l'Entreprise, 2026. https://www.amrae.fr/lucy-lumiere-sur-la-cyberassurance-edition-2026.

Autorité des marchés financiers. Rapport sur les incidents majeurs DORA déclarés à l'AMF en 2025. Rapport technique, Autorité des marchés financiers, septembre 2026. https://www.amf-france.org/fr/actualites-publications/publications/rapports-etudes-et-analyses/rapport-sur-les-incidents-majeurs-dora-declares-lamf-en-2025, consulté le 28 septembre 2026.

Autorités européennes de surveillance (ESAs). Premier rapport annuel sur les incidents liés aux TIC au titre de DORA, 2026. https://www.eiopa.europa.eu/esas-publish-first-report-dora-major-ict-related-incidents-2026-06-03_en.

Avast Threat Labs. WannaCry, un an après : bilan des attaques bloquées dans le monde. Laboratoire des menaces Avast, 2018. Période observée : 12 mai 2017 – 1er avril 2018.

Adrian Baldwin, Iffat Gheyas, Christos Ioannidis, David Pym et Julian Williams. Contagion in cyber security attacks. *Journal of the Operational Research Society*, 68(7), 2017.

Banque centrale européenne. Analyse des registres d'externalisation des établissements importants, 2024. Plus de 30 % du budget d'externalisation sur 10 prestataires ; 50 % du budget critique sur 30 ; 19 prestataires TIC critiques désignés par les ESAs (novembre 2025). https://www.bankingsupervision.europa.eu/ecb/pub/pdf/ssm.outsourcing_horizontal_analysis_202402~2b85022be5.en.pdf.

Yannick Bessy-Roland, Alexandre Boumezoued et Caroline Hillairet. Multivariate Hawkes process for cyber insurance. *Annals of Actuarial Science*, 15(1):14–39, 2021. doi: 10.1017/S1748499520000093.

Christian Biener, Martin Eling et Jan Hendrik Wirfs. Insurability of cyber risk: An empirical analysis. *The Geneva Papers on Risk and Insurance – Issues and Practice*, 40:131–158, 2015.

Klaus Böcker et Claudia Klüppelberg. Operational VaR: a closed-form approximation. *Risk Magazine*, 18 (12):90–93, 2005.

Rainer Böhme et Gaurav Kataria. Models and measures for correlation in cyber-insurance. Dans *Workshop on the Economics of Information Security (WEIS)*, 2006.

Alexandre Boumezoued, Yousra Cherkaoui et Caroline Hillairet. Cyber risk modeling using a two-phase Hawkes process with external excitation, 2023. arXiv:2311.15701. https://arxiv.org/abs/2311.15701.

Javier Castro, Daniel Gómez et Juan Tejada. Polynomial calculation of the Shapley value based on sampling. *Computers & Operations Research*, 36(5):1726–1730, 2009. doi: 10.1016/j.cor.2008.04.004.

Comité de Bâle sur le contrôle bancaire. Bâle III : finalisation des réformes de l'après-crise. Rapport technique, Banque des règlements internationaux, décembre 2017.

Commission européenne. Règlement d'exécution (UE) 2024/2956 établissant les modèles du registre d'information des accords contractuels portant sur l'usage de services TIC fournis par des prestataires tiers (DORA). Journal officiel de l'Union européenne, 2024. Modèles B_01.01 à B_99.01 ; chaîne de sous-traitance, criticité, substituabilité.

Commission européenne. Règlement délégué (UE) 2025/301 : contenu et délais des notifications et rapports d'incidents majeurs liés aux TIC. Journal officiel de l'Union européenne, 2025. Article 5. https://eur-lex.europa.eu/eli/reg_del/2025/301/oj.

Sébastien Decupère. Agrégation des risques et allocation de capital sous Solvabilité II, 2011. Mémoire d'actuariat, ENSAE. Déposé sur https://www.ressources-actuarielles.net.

Michel Denault. Coherent allocation of risk capital. *Journal of Risk*, 4(1):1–34, 2001.

Franck Osée Dountio Zaboue. Modélisation de la sévérité du risque cyber en assurance : apports du NLP et de l'IA générative face au déséquilibre des données, 2026. Mémoire d'actuariat, ENSAE. Déposé sur https://www.ressources-actuarielles.net.

Benjamin Edwards, Steven Hofmeyr et Stephanie Forrest. Hype and heavy tails: a closer look at data breaches. *Journal of Cybersecurity*, 2, 2016.

Martin Eling et Nicola Loperfido. Data breaches: Goodness of fit, pricing, and risk measurement. *Insurance: Mathematics and Economics*, 75:126–136, 2017.

Martin Eling et Jan Wirfs. What are the actual costs of cyber risk events? *European Journal of Operational Research*, 272(3):1109–1119, 2019.

Paul Embrechts et Marco Frei. Panjer recursion versus FFT for compound distributions. *Mathematical Methods of Operations Research*, 69(3):497–508, 2009.

ENISA. ENISA Threat Landscape 2025. Rapport technique, European Union Agency for Cybersecurity, octobre 2025. https://www.enisa.europa.eu/topics/cyber-threats/threat-landscape.

Sébastien Farkas, Olivier Lopez et Maud Thomas. Cyber claim analysis using generalized Pareto regression trees with applications to insurance. *Insurance: Mathematics and Economics*, 98:92–105, 2021.

France Assureurs. Cartographie prospective des risques de la profession de l'assurance et de la réassurance. Rapport technique, France Assureurs, Paris, 2026. https://www.franceassureurs.fr/wp-content/uploads/2026-fa-cartographie-prospective.pdf.

Greg M. Gupton, Christopher C. Finger et Mickey Bhatia. CreditMetrics: Technical document. Rapport technique, J.P. Morgan, 1997. https://www.msci.com/documents/10199/93396227-d449-4229-9143-24a94dab122f.

Hemantha Herath et Tejaswini Herath. Copula-based actuarial model for pricing cyber-insurance policies. *Insurance Markets and Companies*, 2, 2011.

Bruce M. Hill. A simple general approach to inference about the tail of a distribution. *The Annals of Statistics*, 3(5):1163–1174, 1975.

Caroline Hillairet et Olivier Lopez. Propagation of cyber incidents in an insurance portfolio: counting processes combined with compartmental epidemiological models. *Scandinavian Actuarial Journal*, 2021(8): 671–694, 2021.

Caroline Hillairet, Anthony Réveillac et Mathieu Rosenbaum. An expansion formula for Hawkes processes and application to cyber-insurance derivatives, 2021. arXiv:2104.01579, Stochastic Processes and their Applications (2023). https://arxiv.org/abs/2104.01579.

Caroline Hillairet, Olivier Lopez, Louise d'Oultremont et Brieuc Spoorenberg. Cyber-contagion model with network structure applied to insurance. *Insurance: Mathematics and Economics*, 2022.

Bertrand Iooss et Clémentine Prieur. Shapley effects for sensitivity analysis with correlated inputs: Comparisons with Sobol' indices, numerical estimation and applications. *International Journal for Uncertainty Quantification*, 9(5):493–514, 2019. doi: 10.1615/Int.J.UncertaintyQuantification.2019028372.

Jay Jacobs. Analyzing Ponemon cost of data breach. Data Driven Security, 2014.

N. Karimi, E. Salavati et F. Shokrollahi. Climate-conditioned cascade modeling for multi-peril reinsurance: Analysis and controlled numerical applications. Prépublication arXiv:2608.09456v1 [q-fin.RM], 2026. Déposée le 10 août 2026.

David Kempe, Jon Kleinberg et Éva Tardos. Maximizing the spread of influence through a social network. Dans *Proceedings of the Ninth ACM SIGKDD International Conference on Knowledge Discovery and Data Mining*, pages 137–146, 2003.

Justin Kher, Olivier Lopez et Hugo Rapior. Cyber incident reports: extrapolating severity using neural networks, 2023. Document de travail. https://detralytics.com/en/publications/cyber-incident-reports-extrapolating-severity-using-neural-networks/.

Wassily Leontief. Quantitative input and output relations in the economic system of the United States. *The Review of Economics and Statistics*, 18(3), 1936.

David X. Li. On default correlation: A copula function approach. *The Journal of Fixed Income*, 9(4):43–54, 2000.

Yang Lu, Yaodi Zhang et Wenjun Zhu. Cyber risk modeling: a discrete multivariate count process approach. *Scandinavian Actuarial Journal*, 2024(6), 2024.

Thomas Maillart et Didier Sornette. Heavy-tailed distribution of cyber-risks. *The European Physical Journal B*, 75(3):357–364, 2010.

Charles F. Manski. Nonparametric bounds on treatment effects. *American Economic Review*, 80(2):319–323, 1990.

Charles F. Manski. *Identification Problems in the Social Sciences*. Harvard University Press, 1995.

Marsh. European Cyber Claims Report 2025. Rapport technique, Marsh, avril 2025. https://www.marsh.com/en-gb/services/cyber-risk/insights/cyber-claims-report-2025.html.

Alexander J. McNeil, Rüdiger Frey et Paul Embrechts. *Quantitative Risk Management: Concepts, Techniques and Tools*. Princeton University Press, revised édition, 2015.

OpinionWay et CESIN. 11e baromètre de la cybersécurité des entreprises. Rapport technique, Club des Experts de la Sécurité de l'Information et du Numérique, 1 2026. Enquête auprès des entreprises membres. https://www.opinion-way.com/fr/publications/barometre-de-la-cybersecurite-des-entreprises-francaises-2026-22229/.

Art B. Owen. Sobol' indices and Shapley value. *SIAM/ASA Journal on Uncertainty Quantification*, 2(1): 245–251, 2014. doi: 10.1137/130936233.

Harry H. Panjer. Recursive evaluation of a family of compound distributions. *ASTIN Bulletin*, 12(1):22–26, 1981.

Chen Peng, Maochao Xu, Shouhuai Xu et Taizhong Hu. Modeling and predicting extreme cyber attack rates via marked point processes. *Journal of Applied Statistics*, 44(14):2534–2563, 2017. doi: 10.1080/02664763.2016.1257590. Première publication en ligne en 2016.

Anna Ranguin. Modélisation du risque cyber des entreprises françaises, 2024. Mémoire d'actuariat, ISUP, Institut des actuaires. Déposé sur https://www.ressources-actuarielles.net.

Hugo Rapior et Kélian Kaddouri. Rapport LUCY 2026 : analyse actuarielle du marché français de la cyberassurance. Rapport technique, Nexialog Consulting, Paris, juin 2026. https://www.nexialog.com/publication/rapport-lucy-2026-analyse-marche-cyberassurance/.

Lloyd S. Shapley. A value for n-person games. Dans Harold W. Kuhn et Albert W. Tucker, éditeurs, *Contributions to the Theory of Games, Volume II*, numéro 28 de la collection Annals of Mathematics Studies, pages 307–317. Princeton University Press, 1953.

Eunhye Song, Barry L. Nelson et Jeremy Staum. Shapley effects for global sensitivity analysis: Theory and computation. *SIAM/ASA Journal on Uncertainty Quantification*, 4(1):1060–1083, 2016. doi: 10.1137/15M1048070.

Elie Tamer. Partial identification in econometrics. *Annual Review of Economics*, 2:167–195, 2010. doi: 10.1146/annurev.economics.050708.143401.

Dirk Tasche. Risk contributions and performance measurement. Rapport technique, Zentrum Mathematik, TU München, 1999. https://www.semanticscholar.org/paper/002fb9788abeab17fe54a7703303c95a252d05a7.

UK Government, Department for Science, Innovation and Technology. Survey on the state of UK cyber insurance market. Rapport technique, DSIT, janvier 2025. https://www.techuk.org/resource/survey-on-the-state-of-uk-cyber-insurance-market.html.

Union européenne. Règlement (UE) 2016/679 du 27 avril 2016 relatif à la protection des personnes physiques à l'égard du traitement des données à caractère personnel (RGPD). Journal officiel de l'Union européenne, 2016. https://eur-lex.europa.eu/eli/reg/2016/679/oj.

Union européenne. Règlement (UE) 2022/2554 du 14 décembre 2022 sur la résilience opérationnelle numérique du secteur financier (DORA). Journal officiel de l'Union européenne, 2022a. Applicable depuis le 17 janvier 2025. https://eur-lex.europa.eu/eli/reg/2022/2554/oj.

Union européenne. Directive (UE) 2022/2555 du 14 décembre 2022 concernant des mesures destinées à assurer un niveau élevé commun de cybersécurité dans l'ensemble de l'Union (NIS 2). Journal officiel de l'Union européenne, 2022b. Abroge la directive (UE) 2016/1148. https://eur-lex.europa.eu/eli/dir/2022/2555/oj.

Union européenne. Directive (UE) 2022/2557 du 14 décembre 2022 sur la résilience des entités critiques. Journal officiel de l'Union européenne, 2022c. https://eur-lex.europa.eu/eli/dir/2022/2557/oj.

Union européenne. Règlement (UE) 2024/2847 du 23 octobre 2024 concernant des exigences horizontales de cybersécurité pour les produits comportant des éléments numériques (*cyber resilience act*). Journal officiel de l'Union européenne, 2024. Applicable à partir du 11 décembre 2027. https://eur-lex.europa.eu/eli/reg/2024/2847/oj.

Oldrich Vasicek. The distribution of loan portfolio value. *Risk*, 2002.

Thomas Verma et Judea Pearl. Equivalence and synthesis of causal models. Dans *Proceedings of the Sixth Conference on Uncertainty in Artificial Intelligence*, 1990.

Spencer Wheatley, Thomas Maillart et Didier Sornette. The extreme risk of personal data breaches and the erosion of privacy. *The European Physical Journal B*, 89(1):7, 2016.

Maochao Xu et Lei Hua. Cybersecurity insurance: modeling and pricing. *North American Actuarial Journal*, 23(2):220–249, 2019. doi: 10.1080/10920277.2019.1566076.